**Exam** : **ISO-IEC-27001-Lead-Auditor-CN**

Title : PECB Certified ISO/IEC 27001 Lead Auditor exam (ISO-IEC-27001-Lead-Auditor中文版)

**Vendor** : PECB

**Version** : V15.35

ACTUALTEST.COM

**QUESTION NO: 1**
認證審核的審核計畫不需要下列哪兩個資訊選項？
**A.**抽樣計劃
**B.**文件審查
**C.**管理系統所代表的工作經驗
**D.**審核清單
**E.**組織的財務報表
**F.**審核計劃
***Answer:*** C,E
Explanation:
These two options are not required for audit planning of a certification audit, as they are not relevant to the audit objectives, scope, criteria, and methods. The working experience of the management system representative is not a requirement of ISO/IEC 27001, nor does it affect the conformity or effectiveness of the ISMS. The organisation's financial statement is not part of the ISMS documentation, nor does it provide evidence of the ISMS performance or improvement. The other options are required for audit planning, as they help to determine the audit activities, resources, schedule, and sampling strategy. Reference: PECB Candidate Handbook1, page 19-20; ISO 9001 Auditing Practices Group Guidance on2, page 1-2; ISO/IEC 27001:2022 (en)3, clause 9.2.

**QUESTION NO: 2**
下列哪兩項標準被用作ISMS第三方認證審核標準？
**A.**ISO/IEC 27002
**B.**ISO/IEC 20000-1
**C.**ISO 19011
**D.**ISO/IEC 27001
**E.**相關法律、法規和監管要求
**F.**ISO/IEC 17021-1
***Answer:*** D,E
Explanation:
The two standards that are used as ISMS third-party certification audit criteria are ISO/IEC 27001 and relevant legal, statutory, and regulatory requirements. ISO/IEC 27001 specifies the requirements for establishing, implementing, maintaining, and continually improving an information security management system (ISMS)1. Relevant legal, statutory, and regulatory requirements are those that apply to the organization's information security aspects and objectives2. The other options are either not standards (E) or not directly related to the ISMS certification audit criteria (A, B, C, F). Reference: 1: ISO/IEC 27001:2022, Information technology - Security techniques - Information security management systems - Requirement s, Clause 1 \n2: ISO/IEC 27001:2022, Information technology - Security techniques - Information security management systems - Requirements, Clause 4.2

**QUESTION NO: 3**
EquiBank 正在接受其財務管理系統的外部審計。審計員評估 EquiBank 財務軟體處理的交易邏輯。為了確保準確性，他們使用模擬來驗證軟體應用程式中程式設計的

ACTUAL4TEST.COM

操作、計算和控制。使用哪種類型的電腦輔助審計技術（CAAT）？
**A.**繪圖和製圖軟體應用程式
**B.**實用軟體
**C.**資料測試
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct Answer:
Data test techniques simulate transactions within financial software to verify logic, calculations, and programmed controls.
ISO 19011:2018 recognizes CAATs as audit tools that validate data processing integrity.
A . Incorrect:
Plotting and cartography software is used for geospatial analysis, not financial transaction testing.
B . Incorrect:
Utility software supports general IT functions but does not conduct audit simulations.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.4.10 (Use of CAATs in Auditing)

**QUESTION NO: 4**
在啟動審計活動之前，審計員會考慮被審計方的背景、關鍵流程和期望。運用了哪一項審計原則？
**A.**應有的專業謹慎
**B.** 專業懷疑論
**C.**誠信
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
Due professional care refers to auditors carefully considering all relevant factors before initiating an audit.
In this scenario, the auditors assessed the auditee's context, processes, and expectations, which aligns with ISO 19011:2018 Clause 4 (Principles of Auditing: Due Professional Care).
B . Incorrect:
Professional skepticism is about challenging evidence and avoiding assumptions, not about contextual planning.
C . Incorrect:
Integrity refers to acting honestly and ethically, which is not the focus here.
Relevant Standard Reference:
ISO 19011:2018 Clause 4.5 (Due Professional Care)

**QUESTION NO: 5**
在第三方認證審核中，保密性是審核計畫中的一個問題。選擇正確說明審計中保密功能的兩個選項
**A.**監理要求迫使審核員在審核中保密

ACTUAL4TEST.COM

**B.**審核團隊中的觀察員無法存取任何機密資訊
**C.**保密是審計行為的原則之一
**D.**審核員在使用攝影機或錄音設備之前應獲得受審核方的許可
**E.**審計資訊可用於審計人員提升個人能力
**F.**由於審核員始終有導遊陪同，因此不會對受審核方的敏感資訊造成風險
***Answer:*** C,D
Explanation:
Confidentiality is one of the principles of audit conduct that auditors should adhere to when performing audits. Confidentiality means that auditors should exercise discretion in the use and protection of information acquired in the course of their duties3. Auditors should respect the intellectual property rights of the auditee and other parties involved in the audit, and should not disclose any information that is sensitive, proprietary, or confidential without prior approval from the auditee or other authorized parties3. Auditors should also obtain the auditee's permission before using a camera or recording equipment during an audit, as these devices may capture confidential information or infringe on the privacy of individuals3. Therefore, these two options correctly state the function of confidentiality in an audit. The other options are either incorrect or irrelevant to confidentiality. For example, auditors are not forced by regulatory requirements to maintain confidentiality in an audit, but rather by ethical obligations and contractual agreements3. Observers in an audit team can access confidential information if they have signed a confidentiality agreement and have been authorized by the auditee3. Audit information can be used for improving personal competence by the auditor only if it does not compromise confidentiality or conflict with other interests3. As an auditor is always accompanied by a guide, there is still a risk to the auditee's sensitive information if the guide is not trustworthy or authorized to access such information3. Reference: ISO 19011:2018 - Guidelines for auditing management systems

**QUESTION NO: 6**
場景 4：Branding
是一家行銷公司，與美國一些最著名的公司合作。降低內部成本。兩年多來，Branding 已將軟體開發和 IT 幫助台營運外包給
Techvology。技術學。配備必要的專業知識，管理品牌的軟體、網路和硬體需求。 Branding 已實施資訊安全管理系統 (ISMS) 並獲得了 ISO/IEC 27001
認證，表明其致力於維護高標準的資訊安全。它積極對技術進行審計，以確保其外包業務的安全性符合 ISO/IEC 27001 認證要求。
在上次審計期間。品牌的審計團隊定義了要審計的流程和審計計畫。他們採用了基於證據的方法，特別是考慮到 Techvology 在過去一年中報告的兩起資訊安全事件。所有方面。
此外，審計也對Techvology用於管理其外包業務和其他組織的治理流程進行了嚴格的評估。此步驟對於品牌推廣至關重要，可以驗證是否有適當的控制和監督機制來減輕與外包安排相關的潛在風險。
審計員對 Techvology 各級人員進行了採訪，並分析了事件解決記錄。此外，Techvology 還提供了記錄作為證據，證明他們為員工開展了事件管理意識會議。根據收集到的信息，他們預測這兩起資訊安全事件都是由人員不稱職造成的。因此，審計人員要求查看涉事員工的人事檔案，以審查其能力的證據，例如相關經驗、證書和參與培訓的記錄。
Branding
的審計員對所獲得的證據的有效性進行了嚴格評估，並對可能與收到的記錄資訊的可靠性相矛

盾或質疑的證據保持警惕。在對 Techvology
進行審計期間，審計員堅持這種方法，嚴格評估事件解決記錄，並對不同級別和職能的員工進行徹底的訪談。他們不只把 Techvology
代表的話當作事實；相反，他們尋求具體的證據來支持代表們對事件管理流程的主張。
根據上述情景，回答以下問題：
根據 ISO/IEC 27001 的要求，是否需要透過品牌來持續控制 Techvology 提供的服務？
**A.**是的，品牌負責控制和監控 Techvology 服務的品質
**B.**是的，但前提是這是兩家公司之間合約協議中規定的要求
**C.**不，Branding 不負責控制 Techvology 提供的服務，但負責監控它們
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct answer:
ISO/IEC 27001:2022 Annex A Control A.5.19 (Information Security in Supplier Relationships) requires organizations to monitor and control their suppliers to ensure compliance with security requirements.
Branding must monitor, assess, and ensure Techvology maintains compliance with ISO/IEC 27001 and outsourcing agreements.
B . Incorrect:
Even if not explicitly stated in the contract, ISO/IEC 27001 requires continual supplier monitoring.
C . Incorrect:
Branding is responsible for both controlling and monitoring outsourced services, not just monitoring them.
Relevant Standard Reference:
ISO/IEC 27001:2022 Annex A Control A.5.19 (Supplier Security Compliance)

**QUESTION NO: 7**
選擇最能描述如何進行資訊安全管理系統審核的選項：
**A.**應使用審核標準來評估間接證據，以產生審核結果。
然後，應建立審核報告並在審核組會議上提交給審核組。
**B.**應使用審核標準來評估客觀證據，以產生審核結果。然後，應建立審核報告並在末次會議上提交給審核組組長。
**C.**應使用審核方法來評估審核證據，以產生審核建議。
然後，應建立審核建議並在末次會議上提交給受審核方。
**D.**應使用審核方法來評估客觀證據，以得出審核結果。然後，應制定審核結論並在末次會議上提交給受審核方。
**E.**審計目標應用於評估審計證據，以得出審計結論。然後，應建立審核結果並在末次會議上提交給審核客戶。
**F.**審計目標應用於評估客觀證據，以得出審計結論。
然後，應建立審計建議並在管理審查時提交給最高管理層。
***Answer:*** D
Explanation:
The option that best describes how Information Security Management System (ISMS) audits

should be conducted, aligning with best practices and standards like ISO/IEC 27001:2022, is:
D . Audit methods should be used to assess objective evidence in order to generate audit findings. Then, the audit conclusion should be created and presented to the auditee at the closing meeting.
This option accurately reflects the audit process, emphasizing the use of systematic audit methods to assess objective evidence, which is crucial for impartiality and accuracy in auditing. Audit findings are the results derived from evaluating the objective evidence against the audit criteri a. The conclusion, based on the audit findings, provides a comprehensive summary of the audit's outcomes, indicating whether the audited ISMS meets the established criteria. Presenting these conclusions to the auditee during the closing meeting ensures transparency and provides an opportunity for immediate clarification and discussion of the results and potential next steps.

**QUESTION NO: 8**
場景 9：Techmanic 是一家比利時公司，成立於 1995 年，目前在布魯塞爾運作。它提供 IT 諮詢、軟體設計和硬體/軟體服務，包括部署和維護。該公司服務於公共服務、金融、電信、能源、醫療保健和教育等行業。作為一家以客戶為中心的公司，它優先考慮建立牢固的客戶關係並引領安全實踐。
Techmanic 已獲得 ISO/IEC 27001
認證一年，並對此認證感到自豪。在認證審核期間，審核員發現其 ISMS
實施上存在一些不一致之處。由於觀察到的情況並不影響其 ISMS
實現預期結果的能力，因此在審計師遠端跟進根本原因分析和糾正措施後，Techmanic
獲得了認證。的遵守情況。認識持續改進的價值並從過去的評估中學習。 Techmanic
實施了審查先前的監督審計報告的做法。這種積極主動的方法不僅有助於識別和解決潛在的不合格情況，而且還旨在簡化 IT 諮詢領域的重新認證流程。
監督審核期間，發現了多處不符合項。 ISMS 繼續滿足 ISO/IEC 27001*s
的要求，但根據內部稽核員的報告，Techmanic
未能解決與託管服務相關的不符合問題。此外，內部稽核報告存在多處不一致之處，這使人們對內部稽核師在託管服務審計過程中的獨立性產生了質疑。基於此，延期認證未獲核准。因此。 Techmanic 請求轉移到另一個認證機構。同時，該公司向客戶發布聲明稱，ISO/IEC 27001 認證涵蓋 IT 服務以及託管服務。
根據上述情景，回答以下問題：
下列哪一個選項是內部稽核程序不允許的？
**A.**驗證糾正措施的有效性
**B.** 減少人工審計任務
**C.**預防不合規
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct answer:
Internal audits detect nonconformities but do not actively prevent them.
A . Incorrect:
Internal audits verify corrective actions.
B . Incorrect:
Technology can reduce manual tasks in internal audits.

Relevant Standard Reference:

**QUESTION NO: 9**
情境 6：Sinvestment
是一家提供家庭保險、商業保險和人壽保險的保險公司。該公司成立於北卡羅來納州，但最近在其他地區進行了擴張，包括歐洲和非洲。
Sinvestment
致力於遵守適用於其行業的法律法規，並防止任何資訊安全事件。他們實施了基於 ISO/IEC 27001 的 ISMS 並申請了 ISO/IEC 27001 認證。
認證機構指派兩名審核員進行審核。與Sinvestment簽訂保密協議後。他們開始了審計活動。首先，他們審查了標準要求的文件，包括 ISMS
範圍聲明、資訊安全政策和內部稽核報告。審查過程並不容易，因為儘管 Sinvestment
表示他們已製定文件程序，但並非所有文件都具有相同的格式。
隨後，審計小組對Sinvestment的高階主管進行了多次訪談，以了解他們在ISMS實施中的作用。第一階段審計的所有活動都是遠端進行的，除了根據 Sinvestment
的要求在現場進行的文件資訊審查之外。
在此階段，審計人員發現沒有與資訊安全培訓和意識計劃相關的文件。被問及時，Sinvestment代表表示，公司已為所有員工提供資訊安全培訓課程。第一階段審計讓審計團隊對
Sinvestment 的營運和 ISMS 有了整體了解。
第二階段審核在第一階段審核三週後進行。審計小組觀察到，行銷部門（未包含在審計範圍內）沒有適當的程序來控制員工的存取權限。由於控制員工的存取權限是ISO/IEC
27001的要求之一，並且已包含在公司的資訊安全政策中，因此該問題包含在審計報告中。此外，在第二階段審計中，審計小組觀察到Sinvestment沒有記錄使用者活動日誌。
該公司的程序規定“記錄用戶活動的日誌應保留並定期審查”，但該公司沒有提供任何執行該程序的證據。
在所有審核活動中，審核員透過觀察、訪談、文件化資訊審查、分析和技術驗證來收集資訊和證據。對第一階段和第二階段的所有審核結果進行了分析，審核小組決定發布積極的認證建議。
根據情境 6，在第一階段審核期間，審核員發現一些有關 ISMS
的文件具有不同的格式。在這種情況下，審計師該做什麼？
**A.**驗證記錄的資訊是否具有適當的格式並且符合公司的記錄程序，因為這是標準的要求
**B.**僅驗證是否記錄了標準要求的信息，而不考慮格式，因為這不是標準的要求
**C.**將此觀察結果記錄為第 2 階段應在審核期間驗證的問題
***Answer:*** B
Explanation:
The auditor should verify if the information required by the standard is documented, without necessarily focusing on the format, as long as the content meets the requirements of the standard. ISO/IEC 27001 does not mandate a specific format for documentation, only that necessary information is appropriately documented, maintained, and controlled.

**QUESTION NO: 10**
場景 8：苔絲
一個。 Malik 和 Michael
是一個由安全、合規以及業務規劃和策略領域的獨立且合格的專家組成的審計團隊。他們被指派到一家大型網頁設計公司Clastus進行認證審核。他們在進行審計時表現出了出色的職業道

德，包括公正和客觀。這一次，Clastus 確信，如果獲得 ISO/IEC 27001
認證，他們將領先一步。
審計團隊負責人 Tessa 擁有審計專業知識，並且在 IT
相關問題、合規性和治理方面擁有非常成功的背景。馬利克擁有組織規劃和風險管理背景。他的專業知識依賴於對組織的安全控制及其風險承受能力的綜合和分析水平，以準確描述組織內部的風險水平 另一方面，Michael
是通過遵循嚴格的標準化程序進行控制評估的實際安全性的專家。
在執行所需的審計活動後，泰莎發起了一次審計團隊會議，他們分析了邁克爾的一項發現，以客觀、準確地就該問題做出決定。 Michael
遇到的問題是組織日常運作中的一個小問題，他認為這是由組織的一名 IT
技術人員造成的，因此，Tessa
會見了高層管理人員，並在他們詢問了責任人姓名後，告訴他們誰應該對這一問題負責，為了方便澄清和理解，Tessa 在審核的最後一天召開了結束會議。在這次會議上，她向 Clastus
管理層報告了發現的不符合情況。然而，Tessa 收到建議，避免在 Clastus
認證審核的審核報告中提供不必要的證據，確保報告保持簡潔並專注於關鍵發現。
根據審查的證據，審核小組起草了審核結論，並決定在授予認證之前必須對該組織的兩個領域進行審核。這些決定後來被提交給被審計方，但被審計方不接受調查結果並提議提供更多資訊。儘管受審計方提出了意見，但審計員已經決定接受認證建議，因此沒有接受補充資訊。被審計單位的高階主管堅持審計結論並不代表事實，但審計小組仍堅持他們的決定。
根據上述情景，回答以下問題：
對於末次會議上提出的不符合項，Tessa 必須做什麼？

**A.**提供每項不合格情況的詳細分析，包括對組織的潛在影響

**B.**僅有重大不符合項

**C.**始終將討論與相關標準條款保持一致

***Answer:*** A

Explanation:
Comprehensive and Detailed In-Depth
A . Correct answer:
ISO 19011:2018 mandates that auditors present all nonconformities with sufficient detail and context to ensure proper understanding and corrective action planning.
Failure to explain nonconformities fully could lead to ineffective remediation.
B . Incorrect:
Minor nonconformities must also be presented to ensure full transparency.
C . Incorrect:
Aligning with standard clauses is necessary, but detailed analysis is more critical.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.6.2 (Presentation of Audit Findings in Closing Meetings)

**QUESTION NO: 11**
檢查以下陳述並確定哪兩個是錯誤的：

**A.**在虛擬審核之前進行技術檢查可以提高審核的有效性和效率

**B.**在虛擬審核期間，強烈建議參與面談的受審核方保持網路攝影機處於啟用狀態

**C.**分配給第三方審核的天數取決於受審核方的空閒時間

**D.**出於保密和安全考慮，虛擬審核期間的螢幕共享是審核團隊審查受審核方文件的一種方法

**E.**選擇現場、虛擬或組合審核應考慮歷史績效和先前的審核結果

**F.**獲準進行現場審核的審核員不需要進行虛擬審核的額外培訓，因為所需的技能沒有顯著差異

***Answer:*** C,F

Explanation:

The number of days assigned to a third-party audit is not determined by the auditee's availability, but by the audit program, which considers the audit scope, objectives, criteria, risks, and resources12. The auditee's availability is only one factor that affects the audit planning and scheduling, but not the audit duration3. Auditors approved for conducting onsite audits do require additional training for virtual audits, as there are significant differences in the skillset required. Virtual audits pose different challenges and opportunities than onsite audits, such as communication, technology, security, and evidence collection4 . Auditors need to be familiar with the tools and techniques for conducting remote audits, as well as the ethical and professional behavior expected in a virtual environment . Reference:

PECB Candidate Handbook - ISO 27001 Lead Auditor, page 18

ISO 19011:2018, Guidelines for auditing management systems, clause 5.3.2 ISO 19011:2018, Guidelines for auditing management systems, clause 6.3.1 Deloitte - Conducting a Virtual Internal Audit, page 1

[A Guide to Conducting Effective and Efficient Remote Audits], page 1

[ISO 19011:2018, Guidelines for auditing management systems], clause 7.2.3

[Remote Auditing Best Practices & Checklist for Regulatory Compliance], page 1

**QUESTION NO: 12**

您是認證機構審核員，負責對為 ICT 設施提供託管服務的客戶營運的資料中心進行 ISO/IEC 27001:2022 監督審核。

您和您的導遊目前位於客戶出租給客戶的私人套房之一。每間套房的出入均使用密碼鎖進行控制。每間套房也安裝了閉路電視。

每個套件內有三個資料櫃，客戶可以在其中放置關鍵任務伺服器和其他網路設備，例如交換器和路由器。

您注意到，雖然套房中的兩個櫃子已上鎖，但第三個櫃子卻未上鎖。你問導遊為什麼。他們回覆「這是因為客戶目前正在更換硬碟單元。他們的技術人員目前正在午休」。

接下來你應該採取哪三項行動？

**A.**什麼也不做，房間看起來受到了充分的保護，因此不太可能發生安全事件。

**B.**針對控制措施 5.16「身分管理」提出不符合項，因為可能無法辨識誰未上鎖櫃子。

**C.**針對控制措施 7.2「實體進入」提出不符合項，因為客戶設備所在的區域不受保護。

**D.**針對控制措施

7.4「實體安全監控」提出不符合項，因為私人套房未持續受到未經授權的實體存取監控。

**E.**提出改進的機會，建議每當客戶離開套房時就鎖上櫃門，即使他們打算在短時間內返回。

**F.**查看閉路電視記錄，確保自上次確認櫃子鎖定以來只有客戶曾造訪過櫃子。

**G.**當技術人員吃完午餐回來時，斥責他們沒有打開櫃子。

**H.**在嚮導許可的情況下，與客戶聯繫以確認他們正在更換驅動器。

***Answer:*** E,F,H

Explanation:

Leaving the cabinet unlocked while the technician is on a lunch break exposes the client's equipment and data to potential physical security risks, such as theft, damage, or tampering. This is a violation of the ISO/IEC 27001:2022 requirements for physical entry (control 7.2)

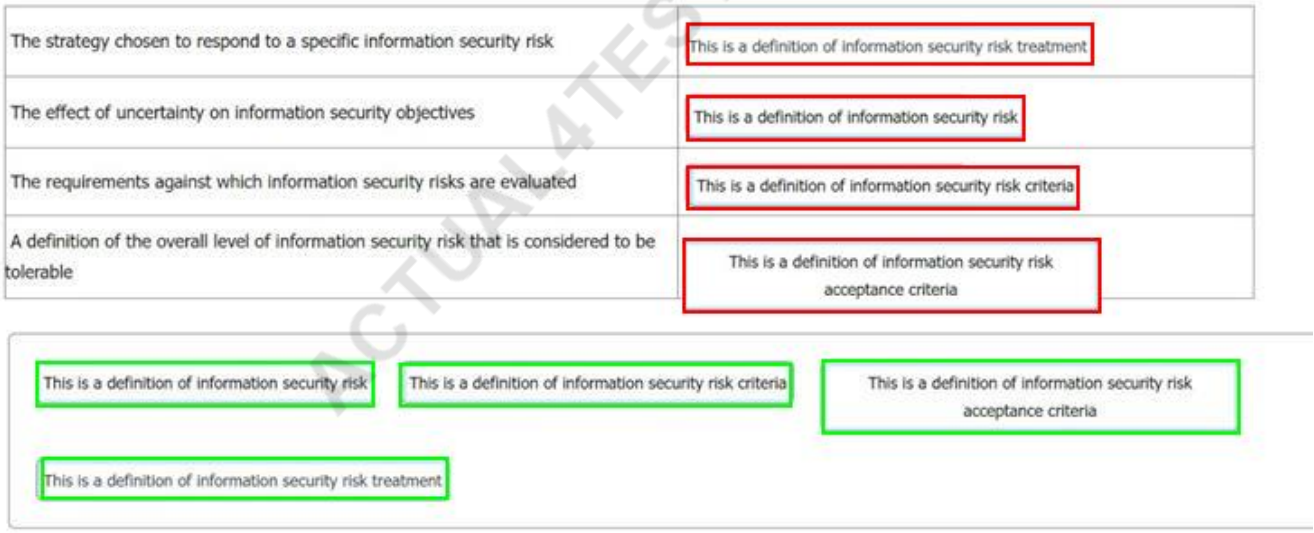
and physical security monitoring (control 7.4), which aim to prevent unauthorized access to information processing facilities and assets. Therefore, the appropriate actions for the auditor are:
Raise an opportunity for improvement (OFI) suggesting that the cabinet doors are locked whenever clients leave their suites, even if they intend to return within a short time. This would enhance the security of the client's equipment and data, and reduce the likelihood of security incidents.
Review the CCTV records to ensure that only the client has accessed the cabinet since it was last confirmed as locked. This would verify the integrity and availability of the client's equipment and data, and identify any possible unauthorized access or interference.
With the permission of the guide, speak to the customer to confirm that they are in the process of swapping out a drive. This would validate the reason for leaving the cabinet unlocked, and assess the impact and risk of the activity on the client's information security.
Reference:
ISO/IEC 27001:2022, clause 7.2, Physical entry
ISO/IEC 27001:2022, clause 7.4, Physical security monitoring
PECB Candidate Handbook ISO 27001 Lead Auditor, page 19, Audit Process
PECB Candidate Handbook ISO 27001 Lead Auditor, page 21, Audit Findings

**QUESTION NO: 13**
下列哪兩項敘述是正確的？
**A.**認證機構審核員的角色包括評估組織的流程，以確保遵守其法律要求
**B.**透過第三方審核，審核員評估組織如何確保 4 6 了解法律要求的變更
**C.**作為認證機構審核的一部分，審核員負責驗證組織的法律合規狀態
***Answer:*** A,B
Explanation:
The following statements are true:
The role of a certification body auditor involves evaluating the organization's processes for ensuring compliance with their legal requirements. This is part of the auditor's responsibility to assess the effectiveness and conformity of the organization's ISMS against the ISO/IEC 27001:2022 standard and the applicable legal and regulatory requirements.
During a third-party audit, the auditor evaluates how the organization ensures that they are made aware of changes to the legal requirements. This is part of the auditor's responsibility to verify that the organization has established and maintained a process for identifying and updating their legal and other requirements related to information security. The following statement is false:
As part of a certification body audit, the auditor is responsible for verifying the organization's legal compliance status. This is not true, as the auditor is not authorized or qualified to provide legal advice or judgment on the organization's compliance status. The auditor can only report on the evidence of compliance or noncompliance observed during the audit, but the ultimate responsibility for ensuring legal compliance lies with the organization. Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 66. : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 67. : ISO/IEC 27001 LEAD AUDITOR - PECB, page 22.

**QUESTION NO: 14**
當 IT
經理找到您並請您協助修改公司的風險管理流程時，您剛完成了組織的預定資訊安全審核。
他正在嘗試更新當前的文檔，以使其他經理更容易理解，但是，從您的討論中可以清楚地看出，他混淆了幾個關鍵術語。
您要求他將每個描述與適當的風險術語相匹配。正確答案應該是什麼？




***Answer:***




**QUESTION NO: 15**
場景 9：Techmanic 是一家比利時公司，成立於 1995 年，目前在布魯塞爾運作。它提供 IT 諮詢、軟體設計和硬體/軟體服務，包括部署和維護。該公司服務於公共服務、金融、電信、能源、醫療保健和教育等行業。作為一家以客戶為中心的公司，它優先考慮建立牢固的客戶關係並引領安全實踐。
Techmanic 已獲得 ISO/IEC 27001
認證一年，並對此認證感到自豪。在認證審核期間，審核員發現其 ISMS
實施上存在一些不一致之處。由於觀察到的情況並不影響其 ISMS
實現預期結果的能力，因此在審計師遠端跟進根本原因分析和糾正措施後，Techmanic
獲得了認證。的遵守情況。認識持續改進的價值並從過去的評估中學習。 Techmanic

實施了審查先前的監督審計報告的做法。這種積極主動的方法不僅有助於識別和解決潛在的不合格情況，而且還旨在簡化 IT 諮詢領域的重新認證流程。
監督審核期間，發現了多處不符合項。 ISMS 繼續滿足 ISO/IEC 27001*s
的要求，但根據內部稽核員的報告，Techmanic
未能解決與託管服務相關的不符合問題。此外，內部稽核報告存在多處不一致之處，這使人們對內部稽核師在託管服務審計過程中的獨立性產生了質疑。基於此，延期認證未獲核准。因此。 Techmanic 請求轉移到另一個認證機構。同時，該公司向客戶發布聲明稱，ISO/IEC 27001 認證涵蓋 IT 服務以及託管服務。
根據上述情景，回答以下問題：
在 Techmanic 重新認證活動中審查先前的監督審核報告的目的是否被適當定義？
**A.**是的，重新認證活動的目的是取代 IT 諮詢行業對重新認證審核的需求
**B.**不，重新認證活動的目的是將 Techmanic 的軟體開發與產業基準進行比較
**C.**不，重新認證活動的目的是考慮 Techmanic 管理系統在認證週期內的表現
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct answer:
Recertification reviews the overall ISMS performance over the certification cycle, not just past audit findings.
A . Incorrect:
Previous audit findings do not replace the need for a full recertification audit.
B . Incorrect:
Recertification is not about industry benchmarking-it is about ISMS effectiveness.
Relevant Standard Reference:

**QUESTION NO: 16**
下列哪兩項敘述是正確的？
**A.**認證 ISMS 的好處是在網站上顯示認可證書。
**B.**ISMS 的目的在於展現管理階層對資訊安全問題的認知。
**C.**認證 ISMS 的好處是增加客戶數量。
**D.**實施 ISMS 的好處主要來自於資訊安全風險的降低。
**E.**ISMS 的目的在於應用風險管理流程來保護資訊安全。
**F.**ISMS 的目的在於證明符合法規要求。
***Answer:*** D,E
Explanation:
The benefits of implementing an ISMS primarily result from a reduction in information security risks.
E). The purpose of an ISMS is to apply a risk management process for preserving information security. Comprehensive and Detailed Explanation: According to the ISO 27001 standard, the benefits of implementing an ISMS include the following1:
Assuring customers and other stakeholders of the confidentiality, integrity and availability of information Enhancing the ability to respond to information security incidents and minimize their impacts Improving the governance and management of information security Reducing the costs and losses associated with information security breaches Increasing the

competitiveness and reputation of the organization Complying with legal, regulatory and contractual obligations
The purpose of an ISMS is to provide a systematic approach to managing information security risks, based on the Plan-Do-Check-Act (PDCA) cycle1.
The ISMS enables the organization to establish, implement, maintain and continually improve its information security performance, in alignment with its business objectives and the needs and expectations of interested parties1.
The ISMS consists of the following elements1:
The information security policy and objectives
The scope and boundaries of the ISMS
The processes and procedures for information security risk assessment and treatment
The resources and competencies for information security
The roles and responsibilities for information security
The performance evaluation and improvement of the ISMS
The internal and external communication and awareness of the ISMS
Reference:
ISO/IEC 27001:2013, Information technology - Security techniques - Information securit y management systems - Requirements, clauses 1, 4, 5, 6, 7, 8, 9 and 10 PECB Candidate Handbook ISO 27001 Lead Auditor, pages 9-11 ISO/IEC 27001:2013 Information Security Management Standards 4 Key Benefits of ISO 27001 Implementation | ISMS.online ISO/IEC 27001:2022
An Introduction to the ISO 27001 ISMS | Secureframe

**QUESTION NO: 17**
審核過程中，審核組長透過邏輯推理和分析，及時得出結論。
審計組長表現出了哪些專業行為？
**A.**決定性的
**B.**思想開放
**C.**道德
**D.**有洞察力
***Answer:*** A
Explanation:
According to the PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, one of the professional behaviours expected from an audit team leader is to be decisive, which means to "reach timely conclusions based on logical reasoning and analysis" (page 8). Being open minded, ethical, and perceptive are also desirable qualities for an audit team leader, but they do not match the description given in the question. Reference: PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, page 8.

**QUESTION NO: 18**
情境 5：Data Grid Inc.
是一家知名公司，為整個資訊科技基礎設施提供安全服務。它提供網路安全軟體，包括端點安全、防火牆和防毒軟體。二十年來，Data Grid Inc.
透過先進的產品和服務幫助多家公司保護其網路安全。 Data Grid Inc.
在資訊和網路安全領域享有盛譽，決定獲得 ISO/IEC 27001

認證，以更好地保護其內部和客戶資產並獲得競爭優勢。
Data Grid Inc. 任命了審計團隊，該團隊同意審計任務的條款。此外，Data Grid Inc.明確了審核範圍，明確了審核標準，並建議在五天內結束審核。由於Data Grid Inc.員工人數眾多，流程複雜，審計小組拒絕了Data Grid Inc.在五天內進行審計的提議。 Data Grid Inc.堅稱他們計劃在五天內完成審核，因此雙方同意在規定的時間內進行審核。審計小組遵循基於風險的審計方法。
為了獲得主要業務流程和控制的概述，審計團隊存取了流程描述和組織圖表。他們無法對 IT 風險和控制進行更深入的分析，因為他們對 IT 基礎架構和應用程式的存取受到限制。然而，審計小組表示，Data Grid Inc. 的 ISMS 出現重大缺陷的風險很低，因為該公司的大部分流程都是自動化的。因此，他們透過詢問 Data Grid Inc. 的代表以下問題來評估 ISMS 整體上符合標準要求：
*如何定義和指派 IT 和 IT 控制的職責？
*Data Grid Inc. 如何評估控制措施是否達到了預期效果？
*Data Grid Inc. 採取了哪些控制措施來保護操作環境和資料免受惡意軟體的侵害？
*是否實施了與防火牆相關的控制？
Data Grid Inc. 的代表提供了充分且適當的證據來解決所有這些問題。
審計組長起草審計結論並向Data Grid Inc. 的最高管理階層報告。
儘管審核員推薦Data Grid Inc.進行認證，但Data Grid Inc.與認證機構之間在審核目標方面產生了誤解。Data Grid Inc. 表示，儘管審計目標包括確定潛在改進的領域，但審計團隊並未提供此類資訊。
根據該場景，回答以下問題：
Data Grid Inc. 對以下所有行為負責，但以下情況除外：

**A.**指定審核標準

**B.**任命審核團隊

**C.**定義審核範圍

***Answer:*** B

Explanation:
In the context of ISO/IEC 27001 audits, the audit team is appointed by the certification body, not by the organization being audited. Data Grid Inc. is responsible for specifying the audit criteria and defining the audit scope, but not for appointing the audit team.

**QUESTION NO: 19**
您正在一家名為 ABC 的提供醫療保健服務的住宅療養院進行 ISMS 審核。
審核計劃的下一步是驗證 ABC 醫療保健行動應用程式開發、支援和生命週期流程的資訊安全性。在審核過程中，您了解到該組織將行動應用程式開發外包給了一家具有 CMMI 5 級、ITSM（ISO /IEC 20000-1)、BCMS (ISO 22301) 和 ISMS (ISO/IEC 27001) 認證。
IT經理介紹了軟體安全管理流程，並將流程總結如下：
行動應用程式開發至少應採用「設計安全」和「預設安全」原則。應具備以下個人資料保護安全功能：
存取控制。
個人資料加密，即高階加密標準（AES）演算法，金鑰長度：256位元；個人資料假名化。
已檢查漏洞，無安全後門

您可以獲得最新的行動應用測試報告樣本 - 詳細資訊如下：

| Target of Test: ABC's healthcare mobile app, version 1 | Test results | Test summary |
|---|---|---|
| **Security test** | | |
| Personal data encryption | Fail | Not able to perform the encryption. |
| Personal data pseudonymisation | Fail | Not able to perform the pseudonymisation. |
| **Final approval:** | | |
| *Service Manager* | | signed by: |

您詢問 IT
經理，為什麼組織仍在使用行動應用程序，而個人資料加密和假名化測試卻失敗了。此外，服務經理是否有權批准測試。
IT經理解釋說，根據軟體安全管理程序，測試結果應由他批准。加密和假名功能失敗的原因是這些功能嚴重降低了系統和服務效能。額外的
需要 150%
的資源來實現這一點。服務經理同意存取控制足夠好並且可以接受。這就是服務經理簽署批准書的原因。
您對醫務人員的手機進行採樣，發現 ABC 的醫療保健行動應用程式版本
1.01 已安裝。你發現1.01版本沒有測試記錄。
IT經理解釋說，由於勒索軟體攻擊頻繁，外包行動應用開發公司對受測軟體進行了免費小幅更新，並對更新後的軟體進行了緊急發布，並口頭保證不會對安全造成任何影響。以他20年的資訊安全經驗來看，沒有必要重新測試。
您正在準備審核結果 請選擇兩個正確的選項。
**A.**存在不合格項 (NC)。 IT。管理者不遵守軟體安全管理程序。 （與第 8.1 條相關，控制措施 A.8.30）
**B.**存在不合格項 (NC)。組織不控制計劃的變更並審查非預期變更的後果。 （與第8.1條相關）
**C.**還有改進的機會 (OI)。 IT 經理應根據適當的測試做出是否繼續提供服務的決定。 （與第 8.1 條相關，控制措施 A.8.30）
**D.**還有改進的機會 (OI)。該組織根據其提供的免費服務的範圍選擇外部服務提供者。 （與第 8.1 條相關，控制措施 A.5.21）
**E.**不存在不合格項 (NC)。 IT 經理展現了良好的領導能力。 （與條款相關
5.1，控制5.4）
**F.**不存在不合格項 (NC)。 IT 經理證明他完全有能力。 （與第7.2條相關）
***Answer:*** A,B
Explanation:
According to ISO/IEC 27001, organizations must control planned changes and review the consequences of unintended changes in order to ensure continued alignment with information security requirements. In this scenario, the organization failed to perform appropriate testing after an emergency update to the mobile app, which constitutes a nonconformity with clause 8.1 of the standard.

**Reference**:
- ISO/IEC 27001 Lead Auditor Reference Materials
- PECB Candidate Handbook for ISO 27001 Lead Auditor
ISO/IEC 27001 requires that organizations adhere to their established procedures for software security management. The IT Manager's approval of the app despite failed security tests and lack of proper documentation for the new version indicates noncompliance with the procedure, thus reflecting a nonconformity.
**Reference**:
- ISO/IEC 27001 Lead Auditor Reference Materials
- PECB Candidate Handbook for ISO 27001 Lead Auditor

**QUESTION NO: 20**
下列哪一種情況代表威脅？
**A.**HackX 使用並分發盜版軟體
**B.**僅向組織的 IT 團隊成員提供資訊安全培訓
**C.**駭客透過破解密碼入侵了管理員帳戶
***Answer:*** C

**QUESTION NO: 21**
以下是資訊安全的目的，但以下情況除外：
**A.**確保業務連續性
**B.**最小化業務風險
**C.**增加企業資產
**D.**最大化投資回報
***Answer:*** C
Explanation:
The following are purposes of information security, except increasing business assets. Increasing business assets is not a purpose of information security, as it is not directly related to protecting information and systems from threats and risks. Information security may contribute to increasing business assets by enhancing customer trust, reputation, compliance, and efficiency, but it is not its primary goal. Ensuring business continuity is a purpose of information security, as it aims to prevent or minimize disruptions or losses caused by incidents affecting information and systems. Minimizing business risk is a purpose of information security, as it aims to identify and reduce threats and vulnerabilities that may compromise information and systems. Maximizing return on investment is a purpose of information security, as it aims to optimize the costs and benefits of implementing and maintaining information security controls and measures. Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 23. : [ISO/IEC 27001 Brochures | PECB], page 4.

**QUESTION NO: 22**
場景 9：Techmanic 是一家比利時公司，成立於 1995 年，目前在布魯塞爾運作。它提供 IT 諮詢、軟體設計和硬體/軟體服務，包括部署和維護。該公司服務於公共服務、金融、電信、能源、醫療保健和教育等行業。作為一家以客戶為中心的公司，它優先考慮建立牢固的客戶關係並引領安全實踐。

ACTUAL4TEST.COM

Techmanic 已獲得 ISO/IEC 27001
認證一年，並對此認證感到自豪。在認證審核期間，審核員發現其 ISMS
實施上存在一些不一致之處。由於觀察到的情況並不影響其 ISMS
實現預期結果的能力，因此在審計師遠端跟進根本原因分析和糾正措施後，Techmanic
獲得了認證。的遵守情況。認識持續改進的價值並從過去的評估中學習。 Techmanic
實施了審查先前的監督審計報告的做法。這種積極主動的方法不僅有助於識別和解決潛在的不合格情況，而且還旨在簡化 IT 諮詢領域的重新認證流程。
監督審核期間，發現了多處不符合項。 ISMS 繼續滿足 ISO/IEC 27001*s
的要求，但根據內部稽核員的報告，Techmanic
未能解決與託管服務相關的不符合問題。此外，內部稽核報告存在多處不一致之處，這使人們對內部稽核師在託管服務審計過程中的獨立性產生了質疑。基於此，延期認證未獲核准。因此。 Techmanic 請求轉移到另一個認證機構。同時，該公司向客戶發布聲明稱，ISO/IEC 27001 認證涵蓋 IT 服務以及託管服務。
根據上述情景，回答以下問題：
根據 ISO/IEC 17021-1，監督審核的目的為何？
**A.**評估合規性並授予初始認證
**B.**評估組織的財務績效
**C.** 在審核期間保持對認證管理系統的信心
***Answer:*** C
Explanation:
Relevant Standard Reference:
ISO/IEC 17021-1:2015 Clause 9.6.2 (Purpose of Surveillance Audits)

**QUESTION NO: 23**
您是 ISMS 審計團隊負責人，負責在客戶的資料中心進行後續審計。
現場兩天后，您得出結論，在促使進行後續審核的最初 12 項輕微不符合項和 1
項重大不符合項中，只有 1 項輕微不符合項仍未解決。
選擇您可以採取的動作的四個選項。
**A.**與受審核方/審核客戶同意如何清除剩餘的不合格項、何時以及如何驗證其清除
**B.**建議下次監督審核時處理未解決的輕微不符合項
**C.**結束後續審核，因為組織已證明其致力於清除提出的不合格項
**D.**建議暫停組織的認證，因為組織未能在商定的時間內實施商定的糾正措施和糾正措施
**E.**告知受審核方您將安排下一次審核為線上審核，以處理突出的不合格項
**F.**記錄所取得的進展，但保持審核開放，直到所有糾正措施均已清除
**G.**建議管理審核計畫的個人就突出的不合格項所做的任何決定
**H.**在一項未通知的輕微不符合項被清除後，進行現場後續審核以對其進行審查
***Answer:*** A,C,F,G
Explanation:
The four options for the actions you could take are A, C, F, and G. These options are consistent with the guidance and requirements of ISO 19011:2018, Clause 6.712. You could agree with the auditee/audit client how the remaining nonconformity will be cleared, by when, and how its clearance will be verified (A), and document the agreement in the audit report1. You could close the follow-up audit as the organisation has demonstrated it is committed to clearing the nonconformities raised , and report the outcome to the audit client and other

relevant parties1. You could note the progress made but hold the audit open until all corrective action has been cleared (F), and determine the need for another follow-up audit or other actions1. You could also advise the individual managing the audit programme of any decision taken regarding the outstanding nonconformity (G), as they are responsible for the overall management and coordination of the audit programme3. The other options are either not appropriate or not necessary for the situation. You should not recommend that the outstanding minor nonconformity is dealt with at the next surveillance audit (B), as this may compromise the audit objectives and the audit programme1. You should not recommend suspension of the organisation's certification as they have failed to implement the agreed corrections and corrective actions within the agreed timescale (D), as this is not within your role or authority as an ISMS auditor4. You should not advise the auditee that you will arrange for the next audit to be an online audit to deal with the outstanding nonconformity (E), as this may not be feasible or effective depending on the nature and complexity of the nonconformity1. You should not conduct an unannounced follow-up audit on-site to review the one outstanding minor nonconformity once it has been cleared (H), as this may not be in accordance with the audit agreement or the audit programme1. Reference: 1: ISO 19011:2018, Guidelines for auditing management systems, Clause 6.7 \n2: PECB Certified ISO/IEC 27001 Lead Auditor Exam Preparation Guide, Domain 6: Closing an ISO/IEC 27001 audit \n3: ISO 19011:2018, Guidelines for auditing management systems, Clause 5.3 \n4: ISO/IEC 27006:2022, Information technology - Security techniques - Requirements for bodie s providing audit and certification of information security management systems, Clause 9.6

**QUESTION NO: 24**
下列哪一項描述了第一階段審核的主要目的？
**A.**確定第二階段的準備情況
**B.**檢查組織是否遵守法律
**C.**了解組織
**D.**編制審核計劃
***Answer:*** A
Explanation:
The main purpose of a Stage 1 audit is to evaluate the adequacy and effectiveness of the organisation's ISMS documentation, and to assess whether the organisation is prepared for the Stage 2 audit, where the implementation and operation of the ISMS will be verified. The Stage 1 audit also involves verifying the scope, objectives, and context of the ISMS, as well as identifying any areas of concern or nonconformities that need to be addressed before the Stage 2 audit.
Reference:
ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) objectives and content from Quality.org and PECB ISO/IEC 27006:2015 Information technology - Security techniques - Requirements for bodies providing audit and certification of information security management systems Section 7.3.1

**QUESTION NO: 25**
您是一位經驗豐富的 ISMS 審核團隊領導，為審核員提供培訓指導。
受訓的審核員似乎對 ISO 27001:2022

ACTUAL4TEST.COM

中能力的解釋感到困惑，並且正在尋求您的澄清，以確保他的理解是正確的。他列出了一系列小情景，並詢問您將其中哪一個歸因於缺乏能力。選擇四個正確選項。

**A.**一位最近從 IT 網路團隊調到軟體開發團隊的員工不知道在出貨前需要填寫產品發佈表格

**B.**一位高級程式設計師沒有檢查他們的編碼是否有錯誤，因為他們去看醫生遲到了

**C.**新啟動者無法開啟閉路電視監控，因為他們沒有被告知如何執行此操作

**D.**IT 技術人員因未閱讀提供的說明而未能正確配置新型號的伺服器

**E.**一位經驗豐富的接待員允許她認識的承包商在沒有門禁卡的情況下進入資料中心

**F.**系統管理員因收到錯誤指令而刪除了兩個真實帳戶以及五個冗餘帳戶

**G.**資料中心操作員因急於執行另一項任務而無意中將備份磁帶放入了錯誤的磁碟機中

**H.**高階經理人無法協助組織的資訊安全事件復原流程，因為她沒有接受過所需的培訓

***Answer:*** A,C,D,H

Explanation:

These four scenarios are examples of a lack of competence, which is defined as the ability to apply the knowledge and skills needed to perform a work role or a task effectively and efficiently12. Competence in ISO 27001:2022 is determined by the organisation's needs and expectations, and it is based on the relevant education, training, or experience of the people involved in the ISMS34. The organisation is required to ensure that all the people who affect the performance of the ISMS are competent, and to provide them with the necessary training and awareness to fulfil their roles and responsibilities35. The four scenarios indicate that the people involved either lack the knowledge or skills to perform their tasks, or have not received the appropriate training or guidance to do so. The other scenarios are not related to competence, but to other factors such as negligence, error, or policy violation.

**QUESTION NO: 26**

場景 2：Knight 是一家來自美國北加州的電子公司，開發電玩遊戲機。 Knight 在全球擁有 300 多名員工。在成立五週年之際，他們決定推出 G-Console，這是一款面向全球市場的新一代電玩遊戲機。 G-Console被認為是2021年的終極媒體機，將為玩家帶來最佳的遊戲體驗。主機包將包括一副 VR 耳機、兩個遊戲和其他禮物。

多年來，公司透過誠信、誠實和尊重客戶而建立了良好的聲譽。這種良好的聲譽是大多數熱衷遊戲玩家在Knight的G-console一上市就想擁有它的原因之一。

Knight 除了是一家非常以客戶為導向的公司之外，也因其開發品質獲得了遊戲產業的廣泛認可。他們的價格比合理標準允許的要高一些。儘管如此，對於 Knight 的大多數忠實客戶來說，這並不是一個問題，因為它們的品質是一流的。

作為世界頂級視訊遊戲機開發商之一，Knight 也經常成為惡意活動的焦點。該公司的 ISMS 已投入運作一年多了。 ISMS 範圍包括 Knight 的所有部門（財務和人力資源部門除外）。

最近，奈特的一些包含專有資訊的文件被駭客洩露。 Knight 的事件回應團隊 (IRT) 立即開始分析系統的每個部分以及事件的詳細資訊。

IRT 的第一個懷疑是 Knight 的員工使用了弱密碼，因此很容易被未經授權存取其帳戶的駭客破解。然而，在仔細調查該事件後，IRT 確定駭客透過擷取檔案傳輸協定 (FTP) 流量來存取帳戶。

FTP 是一種用於在帳戶之間傳輸檔案的網路協定。它使用明文密碼進行身份驗證。

受此資訊安全事件的影響，在IRT的建議下，Knight決定用Secure Shell

(SSH)協定取代FTP，這樣任何捕獲流量的人都只能看到加密的資料。
在這些變化之後，奈特進行了風險評估，以驗證控制措施的實施是否已將類似事件的風險降至最低。該過程的結果得到了 ISMS
專案經理的批准，他聲稱實施新控制措施後的風險等級符合公司的風險接受程度。
根據該場景，回答以下問題：
Knight 在以 SSH 取代 FTP 時使用了哪種風險處理選項？請參閱場景 2。
**A.**風險自留
**B.**規避風險
**C.**風險修改
***Answer:*** C
Explanation:
Risk modification involves implementing controls to reduce the likelihood or impact of a risk. By replacing FTP with SSH, Knight has modified the risk associated with the transfer of files by ensuring that the data is encrypted, thereby reducing the likelihood of unauthorized access through traffic capturing1. Reference: = This answer is based on the standard risk treatment options provided in ISO/IEC 27001, which include avoiding, modifying, sharing, or retaining risks as part of the risk management process

**QUESTION NO: 27**
受限文件和機密文件有什麼差別？
**A.**受限 - 在授權組之間共用
機密 - 在指定個人之間共用
**B.**受限 - 在指定個人之間共用
機密 - 在授權組之間共用
**C.**受限 - 在指定個人之間共用
機密 - 僅在整個組織內共享
**D.**受限 - 在指定個人之間共用
機密 - 與朋友和家人分享
***Answer:*** B
Explanation:
The difference between a restricted and confidential document is that a restricted document is to be shared among named individuals, while a confidential document is to be shared among an authorized group. Restricted and confidential are examples of information classification levels that indicate the sensitivity and value of information and the degree of protection required for it. Restricted documents contain information that could cause serious damage or harm to the organization or its stakeholders if disclosed to unauthorized persons. Therefore, they should only be accessed by specific individuals who have a legitimate need to know and are authorized by the information owner. Confidential documents contain information that could cause damage or harm to the organization or its stakeholders if disclosed to unauthorized persons. Therefore, they should only be accessed by a defined group of people who have a legitimate need to know and are authorized by the information owner. ISO/IEC 27001:2022 requires the organization to classify information in terms of legal requirements, value, criticality and sensitivity to unauthorized disclosure or modification (see clause A.8.2.1). Reference: CQI & IRCA Certified ISO/IEC 27001:2022 Lead Auditor Training Course, ISO/IEC 27001:2022 Information technology - Security techniques - Informatio

ACTUAL4TEST.COM

n security management systems - Requirements, What is Information Classification?

**QUESTION NO: 28**
您是一位經驗豐富的 ISMS
審核團隊負責人，負責對網路服務供應商進行第三方監督審核。您正在檢視組織的風險評估流程是否符合 ISO
/IEC 27001:2022。
以下哪三項審核結果會促使您提出不合格報告？
**A.**兩個系統都包含與保護資訊的機密性、完整性和可存取性無關的額外資訊安全風險
**B.**組織正在按照識別的順序處理資訊安全風險
**C.**組織的資訊安全風險評估流程建議為每個風險分配一個風險負責人
**D.**組織尚未使用 RAG（紅色、琥珀色、綠色）對其資訊安全風險進行分類。
相反，它使用了微笑表情符號、中性表情符號和悲傷表情符號
**E.**組織的風險評估標準尚未經過最高管理層的審查和批准
**F.**組織的資訊安全風險評估流程僅基於對每個風險影響的評估
**G.**組織已將其所有資訊安全風險的機率評估為 0%、25%、
50%、75% 或 100%
**H.**有不同的系統用於評估營運資訊安全風險和評估策略資訊安全風險
***Answer:*** B,E,F
Explanation:
The three audit findings that would prompt you to raise a nonconformity report are:
* The organisation is treating information security risks in the order in which they are identified
* The organisation's risk assessment criteria have not been reviewed and approved by top management
* The organisation's information security risk assessment process is based solely on an assessment of the impact of each risk According to ISO/IEC 27001:2022, clause 6.1.2, the organisation must establish and maintain an information security risk management process that is consistent with the organisation's context and aligned with its overall risk management approach1. This process must include the following steps:
* Establishing the risk assessment criteria, which must be approved by top management and reflect the organisation's risk appetite and objectives2
* Identifying the information security risks, which must consider the assets, threats, vulnerabilities, impacts, and likelihoods3
* Analysing the information security risks, which must determine the levels of risk and compare them with the risk criteria4
* Evaluating the information security risks, which must prioritise the risks and decide whether they need treatment or not5 Therefore, the audit findings B, E, and F indicate that the organisation is not following the required steps of the information security risk management process, and thus are nonconformities with the standard.
The other audit findings are not necessarily nonconformities, as they may be acceptable depending on the organisation's context and justification. For example:
* Audit finding A may be acceptable if the organisation has identified and treated the additional information security risks that are relevant to its scope and objectives, and has documented the rationale for doing so6

* Audit finding C may be acceptable if the organisation has assigned clear roles and responsibilities for the information security risk management process, and has ensured that the risk owners have the authority and competence to manage the risks7
* Audit finding D may be acceptable if the organisation has defined and communicated the meaning and implications of the emoji-based risk classification, and has ensured that it is consistent with the risk criteria and the risk treatment process8
* Audit finding G may be acceptable if the organisation has justified the use of discrete values for the probability of the information security risks, and has ensured that they are realistic and consistent with the risk criteria and the risk analysis method9
* Audit finding H may be acceptable if the organisation has established and maintained different systems for assessing operational and strategic information security risks, and has ensured that they are integrated and aligned with the overall risk management approach and the ISMS objectives10

**QUESTION NO: 29**
下列哪兩項是有效的審計結論？
**A.**ISMS 入門訓練不提供惡意軟體預防的指導
**B.**風險登記冊自 202X 年 6 月以來尚未更新
**C.**兩次內部審核的糾正措施尚未完成
**D.**ISMS 政策已有效傳達給組織
**E.**組織的 ISMS 目標符合 ISO/IEC 27001:2022 的要求
**F.**適用範圍基於 ISO/IEC 27001 2013 版，而非 2022 版
***Answer:*** D,E
Explanation:
The two statements that are valid audit conclusions are:
* The ISMS policy has been effectively communicated to the organisation
* The organisation's ISMS objectives meet the requirements of ISO/IEC 27001:2022
According to ISO 19011:2018, an audit conclusion is the outcome of an audit, provided by the audit team after considering the audit objectives and all audit findings1. An audit conclusion can be positive or negative, depending on whether the audit criteria are fulfilled or not. An audit conclusion can also include recommendations for improvement or recognition of good practices.
The statements D and E are valid audit conclusions, because they express the outcome of the audit based on the audit criteria and findings. For example:
* Statement D is a positive audit conclusion, because it indicates that the organisation has fulfilled the requirement of clause 5.2.2 of ISO/IEC 27001:2022, which states that the ISMS policy must be communicated within the organisation and to relevant interested parties2. The audit team must have obtained sufficient and appropriate audit evidence to support this conclusion, such as records of communication, awareness activities, feedback, etc.
* Statement E is a positive audit conclusion, because it indicates that the organisation has fulfilled the requirement of clause 6.2 of ISO/IEC 27001:2022, which states that the organisation must establish ISMS objectives that are consistent with the ISMS policy and relevant to the information security risks3. The audit team must have obtained sufficient and appropriate audit evidence to support this conclusion, such as records of objective setting, risk assessment, alignment with policy, etc.

ACTUAL4TEST.COM

The other statements are not valid audit conclusions, because they do not express the outcome of the audit based on the audit criteria and findings. They are rather examples of audit findings, which are the results of the evaluation of the collected audit evidence against the audit criteria4. Audit findings can indicate either conformity or nonconformity with the audit criteria, or opportunities for improvement. For example:
* Statement A is a negative audit finding, because it indicates a nonconformity with the requirement of clause 7.2.2 of ISO/IEC 27001:2022, which states that the organisation must provide information security awareness education and training to persons under its control5. The audit team must have identified and documented this nonconformity, and reported it to the auditee.
* Statement B is a negative audit finding, because it indicates a nonconformity with the requirement of clause 6.1.2 of ISO/IEC 27001:2022, which states that the organisation must maintain and review the information security risk assessment at planned intervals or when significant changes occur6. The audit team must have identified and documented this nonconformity, and reported it to the auditee.
* Statement C is a negative audit finding, because it indicates a nonconformity with the requirement of clause 10.1 of ISO/IEC 27001:2022, which states that the organisation must take action to eliminate the causes of nonconformities and prevent recurrence7. The audit team must have identified and documented this nonconformity, and reported it to the auditee.
* Statement F is a negative audit finding, because it indicates a nonconformity with the requirement of clause 6.1.3 of ISO/IEC 27001:2022, which states that the organisation must determine the controls that are necessary to implement the risk treatment plan, and document them in the statement of applicability8. The audit team must have identified and documented this nonconformity, and reported it to the auditee.

**QUESTION NO: 30**
場景 6：Cyber ACrypt
是一家網路安全公司，透過提供反惡意軟體和設備安全、資產生命週期管理和設備加密來提供端點保護。為了根據 ISO/IEC 27001 驗證其 ISMS
並證明其對網路安全卓越的承諾，該公司經歷了由指定審計團隊負責人 John
領導的細緻的審計過程。
在接受審計任務後，John 立即組織了一次會議，概述了審計計劃和團隊角色。他們審查了 Cyber ACrypt
的文檔信息，包括資訊安全政策和操作程序，確保每一份文件都符合標準並具有標準化的格式，包括作者標識、生產日期、版本號和批准日期。這次徹底的檢查旨在確定持續改進和遵守 ISMS 要求。該文件對於審計團隊和 Cyber ACrypt
了解初步審計結果和需要關注的領域至關重要。
審計組也決定對主要相關方進行訪談。這項決定的目的是收集可靠的審計證據來驗證管理系統是否符合 ISO/IEC 27001 的要求。與 Cyber ACrypt
各個層級的相關方進行接觸為審計團隊提供了寶貴的觀點以及對 ISMS
的實施和有效性的理解。
第一階段審計報告揭露了值得關注的關鍵領域。適用性聲明 (SoA) 和 ISMS
政策在多個方面存在缺陷，包括風險評估不足、存取控制不充分以及缺乏定期政策審查。這促使 Cyber ACrypt
立即採取行動來解決這些缺陷。他們對戰略文件的快速回應和修改體現出了對實現合規的堅定承諾。

為了彌補審計團隊的網路安全知識差距而引入的技術專長在識別風險評估方法中的缺陷和審查網路架構方面發揮了關鍵作用。這包括評估防火牆、入侵偵測和預防系統以及其他網路安全措施，以及評估 Cyber ACrypt
如何偵測、回應和恢復外部和內部威脅。在約翰的監督下，技術專家將審計結果傳達給了 Cyber ACrypt
的代表。然而，審計小組發現，由於收取了被審計單位的諮詢費，該專家的客觀性可能受到影響。考慮到技術專家在審核過程中的行為，審核組長決定與認證機構討論這個問題。
根據上述情景，回答以下問題：
在第一階段審計中，審計團隊沒有正確進行哪項活動？
**A.**準備現場活動，包括資訊安全政策和操作程序以供審查
**B.**透過評估 Cyber ACrypt 政策的管理責任來進行現場活動
**C.**記錄第一階段稽核輸出時未包含相關證據或支持文件
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct Answer:
The audit team documented findings, but the scenario does not confirm whether sufficient supporting evidence was included.
ISO 19011:2018 requires audit findings to be properly documented and justified with evidence.
Failing to document evidence reduces audit credibility.
A . Incorrect:
Preparing for the audit by reviewing policies and procedures is correct practice.
B . Incorrect:
Evaluating management responsibility for ISMS compliance is a required step in Stage 1.
Relevant Standard Reference:
ISO/IEC 27001:2022 Clause 9.2 (Internal Audit)

**QUESTION NO: 31**
選擇兩個描述使用清單的優點的選項。
**A.**每次審核都使用相同的清單，無需審核
**B.**限制訪談指定方
**C.**確保遵循相關審核跟踪
**D.**確保審核計畫得到實施
**E.**減少審核時間
**F.**必要時不要改變清單
***Answer:*** C,D
Explanation:
A checklist is a tool that helps auditors to collect and verify information relevant to the audit objectives and scope. It can provide the following advantages:
Ensuring relevant audit trails are followed: A checklist can help auditors to identify and trace the sources of evidence that support the conformity or nonconformity of the audited criteria. It can also help auditors to avoid missing or overlooking any important aspects of the audit.
Ensuring the audit plan is implemented: A checklist can help auditors to follow and fulfil the

ACTUAL4TEST.COM

audit plan, which describes the arrangements and details of the audit, such as the objectives, scope, criteria, schedule, roles, and responsibilities. It can also help auditors to manage their time and resources effectively and efficiently.
The other options are not advantages of using a checklist, but rather:
Using the same checklist for every audit without review: This is a disadvantage of using a checklist, as it can lead to a rigid and ineffective audit approach. A checklist should be tailored and adapted to each specific audit, taking into account the context, risks, and changes of the auditee and the audit criteria. A checklist should also be reviewed and updated periodically to ensure its validity and relevance.
Restricting interviews to nominated parties: This is a disadvantage of using a checklist, as it can limit the scope and depth of the audit. A checklist should not prevent auditors from interviewing other relevant parties or sources of information that may provide valuable evidence or insights for the audit. A checklist should be used as a guide, not as a constraint.
Reducing audit duration: This is not necessarily an advantage of using a checklist, as it depends on various factors, such as the complexity, size, and maturity of the auditee's ISMS, the availability and quality of evidence, the competence and experience of the auditors, and the level of cooperation and communication between the auditors and the auditee. A checklist may help reduce audit duration by improving efficiency and organization, but it may also increase audit duration by requiring more evidence or verification.
Not varying from the checklist when necessary: This is a disadvantage of using a checklist, as it can result in a superficial or incomplete audit. A checklist should not prevent auditors from exploring or investigating any issues or concerns that arise during the audit, even if they are not included in the checklist. A checklist should be used as a support, not as a substitute.
Reference:
ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) objectives and content from Quality.org and PECB ISO 19011:2018 Guidelines for auditing management systems [Section 6.2.2]

**QUESTION NO: 32**
情境 8：EsBank 自 9 月起為愛沙尼亞銀行業提供銀行和金融解決方案
2010年，該公司在全國擁有30家分行和100多台ATM機。
EsBank
在高度監管的行業中運營，必須遵守許多有關資料安全和隱私的法律和法規。他們需要透過實施技術和非技術控制來管理整個營運的資訊安全。 EsBank 決定實施基於 ISO/IEC 的 ISMS 27001，因為它提供了更好的安全性、更多的風險控制以及符合法律法規的關鍵要求。
在成功實施 ISMS 九個月後，EsBank 決定由獨立認證機構根據 ISO/IEC 27001 對其 ISMS 進行認證。
第一階段和第二階段審核是共同進行的，發現了一些不符合項。第一個不合格之處與 EsBank 的資訊標籤有關。該公司有資訊分類方案，但沒有資訊標籤程序。因此，需要相同保護等級的文件將被貼上不同的標籤（有時為機密，有時為敏感）。
考慮到所有文件也以電子方式存儲，不合格情況也影響了媒體處理。審計小組透過抽樣得出結論，200 個可移動媒體中有 50
個儲存了被錯誤分類為機密的敏感資訊。根據資訊分類方案，允許將機密資訊儲存在可移動媒體中，而嚴格禁止儲存敏感資訊。這標誌著另一個不合格之處。
他們起草了不合格報告，並與 EsBank
代表討論了審計結論，代表同意在兩個月內針對發現的不合格問題提交行動計劃。

EsBank
接受了審計組組長提出的解決方案。他們根據實體和電子格式的分類方案起草了資訊標籤程序，解決了不合格問題。可移動媒體程式也基於此程式進行了更新。
審計完成兩週後，EsBank
提交了總體行動計畫。在那裡，他們解決了檢測到的不合格問題以及採取的糾正措施，但沒有包括有關受影響的系統、控製或操作的任何詳細資訊。審核小組評估了該行動計劃並得出結論，該計劃將解決不合格問題。然而，EsBank 收到了不利的認證建議。
根據上述場景，回答以下問題：
場景 8 所示的哪一種行為在外部審計中是不可接受的？
**A.**審核組長提出了解決不符合項的具體解決方案
**B.**第一階段審核與第二階段審核同時進行
**C.**缺乏資訊標籤程序標示為輕微不合格
***Answer:*** A

**QUESTION NO: 33**
場景3：NightCore是一家總部位於美國的跨國科技公司，專注於電子商務、雲端運算、數位串流媒體和人工智慧。在實施資訊安全管理系統 (ISMS) 8
個多月後，他們聘請了認證機構進行第三方審核，以獲得 ISO/IEC 27001 認證。
認證機構成立了一個由七名審核員組成的團隊。傑克是最有經驗的審核員，被任命為審核組組長。多年來，他獲得了許多知名認證，例如 ISO/IEC 27001 首席審核員、CISA、CISSP 和 CISM。
Jack 透過研究和評估 NightCore 實施的每項資訊安全要求和控制，對 ISMS
審查的每個階段進行了全面分析。在第二階段審核期間。傑克發現了一些不合格項。在將購買的軟體許可證發票數量與軟體庫存進行比較後，傑克發現該公司的許多電腦一直在使用非法版本的軟體。他決定要求高階主管對這項違規行為做出解釋，看看他們是否意識到這一點。他的下一步是審計 NightCore 的 IT 部門。高層指派 NightCore 的系統管理員 Tom 擔任指導，陪伴 Jack 和稽核團隊了解系統和數位資產基礎設施的內部運作。
在採訪財務部的一名成員時，審計人員發現該公司最近向其一名顧問進行了一些不尋常的大額交易。收集有關交易的所有必要詳細資訊後。傑克決定直接訪問高階主管。
在討論第一個不合格項時，高階主管告訴傑克，他們願意決定使用複製軟體而不是原始軟體，因為它更便宜。 Jack向NightCore的高層解釋說，使用非法版本的軟體違反了ISO/IEC 27001和國家法律法規的要求。然而，他們似乎對此感到滿意。
在審計幾個月後，Jack 將他在審計期間收集的一些 NightCore 資訊出售給了 NightCore 的競爭對手，以獲取巨額資金。
根據該場景，回答以下問題：
根據場景3，Jack在審計後出售NightCore的資訊時，損害了哪一項審計原則？
**A.**獨立
**B.**誠信
**C.**保密性
***Answer:*** C
Explanation:
Jack compromised the audit principle of confidentiality by selling NightCore's information after the audit. Confidentiality ensures that information is accessible only to those authorized to have access and is protected throughout its lifecycle.

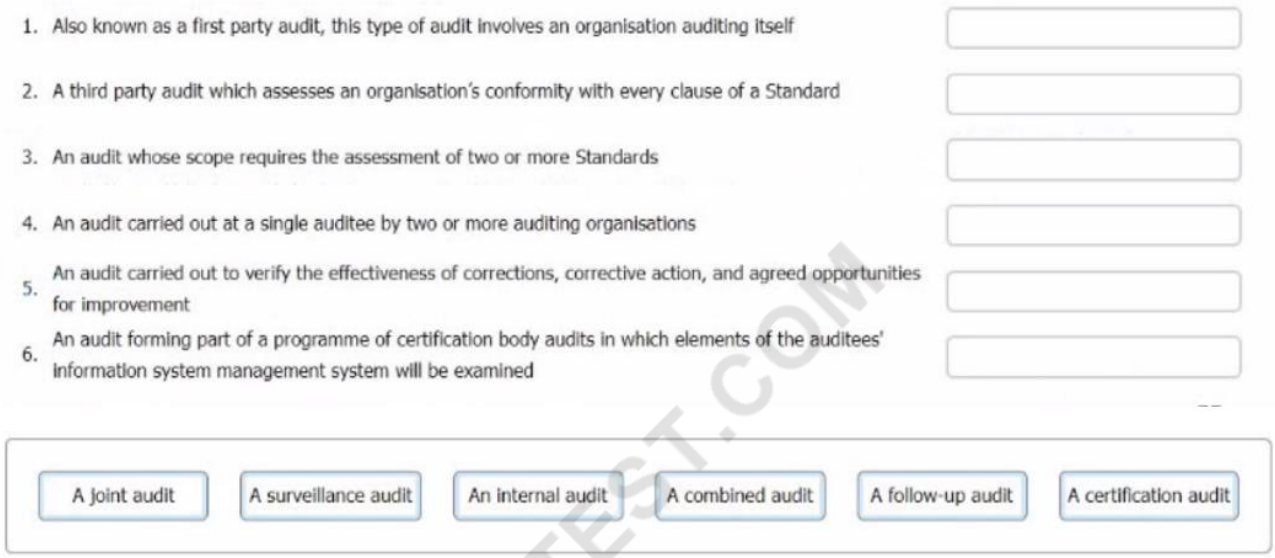
**QUESTION NO: 34**
通過 ISO/IEC 27001
認證的組織範圍規定，他們提供編輯和網站託管服務。然而，由於組織的一些變化，與網站託管服務相關的技術支援已外包。在這種情況下是否應該啟動範圍變更？
**A.**是的，因為外在環境的任何變化都會引發範圍的變化
**B.**否，因為變更不需要實施新的安全控制
**C.**否，因為該組織已獲得編輯和網站託管服務認證
***Answer:*** A
Explanation:
Yes, a change in the scope should be initiated because outsourcing a significant part of the service, such as technical support related to web hosting, could impact the risk landscape and the controls needed to manage those risks. This change affects the external environment and how the ISMS operates, necessitating a scope review and possible adjustment.

**QUESTION NO: 35**
場景 9：Techmanic 是一家比利時公司，成立於 1995 年，目前在布魯塞爾運作。它提供 IT 諮詢、軟體設計和硬體/軟體服務，包括部署和維護。該公司服務於公共服務、金融、電信、能源、醫療保健和教育等行業。作為一家以客戶為中心的公司，它優先考慮建立牢固的客戶關係並引領安全實踐。
Techmanic 已獲得 ISO/IEC 27001
認證一年，並對此認證感到自豪。在認證審核期間，審核員發現其 ISMS
實施上存在一些不一致之處。由於觀察到的情況並不影響其 ISMS
實現預期結果的能力，因此在審計師遠端跟進根本原因分析和糾正措施後，Techmanic
獲得了認證。的遵守情況。認識持續改進的價值並從過去的評估中學習。 Techmanic
實施了審查先前的監督審計報告的做法。這種積極主動的方法不僅有助於識別和解決潛在的不合格情況，而且還旨在簡化 IT 諮詢領域的重新認證流程。
監督審核期間，發現了多處不符合項。 ISMS 繼續滿足 ISO/IEC 27001*s
的要求，但根據內部稽核員的報告，Techmanic
未能解決與託管服務相關的不符合問題。此外，內部稽核報告存在多處不一致之處，這使人們對內部稽核師在託管服務審計過程中的獨立性產生了質疑。基於此，延期認證未獲核准。因此。 Techmanic 請求轉移到另一個認證機構。同時，該公司向客戶發布聲明稱，ISO/IEC 27001 認證涵蓋 IT 服務以及託管服務。
根據上述情景，回答以下問題：
鑑於內部稽核報告中發現的不一致之處，質疑內部稽核師的獨立性是否重要？
**A.**不，內部稽核員只有在監督稽核依賴其調查結果時才應保持獨立
**B.**不，內部稽核師不能獨立，因為他們有顧問角色
**C.**是的，內部稽核員必須獨立於被稽核活動
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct answer:
ISO/IEC 27001:2022 Clause 9.2.2 requires internal auditors to be independent of the activities they audit.
Inconsistencies in the internal audit report raise valid concerns about independence.
A . Incorrect:

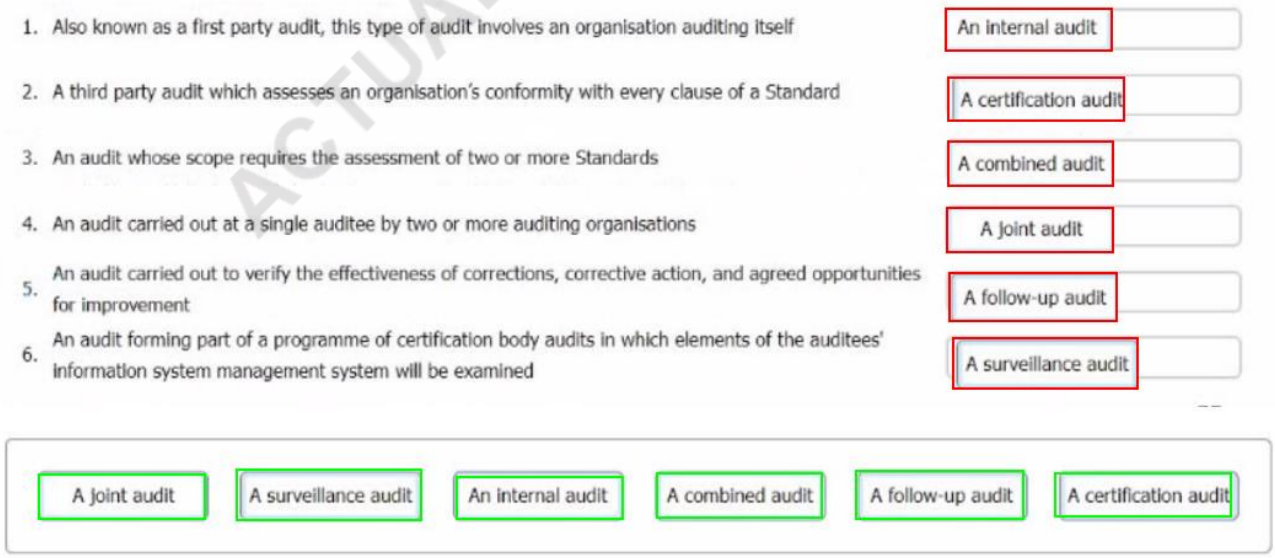
Internal auditors must always be independent, not just for surveillance audits.
B . Incorrect:
Internal auditors have a compliance role, not just an advisory role.
Relevant Standard Reference:

**QUESTION NO: 36**
在可接受的資訊資產使用中，哪一個是最佳實務？
**A.**僅出於商業目的提供資訊和通訊系統的訪問
**B.**幹擾或拒絕提供員工主機以外的任何使用者服務
**C.**在辦公時間玩任何電腦遊戲
**D.**存取電話或網路傳輸，包括無線或 WiFi 傳輸
***Answer:*** A
Explanation:
The best practice in acceptable use of information assets is A: access to information and communication systems are provided for business purpose only. This means that the organization grants access to its information and communication systems only to authorized users who need to use them for legitimate and approved business activities. The organization does not allow or tolerate any unauthorized, inappropriate or personal use of its information and communication systems, as this could compromise information security, violate policies or laws, or cause damage or harm to the organization or its stakeholders. The other options are not best practices in acceptable use of information assets, as they could violate information security policies and procedures, as well as ethical or legal standards. Interfering with or denying service to any user other than the employee's host (B) is a malicious act that could disrupt the availability or performance of the information systems or services of another user or organization. Playing any computer games during office hours is a personal and unprofessional use of the information and communication systems that could distract the employee from their work duties, waste resources and bandwidth, or expose the systems to malware or other risks. Accessing phone or network transmissions, including wireless or wifi transmissions (D) is a potential breach of confidentiality or privacy that could intercept, monitor or modify the information transmitted by another user or organization without their consent or authorization. ISO/IEC 27001:2022 requires the organization to implement rules for acceptable use of assets (see clause A.8.1.3). Reference: CQI & IRCA Certified ISO/IEC 27001:2022 Lead Auditor Training Course, ISO/IEC 27001:2022 Information technology - Security techniques - Information security management systems - Requirements, What i s Acceptable Use?

**QUESTION NO: 37**
您是一位經驗豐富的 ISMS
審核團隊領導者。受訓的審核員已與您聯繫，要求您澄清她可能需要進行的不同類型的審核。將以下審核類型與描述相符。
要填寫表格，請按一下要填寫的空白部分，以便反白顯示“In
fed”，然後從下面的選項中按一下適用的文字。或者，您可以將每個選項拖曳到相應的空白部分。




***Answer:***




**QUESTION NO: 38**
下列關於審計報告的四項敘述是正確的？
**A.**審核報告應由審核小組組長依審核小組的意見製作
**B.**審核報告應包含或引用審核計劃
**C.**審計報告應首先發送給組織的最高管理層，因為其內容可能會令人尷尬
**D.**審計報告應假定適合廣泛傳播，除非特別標示為機密
**E.**審核報告應僅證明不合格狀況
**F.**審核報告應在商定的時間範圍內生成
**G.**不再需要的審計報告可以作為組織一般廢棄物的一部分進行銷毀
**H.**審核報告應始終由客戶審核、註明日期並簽名為"已接受"
***Answer:*** A,B,F,H
Explanation:

According to the PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, the audit reports should be produced by the audit team leader with input from the audit team, as they are responsible for collecting and analysing the audit evidence1. The audit reports should also include or refer to the audit plan, as it provides the basis for the audit objectives, scope, criteria, and methodology2. Furthermore, the audit reports should be produced within an agreed timescale, as it is part of the audit programme management and ensures timely communication of the audit results3. Additionally, the audit reports should always be reviewed by the client, dated, and signed as 'accepted', as it confirms the audit completion and the formal agreement on the audit findings and conclusions4.
The other statements are false because:
Audit reports should not be sent to the organisation's top management first because their contents could be embarrassing, as this would compromise the audit impartiality and confidentiality5. Audit reports should be distributed according to the audit programme procedures and the audit plan.
Audit reports should not be assumed suitable for general circulation unless they are specifically marked confidential, as this would violate the audit confidentiality and the protection of personal information. Audit reports should be treated as confidential documents and only shared with the authorised parties.
Audit reports should not only evidence nonconformity, as this would limit the audit scope and value. Audit reports should also evidence conformity, improvement opportunities, good practices, and audit observations.
Audit reports that are no longer required should not be destroyed as part of the organisation's general waste, as this would pose a risk to the audit confidentiality and the information security. Audit reports should be retained, disposed, or destroyed according to the audit programme procedures and the applicable legal requirements.

**QUESTION NO: 39**
您是一位經驗豐富的 ISMS 審核團隊領導，協助審核員接受培訓，撰寫第一份審核報告。
您想要檢查培訓中的審核員對審核報告內容相關術語的理解，並選擇透過展示以下範例來實現此目的。
對於每個範例，您在培訓中詢問審核員描述活動的正確術語是什麼 將活動與描述進行配對。

| | |
|---|---|
| An auditor using a copy of ISO/IEC 27001:2022 to check that its requirements are met | |
| An auditor's note that the auditee is not adhering to its' clear desk policy | |
| An auditor making a decision regarding the auditee's conformity or otherwise to criteria | |
| An auditor examining verifiable records relevant to the audit process | |

*To complete the table, click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable text from the options below. Alternatively, you may drag and drop each option to the appropriate blank section.*

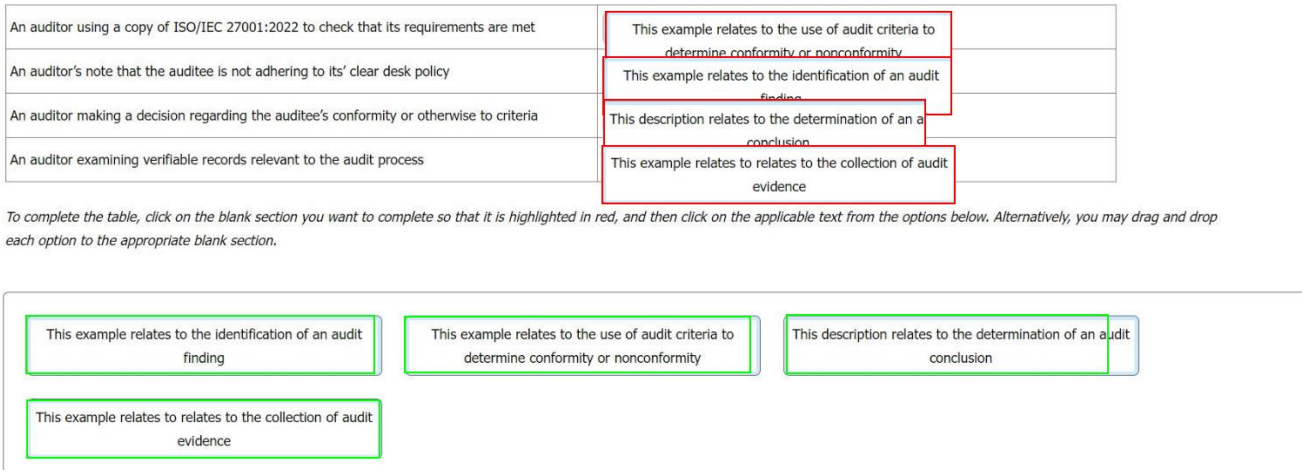
This example relates to the identification of an audit finding

This example relates to the use of audit criteria to determine conformity or nonconformity

This description relates to the determination of an audit conclusion

This example relates to relates to the collection of audit evidence

***Answer:***




**QUESTION NO: 40**
情境 8：EsBank 自 9 月起為愛沙尼亞銀行業提供銀行和金融解決方案
2010年，該公司在全國擁有30家分行和100多台ATM機。
EsBank
在高度監管的行業中運營，必須遵守許多有關資料安全和隱私的法律和法規。他們需要透過實施技術和非技術控制來管理整個營運的資訊安全。 EsBank 決定實施基於 ISO/IEC 的 ISMS 27001，因為它提供了更好的安全性、更多的風險控制以及符合法律法規的關鍵要求。
在成功實施 ISMS 九個月後，EsBank 決定由獨立認證機構根據 ISO/IEC 27001 對其 ISMS 進行認證。
第一階段和第二階段審核是共同進行的，發現了一些不符合項。第一個不合格之處與 EsBank 的資訊標籤有關。該公司有資訊分類方案，但沒有資訊標籤程序。因此，需要相同保護等級的文件將被貼上不同的標籤（有時為機密，有時為敏感）。
考慮到所有文件也以電子方式存儲，不合格情況也影響了媒體處理。審計小組透過抽樣得出結論，200 個可移動媒體中有 50
個儲存了被錯誤分類為機密的敏感資訊。根據資訊分類方案，允許將機密資訊儲存在可移動媒體中，而嚴格禁止儲存敏感資訊。這標誌著另一個不合格之處。
他們起草了不合格報告，並與 EsBank
代表討論了審計結論，代表同意在兩個月內針對發現的不合格問題提交行動計劃。
EsBank
接受了審計組組長提出的解決方案。他們根據實體和電子格式的分類方案起草了資訊標籤程序，解決了不合格問題。可移動媒體程式也基於此程式進行了更新。
審計完成兩週後，EsBank
提交了總體行動計畫。在那裡，他們解決了檢測到的不合格問題以及採取的糾正措施，但沒有包括有關受影響的系統、控製或操作的任何詳細資訊。審核小組評估了該行動計劃並得出結論，該計劃將解決不合格問題。然而，EsBank 收到了不利的認證建議。
根據上述場景，回答以下問題：
哪個選項可以證明不利的認證建議是合理的？請參閱場景 8。
**A.**與在可移動媒體中儲存敏感資訊相關的主要不符合項
**B.**與缺乏資訊標籤程序相關的輕微不合格項
**C.**提交的行動計劃的不切實際的日期（兩週）
***Answer:*** A

**QUESTION NO: 41**

您是經驗豐富的審核團隊領導，指導審核員進行培訓。
您的團隊目前正在對代表外部客戶儲存資料的組織進行第三方監督審核。接受培訓的審核員的任務是審查適用性聲明 (SoA) 中列出的並在現場實施的技術控制措施。
從以下內容中選擇您希望接受培訓的審核員審查的四項控制措施。
**A.**保密與保密協議
**B.**如何管理對原始程式碼和開發工具的訪問
**C.**電源線和資料線如何進入建築物
**D.**如何實施針對惡意軟體的防護
**E.**組織如何評估其技術漏洞的暴露程度
**F.**資訊安全意識、教育與培訓
**G.**機構對資訊刪除的安排
**H.**組織的業務連續性安排
***Answer:*** B,D,E,G
Explanation:
The four controls from the list that the auditor in training should review are:
* B. How access to source code and development tools are managed: This control requires the organisation to restrict and monitor the access to the source code and development tools that are used to create, modify, or maintain the software applications and systems that process or store the data of external clients. This is important for ensuring the integrity, confidentiality, and availability of the software and the data, as well as for preventing unauthorized changes, errors, or malicious code injection.
* D. How protection against malware is implemented: This control requires the organisation to implement appropriate measures to detect, prevent, and remove malware from the IT systems and devices that process or store the data of external clients. This includes using antivirus software, firewalls, email filtering, web filtering, and other tools to protect against viruses, worms, ransomware, spyware, and other malicious software. This is essential for safeguarding the data and the systems from corruption, theft, or damage caused by malware.
* E. How the organisation evaluates its exposure to technical vulnerabilities: This control requires the organisation to identify and assess the technical vulnerabilities that may affect the IT systems and devices that process or store the data of external clients. This includes using vulnerability scanning tools, penetration testing tools, threat intelligence sources, and other methods to discover and evaluate the weaknesses and gaps in the security of the systems and the devices. This is necessary for prioritizing and implementing the appropriate corrective actions and controls to mitigate the risks posed by the vulnerabilities.
* G. The organisation's arrangements for information deletion: This control requires the organisation to establish and implement policies and procedures for deleting the data of external clients from the IT systems and devices when it is no longer needed or required. This includes defining the criteria and methods for data deletion, such as secure erasure, encryption, or physical destruction. This is important for complying with the contractual obligations and the legal and regulatory requirements regarding the retention and disposal of the data, as well as for protecting the confidentiality and integrity of the data.

**QUESTION NO: 42**
您是認證機構指派的 ISMS 審核小組組長，負責對資料中心客戶進行後續審核。
根據 ISO 19011:2018，後續審核的目的是要驗證下列哪一項？

**A.**管理系統的有效性
**B.**ISMS 目標的實施
**C.**風險處理計劃的實施
**D.**糾正措施的完成情況和有效性
***Answer:*** D
Explanation:
The purpose of a follow-up audit is to verify the completion and effectiveness of corrective actions taken by the auditee in response to the nonconformities identified in a previous audit1. A follow-up audit is a type of audit that is conducted after an initial audit, and it focuses on the specific areas where nonconformities were found and corrective actions were agreed upon2. A follow-up audit can be conducted as a separate audit or as part of a scheduled audit, depending on the nature and severity of the nonconformities and the audit programme objectives3.
The other options are not the purpose of a follow-up audit, but rather the purpose of other types of audits. For example:
* Option A is the purpose of a performance audit, which is a type of audit that evaluates the effectiveness of the management system in achieving its intended results4.
* Option B is the purpose of a compliance audit, which is a type of audit that verifies the conformity of the management system with the specified requirements, such as the ISMS objectives5.
* Option C is the purpose of a process audit, which is a type of audit that examines the inputs, activities, outputs, and interactions of a specific process within the management system, such as the risk treatment process.

**QUESTION NO: 43**
身為稽核員，您注意到 ABC Inc. 已經建立了管理可移動儲存媒體的程式。該程式基於 ABC Inc.
採用的分類方案。但是，公開資訊沒有保密性要求，因此只適用完整性和可用性控制。這是什麼類型的審計發現？
**A.**不符合
**B.**異常
**C.**一致
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct Answer:
The classification-based security approach aligns with ISO/IEC 27001:2022 Annex A Control A.5.12 (Classification of Information).
The organization is applying a security control in accordance with the classification policy, ensuring conformity to information security best practices.
A . Incorrect:
Nonconformity occurs when a process does not comply with ISO/IEC 27001 requirements. However, in this case, the classification system is correctly implemented.
B . Incorrect:
Anomaly refers to unexpected deviations in operations, but this is an intentional

ACTUAL4TEST.COM

implementation.
Relevant Standard Reference:

**QUESTION NO: 44**
下列哪一個選項不是審核組組長的角色？
**A.**審核期間預防與解決衝突
**B.**設立道德委員會
**C.**準備並解釋審核結論
***Answer:*** B
Explanation:
The role of the audit team leader does not include setting up an ethics committee. The primary responsibilities of the audit team leader include planning the audit, directing the activities of the audit team, ensuring compliance with the auditing standards, managing conflicts that arise during the audit, and presenting audit conclusions.

**QUESTION NO: 45**
場景七：Webvue。總部位於日本，是一家專門從事電腦軟體開發、支援和維護的技術公司。Webvue 提供跨各個技術領域和業務領域的解決方案。其旗艦服務是CloudWebvue，一個提供儲存、網路和虛擬運算服務的綜合雲端運算平台。專為企業和個人用戶設計。 CloudWebvue 以其靈活性、可擴展性和可靠性而聞名。
Webvue 決定僅將 CloudWebvue 納入其 ISO/IEC 27001 認證範圍。因此，第 1 階段和第 2 階段審計同時進行 Webvue
以其對資產保密的嚴格性而自豪，他們使用適當的加密控制來保護儲存在 CloudWebvue 中的資訊。任何機密級別的每條信息，無論是否供內部使用。受限的或機密的資訊首先用唯一的對應哈希值加密，然後儲存在雲端。肖恩。萊拉，山姆。和 Tin a。 Keith 是 IT 和資訊安全審計團隊中最有經驗的審計員，也是審計團隊的負責人。他的職責包括規劃審計和管理審計團隊。尚實踐生成的。在檢查了 Webvue
的加密政策後，他們得出結論，採訪中獲得的資訊是真實的。然而，由於該策略沒有解決加密金鑰的使用和壽命問題，因此加密金鑰仍在使用中。
依照 Webvue 和認證機構後來達成的協議，審計團隊選擇進行虛擬審計，專門專注於驗證 Webvue 是否符合 ISO/IEC 27001 的控制 8.11
資料屏蔽，以符合認證範圍和審計目標。他們檢查了 CloudWebvue 中保護資料所涉及的流程。重點關注公司如何遵守其政策和監管標準。作為此過程的一部分。審計團隊負責人 Keith 對相關文件和加密金鑰管理程序進行了截圖，以記錄和分析 Webvue 實踐的有效性。
Webvue 使用產生的測試資料用於測試目的。然而，根據與 QA 部門經理的訪談以及該部門使用的程序確定，有時會使用即時系統資料。在這樣的場景中，會產生大量數據，同時產生更準確的結果。測試資料受到保護和控制，這透過 Webvue 人員在審計期間執行的加密過程模擬得到驗證。儘管不在審計範圍之內，但安全培訓部門的不合規情況可能會對審計範圍內的流程產生影響，具體會影響 CloudWebvue 中的資料安全和加密實踐。因此，Keith將此發現納入審計報告中，並告知被審計方。
根據上述情景，回答以下問題：
在虛擬審計期間，Keith 是否對 Webvue 的文件做出了適當的決定？
**A.**是的，允許在未經事先許可的情況下對文件副本進行截圖，前提是審計過程沒有被記錄
**B.**不，因為他在截取文件副本的截圖之前應該已經取得許可

**C.**不可以，因為在虛擬審計期間根本不允許截圖複製

***Answer:*** B

Explanation:

Comprehensive and Detailed In-Depth

B . Correct Answer:

ISO 19011:2018 mandates that auditors must obtain permission before making copies of documents.

Virtual audits must adhere to confidentiality agreements to protect sensitive data.

A . Incorrect:

Screenshots cannot be taken without permission, even if the audit is not recorded.

C . Incorrect:

Screenshots are allowed with prior authorization, ensuring proper data handling.

Relevant Standard Reference:

**QUESTION NO: 46**

設想：

Northstorm

是一家線上零售商店，提供獨特的復古和現代配件。它最初進入了一個小型市場，但隨著整個電子商務格局的發展而逐漸發展壯大。 Northstorm

專門在線上工作，確保高效的付款處理、庫存管理、行銷工具和出貨訂單。它採用優先排序來接收、補貨和運送其最受歡迎的產品。

Northstorm

傳統上透過託管其網站並完全控制其基礎架構（包括硬體、軟體和資料管理）來管理其 IT 營運。然而，由於缺乏響應的基礎設施，這種方法阻礙了其發展。為了增強其電子商務和支付系統，Northstorm

選擇擴展其內部資料中心，並在三個月內分兩個階段完成擴建。最初，該公司升級了其核心伺服器、銷售點、訂購、計費、資料庫和備份系統。第二階段涉及改善郵件、付款和網路功能。此外，在此階段，Northstorm 採用了針對個人識別資訊 (PII) 控制者和 PII

處理者的國際標準，以確保其資料處理實務安全並符合全球法規。

儘管進行了擴張，但 Northstorm

升級後的資料中心仍未能滿足其不斷變化的業務需求。這種不足導致了一些新的挑戰，包括訂單優先事項問題。客戶報告未收到優先訂單，且公司難以迅速回應。這主要是因為主伺服器無法處理來自 YouDecide 的訂單，YouDecide

是一款旨在優先處理訂單和模擬客戶互動的應用程式。該應用程式依賴先進的演算法，與升級期間安裝的新作業系統（OS）不相容。

面對緊急的兼容性問題，Northstorm

在沒有經過適當驗證的情況下迅速修補了應用程序，導致安裝了受損版本。這次安全漏洞導致主伺服器受到影響，該公司的網站離線一週。認識到需要更可靠的解決方案，該公司決定將其網站託管外包給電子商務提供者。該公司簽署了有關產品所有權的保密協議，並在過渡之前對使用者存取權限進行了徹底審查，以增強安全性。

下列哪一種情況代表 Northstorm 系統存在漏洞？

**A.**應用程式的新版本直接影響了主伺服器

**B.**需要更換應用程式版本

**C.**應用程式的新版本不合法

***Answer:*** C

Explanation:
Comprehensive and Detailed In-Depth
A vulnerability in information security refers to a weakness in a system, process, or software that can be exploited, leading to security incidents. In this case, the most significant vulnerability in Northstorm's system was the installation of an illegitimate (compromised) version of the application, which directly impacted the main server and resulted in system downtime.
A . The new version of the application directly affecting the main server is an outcome rather than the vulnerability itself. The reason it affected the server was due to its compromised nature.
B . The need for a replacement version of the application is not a vulnerability but rather a necessity due to the incompatibility issue introduced by the OS upgrade.
C . The new version of the application being illegitimate is the true vulnerability because it represents an unauthorized or unverified change that introduced malicious code or other security risks. This could have been mitigated by proper validation, secure software development practices, and adherence to change management policies outlined in ISO/IEC 27001:2022 Annex A controls:
A .8.8 Management of Technical Vulnerabilities - Ensures that systems and applications are updated and maintained securely.
A .8.9 Configuration Management - Covers proper software deployment and validation procedures.
A .8.14 Redundancy of Information Processing Facilities - Ensures resilience to failures like server downtimes.

**QUESTION NO: 47**
在第三方認證審核的背景下，哪兩個選項規定了審核組長在管理審核和審核小組的管理職責？
**A.**採訪 ISMS 經理
**B.**採用風險為本的方法來規劃審核
**C.**審核高階管理人員
**D.**與受審核方建立聯繫
**E.**頒發管理體系證書
**F.**準備審核不合格報告
***Answer:*** B,D
Explanation:
In the context of a third-party certification audit, the management responsibilities of the audit team leader in managing the audit and the audit team include adopting a risk-based approach to planning the audit and establishing contact with the auditee. A risk-based approach to planning the audit means that the team leader should consider the risks and opportunities that may affect the achievement of the audit objectives, the scope and criteria, the audit methods and techniques, the allocation of resources and the assignment of tasks to the audit team members. Establishing contact with the auditee means that the team leader should communicate with the auditee before, during and after the audit, to confirm the audit arrangements, to obtain relevant information, to address any issues or concerns, to provide feedback and to report the audit results and conclusions. Reference: = ISO 19011:2022, clauses 6.4.1 and 6.4.2; PECB Candidate Handbook ISO 27001 Lead Auditor, pages 24 and

25.

**QUESTION NO: 48**
使用審計測試計劃組合的目的是什麼？
**A.**透過多種方法驗證是否符合標準和準則
**B.**確保組織的所有領域都受到平等的審計
**C.**減少頻繁審計的需要
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
Combining multiple audit test plans ensures different perspectives and validation techniques are applied, improving audit accuracy.
ISO 19011:2018 encourages a diversified approach to auditing to ensure comprehensive results.
B . Incorrect:
Not all areas require equal auditing-risk-based focus is preferred.
C . Incorrect:
Frequent audits may still be required depending on organizational needs.
Relevant Standard Reference:

**QUESTION NO: 49**
下列哪一項最能描述第一階段第三方審核的主要目的？
**A.**向客戶介紹審核團隊
**B.**了解組織的採購狀況
**C.**確定第 2 階段審核的紅色程度
**D.**檢查組織是否遵守法律
**E.**準備獨立審計報告
**F.**了解組織的客戶
***Answer:*** C
Explanation:
The main purpose of a Stage 1 third-party audit is to determine readiness for a Stage 2 audit. A Stage 1 audit is a preliminary assessment that evaluates the organization's ISMS documentation, scope, context, and objectives, and identifies any major gaps or nonconformities that need to be addressed before the Stage 2 audit. A Stage 1 audit does not introduce the audit team to the client, as this is done during the audit planning phase. A Stage 1 audit does not check for legal compliance by the organization, as this is done during the Stage 2 audit. A Stage 1 audit does not prepare an independent audit report, as this is done after the Stage 2 audit. Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 70. : ISO/IEC 27001 LEAD AUDITOR - PECB, page 23.

**QUESTION NO: 50**
下列哪兩個選項不參與 ISO/IEC 27001 的第二方審核？
**A.**由審核員認證機構認證的審核員

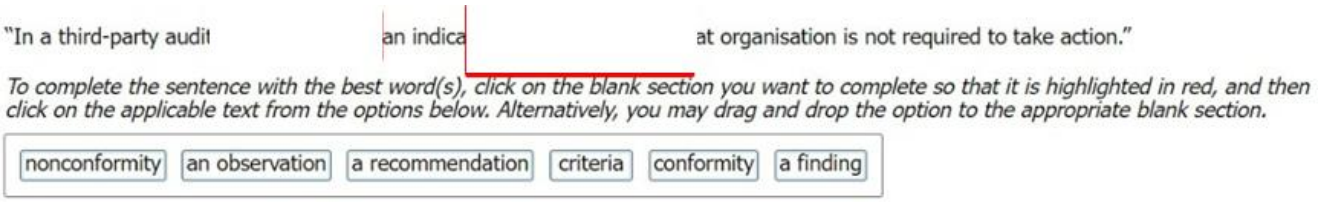
ACTUAL4TEST.COM

**B.**認證機構聘用的審核員
**C.**外部諮詢機構聘用的審核員
**D.**來自認證機構的審核員
**E.**接受過 CQI 和 IRCA 計畫訓練的審核員
**F.**客戶的內部稽核員
***Answer:*** D,E
Explanation:
* Second-Party Audits: These involve an organization (the customer) auditing another organization with which it has a relationship (such as a supplier). The focus is on ensuring the supplier meets the customer's information security requirements.
* Accreditation Bodies: These assess the competence of certification bodies but don't directly participate in second-party audits.
* CQI and IRCA: These organizations provide auditor certifications but their training alone doesn't automatically qualify someone for second-party ISO/IEC 27001 audits. The auditor should have specific knowledge of the standard.
Reference:
* ISO/IEC 17021-1:2015 Conformity assessment - Requirements for bodies providing audit and certification of management systems: Provides requirements for certification bodies but also outlines how first-, second-, and third-party audits work.

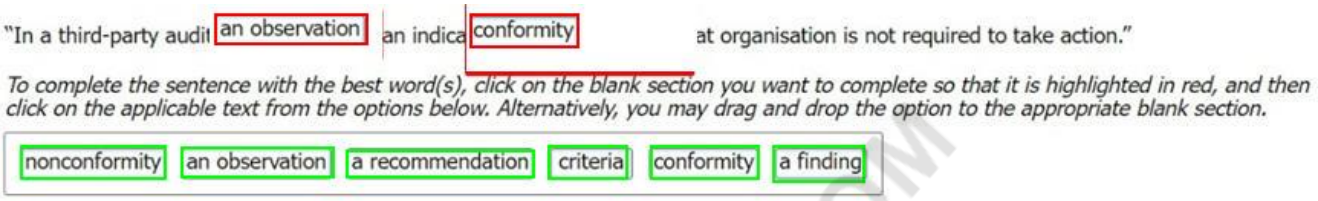
**QUESTION NO: 51**
為什麼在初次接觸時要考慮重要性？
**A.**確定審核時長
**B.**定義審計團隊角色
**C.**設定稽核目標
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct Answer:
Materiality helps auditors identify significant areas for audit focus and is used to set audit objectives appropriately.
Materiality determines which processes, risks, or controls are critical for achieving effective ISMS implementation.
A . Incorrect:
Materiality affects audit scope but does not directly determine duration.
B . Incorrect:
Team roles are assigned based on expertise, not materiality considerations.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.2.3 (Determining Feasibility of Audit)

**QUESTION NO: 52**
選出最能完成句子的單字：

ACTUAL4TEST.COM




***Answer:***




**QUESTION NO: 53**
下列哪一個選項關於審計計畫是正確的？
**A.**審計計劃涉及使用多種審計程序
**B.** 審計計劃應具有彈性，以便進行修改
**C.**受審計方高階管理人員制定審計計劃
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:
Audit plans must remain flexible to adapt to unforeseen findings and risks.
ISO 19011:2018 specifies that audit planning should allow dynamic adjustments.
A . Incorrect:
Audit procedures are part of execution, not planning.
C . Incorrect:
The audit team, not top management, prepares the audit plan.
Relevant Standard Reference:
ISO 19011:2018 Clause 5.4 (Audit Planning Flexibility)

**QUESTION NO: 54**
一家電信公司使用 AES 方法來確保機密資訊受到保護。
這意味著他們使用單一密鑰來加密和
解密資訊。公司使用什麼樣的控制？
**A.**偵探
**B.**修正
**C.**預防性
***Answer:*** C
Explanation:
The AES (Advanced Encryption Standard) method is a symmetric-key algorithm, meaning the same key is used for both encrypting and decrypting data1. This type of control is considered preventive because it is implemented to prevent unauthorized access to confidential information by ensuring that the data is unreadable to anyone who does not have the key. Reference: = The explanation is based on the general understanding of encryption as a security control within the field of information security, particularly as it pertains to the

ACTUAL4TEST.COM

ISO/IEC 27001 standard for information security management systems (ISMS), which includes encryption as a preventive control measure.

**QUESTION NO: 55**
情境 6：Sinvestment
是一家提供家庭保險、商業保險和人壽保險的保險公司。該公司成立於北卡羅來納州，但最近在其他地區進行了擴張，包括歐洲和非洲。
Sinvestment
致力於遵守適用於其行業的法律法規，並防止任何資訊安全事件。他們實施了基於 ISO/IEC 27001 的 ISMS 並申請了 ISO/IEC 27001 認證。
認證機構指派兩名審核員進行審核。與Sinvestment簽訂保密協議後。他們開始了審計活動。首先，他們審查了標準要求的文件，包括 ISMS
範圍聲明、資訊安全政策和內部稽核報告。審查過程並不容易，因為儘管 Sinvestment
表示他們已製定文件程序，但並非所有文件都具有相同的格式。
隨後，審計小組對Sinvestment的高階主管進行了多次訪談，以了解他們在ISMS實施中的作用。第一階段審計的所有活動都是遠端進行的，除了根據 Sinvestment
的要求在現場進行的文件資訊審查之外。
在此階段，審計人員發現沒有與資訊安全培訓和意識計劃相關的文件。被問及時，Sinvestment代表表示，公司已為所有員工提供資訊安全培訓課程。第一階段審計讓審計團隊對 Sinvestment 的營運和 ISMS 有了整體了解。
第二階段審核在第一階段審核三週後進行。審計小組觀察到，行銷部門（未包含在審計範圍內）沒有適當的程序來控制員工的存取權限。由於控制員工的存取權限是ISO/IEC 27001的要求之一，並且已包含在公司的資訊安全政策中，因此該問題包含在審計報告中。此外，在第二階段審計中，審計小組觀察到Sinvestment沒有記錄使用者活動日誌。
該公司的程序規定“記錄用戶活動的日誌應保留並定期審查”，但該公司沒有提供任何執行該程序的證據。
在所有審核活動中，審核員透過觀察、訪談、文件化資訊審查、分析和技術驗證來收集資訊和證據。對第一階段和第二階段的所有審核結果進行了分析，審核小組決定發布積極的認證建議。
在第一階段審核中，審核小組發現Sinvestment沒有資訊安全訓練和意識的記錄。在這種情況下，Sinvestment 會做什麼？請參閱場景 6。
**A.**在第 2 階段審核之前修正已識別的問題
**B.**記錄已識別的問題並在認證審核完成後進行更正
**C.**執行新的風險評估流程以了解問題是否需要修改
***Answer:*** A
Explanation:
Sinvestment should correct the identified issue related to the lack of documentation on information security training and awareness before the stage 2 audit. Addressing this gap promptly ensures that the ISMS is fully compliant and effective when assessed in the subsequent audit stage.

**QUESTION NO: 56**
審核小組負責人為 ISO/IEC 27001:2022 的初始認證第 2 階段審核準備審核計畫。
下列哪一項敘述是正確的？
**A.**審核小組負責人應確保審核得到技術專家的支持

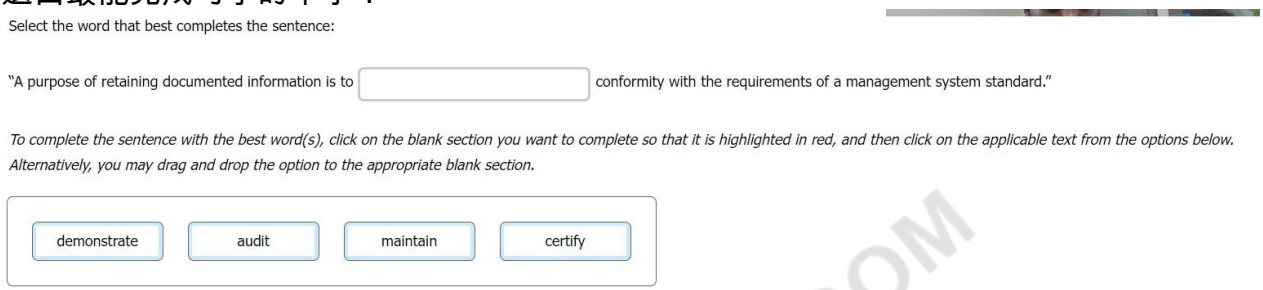
**B.**審核小組組長應任命具有 IT 經驗的審核小組成員
**C.**審核小組負責人應計劃在範圍內採訪每位員工
**D.**組織應審查審核計劃以獲得一致意見
***Answer:*** D
Explanation:
* D. This statement is true because the audit team leader should communicate the audit plan to the audit client and the auditee, and obtain their approval before conducting the audit12. The audit plan should include the audit objectives, scope, criteria, methods, schedule, resources, roles and responsibilities, and other relevant information12. The audit plan should also be reviewed and updated as necessary during the audit process, and any changes should be agreed upon by the audit team leader, the audit client, and the auditee12. The purpose of reviewing and agreeing on the audit plan is to ensure that the audit is conducted in an efficient and effective manner, and that the audit expectations and requirements are clear and consistent among all parties involved.
References:
1: PECB Candidate Handbook - ISO 27001 Lead Auditor, page 23 2: ISO 19011:2018 - Guidelines for auditing management systems, clause 6.4.2

**QUESTION NO: 57**
身為資訊安全管理系統審核小組組長，您正在代表一家線上零售商對一家國際物流公司進行第二方審核。在審核期間，您的一名團隊成員報告了與 ISO/IEC 27001 附錄 A 的控制 5.18（存取權限）相關的不合格項：
2022 年。 她發現證據表明，刪除過去 3 個月內離開的 20 名人員的伺服器存取協定需要長達 1 週的時間，而政策要求在他們離開後 24 小時內刪除存取權限。
當被審核方被問及為何延遲刪除訪問權限時，他們回答說，“由於 COVID-19 的影響，IT 部門在此期間沒有人可用。”一旦 IT 官員出現，這些權利就被取消。
您注意到她打算針對存取權限控制 (5.18) 提出輕微不符合項。對此你該如何回應？
**A.**同意提出輕微不合格項，但反對控制措施 5.15，而不是 5.18。
**B.**同意針對 5.18 提出輕微不符合項。
**C.**不同意提出輕微合規性，因為已儘早採取適當行動，不再採取進一步行動。
**D.**不同意提出輕微不符合項，因為已儘早採取適當行動。相反，提出改進的機會。
**E.**不同意提出輕微不符合項，有足夠的證據證明昇級為重大不符合項是合理的。
**F.**在確定不合格項是否適當之前，需要先取得額外的審核證據。
***Answer:*** A

**QUESTION NO: 58**
以下是資訊的定義，但以下情況除外：
**A.**準確及時的數據
**B.**用於特定目的的特定且有組織的數據
**C.**成熟且可衡量的數據
**D.**可以促進理解並減少不確定性
***Answer:*** C
Explanation:
The definition of information that is not correct is C: mature and measurable data. This is not

a valid definition of information, as information does not have to be mature or measurable to be considered as such. Information can be any data that has meaning or value for someone or something in a certain context. Information can be subjective, qualitative, incomplete or uncertain, depending on how it is interpreted or used. Mature and measurable data are characteristics that may apply to some types of information, but not all. The other definitions of information are correct, as they describe different aspects of information, such as accuracy and timeliness (A), specificity and organization (B), and understanding and uncertainty reduction (D). ISO/IEC 27001:2022 defines information as "any data that has meaning" (see clause 3.25). Reference: CQI & IRCA Certified ISO/IEC 27001:2022 Lead Auditor Training Course, ISO/IEC 27001:2022 Information technology - Security techniques - Informatio n security management systems - Requirements, What is Information?

**QUESTION NO: 59**
選出最能完成句子的單字：




***Answer:***




ACTUAL4TEST.COM

**QUESTION NO: 60**
哪一項不是 HR 在招募前的要求？
**A.**接受背景驗證
**B.**申請人必須完成就業前文件要求
**C.**必須接受資訊安全意識訓練。
**D.**必須成功通過背景調查
***Answer:*** C
Explanation:
According to ISO/IEC 27001:2022, clause 7.2.2, the organization shall ensure that all persons who have access to information are aware of the information security policy and their contribution to the effectiveness of the ISMS, including the benefits of improved information security performance2. Therefore, awareness training on information security is a requirement for all persons, not just new hires. Reference: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) | CQI | IRCA

**QUESTION NO: 61**
風險評估過程中滲透測試的目標是什麼？
**A.**進行徹底的程式碼審查
**B.** 辨識 ICT 保護方案中的潛在故障
**C.**實體檢查硬體組件
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
Penetration testing (pen testing) is a simulated cyberattack used to assess security weaknesses in an ICT system.
B). Identifying failures in ICT protection schemes - Correct answer.
The goal of penetration testing is to find vulnerabilities in networks, applications, and systems before attackers can exploit them.
This aligns with ISO/IEC 27001:2022 Annex A Control A.8.16 (Monitoring Activities) and A.8.8 (Management of Technical Vulnerabilities).
A). Code reviews are not the primary goal of pen testing; static analysis tools are used for code security.
C). Physical inspections relate to hardware security audits, which are separate from penetration testing.

**QUESTION NO: 62**
情境 5：Data Grid Inc.
是一家知名公司，為整個資訊科技基礎設施提供安全服務。它提供網路安全軟體，包括端點安全、防火牆和防毒軟體。二十年來，Data Grid Inc.
透過先進的產品和服務幫助多家公司保護其網路安全。 Data Grid Inc.
在資訊和網路安全領域享有盛譽，決定獲得 ISO/IEC 27001
認證，以更好地保護其內部和客戶資產並獲得競爭優勢。
Data Grid Inc. 任命了審計團隊，該團隊同意審計任務的條款。此外，Data Grid Inc.明確了審核範圍，明確了審核標準，並建議在五天內結束審核。由於Data Grid Inc.員工人數眾多，流程複雜，審計小組拒絕了Data Grid Inc.在五天內進行審計的提議。 Data Grid
Inc.堅稱他們計劃在五天內完成審核，因此雙方同意在規定的時間內進行審核。審計小組遵循基於風險的審計方法。
為了獲得主要業務流程和控制的概述，審計團隊存取了流程描述和組織圖表。他們無法對 IT 風險和控制進行更深入的分析，因為他們對 IT
基礎架構和應用程式的存取受到限制。然而，審計小組表示，Data Grid Inc. 的 ISMS 出現重大缺陷的風險很低，因為該公司的大部分流程都是自動化的。因此，他們透過詢問 Data Grid Inc. 的代表以下問題來評估 ISMS 整體上符合標準要求：
*如何定義和指派 IT 和 IT 控制的職責？
*Data Grid Inc. 如何評估控制措施是否達到了預期效果？
*Data Grid Inc. 採取了哪些控制措施來保護操作環境和資料免受惡意軟體的侵害？
*是否實施了與防火牆相關的控制？
Data Grid Inc. 的代表提供了充分且適當的證據來解決所有這些問題。
審計組長起草審計結論並向Data Grid Inc. 的最高管理階層報告。
儘管審核員推薦Data Grid Inc.進行認證，但Data Grid

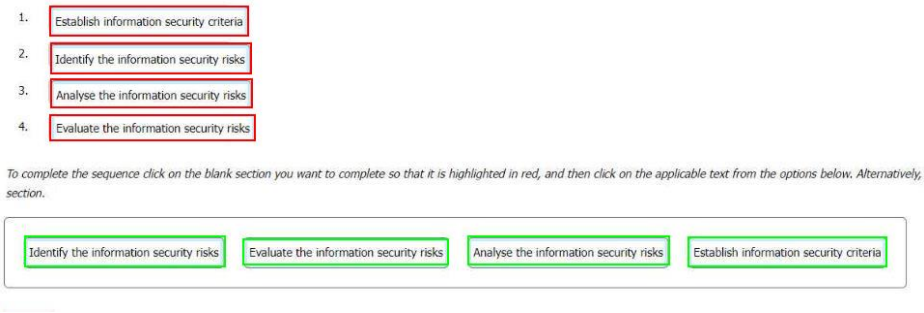
Inc.與認證機構之間在審核目標方面產生了誤解。 Data Grid Inc.
表示，儘管審計目標包括確定潛在改進的領域，但審計團隊並未提供此類資訊。
根據該場景，回答以下問題：
基於情境5，審核小組對ISMS進行整體評估，而不是評估每個流程的有效性和符合性。這是可以接受的嗎？
**A.**是的，由於審核完成的時間有限，審核團隊必須透過整體評估 ISMS 來獲得絕對保證
**B.**不，審核團隊應透過評估每個流程來確保 ISMS 符合標準要求
**C.**是，如果審核團隊已獲得合理的保證來幫助他們評估 ISMS 合規性
***Answer:*** C
Explanation:
Yes, assessing the ISMS as a whole can be acceptable if the audit team obtains reasonable assurance that the system conforms to the standard requirements. The approach taken by the audit team must still ensure that all significant aspects of the ISMS are evaluated adequately, and if this is achieved through a holistic assessment, it is considered sufficient.

**QUESTION NO: 63**
下列哪一項最能定義管理控制？
**A.**與人員管理相關的控制，包括員工訓練、管理評審和內部稽核
**B.**與組織結構相關的控制，例如職責劃分、工作輪調、職位說明和審批流程
**C.**與使用技術措施或技術相關的控制，例如防火牆、警報系統、監視器和入侵偵測系統
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
Managerial controls (also called administrative controls) include policies, procedures, and processes to ensure effective security governance. These controls include training, internal audits, security awareness programs, and management reviews. These align with ISO/IEC 27001:2022 Annex A Control A.5.2 (Information Security Roles and Responsibilities) and A.5.3 (Segregation of Duties).
B . Organizational structure controls relate to segregation of duties and job rotations, making them structural controls rather than purely managerial.

**QUESTION NO: 64**
為 ISMS 中的資訊安全風險評估流程選擇正確的順序。
要完成序列，請按一下要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，您可以將選項拖曳到適當的空白處




***Answer:***




**QUESTION NO: 65**

您正在一家名為 ABC 的提供醫療保健服務的住宅療養院進行 ISMS 審核。
審核計劃的下一步是驗證 ABC
醫療保健行動應用程式開發、支援和生命週期流程的資訊安全性。在審核過程中，您了解到該組織將行動應用程式開發外包給了經過CMMI 5 級、ITSM (ISO/IEC 20000-1)、BCMS (ISO 22301) 和ISMS (ISO/IEC 27001) 認證的專業軟體開發組織。
IT經理介紹了軟體安全管理流程，並將流程總結如下：
行動應用程式開發至少應採用「設計安全」和「預設安全」原則。應具備以下個人資料保護安全功能：
存取控制。
個人資料加密，即高階加密標準（AES）演算法，金鑰長度：256位元；個人資料假名化。
已檢查漏洞，無安全後門
您採樣最新的行動應用測試報告 - 參考 ID：0098，詳細資訊如下：

| Target of Test: ABC's healthcare mobile app, version 1 | Test results | Test summary |
|---|---|---|
| **Performance test** | | |
| Response time | GOOD | Sampling 20 users, aged between 15-20, all of them feel good about the response time. |
| Useability and user interface | GOOD | Sampling 20 users, aged between 15-20, all of them feel good about the user interface, size of the text, and colour. |
| **Security test** | | |
| Access control (username and password) | PASS | Compliance with the organisation's information security policy, unique username and minimal 12 digits password (with Capital/Lower case, numbers, symbols combination) |
| Access control – One-time-password (OTP) | PASS | The mobile app generates an 8-digit OTP and sends it to an authorised user's mobile phone via SMS, as a second factor of identity authentication. |

ACTUALTEST.COM

| | | |
|---|---|---|
| Personal data encryption | Fail | Not able to perform the encryption. |
| Personal data pseudonymization | Fail | Not able to perform the pseudonymization. |
| **Final approval:** | | |
| by: *Service Manager* | | signed |

您想進一步調查其他領域以收集更多審計證據。選擇三個不會出現在您的審核追蹤中的選項。
**A.**收集更多證據，了解居民家庭成員為安裝 ABC 的醫療保健行動應用程式支付的費用。（與第4.2條相關）
**B.**透過在手機上下載並測試行動應用程式來收集更多證據。（與控制 A.8.1 相關）
**C.**收集更多證據以確定 ABC 醫療保健行動應用程式的使用者數量。（與第4.2條相關）
**D.**收集更多有關組織如何執行個人資料處理測試的證據。（與控制措施 A.5.34 相關）
**E.**收集更多有關組織業務連續性政策的證據。（與控制措施 A.5.30 相關）
**F.**收集更多有關組織在選擇外部服務提供者時如何管理資訊安全的證據。（與控制措施 A.5.19 相關）
**G.**收集更多有關開發人員如何培訓其產品支援人員的證據。（與第7.2條相關）
**H.**收集更多證據來驗證開發人員的 CMMI Level 5、ITSM (ISO/IEC 20000-1)、BCMS (ISO22301) 和 ISMS (ISO/IEC 27001) 認證。（與控制措施 A.5.21 相關）
***Answer:*** A,C,H
Explanation:
The three options that will not be in your audit trail are A, C, and H. These options are either not relevant to the information security of ABC's healthcare mobile app development, support, and lifecycle process, or not within the scope of your audit. The amount of money that residents' family members pay to install the app (A) and the number of users of the app are not related to the information security aspects or objectives of the ISMS1. The verification of the developer's certifications (H) is not your responsibility as an ISMS auditor, as you should rely on the competence and impartiality of the certification bodies that issued them2. The other options are relevant and within the scope of your audit, as they relate to the security functions, testing, policies, and procedures of the mobile app development, support, and lifecycle process13. Reference: 1: ISO/IEC 27001:2022, Information technology - Security techniques - Information security management systems - Requirements, Clause 4. 2 \n2: ISO/IEC 27006:2022, Information technology - Security techniques - Requirements fo r bodies providing audit and certification of information security management systems, Clause 4.1 \n3: PECB Certified ISO/IEC 27001 Lead Auditor Exam Preparation Guide, Domain 5: Conducting an ISO/IEC 27001 audit

**QUESTION NO: 66**
作為審計員，您已經注意到 ABC Inc. 已製定了管理可移動儲存媒體的程序。該程式基於 ABC Inc.
採用的分類方案。另一方面，被歸類為「公共」的資訊沒有保密要求：因此，僅適用確保其完整性和可用性的程序。這是什麼類型的審計結果？
**A.**不合格

**B.**異常

**C.**一致性

***Answer:*** C

Explanation:

This scenario represents a conformity because ABC Inc. has implemented procedures for managing removable storage media that align with the classification scheme of the information stored. When information is classified as "confidential," more stringent procedures apply, whereas for "public" information, the procedures focus only on integrity and availability, following the organization's defined information classification policy.

**QUESTION NO: 67**

場景

5：Cobt。位於倫敦的保險公司，提供各種商業、工業和人壽保險解決方案。近年來，Cobt 的客戶數量大幅增加。由於需要處理大量數據，該公司認為通過 ISO/IEC 27001 認證將為資訊安全帶來許多好處，並表明其對持續改進的承諾。儘管該公司擅長進行定期風險評估，但實施 ISMS 會為其日常營運帶來重大變化。在風險評估過程中，發現了一種風險，即組織的內部控制機制未能發現或預防重大缺陷。

公司遵循一套方法論來實施 ISMS，並在僅僅幾個月後就建立了可運行的 ISMS。分配了審核團隊成員的職責。

Sarah 承認，儘管 Cobt 通過提供多樣化的商業和保險解決方案實現了顯著擴張，但它仍然依賴於一些手動流程。，特別是關於被審計方的可用性和合作以及獲取證據的管道。在本案中，Cobt的拒絕引發了人們對審計的完整性及其提供合理保證的能力的質疑。針對這些情況，Sarah決定在簽署認證協議之前退出審核，並將她的決定告知了Cobt和認證機構。做出這項決定是為了確保遵守審計原則並保持透明度，突顯了她始終如一地堅持這些原則的承諾。

根據上述情景，回答以下問題：

根據情境 5，莎拉決定在簽署認證協議之前退出審核。這可以接受嗎？

**A.**是的，Sarah 可以退出審核，但前提是認證機構批准她的退出

**B.**是的，Sarah 退出稽核與認證協定之間沒有任何關係

**C.**不，認證協議與審核員的存在直接相關

***Answer:*** B

Explanation:

Comprehensive and Detailed In-Depth

B . Correct Answer: The certification agreement is between the certification body and the A . Incorrect: Sarah does not need approval from the certification body to withdraw, as she had not yet signed the certification agreement.

C . Incorrect: The certification agreement is not dependent on a specific auditor; it is an agreement between the organization and the certification body.

Relevant Standard Reference:

**QUESTION NO: 68**

進行認證審核的審核員在製定審核計畫時不需要下列哪一份工作文件？

**A.**審核計劃

**B.**範例計劃

**C.**組織的財務報表
**D.**清單
**E.**IT 經理的職業經歷
**F.**外部提供者列表
***Answer:*** C,E,F
Explanation:
According to ISO 19011:2018, which provides guidelines for auditing management systems, an auditor conducting a certification audit should prepare for an audit by reviewing relevant information about the auditee's context and processes1. This may include reviewing documented information related to the audited management system (such as policies, procedures, manuals), previous audit reports and records (such as findings, nonconformities, corrective actions), relevant legal and regulatory requirements (such as laws, standards), relevant risks and opportunities (such as internal and external issues), relevant performance indicators (such as objectives, targets), etc1. Therefore, an auditor may need work documents such as an audit plan (which defines what will be done during an audit), a sample plan (which defines how many samples will be taken from a population), and a checklist (which helps to ensure that all relevant aspects are covered during an audit)1. However, an auditor does not need work documents such as an organisation's financial statement (which is not directly related to information security management), a career history of the IT manager (which is not relevant to assessing conformity with ISO/IEC 27001:2022), or a list of external providers (which is not necessary for planning an audit)1. Reference: ISO 19011:2018 - Guidelines for auditing management systems

**QUESTION NO: 69**
根據發現的不合格項。 A
公司製定了行動計劃，其中包括發現的不合格項、根本原因以及關於將採取的每項行動的一般說明。這是可以接受的嗎？
**A.**不，行動計劃應包括有關將安裝的系統以及這些系統將如何消除根本原因的信息
**B.**否，受審核方必須提交行動計劃，其中包括有關如何實施每項糾正措施的詳細信息
**C.**是的，受審核方必須提交行動計劃，其中包括有關將採取的行動的一般聲明
***Answer:*** B
Explanation:
The auditee is required to submit action plans that include detailed information on how every corrective action will be implemented. General statements are not sufficient; the action plans must specify the corrective actions in detail to ensure that the root causes of the nonconformities are addressed effectively.

**QUESTION NO: 70**
場景 1：Fintive 是一家傑出的線上支付和保護解決方案安全提供者。 Fintive 於 1999 年由 Thomas Fin 在加州聖荷西創立，為線上營運、希望提高資訊安全、防止詐欺並保護 PII 等用戶資訊的公司提供服務。
Fintive的決策和營運流程以以往的案例為中心。他們收集客戶數據，根據情況進行分類並進行分析。該公司需要大量員工才能進行如此複雜的分析。然而，幾年後，協助進行此類分析的技術也取得了進展。現在，Fintive
正計劃使用現代工具聊天機器人來實現模式分析，以即時防止詐騙。該工具也將用於幫助改善

客戶服務。
這個最初的想法已傳達給軟體開發團隊，他們支持該想法並被分配從事該專案。他們開始將聊天機器人整合到現有系統中。此外，團隊也為聊天機器人設定了一個目標，即回答 85%
的聊天查詢。
聊天機器人成功整合後，該公司立即將其發布給客戶使用。
然而，聊天機器人似乎存在一些問題。
由於測試不足，並且在訓練階段缺乏向聊天機器人提供的樣本（在訓練階段，聊天機器人本應「學習」查詢模式），因此聊天機器人無法解決用戶查詢並提供正確的答案。此外，當聊天機器人收到無效輸入（例如奇怪的點圖案和特殊字元）時，它會向使用者發送隨機檔案。因此，聊天機器人無法正確回答客戶的查詢，而傳統的客戶支援因聊天查詢而不堪重負，因此無法幫助客戶解決他們的請求。
因此，Fintive
制定了軟體開發政策。該政策規定，無論軟體是內部開發還是外包，在作業系統上實施之前都將經過黑盒測試。
根據場景
1，聊天機器人在收到無效輸入時會向使用者發送隨機檔案。這可能會導致什麼影響？
**A.**無法提供服務
**B.**聲譽損失
**C.**機密資訊外洩
***Answer:*** B

**QUESTION NO: 71**
場景3：NightCore是一家總部位於美國的跨國科技公司，專注於電子商務、雲端運算、數位串流媒體和人工智慧。在實施資訊安全管理系統 (ISMS) 8
個多月後，他們聘請了認證機構進行第三方審核，以獲得 ISO/IEC 27001 認證。
認證機構成立了一個由七名審核員組成的團隊。傑克是最有經驗的審核員，被任命為審核組組長。多年來，他獲得了許多知名認證，例如 ISO/IEC 27001 首席審核員、CISA、CISSP 和 CISM。
Jack 透過研究和評估 NightCore 實施的每項資訊安全要求和控制，對 ISMS
審查的每個階段進行了全面分析。在第二階段審核期間。傑克發現了一些不合格項。在將購買的軟體許可證發票數量與軟體庫存進行比較後，傑克發現該公司的許多電腦一直在使用非法版本的軟體。他決定要求高階主管對這項違規行為做出解釋，看看他們是否意識到這一點。他的下一步是審計 NightCore 的 IT 部門。高層指派 NightCore 的系統管理員 Tom 擔任指導，陪伴 Jack 和稽核團隊了解系統和數位資產基礎設施的內部運作。
在採訪財務部的一名成員時，審計人員發現該公司最近向其一名顧問進行了一些不尋常的大額交易。收集有關交易的所有必要詳細資訊後。傑克決定直接訪問高階主管。
在討論第一個不合格項時，高階主管告訴傑克，他們願意決定使用複製軟體而不是原始軟體，因為它更便宜。 Jack向NightCore的高層解釋說，使用非法版本的軟體違反了ISO/IEC 27001和國家法律法規的要求。然而，他們似乎對此感到滿意。
在審計幾個月後，Jack 將他在審計期間收集的一些 NightCore 資訊出售給了 NightCore
的競爭對手，以獲取巨額資金。
根據該場景，回答以下問題：
當傑克發現有關軟體的第一個不合格項時，他收集了哪些類型的審核證據？請參閱場景 3。
**A.**分析證據
**B.**口頭證據

**C.**數學證據

***Answer:*** C

Explanation:

Jack collected mathematical evidence when he identified nonconformities by comparing the number of purchased invoices for software licenses with the software inventory. This type of evidence involves numerical, quantifiable data that highlights discrepancies and supports findings of compliance or non-compliance.

**QUESTION NO: 72**

場景 2：

Clinic 成立於 20 世紀 90
年代，是一家專門治療心臟相關疾病和複雜外科手術的醫療器材公司。該公司總部位於歐洲，為患者和醫療保健專業人士提供服務。診所收集患者數據以客製化治療方案、監測結果並改善設備功能。為了增強資料安全性和建立信任，Clinic 正在實施基於 ISO/IEC 27001
的資訊安全管理系統 (ISMS)。
診所僅透過考慮內部問題、介面、內部和外包活動之間的依賴關係以及相關方的期望來確定其 ISMS 的範圍。此範圍已仔細記錄並可供查閱。在定義其 ISMS 時，Clinic
選擇專注於關鍵部門內的關鍵流程，例如研發、病患資料管理和客戶支援。
儘管最初面臨挑戰，Clinic 仍然致力於實施
ISMS，並根據其獨特需求量身定制安全控制。專案團隊從 ISO/IEC 27001 中排除了某些附件 A
控制，同時加入了額外的特定產業控制以增強安全性。該團隊根據內部和外部因素評估了這些控制的適用性，最終制定了全面的適用性聲明
(SoA)，詳細說明了控制選擇和實施背後的理由。
隨著認證準備工作的進展，被任命為團隊負責人的 Brian
採用了自我導向的風險評估方法來識別和評估公司的策略問題和安全實踐。這種積極主動的方法確保診所的風險評估與其目標和使命保持一致。
診所的 SoA 文件是否符合 SoA 的 ISO/IEC 27001 要求？

**A.**是的，因為它包含了 ISO/IEC 27001 附件 A 和其他來源中適用的詳盡控制清單

**B.**否，因為其中包含了從 ISO/IEC 27001 附件 A 以外的來源中選擇的安全控制措施

**C.**否，因為它不包含從 ISO/IEC 27001 附件 A 中排除控制措施的理由

***Answer:*** C

Explanation:

Comprehensive and Detailed In-Depth

The Statement of Applicability (SoA) is a mandatory document in ISO/IEC 27001:2022 that lists all Annex A controls, their applicability, and justifications for inclusion or exclusion.

C . Correct Answer: The SoA must include justifications for excluding Annex A controls. The

A . Incorrect: While the SoA should include an exhaustive list of controls, simply listing applicable controls from Annex A and other sources does not meet the requirement if exclusions are not justified.

B . Incorrect: Including security controls from other sources is allowed and does not invalidate the SoA, as organizations can define additional controls beyond Annex A based on their risk assessment.

**QUESTION NO: 73**

場景 1：Fintive 是一家傑出的線上支付和保護解決方案安全提供者。 Fintive 於 1999 年由 Thomas Fin 在加州聖荷西創立，為線上營運、希望提高資訊安全、防止詐欺並保護 PII 等用戶資訊的公司提供服務。
Fintive的決策和營運流程以以往的案例為中心。他們收集客戶數據，根據情況進行分類並進行分析。該公司需要大量員工才能進行如此複雜的分析。然而，幾年後，協助進行此類分析的技術也取得了進展。現在，Fintive
正計劃使用現代工具聊天機器人來實現模式分析，以即時防止詐騙。該工具也將用於幫助改善客戶服務。
這個最初的想法已傳達給軟體開發團隊，他們支持該想法並被分配從事該專案。他們開始將聊天機器人整合到現有系統中。此外，團隊也為聊天機器人設定了一個目標，即回答 85% 的聊天查詢。
聊天機器人成功整合後，該公司立即將其發布給客戶使用。
然而，聊天機器人似乎存在一些問題。
由於測試不足，並且在訓練階段缺乏向聊天機器人提供的樣本（在訓練階段，聊天機器人本應「學習」查詢模式），因此聊天機器人無法解決用戶查詢並提供正確的答案。此外，當聊天機器人收到無效輸入（例如奇怪的點圖案和特殊字元）時，它會向使用者發送隨機檔案。因此，聊天機器人無法正確回答客戶的查詢，而傳統的客戶支援因聊天查詢而不堪重負，因此無法幫助客戶解決他們的請求。
因此，Fintive
制定了軟體開發政策。該政策規定，無論軟體是內部開發還是外包，在作業系統上實施之前都將經過黑盒測試。
根據該場景，回答以下問題：
聊天機器人應該「學習」查詢模式來解決用戶查詢並提供正確的答案。
什麼類型的技術可以實現
這？

**A.**人工智慧

**B.**雲端運算

**C.**機器學習

***Answer:*** C

**QUESTION NO: 74**
您正在作為審核組組長進行首次第三方 ISMS
監督審核。您目前與審核團隊的另一位成員以及組織的指南一起位於受審核方的資料中心。
您要求進入受密碼鎖和虹膜掃描器保護的上鎖房間。此房間包含幾排不間斷電源以及幾個包含客戶端提供的設備（主要是伺服器和交換器）的資料櫃。
您注意到有一個氣體滅火系統。標籤表示系統需要每 6
個月進行一次測試，但標籤上記錄的最近一次測試是製造商在 12 個月前進行的。
根據上述情況，您現在會採取下列哪兩項操作？

**A.**確定記錄滅火器檢查的要求是否在去年進行了修訂。
如果是這樣，建議在現有標籤上引用這些內容作為改進的機會

**B.**做筆記，向現場維修經理索取6個月前進行過滅火系統測試的證據

**C.**如果房間內有水基滅火器，則無需採取進一步行動，因為它們提供了另一種滅火方法

**D.**由於組織尚未確定需要針對火災威脅採取行動，因此針對控制
A.5.7「威脅情報」提出不符合項

**E.**針對控制

A.7.11「支援公用設施」提出不符合項，因為資訊處理設施沒有充分保護以防止可能的中斷
**F.**需要指南來啟動組織的資訊安全事件流程
***Answer:*** B,E

**QUESTION NO: 75**
設想：
資訊安全事件發生後，組織創建了一套全面的備份程序，包括定期自動將所有關鍵資料備份至異地儲存位置。透過這樣做，該組織在這種情況下應用了哪一條資訊安全原則？
**A.**誠信
**B.**保密性
**C.**可用性
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
The CIA Triad (Confidentiality, Integrity, and Availability) is the foundation of information security principles.
Availability ensures that data and services are accessible when needed. By implementing regular, automated backups and offsite storage, the organization ensures that critical data remains accessible even after a security incident (e.g., data loss, cyberattacks, or hardware failures). This aligns with ISO/IEC 27001:2022 Annex A Control A.8.13 (Information Backup), which emphasizes maintaining and testing backups to ensure system resilience.
Integrity ensures that data remains unaltered and accurate, but backups do not inherently enforce integrity unless accompanied by checksum or validation mechanisms.

**QUESTION NO: 76**
您詢問 IT
經理，為什麼組織仍在使用行動應用程序，而個人資料加密和假名化測試卻失敗了。此外，服務經理是否有權批准測試。
IT經理解釋說，根據軟體安全管理程序，測試結果應由他批准。加密和假名功能失敗的原因是這些功能嚴重降低了系統和服務效能。需要額外 150%
的資源來滿足這一點。服務經理同意存取控制足夠好並且可以接受。這就是服務經理簽署批准書的原因。
您對醫務人員的手機進行採樣，發現安裝了 ABC 的醫療保健移動應用程序，版本
1.01。你發現1.01版本沒有測試記錄。
IT經理解釋說，由於勒索軟體攻擊頻繁，外包行動應用開發公司對受測軟體進行了免費小幅更新，並對更新後的軟體進行了緊急發布，並口頭保證不會對安全造成任何影響。
以他20年的資訊安全經驗來看，沒有必要重新測試。
您正在準備審核結果 請選擇兩個正確的選項。
**A.**不存在不合格項 (NC)。 IT 經理證明他完全有能力。（與第7.2條相關）
**B.**存在不合格項 (NC)。 IT 經理不遵守軟體安全管理程序。（與第 8.1 條相關，控制措施 A.8.30）
**C.**存在不合格項 (NC)。組織不控制計劃的變更並審查非預期變更的後果。（與第8.1條相關）
**D.**還有改進的機會 (OI)。該組織根據其提供的免費服務的範圍選擇外部服務提供者。（與第 8.1 條相關，控制措施 A.5.21）

**E.**不存在不合格項 (NC)。 IT 經理展現了良好的領導能力。 （與條款相關
5.1，控制5.4）
**F.**還有改進的機會 (OI)。 IT 經理應根據適當的測試做出是否繼續提供服務的決定。 （與第 8.1 條相關，控制措施 A.8.30）

***Answer:*** B,C

Explanation:

According to ISO 27001:2022 Annex A Control 8.30, the organisation shall ensure that externally provided processes, products or services that are relevant to the information security management system are controlled. This includes developing and entering into licensing agreements that cover code ownership and intellectual property rights, and implementing appropriate contractual requirements related to secure design and coding in accordance with Annex A 8.25 and 8.2912 In this case, the organisation and the developer have performed security tests that failed, which indicates that the secure design and coding requirements of Annex A 8.29 were not met. The IT Manager explains that the encryption and pseudonymization functions failed because they slowed down the system and service performance, and that an extra 150% of resources are needed to cover this. However, this does not justify the acceptance of the test results by the Service Manager, who is not authorised to approve the test according to the software security management procedure. The Service Manager should have consulted with the IT Manager, who is the owner of the process, and followed the procedure for handling nonconformities and corrective actions. The Service Manager's decision to continue the service based on access control alone exposes the organisation to the risk of compromising the confidentiality, integrity, and availability of personal data processed by the mobile app. Therefore, there is a nonconformity (NC) with clause 8.1, control A.8.30.

According to ISO 27001:2022 Clause 8.1, the organisation shall plan, implement and control the processes needed to meet information security requirements, and to implement the actions determined in Clause 6.1. The organisation shall also control planned changes and review the consequences of unintended changes, taking action to mitigate any adverse effects, as necessary12 In this case, the organisation has not controlled the planned change of the mobile app from version 1.0 to version 1.01, which was a minor update provided by the outsourced developer in response to frequent ransomware attacks. The IT Manager explains that the developer performed an emergency release of the updated software, and gave a verbal guarantee that there will be no impact on any security functions. However, this is not sufficient to ensure that the change is properly assessed, tested, documented, and approved before deployment. The IT Manager should have followed the change management process and procedure, and verified that the updated software meets the security requirements and does not introduce any new vulnerabilities or risks. The IT Manager's reliance on his 20 years of information security experience and the developer's verbal guarantee is not a valid basis for skipping the re-testing of the software. Therefore, there is a nonconformity (NC) with clause 8.1.

Reference:

1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 77**
當組織需要確定內部稽核計畫所需的資源時，下列哪一個問題不會影響其預期結果的實現？
**A.**有能力的審核員和技術專家。
**B.**審核計畫經理可以存取資訊安全管理系統經理的能力記錄。
**C.**必要的文件資訊的可用性。
**D.**不同時區的影響。
***Answer:*** B
Explanation:
While competence is important for an effective ISMS, the specific competence records of the ISMS manager are less relevant when determining resources for the internal audit program. The focus should be on resources directly related to the audit process itself. Here's why the other options matter:
* A . Availability of competent auditors and technical experts: Crucial for conducting thorough audits and accurately assessing the ISMS.
* C . Availability of the necessary documented information: Essential for auditors to review policies, procedures, and records related to the ISMS.
* D . Impact of different time zones: Can affect scheduling, coordination, and communication during the audit, potentially requiring additional resources.
Reference:
* ISO/IEC 27001:2022, Section 9.2 (Internal Audit): Emphasizes the need for competent auditors and emphasizes planning the audit program.

**QUESTION NO: 78**
您正在一家提供醫療保健服務的住宅療養院進行 ISMS
審核。審核計畫的下一步是驗證適用性聲明 (SoA) 是否包含必要的控制措施。
您查看最新的 SoA（版本 5）文檔，對原始程式碼 (A.8.4)
的存取控制進行採樣，並想了解組織如何保護從外包軟體開發人員收到的 ABC
醫療保健行動應用程式原始程式碼。
IT 安全經理解釋說，收到的原始程式碼將被檢查到 SCM
系統中，以確保其完整性和安全性。只有授權使用者才能查看軟體並進行更新。
系統會自動記錄入住和退房活動。版本控制由系統自動管理。
您在 SCM 上總共發現了 10
個使用者帳戶。他們全部來自IT部門。您進一步與人力資源經理核實，並確認其中一位用戶 Scott 已於 9 個月前辭職。 SCM 系統管理員確認 Scott 最後一次檢出原始碼是在 1
個月前。他正在安全區域使用本機網路的授權桌面之一。
您檢查了使用者登出程序，其中規定「管理人員必須確保在辭職批准後立即從相關ICT系統和/或設備註銷使用者帳戶和授權」。用戶Scott沒有註銷記錄。
IT 安全經理解釋說，Scott 是一位非常優秀的軟體工程師、前同事和朋友。
辭職後，他仍然每月回到辦公室提供原始碼維護支援。這就是為什麼他在 SCM
上的帳戶仍然存在。「我們很了解
Scott，他在加入我們時通過了我們所有的背景調查。因此，我們認為沒有必要僅僅因為他現在是外部提供者而與他同意任何進一步的資訊安全要求」。
您準備審計結果。選出三個正確選項。
**A.**存在不合格項
(NC)。斯科特應該被告知與他與療養院的新關係（外部提供者）相關的適用資訊安全要求。然

而，IT 安全經理證實這並沒有發生。這不符合控制措施 A.5.20。

**B.**存在不合格項

(NC)。該組織的存取控制安排未能有效運行，因為不再受該組織僱用的個人被允許訪問療養院的 ICT 系統。這不符合控制措施 A.5.15。

**C.**存在不合格項 (NC)。 IT 安全經理未確保 Scott 的使用者帳戶已從 SCM 中刪除，且在離職後未完成使用者登出流程。

這不符合第 9.1 條和控制措施 A.5.15。

**D.**存在不合格項 (NC)。操作程序沒有很好的記錄。這使得 SCM 系統管理員無法立即刪除使用者帳戶。這不符合第 9.1 條和控制措施 A.5.37。

**E.**存在不合格項

(NC)。該組織沒有記錄程序來規定如何使用系統工具來提供原始程式碼的存取和版本控制。這不符合第 9.1 條和控制措施 A.8.4。

**F.**存在不合格項

(NC)。該組織未能識別與斯科特的帳戶保持開放相關的安全風險，因為他每月只重新使用很短一段時間。這不符合第 8.2 條的規定。

**G.**存在不合格項 (NC)。

SCM是開源系統軟體。它不安全，不能用於原始碼的存取和版本控制。這不符合第 9.1 條和控制措施 A.8.4。

**H.**存在不合格項 (NC)。 SCM 將自動記錄原始碼簽入/簽出活動。如果出現問題，團隊可能無法追蹤。這不符合第 9.1 條和控制措施 A.8.4。

***Answer:*** B,C,F

Explanation:

The correct options are:

There is a nonconformity (NC). The organisation's access control arrangements are not operating effectively as an individual who is no longer employed by the organisation is being permitted to access the nursing home's ICT systems. This does not conform with control A.5.15. (B): This option is correct because control A.5.15 requires the organization to implement secure log-on procedures and manage user access rights. The organization should ensure that only authorized users can access the ICT systems and that the access rights are revoked or modified when the user status changes. The fact that Scott, who resigned 9 months ago, still has an active account on the SCM and can check out the source code, indicates a failure of the access control arrangements and a nonconformity with the control A.5.15.

There is a nonconformity (NC). The IT Security manager did not make sure the user account for Scott was removed from the SCM and did not complete the user deregistration process after the resignation. This does not conform with clause 9.1 and control A.5.15. : This option is correct because clause 9.1 requires the organization to monitor, measure, analyze, and evaluate the performance and effectiveness of the ISMS. The organization should have processes and indicators to verify that the ISMS requirements and objectives are met and that the ISMS is continually improved. The organization should also ensure that the results of the monitoring and measurement are documented and communicated. The fact that the IT Security manager did not follow the user de-registration procedure and did not document or communicate the exception for Scott, indicates a failure of the monitoring and measurement

ACTUALTEST.COM

processes and a nonconformity with clause 9.1 and control A.5.15.
There is a nonconformity (NC). The organisation has failed to identify the security risks associated with leaving Scott's account open when he was only re-engaged for a short period monthly. This does not conform with clause 8.2. (F): This option is correct because clause 8.2 requires the organization to establish and maintain an information security risk management process. The organization should identify the information security risks, analyze and evaluate the risks, and treat the risks according to the risk criteria and the risk treatment options. The organization should also monitor and review the risks and the risk treatment plan periodically and document the results. The fact that the organization did not identify the security risks associated with Scott's access to the SCM and the source code, such as unauthorized disclosure, modification, or deletion of the information, indicates a failure of the risk management process and a nonconformity with clause 8.2.

**QUESTION NO: 79**
下列哪一項敘述最精確地描述了資訊安全面之間的關係？
**A.**威脅利用漏洞損壞或破壞資產
**B.**透過減少威脅來控制保護資產
**C.**風險是損害資產的漏洞的函數
***Answer:*** A
Explanation:
This statement encapsulates the relationship between threats, vulnerabilities, and assets within the context of information security. Threats are potential causes of an unwanted incident, which may result in harm to a system or organization. Vulnerabilities are weaknesses that can be exploited by threats to cause harm. Assets are valuable resources to an organization that need protection. Therefore, when threats exploit vulnerabilities, they can damage or destroy assets. Reference: = The explanation is based on the foundational concepts of information security as outlined in ISO/IEC 27001, which includes understanding the interplay between threats, vulnerabilities, and assets as part of an information security management system (ISMS)

**QUESTION NO: 80**
起草審核結論後，審核組長的工作文件由認證機構選定的另一位審核員進行審核。這是可以接受的嗎？
**A.**是的，審核組長的工作文件在得出審核結論後必須由另一位審核員審核
**B.**不可以，在得出審核結論前必須檢討審核組組長的工作
**C.**不，只有審核組長審核每位審核員的工作文件
***Answer:*** A
Explanation:
Yes, it is acceptable for the work documents of the audit team leader to be reviewed by another auditor after reaching audit conclusions. This is part of the quality control and assurance processes within the audit to ensure the accuracy and reliability of the audit conclusions.

**QUESTION NO: 81**
場景 4：Branding

是一家行銷公司，與美國一些最著名的公司合作。降低內部成本。兩年多來，Branding 已將軟體開發和 IT 幫助台營運外包給
Techvology。技術學。配備必要的專業知識，管理品牌的軟體、網路和硬體需求。 Branding 已實施資訊安全管理系統 (ISMS) 並獲得了 ISO/IEC 27001
認證，表明其致力於維護高標準的資訊安全。它積極對技術進行審計，以確保其外包業務的安全性符合 ISO/IEC 27001 認證要求。
在上次審計期間。品牌的審計團隊定義了要審計的流程和審計計畫。他們採用了基於證據的方法，特別是考慮到 Techvology 在過去一年中報告的兩起資訊安全事件。所有方面。
此外，審計也對Techvology用於管理其外包業務和其他組織的治理流程進行了嚴格的評估。此步驟對於品牌推廣至關重要，可以驗證是否有適當的控制和監督機制來減輕與外包安排相關的潛在風險。
審計員對 Techvology 各級人員進行了採訪，並分析了事件解決記錄。此外，Techvology 還提供了記錄作為證據，證明他們為員工開展了事件管理意識會議。根據收集到的信息，他們預測這兩起資訊安全事件都是由人員不稱職造成的。因此，審計人員要求查看涉事員工的人事檔案，以審查其能力的證據，例如相關經驗、證書和參與培訓的記錄。
Branding
的審計員對所獲得的證據的有效性進行了嚴格評估，並對可能與收到的記錄資訊的可靠性相矛盾或質疑的證據保持警惕。在對 Techvology
進行審計期間，審計員堅持這種方法，嚴格評估事件解決記錄，並對不同級別和職能的員工進行徹底的訪談。他們不只把 Techvology
代表的話當作事實；相反，他們尋求具體的證據來支持代表們對事件管理流程的主張。
根據上述情景，回答以下問題：
場景 4 的最後一段解釋了哪一項審計原則？

**A.**基於風險的方法

**B.**公平展示

**C.**專業懷疑論

***Answer:*** C

Professional skepticism involves challenging evidence, verifying claims, and avoiding assumptions.
The auditors critically assessed the validity of evidence, ensuring claims made by Techvology were backed by concrete proof.
A . Incorrect:
Risk-based auditing prioritizes high-risk areas, but the paragraph focuses on verifying claims and evidence.
B . Incorrect:
Fair presentation ensures accurate reporting of findings, but the paragraph focuses on questioning evidence, not reporting.
Relevant Standard Reference:
Explanation:
Comprehensive and Detailed In-Depth

**QUESTION NO: 82**

情境 6：Sinvestment
是一家提供家庭保險、商業保險和人壽保險的保險公司。該公司成立於北卡羅來納州，但最近在其他地區進行了擴張，包括歐洲和非洲。

Sinvestment
致力於遵守適用於其行業的法律法規，並防止任何資訊安全事件。他們實施了基於 ISO/IEC 27001 的 ISMS 並申請了 ISO/IEC 27001 認證。
認證機構指派兩名審核員進行審核。與Sinvestment簽訂保密協議後。他們開始了審計活動。首先，他們審查了標準要求的文件，包括 ISMS
範圍聲明、資訊安全政策和內部稽核報告。審查過程並不容易，因為儘管 Sinvestment
表示他們已製定文件程序，但並非所有文件都具有相同的格式。
隨後，審計小組對Sinvestment的高階主管進行了多次訪談，以了解他們在ISMS實施中的作用。第一階段審計的所有活動都是遠端進行的，除了根據 Sinvestment
的要求在現場進行的文件資訊審查之外。
在此階段，審計人員發現沒有與資訊安全培訓和意識計劃相關的文件。被問及時，Sinvestment代表表示，公司已為所有員工提供資訊安全培訓課程。第一階段審計讓審計團隊對 Sinvestment 的營運和 ISMS 有了整體了解。
第二階段審核在第一階段審核三週後進行。審計小組觀察到，行銷部門（未包含在審計範圍內）沒有適當的程序來控制員工的存取權限。由於控制員工的存取權限是ISO/IEC
27001的要求之一，並且已包含在公司的資訊安全政策中，因此該問題包含在審計報告中。此外，在第二階段審計中，審計小組觀察到Sinvestment沒有記錄使用者活動日誌。
該公司的程序規定“記錄用戶活動的日誌應保留並定期審查”，但該公司沒有提供任何執行該程序的證據。
在所有審核活動中，審核員透過觀察、訪談、文件化資訊審查、分析和技術驗證來收集資訊和證據。對第一階段和第二階段的所有審核結果進行了分析，審核小組決定發布積極的認證建議。
根據場景 6，行銷部門員工沒有遵守存取控制策略。
在這種情況下哪個選項是正確的？

**A.**行銷部不屬於審核範圍，因此該問題僅應傳達給Sinvestment代表

**B.**員工的存取權限控制包含在Sinvestment的資訊安全政策中，因此該問題必須傳達給Sinvestment的代表並包含在審計報告中

**C.**Sinvestment
未控制員工的存取權限，這存在潛在的資訊安全風險，應作為重大不合格項進行報告

***Answer:*** B

Explanation:
Even though the marketing department was not included in the audit scope, the issue of employees' access rights control must be communicated to Sinvestment's representatives and included in the audit report because it is part of Sinvestment's information security policy. It reflects on the overall adherence to the ISMS requirements.

**QUESTION NO: 83**
場景3：NightCore是一家總部位於美國的跨國科技公司，專注於電子商務、雲端運算、數位串流媒體和人工智慧。在實施資訊安全管理系統 (ISMS) 8
個多月後，他們聘請了認證機構進行第三方審核，以獲得 ISO/IEC 27001 認證。
認證機構成立了一個由七名審核員組成的團隊。傑克是最有經驗的審核員，被任命為審核組組長。多年來，他獲得了許多知名認證，例如 ISO/IEC 27001 首席審核員、CISA、CISSP 和 CISM。
Jack 透過研究和評估 NightCore 實施的每項資訊安全要求和控制，對 ISMS
審查的每個階段進行了全面分析。在第二階段審核期間。傑克發現了一些不合格項。在將購買

的軟體許可證發票數量與軟體庫存進行比較後，傑克發現該公司的許多電腦一直在使用非法版本的軟體。他決定要求高階主管對這項違規行為做出解釋，看看他們是否意識到這一點。他的下一步是審計 NightCore 的 IT 部門。高層指派 NightCore 的系統管理員 Tom 擔任指導，陪伴 Jack 和稽核團隊了解系統和數位資產基礎設施的內部運作。
在採訪財務部的一名成員時，審計人員發現該公司最近向其一名顧問進行了一些不尋常的大額交易。收集有關交易的所有必要詳細資訊後。傑克決定直接訪問高階主管。
在討論第一個不合格項時，高階主管告訴傑克，他們願意決定使用複製軟體而不是原始軟體，因為它更便宜。 Jack向NightCore的高層解釋說，使用非法版本的軟體違反了ISO/IEC 27001和國家法律法規的要求。然而，他們似乎對此感到滿意。
在審計幾個月後，Jack 將他在審計期間收集的一些 NightCore 資訊出售給了 NightCore 的競爭對手，以獲取巨額資金。
根據該場景，回答以下問題：
ISO/IEC 27001 是否要求組織遵守國家法律法規？
**A.**是的，但不需要明確確定相關的法律和合約要求
**B.**否，標準中沒有明確指出組織是否應遵守國家法律法規
**C.**是的，遵守適用的法律是 ISO/IEC 27001 的要求
***Answer:*** C
Explanation:
ISO/IEC 27001 requires organizations to comply with applicable legal, statutory, regulatory, and contractual requirements, including those pertaining to information security. These requirements must be identified, documented, and kept up to date as part of the organization's ISMS.

**QUESTION NO: 84**
您將收到來自 IT 支援團隊的以下郵件：
尊敬的用戶，從下週開始，我們將刪除所有不活動的電子郵件帳戶，以便創建空間共享以下詳細信息，以便繼續使用您的帳戶。如果沒有回复，姓名：
電子郵件地址：
密碼：
出生日期：
請聯絡網路郵件團隊以獲得進一步的支援。感謝您的關注。
下列哪一項是最好的回應？
**A.**忽略電子郵件
**B.**回應說不應與任何人分享密碼
**C.**不應回覆這些郵件並向您的主管報告此類電子郵件
***Answer:*** C
Explanation:
The best response to the email from the IT support team asking for personal details is to not respond to the email and report it to your supervisor. The email is likely a phishing attempt, which is a form of social engineering that uses deceptive emails or other messages to trick recipients into revealing sensitive information, such as passwords, credit card numbers, bank account details, etc. Phishing emails often impersonate legitimate organizations or individuals and create a sense of urgency or curiosity to lure the victims into clicking on malicious links, opening malicious attachments or providing personal information. The IT support team should never ask for your password or other personal details via email, as this is a violation

ACTUALTEST.COM

of information security policies and best practices. Ignoring the email or responding to it by saying that one should not share the password with anyone are not sufficient responses, as they do not alert the IT support team or your supervisor about the phishing attempt, which could affect other users as well. Reporting the email to your supervisor is a responsible action that could help prevent further damage or compromise of information. ISO/IEC 27001:2022 requires the organization to implement awareness and training programs to make users aware of the risks of social engineering attacks, such as phishing, and how to avoid them (see clause A.7.2.2). Reference: CQI & IRCA Certified ISO/IEC 27001:2022 Lead Auditor Training Course, ISO/IEC 27001:2022 Information technology - Security techniques - Information security management systems - Requirements, What is Phishing?

**QUESTION NO: 85**
選擇以下兩個選項，作為認證審核期間審核團隊中的法律技術專家的職責。
**A.**評估受審計方的法律知識
**B.**批評該組織的法律合規問題
**C.**與被審計單位辯論複雜的法律要點
**D.**為審計團隊提供法律檢查點建議
**E.**驗證組織的法律地位
**F.**會見該組織的法定代理人
***Answer:*** D,E
Explanation:
A legal technical expert (LTE) is a person who provides specific knowledge or expertise related to the legal aspects of the information security management system (ISMS) during a certification audit. The LTE is not an auditor, but a member of the audit team who supports the auditors in collecting and evaluating the audit evidence. The LTE is not responsible for evaluating the auditee's legal knowledge, criticising the organisation's legal compliance issues, or debating complex legal points with the auditee, as these tasks may be beyond the scope of the audit, or may compromise the objectivity and impartiality of the audit. The LTE is responsible for advising on legal checkpoints for the audit team, such as the applicable legal, regulatory, and contractual requirements, the relevant sources of information, the methods of verification, and the criteria of evaluation. The LTE is also responsible for verifying the legal status of the organisation, such as the registration, licensing, authorisation, or accreditation of the organisation, and the compliance with the relevant laws and regulations. Reference:
What is the role of a technical expert in ISO audit?
Roles, Responsibilities & Authorities for ISO 27001 5.3
Guide to Become an ISO 27001 Lead Auditor

**QUESTION NO: 86**
場景 2：Knight 是一家來自美國北加州的電子公司，開發電玩遊戲機。 Knight 在全球擁有 300 多名員工。在成立五週年之際，他們決定推出 G-
Console，這是一款面向全球市場的新一代電玩遊戲機。 G-
Console被認為是2021年的終極媒體機，將為玩家帶來最佳的遊戲體驗。
主機包將包括一副 VR 耳機、兩個
遊戲和其他禮物。
多年來，公司透過誠信、誠實和尊重客戶而建立了良好的聲譽。這種良好的聲譽是大多數熱衷

遊戲玩家在Knight的G-console一上市就想擁有它的原因之一。
Knight 除了是一家非常以客戶為導向的公司之外，
也因其開發品質獲得了遊戲產業的廣泛認可。他們的價格比合理標準允許的要高一些。
儘管如此，對於 Knight
的大多數忠實客戶來說，這並不是一個問題，因為它們的品質是一流的。
作為世界頂級視訊遊戲機開發商之一，Knight 也經常成為惡意活動的焦點。該公司的 ISMS 已投入運作一年多了。 ISMS 範圍包括 Knight 的所有部門（財務和人力資源部門除外）。
最近，奈特的一些包含專有資訊的文件被駭客洩露。 Knight 的事件回應團隊 (IRT)
立即開始分析系統的每個部分以及事件的詳細資訊。
IRT 的第一個懷疑是 Knight
的員工使用了弱密碼，因此很容易被未經授權存取其帳戶的駭客破解。然而，在仔細調查該事件後，IRT 確定駭客透過擷取檔案傳輸協定 (FTP) 流量來存取帳戶。
FTP 是一種用於在帳戶之間傳輸檔案的網路協定。它使用明文密碼進行身份驗證。
受此資訊安全事件的影響，在IRT的建議下，Knight決定用Secure Shell
(SSH)協定取代FTP，這樣任何捕獲流量的人都只能看到加密的資料。
在這些變化之後，奈特進行了風險評估，以驗證控制措施的實施是否已將類似事件的風險降至最低。該過程的結果得到了 ISMS
專案經理的批准，他聲稱實施新控制措施後的風險等級符合公司的風險接受程度。
根據該場景，回答以下問題：
根據情境2，ISMS 專案經理批准了風險評估結果。這是可以接受的嗎？

**A.**否，風險處理後剩餘的風險應在任何階段得到最高管理層的批准

**B.**否，實施 ISMS 新控制措施後剩餘的風險應得到 ISMS 團隊的批准

**C.**是，風險處理後剩餘的風險應得到ISMS專案經理的批准

***Answer:*** A

Explanation:

In the context of ISO/IEC 27001, the approval of the risk assessment and the acceptance of the remaining risk levels after treatment are typically responsibilities of the top management. This is because top management is accountable for the information security management system and its outcomes, and they have the authority to accept risks on behalf of the organization12. Reference: = The information provided is based on the standard practices of ISO/IEC 27001 risk assessment and treatment processes, which emphasize the role of top management in the approval and acceptance of risks

**QUESTION NO: 87**

場景9：UpNet是一家網路公司，已通過ISO/IEC 27001認證。
自從獲得 ISO/IEC 27001 認證以來，該公司的認可度大幅提高。此認證證實了 UpNefs 營運的成熟性及其符合廣泛認可和接受的標準。
但認證之後一切還沒結束。 UpNet 透過進行內部稽核不斷審查和增強其安全控制以及 ISMS 的整體有效性和效率。高階主管不願意聘請全職內部稽核團隊，因此決定將內部稽核職能外包。這種形式的內部稽核確保了獨立性、客觀性，並且在 ISMS 的持續改進方面發揮諮詢作用。
在初次認證審核後不久，該公司創建了一個專門從事數據和儲存產品的新部門。他們提供針對資料中心和基於軟體的網路設備（例如網路虛擬化和網路安全設備）進行最佳化的路由器和交換器。這導致 ISMS 認證範圍內已涵蓋的其他部門的營運發生變化。
所以。 UpNet
啟動了風險評估流程和內部稽核。根據內部審計結果，公司確認了現有和新流程和控制的有效

性和效率。
由於新部門符合 ISO/IEC 27001 要求，最高管理層決定將其納入認證範圍。
UpNet宣布取得ISO/IEC 27001認證，認證範圍涵蓋全公司。
在初次認證審核一年後，認證機構對 UpNefs ISMS 進行了另一次審核。
此次審核旨在確定 UpNefs ISMS 是否符合指定的 ISO/IEC 27001 要求，並確保 ISMS 持續改善。審核小組確認，經過認證的 ISMS
繼續符合標準的要求。儘管如此，新部門對管理體系的治理產生了重大影響。此外，認證機構並未獲悉任何變更。因此，UpNefs認證被暫停。
根據上述場景，回答以下問題：
UpNet 將內部稽核職能外包，如場景 9 所示。
**A.**不，內部稽核不一定必須是獨立且客觀的，因為它們具有諮商作用
**B.**否，因為內部審核流程不僅僅包含審核計劃
**C.**是的，它提高了內部稽核的獨立性和公正性，因為審計員不具有與 ISMS 相關的營運角色
***Answer:*** C
Explanation:
Yes, outsourcing the internal audit function can positively impact the internal audit process by increasing its independence and impartiality. This helps ensure that the internal audits are conducted without any bias or influence from the company's internal management.

**QUESTION NO: 88**
下列哪三個短語是與審計相關的目標？
**A.**國際標準
**B.**確定改進機會
**C.**確認管理系統的範圍
**D.**管理策略
**E.**按時完成審核
**F.**監理要求
***Answer:*** B,C,F
Explanation:
According to ISO 19011:2018, which provides guidelines for auditing management systems, the audit objectives are defined by the audit client and may include determining the extent of conformity or nonconformity of the audited management system against the audit criteria, evaluating the ability of the audited management system to ensure that the organization meets applicable statutory, regulatory and contractual requirements, identifying potential improvement opportunities for the audited management system, and facilitating continual improvement of the audited management system1. Therefore, these three phrases are examples of objectives in relation to an audit. The other options are not objectives, but rather elements or factors that may influence or affect an audit. For example, an international standard is a source of audit criteria, a management policy is a part of the audited management system, and completing an audit on time is a requirement for an effective audit.
Reference: ISO 19011:2018 - Guidelines for auditing management systems

**QUESTION NO: 89**
根據 ISO/IEC 27001 第 5.1 條（領導與承諾），下列何者不是高階管理人員的責任？

**A.** 確保 ISMS 資源的可用性並促進持續改進
**B.**定期進行內部審核，以評估 ISMS 的有效性
**C.**指導和支援人員為 ISMS 的有效性做出貢獻
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
ISO/IEC 27001 Clause 5.1 (Leadership and Commitment) defines top management's role in ensuring the effectiveness of the Information Security Management System (ISMS). It requires top management to:
Ensure the availability of resources for the ISMS (Correct Responsibility).
Promote continual improvement of the ISMS (Correct Responsibility).
Direct and support employees to contribute to ISMS effectiveness (Correct Responsibility).
B . Conducting regular internal audits - Incorrect Responsibility:
Internal audits are not a direct responsibility of top management. Instead, Clause 9.2 (Internal Audit) requires audits to be conducted independently of management.
Top management is responsible for ensuring audits are conducted but does not need to conduct them personally.
Thus, top management is responsible for oversight and support but not for conducting internal audits themselves.
Relevant Standard Reference:
ISO/IEC 27001:2022 Clause 5.1 (Leadership and Commitment)
ISO/IEC 27001:2022 Clause 9.2 (Internal Audit)

**QUESTION NO: 90**
您是經驗豐富的 ISMS
審核團隊領導，指導審核員進行培訓。您的團隊剛剛完成了對行動電信供應商的第三方監督審核。培訓中的審核員會詢問您打算如何準備末次會議。下列哪四項是適當的回應？
**A.**我會告知受審核方，末次會議的目的是讓審核團隊傳達我們的調查結果。這不是被審核方質疑調查結果的機會
**B.**我將指示我的審核團隊在受審核方辦公室外等候，以便我們在末次會議後儘快離開。這也節省了我們的時間和客戶的時間
**C.**沒有必要為閉幕會議做準備。一旦您進行了與我一樣多的審核，您就已經知道需要討論什麼了
**D.**我將安排與受審核方代表舉行閉幕會議，會中將提出審核結論
**E.**我將聯繫總部以確保我們的發票已支付，如果沒有，我將取消末次會議並暫時扣留審計報告
**F.**我將與我的審核團隊討論所需的任何後續行動
**G.**我將審查並酌情批准我的團隊的審計結論
**H.**我將與團隊其他成員一起檢視審核證據和審核結果
***Answer:*** A,D,F,H
Explanation:
According to ISO 19011:2018, which provides guidelines for auditing management systems, clause 6.6 requires the audit team leader to conduct a closing meeting with the auditee's representatives at the end of the audit to present the audit conclusions and any findings1. The closing meeting should also provide an opportunity for the auditee to ask questions,

ACTUALTEST.COM

clarify issues, acknowledge the findings, and comment on the audit process1. Therefore, when preparing for the closing meeting, an ISMS auditor should consider the following actions:
I will advise the auditee that the purpose of the closing meeting is for the audit team to communicate our findings. It is not an opportunity for the auditee to challenge these: This action is appropriate because it reflects the fact that the auditor has followed a systematic and consistent approach to collecting and evaluating audit evidence and reaching audit conclusions. The auditor should advise the auditee that the purpose of the closing meeting is for the audit team to communicate their findings, which are based on objective evidence and professional judgement. The auditor should also explain that it is not an opportunity for the auditee to challenge these findings, as they have already been discussed and confirmed during the audit. However, the auditor should also invite the auditee to ask questions, clarify issues, acknowledge the findings, and comment on the audit process1.
I will schedule a closing meeting with the auditee's representatives at which the audit conclusions will be presented: This action is appropriate because it reflects the fact that the auditor has followed a planned and agreed audit programme and schedule. The auditor should schedule a closing meeting with the auditee's representatives at which the audit conclusions will be presented, in accordance with clause 6.6 of ISO 19011:20181. The auditor should also ensure that the closing meeting is attended by those responsible for managing or implementing the ISMS, as well as any other relevant parties1.
I will discuss any follow-up required with my audit team: This action is appropriate because it reflects the fact that the auditor has followed a risk-based approach to determining and reporting any follow-up actions required by the auditee or the certification body. The auditor should discuss any follow-up required with their audit team, such as verifying corrective actions for nonconformities or conducting a subsequent audit1. The auditor should also document any follow-up actions in the audit report1.
I will review and, as appropriate, approve my teams audit conclusions: This action is appropriate because it reflects the fact that the auditor has followed a rigorous and professional process to reaching and reporting audit conclusions. The auditor should review and, as appropriate, approve their teams audit conclusions, which are based on objective evidence and professional judgement. The auditor should also ensure that their teams audit conclusions are consistent with the audit objectives and scope, and reflect the overall performance and conformity of the ISMS1.

**QUESTION NO: 91**
您是 ISMS
審核小組組長，由您的認證機構指派對客戶進行後續審核。您正在為此審核準備審核計畫。
下列哪兩項敘述是正確的？
**A.**驗證應重點關注所採取的任何行動是否有效
**B.**應先驗證糾正措施，然後是糾正措施，最後是改進機會
**C.**驗證應專注於所採取的任何操作是否完成
**D.**應先驗證改進機會，然後再修正，最後採取糾正措施
**E.**應先檢視糾正措施，然後是糾正，最後是改進機會
**F.**驗證應重點關注所採取的任何行動是否有效
***Answer:*** C,F

Explanation:
According to ISO 27001:2022 clause 9.1.2, the organisation shall conduct internal audits at planned intervals to provide information on whether the information security management system conforms to the organisation's own requirements, the requirements of ISO 27001:2022, and is effectively implemented and maintained12 According to ISO 27001:2022 clause 10.1, the organisation shall react to the nonconformities and take action, as applicable, to control and correct them and deal with the consequences. The organisation shall also evaluate the need for action to eliminate the causes of nonconformities, in order to prevent recurrence or occurrence. The organisation shall implement any action needed, review the effectiveness of any corrective action taken, and make changes to the information security management system, if necessary12 A follow-up audit is a type of internal audit that is conducted after a previous audit to verify whether the nonconformities and corrective actions have been addressed and resolved, and whether the information security management system has been improved12 Therefore, the following statements are true for preparing a follow-up audit plan:
Verification should focus on whether any action undertaken is complete. This means that the auditor should check whether the organisation has implemented all the planned actions to correct and prevent the nonconformities, and whether the actions have been documented and communicated as required12 Verification should focus on whether any action undertaken has been undertaken effectively. This means that the auditor should check whether the organisation has achieved the intended results and objectives of the actions, and whether the actions have eliminated or reduced the nonconformities and their causes and consequences12 The following statements are false for preparing a follow-up audit plan:
Verification should focus on whether any action undertaken has been undertaken efficiently. This is false because efficiency is not a criterion for verifying the actions taken to address the nonconformities and corrective actions. Efficiency refers to the optimal use of resources to achieve the desired outcomes, but it is not a requirement of ISO 27001:2022. The auditor should focus on the effectiveness and completeness of the actions, not on the efficiency12 Corrections should be verified first, followed by corrective actions and finally opportunities for improvement. This is false because there is no prescribed order for verifying the corrections, corrective actions, and opportunities for improvement. The auditor should verify all the actions taken by the organisation, regardless of their sequence or priority. The auditor may choose to verify the actions based on their relevance, significance, or impact, but this is not a mandatory requirement12 Opportunities for improvement should be verified first, followed by corrections and finally corrective actions. This is false because there is no prescribed order for verifying the opportunities for improvement, corrections, and corrective actions. The auditor should verify all the actions taken by the organisation, regardless of their sequence or priority. The auditor may choose to verify the actions based on their relevance, significance, or impact, but this is not a mandatory requirement12 Corrective actions should be reviewed first, followed by corrections and finally opportunities for improvement. This is false because there is no prescribed order for reviewing the corrective actions, corrections, and opportunities for improvement. The auditor should review all the actions taken by the organisation, regardless of their sequence or priority. The auditor may choose to review the actions based on their relevance, significance, or impact, but this is not a mandatory requirement12 Reference:

1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 92**
您正在作為審核組組長進行您的第一次第三方 ISMS
監督審核。您目前與審核團隊的另一位成員一起在被審核方的資料中心。
您目前所在的大房間被分成幾個較小的房間，每個房間的門上都有一個數位密碼鎖和刷卡器。
您注意到兩個外部承包商使用中心接待台提供的刷卡和組合號碼進入客戶的套房進行授權的電氣維修。
您前往接待處並要求查看客戶套房的門禁記錄。這表示只刷了一張卡。你問接待員，他們回答說：“是的，這是一個常見問題。我們要求每個人都刷卡，但尤其是承包商，一個人往往會刷卡，而其他人只是'尾隨'進來”，但我們知道他們是誰接待處簽到。
根據上述情況，您現在會採取下列哪一項行動？
**A.**提供改進機會，在接待處設置大型標牌，提醒每個需要進入的人必須始終使用刷卡
**B.**確定是否有任何額外的有效安排來驗證個人對安全區域（例如閉路電視）的存取權限
**C.**由於安全區域未充分保護，因此針對控制 A.7.1「安全邊界」提出不符合項
**D.**針對控制
A.7.6「在安全區域工作」提出不符合項，因為尚未定義在安全區域工作的安全措施
**E.**由於尚未與供應商就資訊安全要求達成一致，因此針對控制措施
A.5.20「解決供應商關係中的資訊安全問題」提出不符合項
**F.**提供改進機會，承包商在訪問安全設施時必須始終有人陪同
***Answer:*** B
Explanation:
The best action to take in this scenario is to determine whether any additional effective arrangements are in place to verify individual access to secure areas, such as CCTV. This action is consistent with the audit principle of evidence-based approach, which requires the auditor to obtain sufficient and appropriate audit evidence to support the audit findings and conclusions1. By verifying the existence and effectiveness of other security controls, the auditor can assess the extent and impact of the nonconformity observed, and determine the appropriate audit finding and recommendation.
The other options are not the best actions to take in this scenario, because they are either premature or inappropriate. For example:
* Option A is inappropriate, because it is not the auditor's role to suggest specific solutions or improvements to the auditee, but rather to report the audit findings and recommendations based on the audit criteria and objectives2. A large sign in reception may not be an effective or feasible solution to address the issue of tailgating, and it may not reflect the root cause of the problem.
* Option C is premature, because it assumes that the control A.7.1 'security perimeters' is not adequately implemented, without verifying the existence and effectiveness of other security controls that may compensate for the observed nonconformity. The auditor should not jump to conclusions based on a single observation, but rather gather sufficient and appropriate audit evidence to support the audit finding3.
* Option D is premature, because it assumes that the control A.7.6 'working in secure areas' is not adequately implemented, without verifying the existence and effectiveness of other

ACTUALTEST.COM

security controls that may compensate for the observed nonconformity. The auditor should not jump to conclusions based on a single observation, but rather gather sufficient and appropriate audit evidence to support the audit finding3.
* Option E is inappropriate, because it is not related to the observed nonconformity, which is about the access control to secure areas, not the information security requirements agreed upon with the supplier. The auditor should not raise a nonconformity based on irrelevant or incorrect audit criteria4.
* Option F is inappropriate, because it is not the auditor's role to suggest specific solutions or improvements to the auditee, but rather to report the audit findings and recommendations based on the audit criteria and objectives2. Requiring contractors to be accompanied at all times when accessing secure facilities may not be an effective or feasible solution to address the issue of tailgating, and it may not reflect the root cause of the problem.

**QUESTION NO: 93**
一個體面的訪客在沒有訪客 ID
的情況下四處閒逛。作為員工，您應該執行以下操作，但以下情況除外：
**A.**打招呼並提供咖啡
**B.**致電接待員並告知訪客狀況
**C.**問候並詢問他有什麼事
**D.**護送他到達目的地
***Answer:*** A
Explanation:
As an employee, you should do the following when you see a visitor roaming around without visitor's ID, except saying "hi" and offering coffee. Saying "hi" and offering coffee is not an appropriate action, as it may imply that you are welcoming or endorsing the visitor without verifying their identity or purpose. This may also give the visitor an opportunity to gain your trust or exploit your kindness. Calling the receptionist and informing about the visitor is an appropriate action, as it alerts the responsible staff to handle the situation and ensure that the visitor is authorized and registered. Greeting and asking him what is his business is an appropriate action, as it shows your concern and curiosity about the visitor's presence and intention. Escorting him to his destination is an appropriate action, as it prevents the visitor from wandering around unattended and accessing unauthorized areas or information.
Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 42. : [ISO/IEC 27001 LEAD AUDITOR - PECB], page 15.

**QUESTION NO: 94**
下列哪一項不屬於資訊安全攻擊類型？
**A.**法律事件
**B.**車輛事故
**C.**技術漏洞
**D.**隱私權事件
***Answer:*** B
Explanation:
Vehicular incidents are not a type of information security attack. A vehicular incident is an event that involves a vehicle or its driver causing damage or injury to people or property. A

vehicular incident may have an impact on information security if it affects the availability or integrity of information or systems that are transported or accessed by vehicles, but it is not an intentional or malicious attack on information security. Legal incidents are a type of information security attack that involve legal actions or disputes that may compromise the confidentiality or integrity of information or systems. Technical vulnerabilities are a type of information security attack that exploit weaknesses or flaws in software or hardware that may compromise the confidentiality, integrity, or availability of information or systems. Privacy incidents are a type of information security attack that involve unauthorized access or disclosure of personal or sensitive information that may compromise the confidentiality or integrity of information or systems. Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 25. : [ISO/IEC 27001 LEAD AUDITOR - PECB], page 13.

**QUESTION NO: 95**

場景 2：
Clinic 成立於 20 世紀 90
年代，是一家專門治療心臟相關疾病和複雜外科手術的醫療器材公司。該公司總部位於歐洲，為患者和醫療保健專業人士提供服務。診所收集患者數據以客製化治療方案、監測結果並改善設備功能。為了增強資料安全性和建立信任，Clinic 正在實施基於 ISO/IEC 27001
的資訊安全管理系統 (ISMS)。
診所僅透過考慮內部問題、介面、內部和外包活動之間的依賴關係以及相關方的期望來確定其 ISMS 的範圍。此範圍已仔細記錄並可供查閱。在定義其 ISMS 時，Clinic
選擇專注於關鍵部門內的關鍵流程，例如研發、病患資料管理和客戶支援。
儘管最初面臨挑戰，Clinic 仍然致力於實施
ISMS，並根據其獨特需求量身定制安全控制。專案團隊從 ISO/IEC 27001 中排除了某些附件 A
控制，同時加入了額外的特定產業控制以增強安全性。該團隊根據內部和外部因素評估了這些控制的適用性，最終制定了全面的適用性聲明
(SoA)，詳細說明了控制選擇和實施背後的理由。
隨著認證準備工作的進展，被任命為團隊負責人的 Brian
採用了自我導向的風險評估方法來識別和評估公司的策略問題和安全實踐。這種積極主動的方法確保診所的風險評估與其目標和使命保持一致。
根據情境 2，Brian 選擇哪一種方法來進行風險評估？

**A.**八度

**B.**梅哈里

**C.**EBIOS

***Answer:*** A

Explanation:
Comprehensive and Detailed In-Depth
A . OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation) - Correct Answer. OCTAVE is a self-directed risk assessment methodology where organizations identify, evaluate, and manage information security risks based on their strategic objectives, aligning with Brian's approach.
B . MEHARI is a quantitative risk analysis method, not self-directed.
C . EBIOS is focused on regulatory compliance and external risk factors, which Brian's methodology did not emphasize.

Thus, Brian's approach aligns best with OCTAVE, as it is self-directed and focuses on organizational security practices.

**QUESTION NO: 96**
設想：
Northstorm
是一家線上零售商店，提供獨特的復古和現代配件。它最初進入了一個小型市場，但隨著整個電子商務格局的發展而逐漸發展壯大。 Northstorm
專門在線上工作，確保高效的付款處理、庫存管理、行銷工具和出貨訂單。它採用優先排序來接收、補貨和運送其最受歡迎的產品。
Northstorm
傳統上透過託管其網站並完全控制其基礎架構（包括硬體、軟體和資料管理）來管理其 IT 營運。然而，由於缺乏響應的基礎設施，這種方法阻礙了其發展。為了增強其電子商務和支付系統，Northstorm
選擇擴展其內部資料中心，並在三個月內分兩個階段完成擴建。最初，該公司升級了其核心伺服器、銷售點、訂購、計費、資料庫和備份系統。第二階段涉及改善郵件、付款和網路功能。此外，在此階段，Northstorm 採用了針對個人識別資訊 (PII) 控制者和 PII
處理者的國際標準，以確保其資料處理實務安全並符合全球法規。
儘管進行了擴張，但 Northstorm
升級後的資料中心仍未能滿足其不斷變化的業務需求。這種不足導致了一些新的挑戰，包括訂單優先事項問題。客戶報告未收到優先訂單，且公司難以迅速回應。這主要是因為主伺服器無法處理來自 YouDecide 的訂單，YouDecide
是一款旨在優先處理訂單和模擬客戶互動的應用程式。該應用程式依賴先進的演算法，與升級期間安裝的新作業系統（OS）不相容。
面對緊急的兼容性問題，Northstorm
在沒有經過適當驗證的情況下迅速修補了應用程序，導致安裝了受損版本。這次安全漏洞導致主伺服器受到影響，該公司的網站離線一週。認識到需要更可靠的解決方案，該公司決定將其網站託管外包給電子商務提供者。該公司簽署了有關產品所有權的保密協議，並在過渡之前對使用者存取權限進行了徹底審查，以增強安全性。
根據情境 1，Northstorm 在第二階段的擴張中採用了哪一種國際標準？

**A.** ISO/IEC 27701

**B.** ISO/IEC 27009

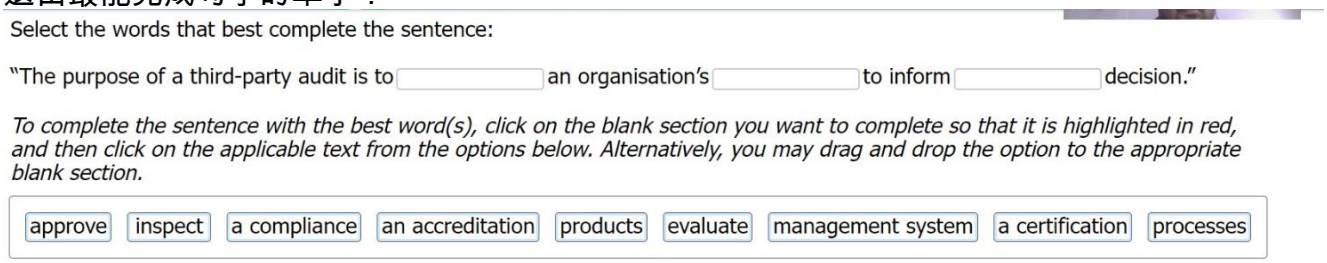
**C.** ISO/IEC 27003

***Answer:*** A

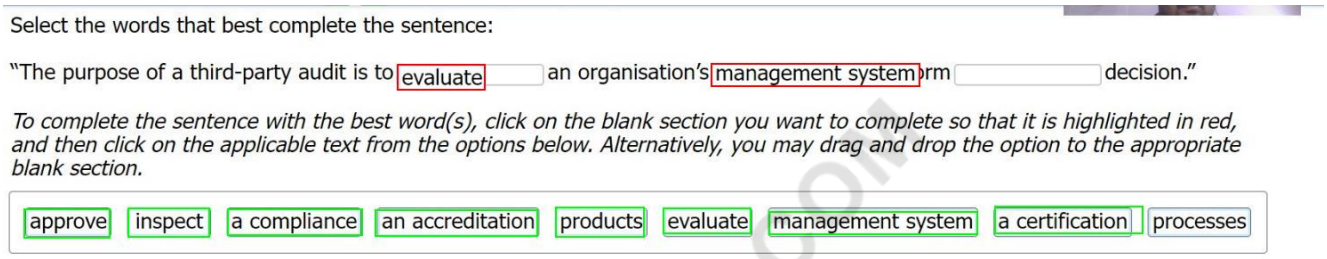
Explanation:
Comprehensive and Detailed In-Depth
Northstorm adopted an international standard for Personally Identifiable Information (PII) controllers and PII processors to ensure its data handling practices were secure and compliant with global regulations. This aligns directly with ISO/IEC 27701, which extends ISO/IEC 27001 and ISO/IEC 27002 to cover Privacy Information Management Systems (PIMS), specifically addressing the protection of PII.
A . ISO/IEC 27701 - Correct Answer. This standard is designed for organizations acting as PII controllers and processors and provides guidelines on privacy management, regulatory compliance, and data protection.
B . ISO/IEC 27009 - Incorrect because this standard provides guidance on sector-specific

requirements for ISMS, not privacy or PII protection.
C . ISO/IEC 27003 - Incorrect because it provides general implementation guidance for ISMS, not specific controls for PII processing.

**QUESTION NO: 97**
選出最能完成句子的單字：




***Answer:***




**QUESTION NO: 98**
您是一位經驗豐富的 ISMS
審核團隊領導，為審核員提供培訓指導。她問您為什麼制定與不合格品分級相關的具體標準很重要。
下列哪一項答案是正確的？
**A.**因為分級標準為評估整個組織的不合格項提供了共同基礎
**B.**因為 ISO/IEC 27001:2022 要求它
**C.**因為評分標準的建立和實施顯示了對糾正措施流程的高度承諾
**D.**因為評分標準將確保所有審核員以完全相同的方式對不合格項進行評分
***Answer:*** A
Explanation:
The correct response is A, because grading criteria provide a common basis for the evaluation of nonconformities across the organization. Grading criteria are the rules or standards that define the severity or impact of nonconformities, and help to determine the appropriate corrective actions and follow-up activities. Grading criteria are important for several reasons, such as:
They ensure consistency and objectivity in the assessment and reporting of nonconformities, and avoid subjective or arbitrary judgments.
They facilitate the communication and understanding of nonconformities among the auditors, the auditees, and the audit clients, and enable the comparison and benchmarking of nonconformities across different processes, functions, or locations.
They support the prioritization and allocation of resources for the resolution of nonconformities, and the monitoring and measurement of the effectiveness of the corrective actions.
They demonstrate the commitment and accountability of the organization to the continual

improvement of the ISMS, and the compliance with the ISMS requirements and expectations.
Reference:
ISO/IEC 27001:2022, Information technology - Security techniques - Information securit y management systems - Requirements1 PECB Candidate Handbook ISO/IEC 27001 Lead Auditor2 ISO 27001:2022 Lead Auditor - PECB3 ISO 27001:2022 certified ISMS lead auditor - Jisc4 ISO/IEC 27001:2022 Lead Auditor Transition Training Course5 ISO 27001 - Information Security Lead Auditor Course - PwC Training Academy ISO 19011:2022 , Guidelines for auditing management systems

**QUESTION NO: 99**
您正在國際物流組織的出貨部門進行 ISMS
審核，該組織為當地醫院和政府辦公室等大型組織提供運輸服務。包裹通常包含藥品、生物樣本以及護照和駕駛執照等文件。您注意到，公司記錄顯示大量退貨，原因包括標籤地址錯誤，以及在 15% 的公司案例中，一個包裹的不同地址有兩個或多個標籤。您正在面試運輸經理 (SM)。
您：出貨前檢查過嗎？
SH：任何明顯損壞的物品都會在出貨前由值班人員移除，但利潤微薄，因此實施正式檢查流程並不經濟。
您：退貨後會採取什麼措施？
SM：這些合約大多價值相對較低，因此我們認為，簡單地重新列印標籤並重新發送單一包裹比實施調查更容易、更方便。
您提出不符合項。參考該場景，您希望受審核方在進行後續審核時實施下列哪六項附錄 A 控制措施？
**A.**5.11 資產返還
**B.**8.12 資料外洩保護
**C.**5.3 職責分離
**D.**6.3 資訊安全意識、教育與培訓
**E.**7.10 儲存介質
**F.**8.3 資訊存取限制
**G.**5.6 與特殊利益團體的聯繫
**H.**6.4 紀律程序
**I.**7.4 實體安全監控
**J.**5.13 資訊標籤
**K.**5.32 智慧財產權
***Answer:*** B,D,E,F,I,J
Explanation:
B . 8.12 Data leakage protection. This is true because the auditee should have implemented measures to prevent unauthorized disclosure of sensitive information, such as personal data, medical records, or official documents, that are contained in the parcels. Data leakage protection could include encryption, authentication, access control, logging, and monitoring of data transfers12.
D . 6.3 Information security awareness, education, and training. This is true because the auditee should have ensured that all employees and contractors involved in the shipping process are aware of the information security policies and procedures, and have received

ACTUAL4TEST.COM

appropriate training on how to handle and protect the information assets in their custody. Information security awareness, education, and training could include induction programmes, periodic refreshers, awareness campaigns, e-learning modules, and feedback mechanisms13.
E . 7.10 Storage media. This is true because the auditee should have implemented controls to protect the storage media that contain information assets from unauthorized access, misuse, theft, loss, or damage. Storage media could include paper documents, optical disks, magnetic tapes, flash drives, or hard disks14. Storage media controls could include physical locks, encryption, backup, disposal, or destruction14.
F . 8.3 Information access restriction. This is true because the auditee should have implemented controls to restrict access to information assets based on the principle of least privilege and the need-to-know basis. Information access restriction could include identification, authentication, authorization, accountability, and auditability of users and systems that access information assets15.
I . 7.4 Physical security monitoring. This is true because the auditee should have implemented controls to monitor the physical security of the premises where information assets are stored or processed. Physical security monitoring could include CCTV cameras, alarms, sensors, guards, or patrols16. Physical security monitoring could help detect and deter unauthorized physical access or intrusion attempts16.
J . 5.13 Labelling of information. This is true because the auditee should have implemented controls to label information assets according to their classification level and handling instructions. Labelling of information could include markings, tags, stamps, stickers, or barcodes1 . Labelling of information could help identify and protect information assets from unauthorized disclosure or misuse1 .
Reference:
ISO/IEC 27002:2022 Information technology - Security techniques - Code of practice fo r information security controls ISO/IEC 27001:2022 Information technology - Security techniques - Information security management systems - Requirements ISO/IEC 27003:202 2 Information technology - Security techniques - Information security management systems - Guidance ISO/IEC 27004:2022 Information technology - Security techniques - Informati on security management systems - Monitoring measurement analysis and evaluation ISO/IEC 27005:2022 Information technology - Security techniques - Information security ris k management ISO/IEC 27006:2022 Information technology - Security techniques - Requirements for bodies providing audit and certification of information security management systems
[ISO/IEC 27007:2022 Information technology - Security techniques - Guidelines for informatio n security management systems auditing]

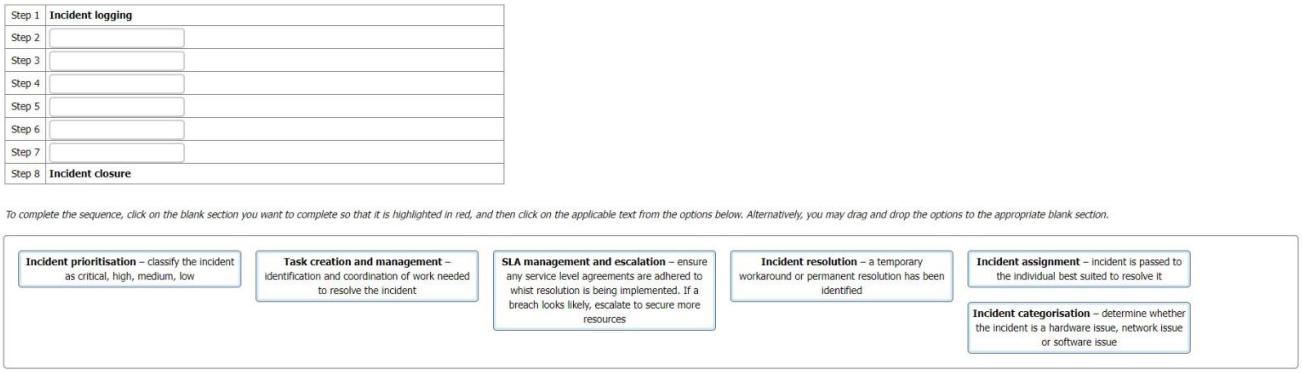
**QUESTION NO: 100**
在與被審計方初次聯繫之前發送業務約定書的主要原因是什麼？
**A.**確認進行稽核的權限
**B.**提供初步審計細節並安排初次聯繫
**C.**建立稽核目標
***Answer:*** B
Explanation:

Comprehensive and Detailed In-Depth
B . Correct Answer:
The engagement letter serves to inform the auditee about the audit details, including:
Audit scope
Audit schedule
Expectations from both parties
It formally introduces the audit process and schedules the initial contact.
A . Incorrect:
The authority to conduct the audit is established by the certification body's agreement, not just the engagement letter.
C . Incorrect:
Audit objectives are determined in the planning phase and are not the primary function of the engagement letter.
Relevant Standard Reference:

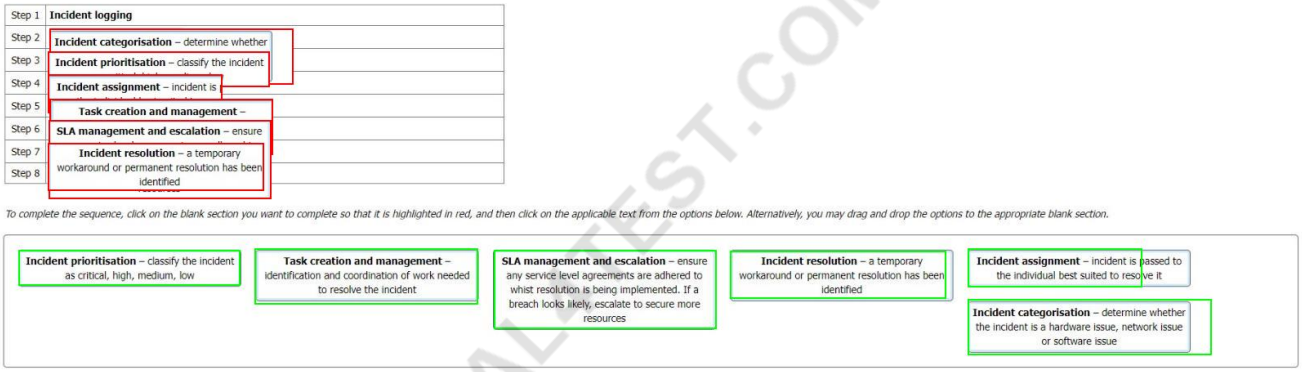
**QUESTION NO: 101**
CEO發送一封電子郵件，表達他對公司現狀和公司未來策略的看法以及CEO的願景和員工在其中的角色。郵件應分類為
**A.**內部郵件
**B.**公共郵件
**C.**機密郵件
**D.**受限郵件
***Answer:*** A
Explanation:
The mail sent by the CEO giving his views on the status of the company and the company's future strategy and the CEO's vision and the employee's part in it should be classified as internal mail. Internal mail is a type of classification that indicates that the information is intended for internal use only, and should not be disclosed to external parties without authorization. The mail sent by the CEO contains information that is relevant and important for the employees of the company, but may not be suitable for public disclosure, as it may contain sensitive or confidential information about the company's performance, goals, or plans. Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 34. : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 37. : [ISO/IEC 27001 LEAD AUDITOR - PECB], page 14.

**QUESTION NO: 102**
您的組織目前正在尋求 ISO/IEC27001:2022 認證。您剛剛獲得內部 ISMS 審核員資格，ICT 經理希望利用您新獲得的知識來協助他設計資訊安全事件管理流程。
他確定了計劃流程中的以下階段，並要求您確認它們應按哪個順序出現。

ACTUALTEST.COM




***Answer:***




Reference:
ISO/IEC 27001:2022, Information technology - Security techniques - Information securit y management systems - Requirements1 PECB Candidate Handbook ISO/IEC 27001 Lead Auditor2 ISO 27001:2022 Lead Auditor - PECB3 ISO 27001:2022 certified ISMS lead auditor - Jisc4 ISO/IEC 27001:2022 Lead Auditor Transition Training Course5 ISO 27001 - Information Security Lead Auditor Course - PwC Training Academy6 ISO/IEC 27035:2022 , Information technology - Security techniques - Information security incident management

**QUESTION NO: 103**
您是一位經驗豐富的 ISMS
審核團隊負責人，正在與分配給您的審核團隊的正在接受培訓的審核員進行交談。您希望確保他們了解計劃-執行-檢查-行動週期的檢查階段對於資訊安全管理系統的運作的重要性。
您可以透過要求他選擇最能描述檢查活動目的的答案來做到這一點
'管理審查。
管理評審的目的是： 選擇 1
**A.**定期評估資訊安全管理體系，以確保其持續有效率、充分且有效。
**B.**定期考慮資訊安全管理體系，以確保其持續合規性、充分性和有效性。
**C.**依計畫的時間間隔檢視資訊安全管理體系，以確保其持續適用性、充分性和有效性。
**D.**定期更新資訊安全管理體系，以確保其持續符合性、充分性和有效性。
***Answer:*** C
Explanation:
The management review is a key component of the "Check" stage in the Plan-Do-Check-Act (PDCA) cycle. Its primary purpose is to evaluate the overall ISMS and make strategic decisions for improvement. Here's why the other options are less accurate:
* A . Random intervals: Reviews should be conducted at planned intervals for consistency

and tracking progress.
* B . Compliance: While compliance is a consideration, the main focus is on the system's suitability for the organization's needs, its adequacy in managing risks, and its overall effectiveness in achieving information security objectives.
* D . Update: The management review might lead to updates, but its primary goal is evaluation, not immediate modification.
Reference:
* ISO/IEC 27001:2022, Section 9.3 (Management Review): Outlines the purpose and requirement for conducting management reviews.

**QUESTION NO: 104**
您正在對提供醫療保健服務的住宅療養院進行 ISMS
審核。審計計劃的下一步是驗證資訊安全事件管理流程。 IT
安全經理介紹資訊安全事件管理程序（文件參考 ID：ISMS_L2_16，版本 4）。
您查看了文件並注意到一條聲明「任何資訊安全漏洞、事件和事故應在發現後 1
小時內報告給聯絡點
(PoC)」。在訪談員工時，您發現對「弱點、事件和事故」一詞的含義的理解存在差異。
IT安全經理解釋說，6個月前曾舉辦過一次線上「資訊安全處理」培訓研討會。所有受訪的人都參加並通過了報告練習和課程考核。
您想進一步調查其他領域以收集更多審計證據。選擇三個不是有效審計追蹤的選項。
**A.**收集更多證據，說明如何隔離發生資訊安全事件的區域，以便在中斷期間維護資訊安全（與控制 A.5.29 相關）
**B.**收集更多關於如何透過適當管道報告資訊安全事件的證據（與控制 A.6.8 相關）
**C.**收集更多關於組織如何進行資訊安全事件訓練的證據並評估其有效性。（與第 7.2 條相關）
**D.**收集更多關於組織如何從資訊安全事件中學習並做出改進的證據。（與控制 A.5.27 相關）
**E.**收集更多關於組織如何管理監控漏洞的聯絡點 (PoC) 的證據。（與第 8.1 條相關）
**F.**收集更多有關組織如何測試業務連續性計畫的證據。（與控制 A.5.30 相關）
**G.**收集更多證據證明資訊安全政策中是否包含術語和定義。（與控制 5.32 相關）
**H.** 收集更多證據以確定 ISO 27035（資訊安全事件管理）是否用作內部稽核標準
***Answer:*** E,G,H
a. (Relevant to clause 8.13)
Explanation:
The three options that would not be valid audit trails are:
* Collect more evidence on how the organisation manages the Point of Contact (PoC) which monitors vulnerabilities. (Relevant to clause 8.1)
* Collect more evidence on whether terms and definitions are contained in the information security policy. (Relevant to control 5.32)
* Collect more evidence to determine if ISO 27035 (Information security incident management) is used as internal audit criteria. (Relevant to clause 8.13) These options are not valid audit trails because they are not directly related to the information security incident management process, which is the focus of the audit. The audit trails should be relevant to the objectives, scope, and criteria of the audit, and should provide sufficient and reliable evidence to support the audit findings and conclusions1.
Option E is not valid because the PoC is not a part of the information security incident management process, but rather a role that is responsible for reporting and escalating

information security incidents to the appropriate authorities2. The audit trail should focus on how the PoC performs this function, not how the organisation manages the PoC.
Option G is not valid because the terms and definitions are not a part of the information security incident management process, but rather a part of the information security policy, which is a high-level document that defines the organisation's information security objectives, principles, and responsibilities3. The audit trail should focus on how the information security policy is communicated, implemented, and reviewed, not whether it contains terms and definitions.
Option H is not valid because ISO 27035 is not a part of the information security incident management process, but rather a guidance document that provides best practices for managing information security incidents4. The audit trail should focus on how the organisation follows the requirements of ISO/IEC 27001:2022 for information security incident management, not whether it uses ISO 27035 as an internal audit criteria.
The other options are valid audit trails because they are related to the information security incident management process, and they can provide useful evidence to evaluate the conformity and effectiveness of the process. For example:
* Option A is valid because it relates to control A.5.29, which requires the organisation to establish procedures to isolate and quarantine areas subject to information security incidents, in order to prevent further damage and preserve evidence5. The audit trail should collect evidence on how the organisation implements and tests these procedures, and how they ensure the continuity of information security during disruption.
* Option B is valid because it relates to control A.6.8, which requires the organisation to establish mechanisms for reporting information security events and weaknesses, and to ensure that they are communicated in a timely manner to the appropriate levels within the organisation6. The audit trail should collect evidence on how the organisation defines and uses these mechanisms, and how they monitor and review the reporting process.
* Option C is valid because it relates to clause 7.2, which requires the organisation to provide information security awareness, education, and training to all persons under its control, and to evaluate the effectiveness of these activities7. The audit trail should collect evidence on how the organisation identifies the information security training needs, how they deliver and record the training, and how they measure the learning outcomes and feedback.
* Option D is valid because it relates to control A.5.27, which requires the organisation to learn from information security incidents and to implement corrective actions to prevent recurrence or reduce impact8. The audit trail should collect evidence on how the organisation analyses and documents the root causes and consequences of information security incidents, how they identify and implement corrective actions, and how they verify the effectiveness of these actions.
* Option F is valid because it relates to control A.5.30, which requires the organisation to establish and maintain a business continuity plan to ensure the availability of information and information processing facilities in the event of a severe information security incident9. The audit trail should collect evidence on how the organisation develops and updates the business continuity plan, how they test and review the plan, and how they communicate and train the relevant personnel on the plan.

**QUESTION NO: 105**
您是經驗豐富的 ISMS

審核團隊領導，指導審核員進行培訓。您決定透過詢問她一系列問題來測試她對後續審核的了解。這是您的問題和她的答案。
她正確回答了您的哪四個問題？
**A.**問：後續審核是否應該尋求發現新的不合格項？答：是的
**B.**問：後續審核是否應確保不合格問題得到有效解決？答：是的
**C.**問：後續審核是否應該考慮商定的改進機會以及糾正措施？
年
**D.**問：後續審核的目的是驗證糾正、糾正措施和改進機會的完成嗎？答：是的
**E.**問：所有審核都需要後續審核嗎？答：沒有
**F.**問：後續審核的結果是否應該向負責最初識別 NC 審核的審核組組長報告？答：是的
**G.**問：後續審核的結果是否該向審核客戶報告？答：沒有
**H.**問：如果需要，後續審核的結果是否可以成為另一次後續審核？答：是的
***Answer:*** B,D,E,H
Explanation:
Based on the understanding of follow-up audits, especially in the context of Information Security Management Systems (ISMS) and the guidelines provided by ISO 19011:2018, here are the four questions from your list that the auditor in training has answered correctly:
B . Q: Should follow-up audits seek to ensure nonconformities have been effectively addressed? A: YES This is correct. The primary purpose of follow-up audits is to verify that nonconformities identified in previous audits have been effectively addressed and the corrective actions taken are suitable and effective.
D . Q: Is the purpose of a follow-up audit to verify the completion of corrections, corrective actions, and opportunities for improvement? A: YES Yes, the follow-up audit aims to verify the completion and effectiveness of corrections and corrective actions. It may also consider the implementation of opportunities for improvement identified during the initial audit.
E . Q: Are follow-up audits required for all audits? A: NO This is correct. Follow-up audits are not automatically required for all audits. They are typically conducted when nonconformities or other significant issues were identified in an earlier audit and there's a need to verify the implementation and effectiveness of the corrective actions.
H . Q: Could an outcome from a follow-up audit be another follow-up audit if required? A: YES Yes, this is a possible outcome. If the follow-up audit finds that the corrective actions have not been fully effective, or if new issues are identified, it may be necessary to conduct another follow-up audit.
The other responses provided by the auditor in training require some clarification or correction. For instance, while a follow-up audit primarily focuses on previously identified nonconformities and corrective actions, it can still identify new nonconformities if observed (A). Opportunities for improvement are generally considered in the scope of regular audits more so than in follow-up audits, which are more narrowly focused on corrective actions (C). Also, the outcomes of follow-up audits should typically be reported to both the audit team leader and the audit client (F and G), ensuring transparency and accountability.
The four questions that the auditor in training has answered correctly are B, D, E, and H. These questions and answers are consistent with the definition and purpose of a follow-up audit as specified in ISO 19011:2018, Clause 6.712. A follow-up audit is conducted to verify the completion and effectiveness of corrective actions taken as a result of a previous audit

(B, D). Follow-up audits are not mandatory for all audits, but they may be required by the audit program, the audit client, or other interested parties (E). The outcome of a follow-up audit may be another follow-up audit if the corrective actions are not satisfactory or not completed within the agreed time frame (H). The other questions and answers are either incorrect or irrelevant. A follow-up audit should not seek to identify new nonconformities, as this is not its objective (A). Follow-up audits should consider agreed opportunities for improvement as well as corrective actions, as they are both outputs of a previous audit . The outcome of a follow-up audit should be reported to the audit client, as well as to other relevant parties, such as the audit team leader who carried out the previous audit (F, G).
Reference: 1: ISO 19011:2018, Guidelines for auditing management systems, Clause 6.7 \n2: PECB Certified ISO/IEC 27001 Lead Auditor Exam Preparation Guide, Domain 6: Closing an ISO/IEC 27001 audit

**QUESTION NO: 106**
設想：
當使用者向緩衝區添加的資料超過其儲存容量允許的數量時，資料處理工具就會崩潰。該事件是由於該工具無法進行數組邊界檢查而引起的。這是什麼樣的弱點？
**A.**固有脆弱性，即無法進行陣列邊界檢查，是資料處理工具的特性
**B.** 外部漏洞，即緩衝區溢位漏洞的利用，是由外部因素造成的
**C.**無；緩衝區溢位不是一個漏洞；這是一種威脅
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
Intrinsic vulnerabilities are inherent flaws in a system, software, or tool. In this case, the inability to bound-check arrays is an inherent weakness of the software, making it an intrinsic vulnerability. This aligns with ISO/IEC 27001:2022 Annex A Control A.8.9 (Configuration Management), which mandates secure software design and validation practices.
Extrinsic vulnerabilities arise due to external factors (e.g., misconfigurations or lack of security patches).
Buffer overflow is a vulnerability, not a threat, because it represents a weakness that can be exploited by an attacker.

**QUESTION NO: 107**
場景9：UpNet是一家網路公司，已通過ISO/IEC 27001認證。
自從獲得 ISO/IEC 27001 認證以來，該公司的認可度大幅提高。此認證證實了 UpNefs 營運的成熟性及其符合廣泛認可和接受的標準。
但認證之後一切還沒結束。 UpNet 透過進行內部稽核不斷審查和增強其安全控制以及 ISMS 的整體有效性和效率。高階主管不願意聘請全職內部稽核團隊，因此決定將內部稽核職能外包。這種形式的內部稽核確保了獨立性、客觀性，並且在 ISMS 的持續改進方面發揮諮詢作用。
在初次認證審核後不久，該公司創建了一個專門從事數據和儲存產品的新部門。他們提供針對資料中心和基於軟體的網路設備（例如網路虛擬化和網路安全設備）進行最佳化的路由器和交換器。這導致 ISMS 認證範圍內已涵蓋的其他部門的營運發生變化。
所以。 UpNet
啟動了風險評估流程和內部稽核。根據內部審計結果，公司確認了現有和新流程和控制的有效性和效率。

由於新部門符合 ISO/IEC 27001 要求，最高管理層決定將其納入認證範圍。
UpNet宣布取得ISO/IEC 27001認證，認證範圍涵蓋全公司。
在初次認證審核一年後，認證機構對 UpNefs ISMS 進行了另一次審核。
此次審核旨在確定 UpNefs ISMS 是否符合指定的 ISO/IEC 27001 要求，並確保 ISMS 持續改善。審核小組確認，經過認證的 ISMS
繼續符合標準的要求。儘管如此，新部門對管理體系的治理產生了重大影響。此外，認證機構並未獲悉任何變更。因此，UpNefs認證被暫停。
根據上述場景，回答以下問題：
根據場景9，為什麼UpNefs認證被暫停？
**A.**因為UpNet使用和應用的認證超出了其範圍
**B.**因為 UpNet 外包了內部稽核職能
**C.**因為UpNefs ISMS不符合標準的要求
***Answer:*** A
Explanation:
UpNet's certification was suspended because the certification body was not informed about the significant changes caused by the new department, impacting the governance of the management system. ISO/IEC 27001 requires organizations to inform the certification body of any changes that significantly impact the ISMS.

**QUESTION NO: 108**
您是一位經驗豐富的審核團隊負責人，負責為其客戶設計網站的組織進行第三方監督審核。您目前正在審查該組織的適用性聲明。
根據 ISO/IEC 27001 的要求，以下關於適用性聲明的觀察哪兩項是正確的？
**A.**需要說明在適用性聲明中包含和排除附件 A 控制措施的理由
**B.**適用性聲明由組織的最高管理階層擁有和修改
**C.**適用性聲明必須至少每年檢討一次
**D.**尋求 ISO/IEC 27001 合規性的組織必須出具適用性聲明
**E.**僅需要對組織選擇排除的任何控制進行說明
**F.**適用性聲明必須在管理審查中進行審查
***Answer:*** A,D

**QUESTION NO: 109**
場景 4：Branding
是一家行銷公司，與美國一些最著名的公司合作。降低內部成本。兩年多來，Branding 已將軟體開發和 IT 幫助台營運外包給
Techvology。技術學。配備必要的專業知識，管理品牌的軟體、網路和硬體需求。 Branding 已實施資訊安全管理系統 (ISMS) 並獲得了 ISO/IEC 27001
認證，表明其致力於維護高標準的資訊安全。它積極對技術進行審計，以確保其外包業務的安全性符合 ISO/IEC 27001 認證要求。
在上次審計期間。品牌的審計團隊定義了要審計的流程和審計計畫。他們採用了基於證據的方法，特別是考慮到 Techvology 在過去一年中報告的兩起資訊安全事件。所有方面。
此外，審計也對Techvology用於管理其外包業務和其他組織的治理流程進行了嚴格的評估。此步驟對於品牌推廣至關重要，可以驗證是否有適當的控制和監督機制來減輕與外包安排相關的潛在風險。

審計員對 Techvology 各級人員進行了採訪，並分析了事件解決記錄。此外，Techvology 還提供了記錄作為證據，證明他們為員工開展了事件管理意識會議。根據收集到的信息，他們預測這兩起資訊安全事件都是由人員不稱職造成的。因此，審計人員要求查看涉事員工的人事檔案，以審查其能力的證據，例如相關經驗、證書和參與培訓的記錄。
Branding
的審計員對所獲得的證據的有效性進行了嚴格評估，並對可能與收到的記錄資訊的可靠性相矛盾或質疑的證據保持警惕。在對 Techvology
進行審計期間，審計員堅持這種方法，嚴格評估事件解決記錄，並對不同級別和職能的員工進行徹底的訪談。他們不只把 Techvology
代表的話當作事實；相反，他們尋求具體的證據來支持代表們對事件管理流程的主張。
根據上述情景，回答以下問題：
根據情境 4，品牌進行了哪種類型的審計？

**A.**第一方審計

**B.**第二方審計

**C.**第三方審計

***Answer:*** B

Explanation:
Comprehensive and Detailed In-Depth
B . Correct answer:
A second-party audit is conducted by an organization on its suppliers or outsourced service providers to ensure compliance with contractual and regulatory requirements.
Branding audited Techvology, an outsourced IT service provider, making this a second-party audit.
A . Incorrect:
A first-party audit is an internal audit, but Techvology is not an internal entity.
C . Incorrect:
A third-party audit is performed by an independent certification body, which is not the case here.
Relevant Standard Reference:

**QUESTION NO: 110**
下列哪一項是組織環境的定義？

**A.**對可能影響組織實現其目標的願望的內部和外部問題的控制

**B.**可能影響組織制定和實現其目標的方法的內部和外部問題的複雜性

**C.**可能影響組織制定和實現其目標的方法的內部和外部問題的組合

**D.**協調可能對組織的成功產生正面或負面影響的內部和外部問題

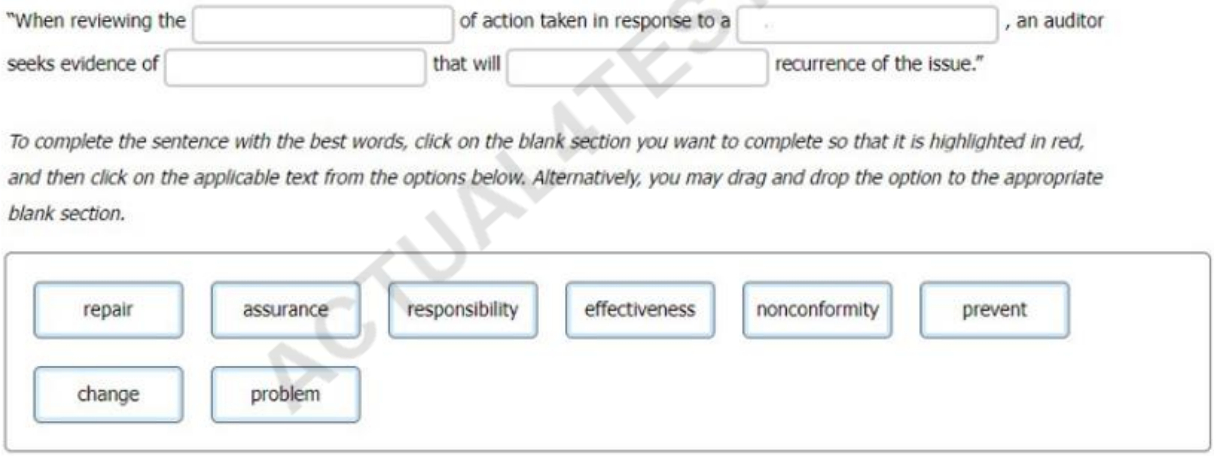
***Answer:*** C

Explanation:
The context of the organisation is the business environment in which the organisation operates and defines its information security management system (ISMS). It includes the internal and external factors and conditions that can influence the organisation's information security objectives, strategies, and policies. The context of the organisation helps the organisation to identify the scope, boundaries, and requirements of the ISMS, as well as the interested parties and their expectations. The context of the organisation is determined by considering both internal and external issues, such as the organisational structure, culture,

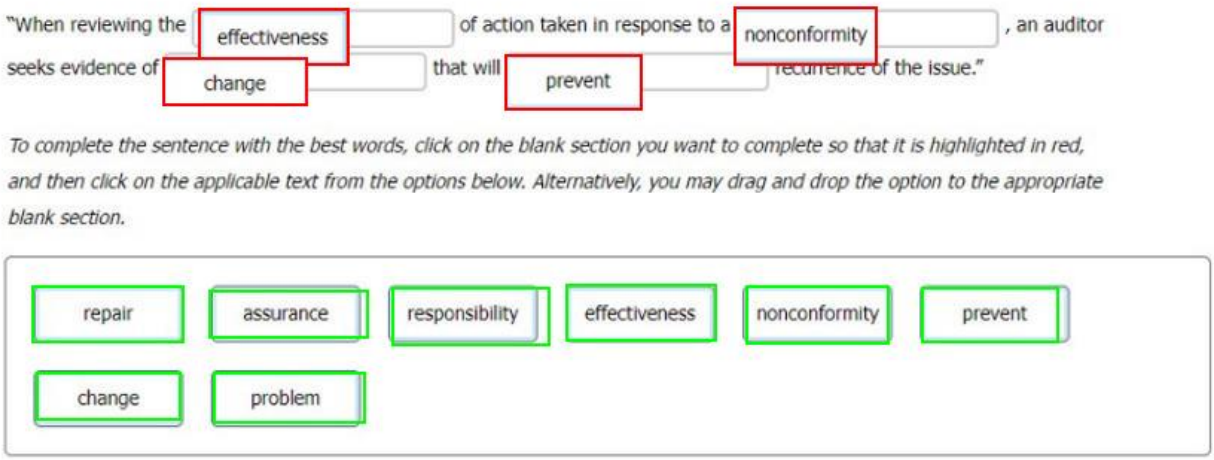
ACTUAL4TEST.COM

values, mission, vision, objectives, strategies, resources, capabilities, processes, activities, products, services, markets, customers, competitors, suppliers, partners, regulators, laws, regulations, standards, guidelines, best practices, risks, opportunities, threats, vulnerabilities, etc. Reference: ISO 27001:2022 Clause 4 Context of the organization, ISO 27001 Requirement 4.1 - Understanding the Context of the Organisation, ISO 27001 context of the organization - How to define it - Advisera

**QUESTION NO: 111**
您正在一家名為 ABC 的歐洲住宿療養院執行 ISMS
審核，該療養院提供醫療保健服務。審核計畫的下一步是驗證持續改善流程的有效性。
審計中了解到，大部分居民家庭成員（90%）每週都會透過農行的醫療保健行動應用程式透過電子郵件和簡訊收到WeCare醫療器材促銷廣告一次。他們均不同意將收集的個人資料用於行銷或與ABC簽訂的服務協議中護理和醫療以外的任何其他目的。他們有充分的理由相信ABC正在向不相關的第三方洩露居民和家庭成員的個人信息，並提出了投訴。
服務經理表示，經調查，所有這些投訴均被視為不合格問題。
已根據不合格和糾正管理程序（文件參考 ID：ISMS_L2_10.1，版本 1）規劃和實施糾正措施。
您寫下不合格項，稍後再跟進。選出最能完成句子的單字：




***Answer:***




**QUESTION NO: 112**

情境 8：EsBank 自 9 月起為愛沙尼亞銀行業提供銀行和金融解決方案
2010年，該公司在全國擁有30家分行和100多台ATM機。
EsBank
在高度監管的行業中運營，必須遵守許多有關資料安全和隱私的法律和法規。他們需要透過實施技術和非技術控制來管理整個營運的資訊安全。 EsBank 決定實施基於 ISO/IEC 的 ISMS 27001，因為它提供了更好的安全性、更多的風險控制以及符合法律法規的關鍵要求。
在成功實施 ISMS 九個月後，EsBank 決定由獨立認證機構根據 ISO/IEC 27001 對其 ISMS 進行認證。
第一階段和第二階段審核是共同進行的，發現了一些不符合項。第一個不合格之處與 EsBank 的資訊標籤有關。該公司有資訊分類方案，但沒有資訊標籤程序。因此，需要相同保護等級的文件將被貼上不同的標籤（有時為機密，有時為敏感）。
考慮到所有文件也以電子方式存儲，不合格情況也影響了媒體處理。審計小組透過抽樣得出結論，200 個可移動媒體中有 50
個儲存了被錯誤分類為機密的敏感資訊。根據資訊分類方案，允許將機密資訊儲存在可移動媒體中，而嚴格禁止儲存敏感資訊。這標誌著另一個不合格之處。
他們起草了不合格報告，並與 EsBank
代表討論了審計結論，代表同意在兩個月內針對發現的不合格問題提交行動計劃。
EsBank
接受了審計組組長提出的解決方案。他們根據實體和電子格式的分類方案起草了資訊標籤程序，解決了不合格問題。可移動媒體程式也基於此程式進行了更新。
審計完成兩週後，EsBank
提交了總體行動計畫。在那裡，他們解決了檢測到的不合格問題以及採取的糾正措施，但沒有包括有關受影響的系統、控製或操作的任何詳細資訊。審核小組評估了該行動計劃並得出結論，該計劃將解決不合格問題。然而，EsBank 收到了不利的認證建議。
根據上述場景，回答以下問題：
透過起草資訊標籤程序，EsBank 已：

**A.**提交了解決不合格問題的行動計劃

**B.**建立資訊分類方案

**C.**消除不合格的根本原因

***Answer:*** A

**QUESTION NO: 113**
您工作的資料中心目前正在尋求 ISO/IEC27001:2022
認證。在為您的初次認證訪問做準備時，您集團內另一個資料中心的同事已進行了多次內部審核。他們在今年稍早獲得了自己的 ISO/IEC 27001:2022 證書。
您剛剛獲得內部 ISMS
審核員資格，您的經理要求您在外部認證機構到達之前審查審核流程和審核結果，作為最終檢查。
以下哪四項會讓您擔心是否符合 ISO/IEC 27001:2022 要求？

**A.**雖然已經定義了每次內部審計的範圍，但尚未為迄今為止進行的審計定義審計標準。

**B.**審計報告不以硬拷貝形式（即紙本形式）保存。它們僅存儲為*。組織內部網路上的 PDF 文件。

**C.**審計流程規定審計結果將提供給「相關」經理，而不是最高管理階層。

**D.**審核計畫未引用審核方法或審核職責。

**E.**審核計畫未考慮資訊安全流程的相對重要性。

**F.**審核程序不考慮先前審核的結果。
**G.**審核計畫尚未簽署「經最高管理階層批准」。
**H.**審計計畫顯示一年中不定期進行的管理審查。
***Answer:*** A,D,E,F

**QUESTION NO: 114**
您正在作為審核組組長進行首次第三方 ISMS
監督審核。您目前與審核團隊的另一位成員以及組織的指南一起位於受審核方的資料中心。您要求進入受密碼鎖和虹膜掃描器保護的上鎖房間。房間角落的桌子上堆放著一堆硬碟。您詢問嚮導驅動器的狀態是什麼。他告訴您驅動器是多餘的並等待處置。這些車輛本應在上週被接走，但由於員工生病，該組織的安全銷毀服務外部提供者無法找到司機。他說這種情況最近變得越來越普遍，儘管他不知道為什麼。然後，他向您提供了一張工作票，確認取件已重新安排在明天。
根據上述情況，您現在會採取以下哪三項行動？
**A.**記錄不符合控制 A.5.13「資訊標籤」的情況，因為磁碟機的狀態不清楚
**B.**針對控制措施
A.7.7「清理桌面和清理螢幕」提出不符合項，因為桌面上的磁碟機未受到保護。
**C.**記錄外部供應商庫存管理安排的改善機會。
**D.**確保遵守組織對設備安全處置和再利用的安排。
**E.**記錄結果，但請注意，無需採取進一步操作，因為取件現已重新安排。
**F.**針對控制 A.7.5「防止物理和環境威脅」提出不符合項，因為驅動器已暴露在桌面上。
**G.**確保遵守組織對儲存媒體生命週期管理的安排。
**H.**遵循審核追蹤來確定組織是否遵守其在控制
A.5.22「供應商服務的監控、評審和變更管理」方面的義務。
***Answer:*** D,G,H

**QUESTION NO: 115**
您是經驗豐富的 ISMS
審核團隊領導，指導審核員進行培訓。您透過詢問她一系列問題來測試她對後續審核的理解，這些問題的答案是“正確*或”
'錯誤的'。以下哪四個問題的答案應該是正確的”'
**A.**如果不合格情況嚴重，可能會進行後續審核
**B.**如果不合格情況輕微，可能會進行後續審核
**C.**後續審核的結果應報告給最高管理階層和對最初發現不合格項進行審核的審核組組長
**D.**後續審核的結果可以將重大不符合項降低為輕微不符合項
**E.**後續審核的結果可能是暫停客戶認證的建議
**F.**後續審核的結果應報告給管理審核計畫的個人和審核客戶
**G.**在所有已發現不合格情況的情況下都需要進行後續審核
**H.**只有在發現重大不合格情況時才需要進行後續審核
***Answer:*** A,B,C,F
Explanation:
A follow-up audit may be carried out where nonconformities are major. This is true because a major nonconformity is a situation that raises significant doubt about the ability of the

organization's management system to achieve its intended results, and therefore requires immediate corrective action. A follow-up audit is necessary to verify the effectiveness of the corrective action and the conformity of the management system12.
A follow-up audit may be carried out where nonconformities are minor. This is true because a minor nonconformity is a situation that does not affect the capability of the management system to achieve its intended results, but represents a deviation from the specified requirements. A follow-up audit may be conducted to check the implementation of the corrective action and the improvement of the management system12.
The outcomes of a follow-up audit should be reported to top management and the audit team leader who carried out the audit where the nonconformities were initially identified. This is true because the top management is responsible for ensuring the effectiveness and continual improvement of the management system, and the audit team leader is accountable for the audit process and the audit conclusions. The follow-up audit report should provide them with objective evidence of the status of the nonconformities and the corrective actions taken by the auditee13.
The outcomes of a follow-up audit should be reported to the individual managing the audit programme and the audit client. This is true because the individual managing the audit programme is responsible for planning, implementing, monitoring and reviewing the audit activities, and the audit client is the organization or person requesting an audit. The follow-up audit report should inform them of the results of the follow-up audit and any changes in the certification status of the auditee13.
Reference:
ISO 19011:2022 Guidelines for auditing management systems
ISO/IEC 27001:2022 Information technology - Security techniques - Information securit y management systems - Requirements ISO/IEC 17021-1:2022 Conformity assessment - Requirements for bodies providing audit and certification of management systems - Part 1 : Requirements

**QUESTION NO: 116**
PayBell
是一家金融公司，正在使用會計軟體來追蹤金融交易。可以從任何有網路連線的地方存取該軟體。它還使 PayBell 的員工能夠輕鬆地相互協作，以確保準確的財務報告。 PayBell 使用什麼類型的服務？
**A.**機器學習
**B.**雲端運算
**C.**人工智慧
***Answer:*** B

**QUESTION NO: 117**
將正確的責任與第二方審核的每位參與者配對：

ACTUAL4TEST.COM

Match the correct responsibility with each participant of a second-party audit:

| Responsibility | Audit Participant |
|---|---|
| Prepares the audit report | |
| Prepares audit checklists for use during the audit | |
| Supports an auditor and provides feedback on their experience | |
| Follows-up on audit findings within an agreed timeframe | |
| Provides an independent account of the audit but does not participate in the audit | |
| Escorts the auditors but does not participate in the audit | |

*To complete the table click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable text from the options below. Alternatively, you may drag and drop each option to the appropriate blank section.*

Audit Team Leader | Auditor in training | Auditor | Auditee | Guide | Observer

***Answer:***

Match the correct responsibility with each participant of a second-party audit:

| Responsibility | Audit Participant |
|---|---|
| Prepares the audit report | Audit Team Leader |
| Prepares audit checklists for use during the audit | Auditor |
| Supports an auditor and provides feedback on their experience | Auditor in training |
| Follows-up on audit findings within an agreed timeframe | Auditee |
| Provides an independent account of the audit but does not participate in the audit | Observer |
| Escorts the auditors but does not participate in the audit | Guide |

*To complete the table click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable text from the options below. Alternatively, you may drag and drop each option to the appropriate blank section.*

Audit Team Leader | Auditor in training | Auditor | Auditee | Guide | Observer

| Responsibility | Audit Participant |
|---|---|
| Prepares the audit report | Audit Team Leader |
| Prepares audit checklists for use during the audit | Auditor |
| Supports an auditor and provides feedback on their experience | Auditor in training |
| Follows-up on audit findings within an agreed timeframe | Auditee |
| Provides an independent account of the audit but does not participate in the audit | Observer |
| Escorts the auditors but does not participate in the audit | Guide |

ACTUAL4TEST.COM

**QUESTION NO: 118**

下列哪兩個選項是使用抽樣計畫進行審核的優點？

**A.**否定審核員的直覺

**B.**減少審核時間

**C.**防止審核團隊內部發生衝突

**D.**增強對審核結果的信心

**E.**高效率實施審核計劃

**F.**使用計劃進行連續審核

***Answer:*** B,D

Explanation:
A sampling plan for the audit is a method of selecting a representative subset of the audit evidence to evaluate the conformity of the ISMS1. The advantages of using a sampling plan are:
It reduces the audit duration by focusing on the most relevant and significant aspects of the ISMS2.
It gives confidence in the audit results by ensuring that the sample is sufficient, reliable, and unbiased3.

**QUESTION NO: 119**
哪些控制與 ISO/IEC 27001 附件 A
控制相關，並且通常從其他指南和標準中選擇或由組織定義以滿足其特定需求？
**A.**一般控制
**B.**戰略控制
**C.**具體控制
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
Specific controls are tailored security controls chosen based on risk assessments, industry best practices, and regulatory requirements. These align with ISO/IEC 27001:2022 Annex A controls, which organizations select based on their risk landscape.
General controls refer to broad security measures that apply to all organizations.
Strategic controls focus on high-level governance and long-term security goals, not detailed security implementations.

**QUESTION NO: 120**
下列哪三個選項是使用抽樣計畫進行審核的優點？
**A.**否定審核員的直覺
**B.**使用計劃進行連續審核
**C.**提供對 ISMS 的適當理解
**D.**有效實施審核計劃
**E.**讓審核結果充滿信心
**F.**遺漏關鍵問題
***Answer:*** C,D,E
Explanation:
According to ISO 19011:2018, which provides guidelines for auditing management systems, a sampling plan is a method for selecting a representative subset of the audit evidence from a defined population1. A sampling plan can have several advantages for the audit, such as providing a suitable understanding of the ISMS by covering its key processes, activities, and controls; implementing the audit plan efficiently by optimizing the use of time and resources; and giving confidence in the audit results by ensuring that the sample is sufficient, reliable, and unbiased1. Therefore, these three options are examples of advantages of using a sampling plan for the audit. The other options are not advantages, but rather disadvantages or risks of using a sampling plan. For example, overruling the auditor's instincts may lead to

missing important evidence or issues that are not covered by the sampling plan; using the same plan for consecutive audits may reduce the effectiveness and validity of the audit results; and missing key issues may result from an inadequate or inappropriate sampling plan1. Reference: ISO 19011:2018 - Guidelines for auditing management systems

**QUESTION NO: 121**

您是 ISMS
審核員，正在對電信供應商進行第三方監督審核。您位於設備暫存室，網路交換器在傳送給客戶之前已預先編程。您注意到，最近未通過初始設定測試並被退回重新編程的交換器數量顯著增加。
你問首席測試員為什麼，她說，「這是最近 ISMS
升級的結果」。在升級之前，每個技術人員都有自己的硬拷貝工作說明。現在，我團隊的八名成員必須共用兩台筆記型電腦才能在線上存取客戶的設定說明。這些延誤給技術人員帶來了壓力，導致更多錯誤。
僅根據上述信息，針對 ISO 的哪一項條款提出不合格項'選擇一項。

**A.**第 7.5 條 - 記錄資訊

**B.**第 8.1 條 - 營運規劃與控制

**C.**第 10.2 條 - 不合格與糾正措施

**D.**第 7.3 條 - 意識

**E.**第 7.2 條 - 能力

**F.**第 7.4 條 - 溝通

***Answer:*** B

Explanation:

According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), clause 8.1 requires an organization to plan, implement and control its processes needed to meet ISMS requirements2. This includes determining what needs to be done, how it will be done, who will do it, when it will be done, what resources are required, how performance will be evaluated, etc2. Therefore, if an ISMS auditor conducting a third-party surveillance audit of a telecom's provider notes that there has been a significant increase in the number of switches failing their initial configuration test and being returned for reprogramming due to a recent ISMS upgrade that reduced access to work instructions, this indicates a nonconformity against clause 8.1 of ISO/IEC 27001:2022. The organization has failed to plan and control its operational processes effectively to ensure information security and quality2. The other options are not correct clauses to raise a nonconformity against based solely on this information. For example, clause 7.5 deals with documented information required by ISMS or determined by an organization as necessary for its effectiveness2, but it does not specify how many copies or formats of work instructions should be available; clause 10.2 deals with nonconformity and corrective action as a response to an identified problem or incident2, but it does not address how to prevent or avoid such problems or incidents in operational processes; clause 7.3 deals with awareness of ISMS policy, objectives, roles and responsibilities among persons doing work under an organization's control2, but it does not relate to how work instructions are accessed or followed; clause 7.2 deals with competence of persons doing work under an organization's control that affects its ISMS performance2, but it does not imply that lack of competence is caused by insufficient work instructions; clause

ACTUALTEST.COM

7.4 deals with communication about ISMS among internal and external interested parties2, but it does not cover how operational information is communicated within an organization.
Reference: ISO/IEC 27001:2022 - Information technology - Security techniques - Informati on security management systems - Requirements

**QUESTION NO: 122**
情境 5：Data Grid Inc.
是一家知名公司，為整個資訊科技基礎設施提供安全服務。它提供網路安全軟體，包括端點安全、防火牆和防毒軟體。二十年來，Data Grid Inc.
透過先進的產品和服務幫助多家公司保護其網路安全。 Data Grid Inc.
在資訊和網路安全領域享有盛譽，決定獲得 ISO/IEC 27001
認證，以更好地保護其內部和客戶資產並獲得競爭優勢。
Data Grid Inc. 任命了審計團隊，該團隊同意審計任務的條款。此外，Data Grid
Inc.明確了審核範圍，明確了審核標準，並建議在五天內結束審核。由於Data Grid
Inc.員工人數眾多，流程複雜，審計小組拒絕了Data Grid Inc.在五天內進行審計的提議。 Data Grid
Inc.堅稱他們計劃在五天內完成審核，因此雙方同意在規定的時間內進行審核。審計小組遵循基於風險的審計方法。
為了獲得主要業務流程和控制的概述，審計團隊存取了流程描述和組織圖表。他們無法對 IT 風險和控制進行更深入的分析，因為他們對 IT
基礎架構和應用程式的存取受到限制。然而，審計小組表示，Data Grid Inc. 的 ISMS
出現重大缺陷的風險很低，因為該公司的大部分流程都是自動化的。因此，他們透過詢問
Data Grid Inc. 的代表以下問題來評估 ISMS 整體上符合標準要求：
*如何定義和指派 IT 和 IT 控制的職責？
*Data Grid Inc. 如何評估控制措施是否達到了預期效果？
*Data Grid Inc. 採取了哪些控制措施來保護操作環境和資料免受惡意軟體的侵害？
*是否實施了與防火牆相關的控制？
Data Grid Inc. 的代表提供了充分且適當的證據來解決所有這些問題。
審計組長起草審計結論並向Data Grid Inc. 的最高管理階層報告。
儘管審核員推薦Data Grid Inc.進行認證，但Data Grid
Inc.與認證機構之間在審核目標方面產生了誤解。 Data Grid Inc.
表示，儘管審計目標包括確定潛在改進的領域，但審計團隊並未提供此類資訊。
根據該場景，回答以下問題：
哪種類型的審計風險被審計團隊定義為「低*」？
**A.**固有的
**B.**控制
**C.**檢測
***Answer:*** B
Explanation:
The audit team stated that the risk of a significant defect occurring in Data Grid Inc.'s ISMS was low. This refers to "Control Risk," which is the risk that a misstatement could occur in any relevant assertion related to an ISMS and that the risk could not be prevented or detected on a timely basis by the organization's internal control systems.

**QUESTION NO: 123**

情境 8：EsBank 自 9 月起為愛沙尼亞銀行業提供銀行和金融解決方案
2010年，該公司在全國擁有30家分行和100多台ATM機。
EsBank
在高度監管的行業中運營，必須遵守許多有關資料安全和隱私的法律和法規。他們需要透過實施技術和非技術控制來管理整個營運的資訊安全。 EsBank 決定實施基於 ISO/IEC 的 ISMS 27001，因為它提供了更好的安全性、更多的風險控制以及符合法律法規的關鍵要求。
在成功實施 ISMS 九個月後，EsBank 決定由獨立認證機構根據 ISO/IEC 27001 對其 ISMS 進行認證。
第一階段和第二階段審核是共同進行的，發現了一些不符合項。第一個不合格之處與 EsBank 的資訊標籤有關。該公司有資訊分類方案，但沒有資訊標籤程序。因此，需要相同保護等級的文件將被貼上不同的標籤（有時為機密，有時為敏感）。
考慮到所有文件也以電子方式存儲，不合格情況也影響了媒體處理。審計小組透過抽樣得出結論，200 個可移動媒體中有 50
個儲存了被錯誤分類為機密的敏感資訊。根據資訊分類方案，允許將機密資訊儲存在可移動媒體中，而嚴格禁止儲存敏感資訊。這標誌著另一個不合格之處。
他們起草了不合格報告，並與 EsBank
代表討論了審計結論，代表同意在兩個月內針對發現的不合格問題提交行動計劃。
EsBank
接受了審計組組長提出的解決方案。他們根據實體和電子格式的分類方案起草了資訊標籤程序，解決了不合格問題。可移動媒體程式也基於此程式進行了更新。
審計完成兩週後，EsBank
提交了總體行動計畫。在那裡，他們解決了檢測到的不合格問題以及採取的糾正措施，但沒有包括有關受影響的系統、控製或操作的任何詳細資訊。審核小組評估了該行動計劃並得出結論，該計劃將解決不合格問題。然而，EsBank 收到了不利的認證建議。
根據上述場景，回答以下問題：
根據情境8，EsBank 提交了總體行動計畫。這是可以接受的嗎？
**A.**是的，具有相同根本原因的不符合項應該有一個總體行動計劃
**B.**不，行動計畫應該只解決一個不合格問題
**C.**不，一般行動計畫無法修正不合格項
***Answer:*** C

**QUESTION NO: 124**
OrgXY 是一家經過 ISO/IEC 27001 認證的軟體開發公司。在獲得認證一年後，OrgXY 的高階主管通知認證機構，該公司尚未準備好進行監督審核。在這種情況下會發生什麼？
**A.**認證已暫停
**B.**目前認證一直使用到下次監督審核
**C.**OrgXY 將其註冊轉移給另一個認證機構
***Answer:*** A
Explanation:
If an organization like OrgXY informs the certification body that it is not ready to conduct the surveillance audit as scheduled, the certification may be suspended. This is because the surveillance audit is a critical part of the ongoing certification maintenance, required to ensure continued compliance with the standard.

**QUESTION NO: 125**

審核方法可以與代表受審核方的個人互動，也可以不互動。下列哪兩種方法具有互動性？
**A.**抽樣（例如產品）
**B.**透過即時視訊串流觀察執行的工作
**C.**與受審核方一起檢討清單
**D.**檢查地方當局的法律合規性
**E.**進行採訪
**F.**分析審核前提供的文件
***Answer:*** C,E
Explanation:
According to the PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, audit methods can be classified into two categories: with or without interaction with individuals representing the auditee (page 12). Audit methods with interaction include reviewing checklists with auditee and conducting interviews, as they involve direct communication and feedback from the auditee. Audit methods without interaction include sampling (e.g. products), observing work performed via live video streaming, checking legal compliance with local authorities, and analysing documents provided in advance of the audit, as they do not require any dialogue or exchange with the auditee. Reference: PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, page 12.

**QUESTION NO: 126**
您是一位經驗豐富的 ISMS
審核團隊領導者。您目前正在對國際運輸組織進行第三方監督審核。您抽取了四份內部稽核報告，其中指出：
報告 1 - 審計員：詹姆斯先生。
一年來，該組織在 100 次中有 23 次未能滿足其承諾的交付日期。
分級 - 次要
矯正措施到期時間：9 個月內。
報告 2 - 審計員：詹姆斯先生。
1 月至 3 月期間，我們收到了 125 起有關服務台團隊的投訴。客戶指責他們粗魯且反應遲鈍。
分級 - 次要
矯正措施到期時間：12 個月內。
報告 3 - 審計員：詹姆斯先生。
上個月收到的 40 個客戶訂單中，有 38 個已正確處理。其餘 2
份中，一份缺簽名，一份缺日期。
評分 -
更正期間：3週內
報告 4 - 審計員：羅傑斯先生。
在檢查的 30 份人事記錄中，發現 26 份已完全填寫，而其餘 4 份均缺少個人的開始日期。
分級 - 主要
更正期間：1週內
哪四個選項顯示了您對這些報告的擔憂？
**A.**我擔心該組織中是否有不合格品分級標準
**B.**我擔心審核員是否理解糾正和糾正措施之間的區別
**C.**我會擔心，因為解決重大不合格問題的行動應始終早於解決輕微不合格問題的行動完成

**D.**我擔心報告 3 沒有記錄任何評分。
**E.**我擔心審核員只專注於資訊安全流程
**F.**我擔心四份報告中解決不合格問題的時間明顯不同
**G.**我擔心沒有進行不合格審查
**H.**我擔心一名審計師似乎正在執行大部分內部審計
***Answer:*** A,B,D,F

**QUESTION NO: 127**
您是 ISMS
審核小組組長，準備在第三方監督審核後主持閉幕會議。您正在起草閉幕會議議程，列出您希望與受審核方討論的主題。
下列哪一項適合納入？
**A.**認證機構申訴流程的詳細說明
**B.**審核計畫及其目的的解釋
**C.**關於審核結果基於證據抽樣的免責聲明
**D.**與不合格項相關的審核方名稱
***Answer:*** C
Explanation:
This option is appropriate for inclusion in the closing meeting agenda, as it is a requirement of the ISO 19011 standard, which provides guidelines for auditing management systems, including ISMS12. The standard states that the audit team leader should advise the auditee of any situations encountered during the audit that may decrease the confidence that can be placed in the audit conclusions, such as limitations in the audit scope, access, or sampling3. The standard also states that the audit report should include a statement that the audit is based on a sample of the information available at the time of the audit, and that the audit does not provide absolute assurance of the conformity or effectiveness of the audited management system4. Therefore, the audit team leader should include a disclaimer in the closing meeting agenda to inform the auditee of the nature and limitations of the audit, and to avoid any misunderstandings or false expectations. The other options are not appropriate for inclusion in the closing meeting agenda, as they are either irrelevant, incorrect, or incomplete. For example:
* A detailed explanation of the certification body's complaints process is not relevant for the closing meeting agenda, as it is not related to the audit findings or conclusions. The certification body's complaints process should be communicated to the auditee before the audit, as part of the audit agreement or contract5.
* An explanation of the audit plan and its purpose is not correct for the closing meeting agenda, as it should have been done at the opening meeting or before the audit. The audit plan is a document that describes the scope, objectives, criteria, and methodology of the audit, as well as the audit schedule, the audit team, the audit locations, and the audit deliverables . The audit plan should be communicated and agreed with the auditee in advance, and any changes or deviations should be notified during the audit.
* Names of auditees associated with nonconformities are not complete for the closing meeting agenda, as they do not provide the details or the evidence of the nonconformities. The audit team leader should present the audit findings, which include the description, the

audit criteria, and the audit evidence of each nonconformity, as well as the audit conclusions and the audit recommendation . The audit team leader should also avoid naming or blaming individuals, and focus on the processes and the system.

**QUESTION NO: 128**
下列哪一項可視為輕微不符合？
**A.**員工缺乏識別網路釣魚嘗試的培訓，增加了惡意軟體風險
**B.**缺乏多因素身份驗證導致帳戶容易受到未經授權的訪問
**C.**資訊安全政策缺乏持續 ISMS 改進的參考
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct Answer:
A missing reference to continual improvement is a documentation issue, not an immediate security risk, making it a minor nonconformity.
A . Incorrect:
Lack of employee training poses a direct security risk (major nonconformity).
B . Incorrect:
Missing multi-factor authentication significantly weakens security (major nonconformity).
Relevant Standard Reference:
ISO/IEC 27001:2022 Clause 10.1 (Continual Improvement)

**QUESTION NO: 129**
哪個是將三元組黏合在一起的黏合劑
**A.**行程
**B.**人
**C.**協作
**D.**技術
***Answer:*** D
Explanation:
The triad refers to the three elements of information security: confidentiality, integrity and availability3. Technology is the glue that ties the triad together, as it provides the means to implement various controls and measures to protect information from unauthorized access, modification or loss3. Reference: ISO/IEC 27001:2022 Lead Auditor Training Course - BSI

**QUESTION NO: 130**
下列哪一項是利害關係方的定義？
**A.**當第三人認為自己受到決策或活動的影響時，可以向組織提出申訴
**B.**可以影響決策或活動、受決策或活動影響或認為自己受決策或活動影響的個人或組織
**C.**可以乾擾管理決策或認為自己受到管理決策幹擾的團體或組織
**D.**可以控制決策或活動、被決策或活動控製或認為自己被決策或活動控制的個人或組織
***Answer:*** B
Explanation:
This is the definition of an interested party according to ISO 27001:2013, clause 3.16. An

interested party is essentially a stakeholder, i.e., a person or organization that can influence or be influenced by the information security management system (ISMS) or its activities. Interested parties can have different needs and expectations regarding the ISMS, and these should be identified and addressed by the organization. Reference:
ISO/IEC 27001:2013, Information technology - Security techniques - Information securit y management systems - Requirements, clause 3.16 PECB Candidate Handbook ISO 27001 Lead Auditor, page 10 Identifying interested parties and their expectations for an ISO 27001 ISMS Examples of ISO 27001 interested parties

**QUESTION NO: 131**
資訊安全是建立和維護 _____ 的問題。
**A.**保密性
**B.**信任
**C.**保護
**D.**防火牆
***Answer:*** B
Explanation:
Information security is a matter of building and maintaining trust. Trust is the confidence that information and information processing facilities are protected from unauthorized or malicious actions that could compromise their confidentiality, integrity or availability. Trust is essential for establishing and maintaining relationships with customers, partners, suppliers, employees and other stakeholders who rely on the organization's information and services. Trust is also a key factor for achieving compliance with legal, regulatory and contractual obligations, as well as meeting the organization's own information security objectives and policies. ISO/IEC 27001:2022 defines information security as "preservation of confidentiality, integrity and availability of information" (see clause 3.28) and states that "the purpose of an information security management system is to provide a framework for managing activities that influence the trustworthiness of information" (see Introduction). Reference: CQI & IRCA Certified ISO/IEC 27001:2022 Lead Auditor Training Course, ISO/IEC 27001:2022 Information technology - Security techniques - Information security management systems - Requirement s, What is Trust?

**QUESTION NO: 132**
您正在作為審核組組長進行您的第一次第三方 ISMS
監督審核。您目前與審核團隊的另一位成員一起在被審核方的資料中心。
您的同事似乎不確定資訊安全事件和資訊安全事件之間的差異。您嘗試透過提供範例來解釋差異。
下列哪三種場景可以定義為資訊安全事件？
**A.**組織的惡意軟體防護軟體可防止病毒
**B.**硬碟機在建議更換日期之後使用
**C.**組織收到網路釣魚電子郵件
**D.**員工在輪班結束時未能清理辦公桌
**E.**未收到付款的承包商刪除了高階管理人員 ICT 帳戶
**F.**不滿意的員工未經許可更改薪資記錄

**G.**組織未通過第三方滲透測試
**H.**組織的行銷資料被駭客複製並出售給競爭對手

***Answer:*** E,F,H

Explanation:

According to ISO/IEC 27000:2018, which provides an overview and vocabulary of information security management systems, an information security event is an identified occurrence of a system, service or network state indicating a possible breach of information security policy or failure of safeguards, or a previously unknown situation that may be security relevant1. An information security incident is a single or a series of unwanted or unexpected information security events that have a significant probability of compromising business operations and threatening information security1. Therefore, based on this definition, three examples of information security incidents are:

A contractor who has not been paid deletes top management ICT accounts: This is an example of an unwanted or unexpected information security event that has a significant probability of compromising business operations and threatening information security, as it may result in loss of access, data, or functionality for the top management.

An unhappy employee changes payroll records without permission: This is an example of an unwanted or unexpected information security event that has a significant probability of compromising business operations and threatening information security, as it may result in financial fraud, legal liability, or reputational damage for the organization.

The organisation's marketing data is copied by hackers and sold to a competitor: This is an example of an unwanted or unexpected information security event that has a significant probability of compromising business operations and threatening information security, as it may result in loss of confidentiality, competitive advantage, or customer trust for the organization.

The other options are not examples of information security incidents, but rather information security events that may or may not lead to incidents depending on their impact and severity. For example:

The organisation's malware protection software prevents a virus: This is an example of an identified occurrence of a system state indicating a possible breach of information security policy or failure of safeguards, but it does not have a significant probability of compromising business operations and threatening information security, as it is prevented by the malware protection software.

A hard drive is used after its recommended replacement date: This is an example of an identified occurrence of a system state indicating a possible breach of information security policy or failure of safeguards, but it does not have a significant probability of compromising business operations and threatening information security, unless it fails or causes other problems.

The organisation receives a phishing email: This is an example of an identified occurrence of a network state indicating a possible breach of information security policy or failure of safeguards, but it does not have a significant probability of compromising business operations and threatening information security, unless it is opened or responded to by the recipient.

An employee fails to clear their desk at the end of their shift: This is an example of an identified occurrence of a service state indicating a possible breach of information security

ACTUAL4TEST.COM

policy or failure of safeguards, but it does not have a significant probability of compromising business operations and threatening information security, unless the desk contains sensitive or confidential information that is accessed by unauthorized persons.
The organisation fails a third-party penetration test: This is an example of an identified occurrence of a system state indicating a possible breach of information security policy or failure of safeguards, but it does not have a significant probability of compromising business operations and threatening information security, unless the penetration test reveals serious vulnerabilities that are exploited by malicious actors.

**QUESTION NO: 133**
場景 7：Lawsy 是一家領先的律師事務所，在新澤西州和紐約市設有辦公室。它擁有 50 多名律師，為商業法、智慧財產權、銀行和金融服務領域的客戶提供完善的法律服務。他們相信，由於他們致力於實施資訊安全最佳實踐並跟上技術發展的步伐，他們在市場上佔據了有利的地位。
Lawsy 已經嚴格實施、評估和進行 ISMS 內部審核兩年了。
現在，他們已向知名且值得信賴的認證機構ISMA申請ISO/IEC 27001認證。
在第一階段審核期間，審核小組審查了實施過程中所建立的所有 ISMS 文件。
他們還審查和評估了管理審查和內部審計的記錄。
Lawsy
提交了證據記錄，表明在必要時對不合格項採取了糾正措施，因此審核組約談了內部審核員。
訪談透過提供對內部稽核計畫和程序的詳細了解，驗證了內部稽核的充分性和頻率。
審計小組繼續驗證戰略文件，包括資訊安全政策和風險評估標準。在資訊安全政策審查期間，團隊注意到描述治理框架（即資訊安全政策）的記錄資訊與程序之間存在不一致。
儘管允許員工將筆記型電腦帶到工作場所之外，但 Lawsy
並沒有製定有關在這種情況下使用筆記型電腦的程序。此政策僅提供有關筆記型電腦使用的一般資訊。該公司依靠員工的常識來保護筆記型電腦中儲存的資訊的機密性和完整性。該問題已記錄在第一階段審計報告中。
完成第一階段審核後，審核組長準備了審核計劃，其中規定了審核目標、範圍、標準和程序。
在第二階段審核期間，審核小組約談了資安經理，資安經理起草了資訊安全政策。他透過指出 Lawsy
每三個月舉辦一次強制性資訊安全培訓和意識課程來證明第一階段中確定的問題的合理性。
面談後，審核小組檢查了 15 份員工培訓記錄（共 50 份），得出的結論是 Lawsy 符合 ISO/IEC 27001
有關培訓和意識的要求。為了支持這個結論，他們影印了檢查過的員工訓練記錄。
根據上述場景，回答以下問題：
審計小組複印了所檢查的員工培訓記錄以支持他們的結論。審計團隊在採取此行動之前是否應該獲得 Lawsy 的批准？請參閱場景 7。
**A.**是的。審核小組在驗證所有情況下流程的存在時（包括做筆記和影印文件時）應獲得受審核方的批准
**B.**是的，如果受審核方同意，審核小組可以影印審核期間觀察到的文件
**C.**不可以，審核小組有權影印文件，以驗證某份文件是否符合審核標準
***Answer:*** B
Explanation:
Yes, the audit team should obtain approval from Lawsy before photocopying documents. This is a best practice to ensure that the auditee agrees to the duplication of documents, which

might contain sensitive or confidential information. Although auditors can observe and note down information, copying documents typically requires explicit permission to maintain trust and ensure compliance with confidentiality agreements.

**QUESTION NO: 134**
以下關於 ISMS 範圍的選項哪一個是正確的？
**A.**ISMS 範圍應作為記錄資訊提供
**B.**ISMS 範圍應確保持續改進
**C.**ISMS 範圍應與組織的策略方向相容
***Answer:*** A
Explanation:
According to ISO/IEC 27001, the scope of an ISMS must be defined and documented. This documentation should include the boundaries and applicability of the information security management system, which helps in defining what information, locations, and assets are covered under the ISMS.

**QUESTION NO: 135**
場景七：Webvue。總部位於日本，是一家專門從事電腦軟體開發、支援和維護的技術公司。Webvue 提供跨各個技術領域和業務領域的解決方案。其旗艦服務是 CloudWebvue，一個提供儲存、網路和虛擬運算服務的綜合雲端運算平台。專為企業和個人用戶設計。 CloudWebvue 以其靈活性、可擴展性和可靠性而聞名。
Webvue 決定僅將 CloudWebvue 納入其 ISO/IEC 27001 認證範圍。因此，第 1 階段和第 2 階段審計同時進行 Webvue
以其對資產保密的嚴格性而自豪，他們使用適當的加密控制來保護儲存在 CloudWebvue 中的資訊。任何機密級別的每條信息，無論是否供內部使用。受限的或機密的資訊首先用唯一的對應哈希值加密，然後儲存在雲端。肖恩。萊拉，山姆。和 Tin a。 Keith 是 IT 和資訊安全審計團隊中最有經驗的審計員，也是審計團隊的負責人。他的職責包括規劃審計和管理審計團隊。尚實踐生成的。在檢查了 Webvue 的加密政策後，他們得出結論，採訪中獲得的資訊是真實的。然而，由於該策略沒有解決加密金鑰的使用和壽命問題，因此加密金鑰仍在使用中。
依照 Webvue 和認證機構後來達成的協議，審計團隊選擇進行虛擬審計，專門專注於驗證 Webvue 是否符合 ISO/IEC 27001 的控制 8.11
資料屏蔽，以符合認證範圍和審計目標。他們檢查了 CloudWebvue 中保護資料所涉及的流程。重點關注公司如何遵守其政策和監管標準。作為此過程的一部分。審計團隊負責人 Keith 對相關文件和加密金鑰管理程序進行了截圖，以記錄和分析 Webvue 實踐的有效性。
Webvue 使用產生的測試資料用於測試目的。然而，根據與 QA 部門經理的訪談以及該部門使用的程序確定，有時會使用即時系統資料。在這樣的場景中，會產生大量數據，同時產生更準確的結果。測試資料受到保護和控制，這透過 Webvue 人員在審計期間執行的加密過程模擬得到驗證。儘管不在審計範圍之內，但安全培訓部門的不合規情況可能會對審計範圍內的流程產生影響，具體會影響 CloudWebvue 中的資料安全和加密實踐。因此，Keith將此發現納入審計報告中，並告知被審計方。
根據上述情景，回答以下問題：
為了驗證是否符合測試資料控制的保護，Webvue 的人員模擬了加密過程。這可以接受嗎？
**A.**不可以，加密過程不能模擬，因為它會影響被審計單位的操作

**B.**是的，如果審核員不具備執行與測試相關的操作的能力，則受審核方的代表可以充當技術專家的角色
**C.**是的，可以在受審核方人員的協助下模擬流程以驗證是否符合控制
***Answer:*** C
ISO 19011:2018 (Audit Guidelines) allows process simulations to verify control effectiveness. Webvue's personnel conducted the test under audit supervision, ensuring realistic evaluation without operational disruption.
A: Incorrect:
Simulations are valid audit techniques and do not negatively impact operations if performed properly.
B: Incorrect:
Technical experts assist auditors, but the focus is on ensuring accurate control verification, not the auditor's competence.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.4.8 (Process Simulation for Audit Evidence Collection)
Explanation:
Comprehensive and Detailed In-Depth

**QUESTION NO: 136**
審計員發現，IT 部門 15 名員工中有兩人沒有接受足夠的資訊安全訓練。這代表什麼？
**A.**審計結果
**B.**審計證據
**C.**資訊來源
***Answer:*** A
Explanation:
This scenario represents an "audit finding." An audit finding refers to results that indicate a deviation from the expected performance or standards. Discovering that two employees have not received the required training is an audit finding indicating noncompliance with the organization's training requirements.

**QUESTION NO: 137**
您是經驗豐富的審核團隊領導，指導審核員進行培訓。
您的團隊目前正在對代表外部客戶儲存資料的組織進行第三方監督審核。接受培訓的審核員的任務是審查適用性聲明 (SoA) 中列出並在現場實施的人員控制措施。
從以下內容中選擇您希望接受培訓的審核員審查的四項控制措施。
**A.**保密與保密協議
**B.**如何實施針對惡意軟體的防護
**C.**資訊安全意識、教育與培訓
**D.**遠距工作安排
**E.**對人員進行驗證檢查
**F.**現場閉路電視和門禁系統的運行
**G.**機構對資訊刪除的安排
**H.**組織的業務連續性安排
***Answer:*** A,C,D,E

ACTUAL4TEST.COM

Explanation:
The four controls from the list that the auditor in training should review are:
*
A . Confidentiality and nondisclosure agreements: This control requires the organisation to ensure that all employees, contractors, and third parties who have access to sensitive information sign appropriate agreements that oblige them to protect the confidentiality and integrity of such information. This is especially important for an organisation that stores data on behalf of external clients, as it demonstrates its commitment to safeguarding their information assets and complying with their contractual obligations.
* C . Information security awareness, education and training: This control requires the organisation to provide regular and relevant information security awareness, education and training to all employees, contractors, and third parties who have access to the organisation's information systems and information assets. This is essential for ensuring that they are aware of their roles and responsibilities, the information security policies and procedures, the potential threats and risks, and the best practices for preventing and responding to information security incidents.
* D . Remote working arrangements: This control requires the organisation to establish and implement policies and procedures for managing the information security risks associated with remote working arrangements, such as teleworking, mobile working, or working from home. This includes defining the conditions and requirements for remote working, such as the authorised devices, applications, and networks, the encryption and authentication methods, the backup and recovery procedures, and the reporting and monitoring mechanisms. This is important for an organisation that stores data on behalf of external clients, as it ensures that the information security level is maintained regardless of the location of the workers and the devices they use.
* E . The conducting of verification checks on personnel: This control requires the organisation to conduct appropriate verification checks on the background, qualifications, and references of all employees, contractors, and third parties who have access to the organisation's information systems and information assets. This is necessary for verifying their identity, suitability, and trustworthiness, and for preventing the hiring of unauthorised or malicious individuals who could compromise the information security of the organisation and its clients.

**QUESTION NO: 138**
您是一位經驗豐富的 ISMS 審核團隊領導，為 ISMS
審核員提供訓練指導。他們被要求對外部提供者進行評估，並準備了一份包含以下活動的清單。他們要求您查看他們的清單，以確認他們提議的行動是適當的。
他們受邀參加的審核是對資料中心的第三方監督審核。資料中心代理是更廣泛的電信集團的一部分。集團內的每個資料中心都運行自己的 ISMS 並持有自己的憑證。
選擇與 ISO/IEC 27001:2022 有關外部提供者的要求相關的三個選項。
**A.**我會檢查其他資料中心是否被視為外部供應商，即使它們屬於同一電信集團
**B.**我將確保外部提供者制定書面流程，以通知組織因使用其產品或服務而產生的任何風險
**C.**我將確保該組織為其確定的對於保護其資訊的機密性、完整性和可訪問性至關重要的每個流程都有一個備用外部提供商
**D.**我將把審核活動限制在外部提供的流程中，因為不需要審核外部提供的產品或服務

**E.**我將確保組織定期監控、審查和評估外部提供者的績效
**F.**我將確保組織已確定需要與外部提供者就 ISMS 進行溝通
**G.**我將確保最高管理階層為提供外部 ISMS 流程和內部 ISMS 流程的人員分配角色和職責
**H.**我將確保組織對其外部提供者進行排名，並將大部分工作分配給那些評級最高的供應商
***Answer:*** A,B,E
Explanation:
A . I will check the other data centres are treated as external providers, even though they are part of the same telecommunication group. This is appropriate because clause 8.1.4 of ISO 27001:2022 requires the organisation to ensure that externally provided processes, products or services that are relevant to the information security management system are controlled. Externally provided processes, products or services are those that are provided by any external party, regardless of the degree of its relationship with the organisation. Therefore, the other data centres within the same telecommunication group should be treated as external providers and subject to the same controls as any other external provider12 B . I will ensure external providers have a documented process in place to notify the organisation of any risks arising from the use of its products or services. This is appropriate because clause 8.1.4 of ISO 27001:2022 requires the organisation to implement appropriate contractual requirements related to information security with external providers. One of the contractual requirements could be the obligation of the external provider to notify the organisation of any risks arising from the use of its products or services, such as security incidents, vulnerabilities, or changes that could affect the information security of the organisation. The external provider should have a documented process in place to ensure that such notification is timely, accurate, and complete12 E . I will ensure the organisation is regularly monitoring, reviewing and evaluating external provider performance. This is appropriate because clause 8.1.4 of ISO 27001:2022 requires the organisation to monitor, review and evaluate the performance and effectiveness of the externally provided processes, products or services. The organisation should have a process in place to measure and verify the conformity and suitability of the external provider's deliverables and activities, and to provide feedback and improvement actions as necessary. The organisation should also maintain records of the monitoring, review and evaluation results12 F . I will ensure the organisation has determined the need to communicate with external providers regarding the ISMS. This is appropriate because clause 7.4.2 of ISO 27001:2022 requires the organisation to determine the need for internal and external communications relevant to the information security management system, including the communication with external providers. The organisation should define the purpose, content, frequency, methods, and responsibilities for such communication, and ensure that it is consistent with the information security policy and objectives. The organisation should also retain documented information of the communication as evidence of its implementation12 The following activities are not appropriate for the assessment of external providers according to ISO 27001:2022:
C . I will ensure that the organisation has a reserve external provider for each process it has identified as critical to preservation of the confidentiality, integrity and accessibility of its information. This is not appropriate because ISO 27001:2022 does not require the organisation to have a reserve external provider for each critical process. The organisation may choose to have a contingency plan or a backup solution in case of failure or disruption of the external provider, but this is not a mandatory requirement. The organisation should

assess the risks and opportunities associated with the external provider and determine the appropriate treatment options, which may or may not include having a reserve external provider12 D . I will limit my audit activity to externally provided processes as there is no need to audit externally provided products or services. This is not appropriate because clause 8.1.4 of ISO 27001:2022 requires the organisation to control the externally provided processes, products or services that are relevant to the information security management system. Externally provided products or services may include software, hardware, data, or cloud services that could affect the information security of the organisation. Therefore, the audit activity should cover both externally provided processes and products or services, as applicable12 G . I will ensure that top management have assigned roles and responsibilities for those providing external ISMS processes as well as internal ISMS processes. This is not appropriate because clause 5.3 of ISO 27001:2022 requires the top management to assign the roles and responsibilities for the information security management system within the organisation, not for the external providers. The external providers are responsible for assigning their own roles and responsibilities for the processes, products or services they provide to the organisation. The organisation should ensure that the external providers have adequate competence and awareness for their roles and responsibilities, and that they are contractually bound to comply with the information security requirements of the organisation12 H . I will ensure that the organisation ranks its external providers and allocates the majority of its work to those providers who are rated the highest. This is not appropriate because ISO 27001:2022 does not require the organisation to rank its external providers or to allocate its work based on such ranking. The organisation may choose to evaluate and compare the performance and effectiveness of its external providers, but this is not a mandatory requirement. The organisation should select and use its external providers based on the information security criteria and objectives that are relevant to the organisation12 Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 139**
您正在一家提供醫療保健服務的住宅療養院進行 ISMS
初始認證審核。審計計劃的下一步是召開末次會議。在最終審核小組會議上，身為審核組組長，您同意報告 2 項輕微不符合項和 1 項改進機會，如下：

ACTUAL4TEST.COM

**Cosmic Certifications Limited**

Summary of audit findings:

**Opportunities for Improvement (OI)**

| Item | Findings | Requirements | Follow-up |
|---|---|---|---|
| 1. | The organisation should improve the overall awareness of information security incident management responsibility and process. | Clause 7.4 and Control A.5.24 | N/A |

Nonconformities (NCs)

| Item | Findings | Grade | Requirements | Follow-up |
|---|---|---|---|---|
| 1. | During the audit on the outsourced process, sampling one of the outsourced service contracts with WeCare the medical device manufacturer found that ABC does not include personal data protection and legal compliance as part of the information security requirements in the contract. | Minor | Clause 4.2 and Control A.5.20 | Corrective actions are required. |
| 2. | During the audit on information security during the business continuity process, sampling one of the service continuity and recovery plans for the resident's healthy status monitoring service. The auditor found the recovery plan has not yet been tested. | Minor | Clause 8.1 and Control A.5.29 | Corrective actions are required. |

signed by *Audit Team Leader*

ACTUAL4TEST.COM

選擇您將在最後一次會議上向受審核方提供建議的審核專案經理的建議選項。

**A.**立即推薦認證

**B.**建議在 6 個月內進行全面的重新審核

**C.**建議在未來某個日期進行突擊審核

**D.**在您批准擬議的糾正措施計劃後建議進行認證 建議可以在 1 年內透過監督審核結束調查結果

**E.**建議在 3 個月內進行部分審核

***Answer:*** D

Explanation:

According to ISO/IEC 17021-1:2015, which specifies the requirements for bodies providing audit and certification of management systems, clause 9.4.9 requires the certification body to make a certification decision based on the information obtained during the audit and any other relevant information1. The certification body should also consider the effectiveness of the corrective actions taken by the auditee to address any nonconformities identified during the audit1. Therefore, when making a recommendation to the audit programme manager, an ISMS auditor should consider the nature and severity of the nonconformities and the proposed corrective actions.

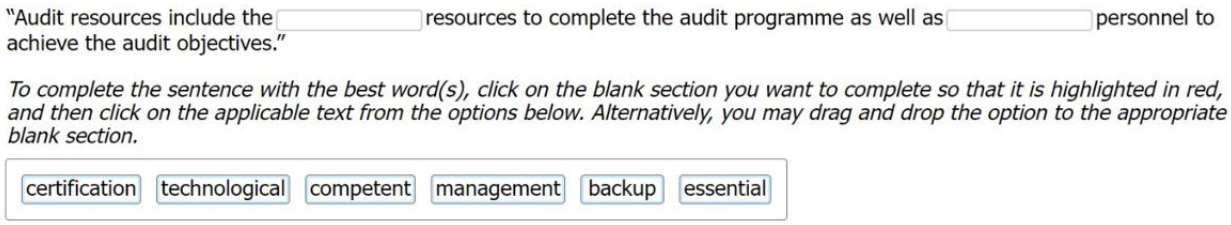
Based on the scenario above, the auditor should recommend certification after their approval of the proposed corrective action plan and recommend that the findings can be closed out at a surveillance audit in 1 year. The auditor should provide the following justification for their

recommendation:
Justification: This recommendation is appropriate because it reflects the fact that the auditee has only two minor nonconformities and one opportunity for improvement, which do not indicate a significant or systemic failure of their ISMS. A minor nonconformity is defined as a failure to achieve one or more requirements of ISO/IEC 27001:2022 or a situation which raises significant doubt about the ability of an ISMS process to achieve its intended output, but does not affect its overall effectiveness or conformity2. An opportunity for improvement is defined as a suggestion for improvement beyond what is required by ISO/IEC 27001:20222. Therefore, these findings do not prevent or preclude certification, as long as they are addressed by appropriate corrective actions within a reasonable time frame. The auditor should approve the proposed corrective action plan before recommending certification, to ensure that it is realistic, achievable, and effective. The auditor should also recommend that the findings can be closed out at a surveillance audit in 1 year, to verify that the corrective actions have been implemented and are working as intended.
The other options are not valid recommendations for the audit programme manager, as they are either too lenient or too strict for the given scenario. For example:
Recommend certification immediately: This option is not valid because it implies that the auditor ignores or accepts the nonconformities, which is contrary to the audit principles and objectives of ISO 19011:20182, which provides guidelines for auditing management systems. It also contradicts the requirement of ISO/IEC 17021-1:20151, which requires the certification body to consider the effectiveness of the corrective actions taken by the auditee before making a certification decision.
Recommend that a full scope re-audit is required within 6 months: This option is not valid because it implies that the auditor overreacts or exaggerates the nonconformities, which is contrary to the audit principles and objectives of ISO 19011:20182. It also contradicts the requirement of ISO/IEC 17021-1:20151, which requires the certification body to determine whether a re-audit is necessary based on the nature and extent of nonconformities and other relevant factors. A full scope re-audit is usually reserved for major nonconformities or multiple minor nonconformities that indicate a serious or widespread failure of an ISMS.
Recommend that an unannounced audit is carried out at a future date: This option is not valid because it implies that the auditor distrusts or doubts the auditee's commitment or capability to implement corrective actions, which is contrary to the audit principles and objectives of ISO 19011:20182. It also contradicts the requirement of ISO/IEC 17021-1:20151, which requires the certification body to conduct unannounced audits only under certain conditions, such as when there are indications of serious problems with an ISMS or when required by sector-specific schemes.
Recommend that a partial audit is required within 3 months: This option is not valid because it implies that the auditor imposes or prescribes a specific time frame or scope for verifying corrective actions, which is contrary to the audit principles and objectives of ISO 19011:20182. It also contradicts the requirement of ISO/IEC 17021-1:20151, which requires the certification body to determine whether a partial audit is necessary based on the nature and extent of nonconformities and other relevant factors. A partial audit may be appropriate for minor nonconformities, but the time frame and scope should be agreed upon with the auditee and based on the proposed corrective action plan.

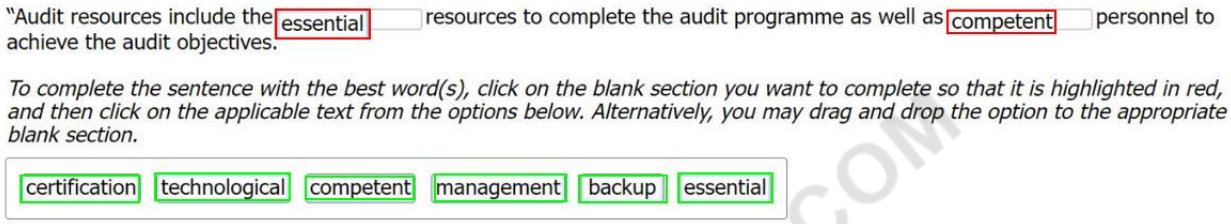
**QUESTION NO: 140**

在準備審計時，下列哪一項敘述是錯誤的？
**A.**每個審核員都會建立自己的審核清單以供審核期間使用
**B.**審核檢查表在審核前與受審核方共用並達成協議
**C.**審核計畫在審核前與受審核方分享
**D.**審核計畫在審核期間可能會更改
***Answer:*** B

**QUESTION NO: 141**
選擇最能完成下面句子的字詞來描述審計資源：




***Answer:***




Reference:
ISO 19011:2018 - Guidelines for auditing management systems, clause 5.3 PECB Candidate Handbook ISO 27001 Lead Auditor, page 19

**QUESTION NO: 142**
AppFolk 是一家軟體開發公司，正在尋求 ISO/IEC 27001 認證。都包括在內。這是可以接受的嗎？
**A.**是的，審核和 ISMS 範圍不一定需要相同
**B.**不，對被審核方所在工業部門不重要的部門可以排除在審核範圍之外
**C.**不，審核範圍應反映 ISMS 涵蓋的組織的所有部門
***Answer:*** C
Explanation:
No, the audit scope should reflect all of the organization's divisions that are covered by the ISMS. If the ISMS scope stated that it includes the whole company, the audit scope should align with this unless specifically justified and agreed upon by all stakeholders.

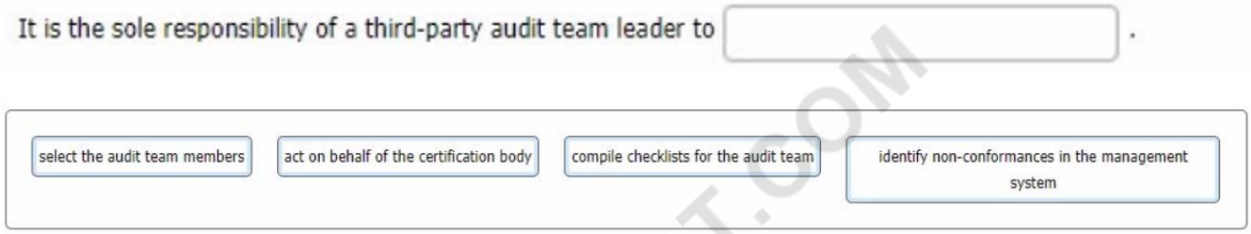
**QUESTION NO: 143**
審核員能力是知識和技能的結合。下列哪兩項活動主要與「知識」相關？
**A.**了解如何辨識發現結果
**B.**設計清單
**C.**遵循偏離準備清單的審核追蹤
**D.**與受審核方溝通

**E.**決定如何向受審核方尋求證據
**F.**決定要收集哪些證據
***Answer:*** B,F
Explanation:
Knowledge is the understanding of facts, concepts, principles, theories and practices related to a specific subject or discipline. Skills are the ability to apply knowledge and use know-how to complete tasks and solve problems. According to ISO 19011:2018, the knowledge and skills of an auditor include the following:
Knowledge of audit principles, procedures and methods
Knowledge of management system standards and reference documents
Knowledge of the organization's context, scope, processes and objectives Knowledge of relevant legal, regulatory and contractual requirements Knowledge of applicable industry, sector or technical disciplines Knowledge of risk management and risk-based thinking Skill in collecting and verifying information Skill in evaluating conformity and effectiveness of management systems Skill in reporting and communicating audit results Skill in managing audit activities and teams Based on this, the activities that are predominately related to knowledge are designing a checklist and determining what evidence to gather, as they require the auditor to understand the audit criteria, scope, objectives and methods, as well as the organization's context, processes and risks. The other activities are more related to skills, as they involve applying knowledge and using know-how to perform tasks and solve problems during the audit.
Reference:
ISO 19011:2018, Guidelines for auditing management systems, clauses 7.2.1, 7.2.2 and 7.2.3 PECB Candidate Handbook - ISO 27001 Lead Auditor, pages 9-10 and 16-17 ISO 9001 Auditing Practices Group Guidance on: Auditing Competence, pages 2-3 and 8

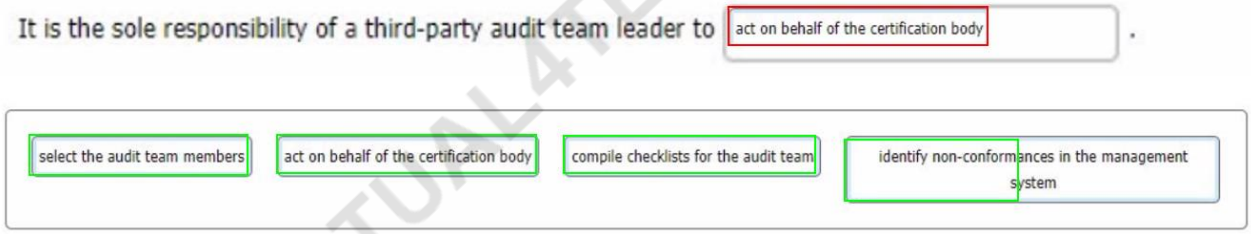
**QUESTION NO: 144**
下列哪兩項敘述是正確的？
**A.**審核小組負責人負責管理審核計畫。
**B.**審核計畫描述了為特定時間範圍並針對特定目的而規劃的一組一項或多項審核的安排。
**C.**一旦達成一致，審核計畫就固定下來，在審核過程中不能更改。
**D.**審核計畫描述了為特定時間範圍規劃並針對特定目的的一組一個或多個審核的安排。
**E.**審核計劃描述了審核的活動和安排。
**F.**審核計劃描述了審核的活動和安排。
***Answer:*** B,E
Explanation:
The two true statements are B and E. According to ISO 19011:2022, the audit plan describes the arrangements for a set of one or more audits planned for a specific time frame and directed towards a specific purpose1, while the audit programme describes the activities and arrangements for an audit2. The other options are either false or irrelevant. The responsibility for managing the audit programme rests with the audit programme manager, not the audit team leader (A)3. The audit plan can be changed during the conducting of the audit if necessary, with the agreement of the audit client and the auditee 4. The audit programme and the audit plan are not the same thing, so D and F are incorrect. Reference: 1: ISO

19011:2022, Guidelines for auditing management systems, Clause 3.8 \n2: ISO 19011:2022, Guidelines for auditing management systems, Clause 3.9 \n3: ISO 19011:2022, Guidelines for auditing management systems, Clause 5.3.1 \n4: ISO 19011:2022, Guidelines for auditing management systems, Clause 6.4.2

**QUESTION NO: 145**
選出最能完成句子的單字：
要使用最佳單字完成句子，請按一下要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，您可以將該選項拖曳到適當的空白部分。




***Answer:***




Reference:
ISO 19011:2022 Guidelines for auditing management systems
ISO/IEC 17021-1:2022 Conformity assessment - Requirements for bodies providing audit and certification of management systems - Part 1: Requirements

**QUESTION NO: 146**
以下是「誠信」的目的，這是資訊安全的基本組成部分之一
**A.**資訊不會提供或揭露給未經授權的個人的屬性
**B.**保障資產準確性和完整性的屬性。
**C.**資訊不會提供或揭露給未經授權的個人的屬性
**D.**根據授權實體的要求可存取和使用的屬性。
***Answer:*** B
Explanation:
Integrity is one of the basic components of information security, along with confidentiality and availability. Integrity means that information is safeguarded from unauthorized or accidental changes that could affect its accuracy and completeness. Integrity ensures that information is reliable and trustworthy3. Reference: ISO/IEC 27001:2022 Lead Auditor Training Course - BSI

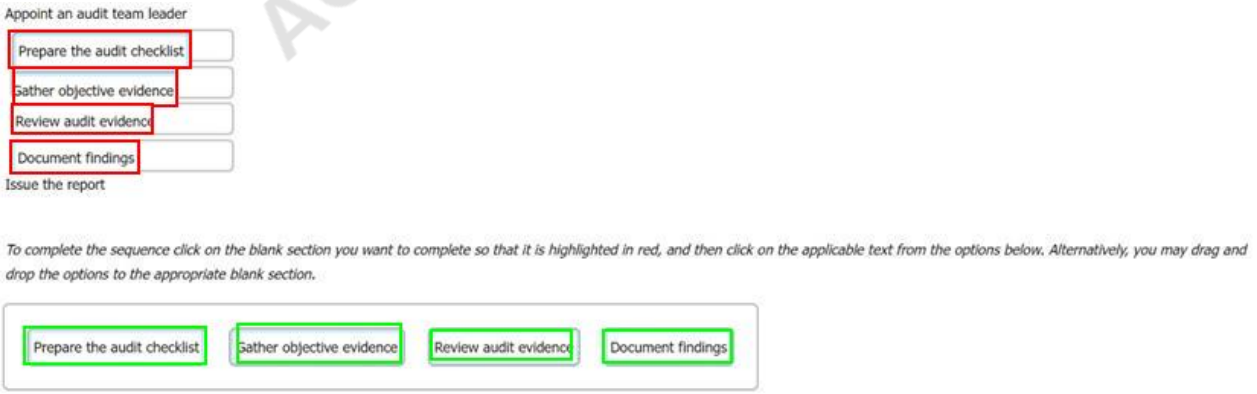
**QUESTION NO: 147**
作為 ISMS 實施的一部分，行銷機構開發了自己的風險評估方法。這是可以接受的嗎？
**A.**是的，可以使用任何符合 ISO/IEC 27001 要求的風險評估方法

**B.**是，只有當風險評估方法與公認的風險評估方法一致時
**C.**否，實施 ISMS 時，應使用 ISO/IEC 27001 提供的風險評估方法
***Answer:*** A
Explanation:
ISO/IEC 27001 does not mandate the use of a specific risk assessment methodology. Organizations are free to choose their own approach as long as it is systematic, consistent, and capable of producing valid and comparable results. This allows organizations, such as the marketing agency in the question, to adapt the methodology to suit their specific needs and business context, provided it complies with the requirements set out in the standard.

**QUESTION NO: 148**
以下選項是第一方審核中涉及的關鍵操作。對階段進行排序以顯示操作發生的順序。




***Answer:***




Reference:
PECB Candidate Handbook ISO 27001 Lead Auditor, pages 19-25
ISO 19011:2018 - Guidelines for auditing management systems
The ISO 27001 audit process | ISMS.online

**QUESTION NO: 149**
本組織擁有第三方認證機構核發的 ISO/IEC 27001 資訊安全管理系統 (ISMS) 認證。下列哪一項代表了擁有認可認證的優點？
**A.**組織產品的行銷價格上漲

**B.**客戶端數量增加
**C.**審核報告的清晰度
**D.**對認證過程可信度的認可。
***Answer:*** D
Explanation:
One of the advantages of having accredited certification of ISMS to ISO/IEC 27001:2022 is that it demonstrates the recognition of the credibility of the certification process. Accredited certification means that the certification body has been assessed and approved by an accreditation body, which ensures that the certification body operates according to international standards and follows impartiality, competence and consistency principles. Accredited certification also enhances the confidence of the organisation's customers, partners, regulators and other interested parties in the organisation's information security performance and compliance. Reference: = ISO/IEC 27001:2022, clause 0.2; [PECB Candidate Handbook ISO 27001 Lead Auditor], page 6; Key Benefits of ISO 27001 Certification - IT Governance.

**QUESTION NO: 150**
下列哪兩個短語適用於業務流程的計畫-執行-檢查-行動週期中的「檢查」？
**A.**進行改進
**B.**管理變更
**C.**驗證訓練
**D.**重設目標
**E.**更新資訊安全策略
**F.**審核流程
***Answer:*** C,F
Explanation:
The two phrases that would apply to 'check' in the Plan-Do-Check-Act cycle for a business process are:
C . Verifying training
F . Auditing processes
C . This phrase applies to 'check' in the PDCA cycle because it involves measuring and evaluating the effectiveness of the training activities that were implemented in the 'do' phase. Training is an important aspect of information security awareness, education, and competence, which are required by clause 7.2 of ISO 27001:20221. Verifying training can help the organisation to assess whether the staff have acquired the necessary knowledge, skills, and behaviour to perform their roles and responsibilities in relation to information security. Verifying training can also help the organisation to identify any gaps or weaknesses in the training program and to plan for improvement actions.
F . This phrase applies to 'check' in the PDCA cycle because it involves examining and reviewing the performance and conformity of the processes that were implemented in the 'do' phase. Auditing is a systematic, independent, and documented process for obtaining objective evidence and evaluating it to determine the extent to which the audit criteria are fulfilled2. Auditing processes can help the organisation to verify whether the information security objectives and requirements are met, whether the information security controls are

ACTUAL4TEST.COM

effective and efficient, and whether the information security risks are adequately managed. Auditing processes can also help the organisation to identify any nonconformities or opportunities for improvement and to plan for corrective or preventive actions.
Reference:
1: ISO/IEC 27001:2022 - Information technology - Security techniques - Information securi ty management systems - Requirements, clause 7.2 2: ISO 19011:2018 - Guidelines fo r auditing management systems, clause 3.2

**QUESTION NO: 151**
您是審計團隊負責人，正在對一家線上保險公司進行第三方審計。在第 1 階段，您發現組織採取了非常謹慎的風險方法，並在其適用性聲明中包含了 ISO/IEC 27001:2022 附錄 A 中的所有資訊安全控制。
在第 2 階段審核期間，您的審核團隊發現沒有證據顯示制定了針對三項控制措施（5.3 職責分離、6.1 篩檢、7.12 佈線安全）的風險處理計劃。您對 ISO 27001:2022 第 6.1.3.e 條提出不符合項。
在閉幕會議上，技術總監發布了修訂後的適用性聲明的摘錄（如圖所示），並要求撤銷不符合項。

| Control Reference | Objective | Control driven by | | | Applicable | Last Assessed | Justification if not applicable |
|---|---|---|---|---|---|---|---|
| | | Business Risk | Legal requirement | Customer Contract | | | |
| 5.3 | Avoid conflicts of interest | Yes | No | No | No | 02/202X | Confirmed in job descriptions |
| 6.1 | Screen personnel | Yes | No | Yes | No | 02/202X | Incorporated by a recruitment agency |
| 7.12 | Cable protection | No | Yes | No | No | 02/202X | No such cabling exists |

選擇三個選項，說明審計組長對技術總監的要求做出正確的回應。
**A.**通知管理階層，審計員將在有更多時間時審查所提供的資訊。
**B.**通知技術總監他的請求將被納入審計報告中。
**C.**告知技術總監，一旦提出不符合項，就無法撤回。
**D.**建議技術總監，由於所獲得的證據很清楚，因此不符合情況必須成立。
**E.**詢問提出問題的審計員，了解您應該如何回應該要求。
**F.**通知技術總監該不合格情況將轉變為改善機會。
**G.**審查產生的文件並撤銷不合格項。
**H.**聲明需要進行後續審計以審查更新後的適用性聲明的證據。
**J.**聲明需要進行後續審計來審查更新後的適用性聲明的證據。
***Answer:*** B,D,H
B . This response is correct because the audit team leader should document the request of the Technical Director and include it in the audit report, along with the audit findings and conclusions12. This will ensure transparency and traceability of the audit process and the audit results.
D . This response is correct because the audit team leader should not withdraw the

nonconformity based on the amended Statement of Applicability alone. The nonconformity was raised against clause 6.1.3.e of ISO 27001:2022, which requires the organisation to produce and maintain a risk treatment plan that defines how the information security risks are treated, including the controls selected and their implementation status34. The Statement of Applicability is only one part of the risk treatment plan, and it does not provide sufficient evidence that the controls have been implemented effectively. The audit team leader should base the nonconformity on the objective evidence obtained during the audit, not on the subjective claims of the auditee12.
H . This response is correct because the audit team leader should state that a follow up audit will be necessary to review the evidence for the updated Statement of Applicability. A follow up audit is an audit that is conducted after a previous audit to verify the implementation and effectiveness of the corrective actions and/or opportunities for improvement that were agreed upon as a result of the previous audit56. The follow up audit should seek to ensure that the nonconformity has been effectively addressed and that the ISMS is compliant and effective. The follow up audit should also consider any new or changed risks or requirements that may affect the ISMS56.
Explanation:
The three options of the correct responses of an audit team leader to the request of the Technical Director are:
B . Advise the Technical Director that his request will be included in the audit report.
D . Advise the Technical Director that the nonconformity must stand since the evidence obtained for it was clear.
Reference:
1: PECB Candidate Handbook - ISO 27001 Lead Auditor, page 25 2: ISO 19011:2018 - Guidelines for auditing management systems, clause 6.7 3: ISO/IEC 27001:2022 - Information technology - Security techniques - Information security management systems - Requirements, clause 6.1.3.e 4: ISO/IEC 27005:2022 - Information technology - Security techniques - Information security risk management, clause 8.3.2 5: PECB Candidate Handbook - ISO 27001 Lead Auditor, page 25 6: ISO 19011:2018 - Guidelines for auditing management systems, clause 6.7

**QUESTION NO: 152**
內部稽核和外部稽核有何關係？
**A.**內部審核確保組織定期監控外部審核報告和行動計劃
**B.**內部審核確保在外部審核員建議組織進行認證之前實施糾正措施
**C.**內部稽核和外部稽核包含在認證週期中，確保定期監控管理體系
***Answer:*** C
Explanation:
Internal audits and external audits are integral components of the certification cycle, ensuring regular monitoring of the management system. Internal audits help organizations prepare for external audits by identifying and addressing potential nonconformities, while external audits validate the compliance of the management system with ISO/IEC 27001 standards.

**QUESTION NO: 153**
**場景**

5：Cobt。位於倫敦的保險公司，提供各種商業、工業和人壽保險解決方案。近年來，Cobt 的客戶數量大幅增加。由於需要處理大量數據，該公司認為通過 ISO/IEC 27001 認證將為資訊安全帶來許多好處，並表明其對持續改進的承諾。儘管該公司擅長進行定期風險評估，但實施 ISMS 會為其日常營運帶來重大變化。在風險評估過程中，發現了一種風險，即組織的內部控制機制未能發現或預防重大缺陷。
公司遵循一套方法論來實施 ISMS，並在僅僅幾個月後就建立了可運行的 ISMS。分配了審核團隊成員的職責。
Sarah 承認，儘管 Cobt 通過提供多樣化的商業和保險解決方案實現了顯著擴張，但它仍然依賴於一些手動流程。，特別是關於被審計方的可用性和合作以及獲取證據的管道。在本案中，Cobt的拒絕引發了人們對審計的完整性及其提供合理保證的能力的質疑。針對這些情況，Sarah決定在簽署認證協議之前退出審核，並將她的決定告知了Cobt和認證機構。做出這項決定是為了確保遵守審計原則並保持透明度，突顯了她始終如一地堅持這些原則的承諾。
根據上述情景，回答以下問題：
根據場景 5 中所描述的莎拉的角色，下列哪一項不應屬於她的職責？

**A.**向審計團隊成員分配職責

**B.**定義審計標準與目標

**C.**規劃審計

***Answer:*** A

Explanation:
Comprehensive and Detailed In-Depth
A . Assigning responsibilities to the audit team members (Correct Answer) - This is not Sarah's responsibility. The certification body assigns the audit team and defines responsibilities, ensuring independence and objectivity.
B . Defining the audit criteria and objectives (Correct Responsibility) - Sarah, as the audit team leader, must establish audit criteria and objectives, per ISO 19011 (Guidelines for Auditing Management Systems).
C . Planning the audit (Correct Responsibility) - The audit team leader is responsible for planning the audit, including timelines and resource allocation.
Relevant Standard Reference:
ISO/IEC 27001:2022 Clause 9.2 (Internal Audit)

**QUESTION NO: 154**
下列哪一個選項存在輕微不符合項？

**A.**風險評估方法阻礙了資訊安全風險的評估

**B.**公司與其供應商的合約沒有適當的文件版本控制

**C.**資料的備份每月進行一次，而公司的流程則要求每天備份一次

***Answer:*** C

Explanation:
This is a minor nonconformity. The backup frequency not adhering to the company's procedure of daily backups but occurring once a month represents a deviation from established processes, yet it might not immediately impact the effectiveness of the information security management system.

**QUESTION NO: 155**
在定義以下內容時，評估與不合格和不遵守法律和合約要求相關的成本：
**A.**重要性
**B.**審計風險
**C.**合理保證
***Answer:*** A
Explanation:
Materiality in the context of an audit involves assessing what level of nonconformities or failures, including those related to legal and contractual compliance, would be significant enough to affect the audit conclusions. Costs related to these issues are considered when determining materiality.

**QUESTION NO: 156**
分類為 _____ 的資訊或資料不需要標記。
**A.**公開
**B.**內部
**C.**機密
**D.**高度機密
***Answer:*** A
Explanation:
Information or data that are classified as public do not require labeling. Public information or data are those that are intended for general disclosure and have no impact on the organization's operations or reputation if disclosed. Labeling is a method of implementing classification, which is a process of structuring information according to its sensitivity and value for the organization. Labeling helps to identify the level of protection and handling required for each type of information. Information or data that are classified as internal, confidential, or highly confidential require labeling, as they contain information that is not suitable for public disclosure and may cause harm or loss to the organization if disclosed.
Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 34. : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 37. : [ISO/IEC 27001 LEAD AUDITOR - PECB], page 14.

**QUESTION NO: 157**
一家網路安全公司實施了一款存取控制軟體，只允許授權人員存取敏感文件。在這種情況下，公司實施了哪種類型的控制？
**A.**預防控制
**B.**偵探控制
**C.**修正控制
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Preventive Control - Correct Answer. Access control software is designed to prevent unauthorized access by enforcing authentication and authorization mechanisms. This aligns with ISO/IEC 27001:2022 Annex A Control A.5.18 (Access Rights).

ACTUAL4TEST.COM

B . Detective controls identify and log unauthorized access attempts, but do not prevent them.
C . Corrective controls take action after a security event has occurred.

**QUESTION NO: 158**
情境 4：SendPay
是一家金融公司，透過代理商和金融機構網路提供服務。他們的主要服務之一是在全球範圍內轉帳。 SendPay
作為一家新公司，致力於為客戶提供最優質的服務。由於該公司提供國際交易，因此要求客戶提供個人信息，例如身份、交易原因以及完成交易可能需要的其他詳細信息。因此，SendPay已實施安全措施來保護客戶的訊息，包括偵測、調查和回應可能出現的任何資訊安全威脅。他們對提供安全服務的承諾也體現在 ISMS 實施過程中，該公司投入了大量時間和資源。
去年，SendPay
推出了他們的數位平台，允許透過智慧型手機或筆記型電腦等電子設備進行貨幣交易，而無需支付額外費用。透過這個平台，SendPay
的客戶可以隨時隨地發送和接收資金。該數位平台幫助SendPay簡化了公司營運並進一步拓展了業務。當時SendPay正在外包其軟體業務，因此該專案是由外包公司的軟體開發團隊完成的。
該團隊還負責維護 SendPay 的技術基礎設施。
最近，該公司在實施 ISMS 近一年後申請了 ISO/IEC 27001
認證。他們與符合其標準的認證機構簽訂了合約。不久之後，認證機構任命了一個由四名審核員組成的團隊來審核 SendPay 的 ISMS。
審計過程中，發現以下情況：
1.外包軟體公司在未事先通知的情況下終止了與SendPay的合約。結果，SendPay
無法立即將服務恢復到內部，其營運中斷了五天。審計人員要求 SendPay
的代表提供證據，證明他們在合約終止的情況下有計劃遵循。這些代表沒有提供任何書面證據，但在接受審計時，他們告訴審計人員，SendPay的高層已經確定了另外兩家軟體開發公司，如果類似情況再次發生，可以立即提供服務。
2. 沒有證據顯示對外包給軟體開發公司的活動進行了監控。 SendPay
的代表再次告訴審計人員，他們定期與軟體開發公司溝通，並適當地告知可能發生的任何變更。
3.防火牆測試未發現異常狀況。審核員測試了防火牆配置，以確定這些服務提供的安全等級。他們使用資料包分析器來測試防火牆策略，這使他們能夠即時檢查發送或接收的資料包。
根據該場景，回答以下問題：
SendPay
的代表表示，該公司沒有計劃與他們外包活動的公司終止合約。相反，最高管理層已經確定了另外兩家可以提供相同服務的軟體開發公司。您如何描述這種情況？
**A.**不可接受，SendPay 用於識別替代軟體開發公司的證據和標準不充分
**B.**可以接受，SendPay可以決定是否制定類似的合約終止計劃，因此不需要額外的證據
**C.**不可接受，SendPay 必須始終制定恢復計劃，說明公司應遵循哪些步驟
***Answer:*** C
Explanation:
ISO/IEC 27001 emphasizes the need for organizations to have a comprehensive incident management and recovery plan for various situations, including the termination of contracts with key service providers. In the case of SendPay, having a specific, documented recovery

plan that outlines steps and protocols in case of sudden termination is necessary to ensure business continuity and compliance with the standard.

**QUESTION NO: 159**
您正在一家名為 ABC 的提供醫療保健服務的住宅療養院進行 ISMS 審核。您會發現所有療養院居民都戴著電子腕帶，用於監控他們的位置、心跳和血壓。您了解到，電子腕帶會自動將所有資料上傳到人工智慧（AI）雲端伺服器，供醫護人員進行健康監測和分析。
為了驗證 ISMS 的範圍，您採訪了管理系統代表 (MSR)，他解釋說 ISMS 範圍涵蓋外包資料中心。
選擇三個選項作為您需要尋找的審核證據，以驗證 ISMS 的範圍。
**A.**被審核方已確定居民對設施和環境安全的需求和期望
**B.**被審核方擁有 ISO 9001 認證
**C.**被審核方已確定政府當局對醫療保健服務和病患資料處理的需求和期望
**D.**受審核方已確定居民對於如何保護居民個人資料的需求和期望
**E.**被審核方已確定居民對舒適設施、醫療專業人員能力和清潔環境的需求和期望
**F.**被審核方已確定居民對健康醫療服務的需求和期望
**G.**與人工智慧雲端伺服器所在資料中心的IT服務協議
**H.**被審核方正在考慮從外部軟體公司購買醫療保健監控應用程式
***Answer:*** C,D,G
Explanation:
According to ISO 27001:2022 clause 4.3, the organisation shall determine the scope of the information security management system (ISMS) by considering the internal and external issues, the requirements of interested parties, and the interfaces and dependencies with other organisations12 In this case, the ISMS scope covers an outsourced data center that hosts the artificial intelligence (AI) cloud server for healthcare monitoring and analysis of the residents' data. Therefore, the audit evidence you need to find to verify the scope of the ISMS should include:
The auditee has identified the governmental authorities' needs and expectations on healthcare services and patient data handling. This is an external issue and an interested party requirement that affects the ISMS scope, as the auditee has to comply with the relevant laws and regulations regarding the quality, safety, and privacy of healthcare services and patient data12 The auditee has identified the resident's needs and expectations on how they should protect the resident's personal data. This is an external issue and an interested party requirement that affects the ISMS scope, as the auditee has to ensure the confidentiality, integrity, and availability of the resident's personal data that is collected, processed, and stored by the electronic wristband and the AI cloud server12 The IT service agreement with the data center where the artificial intelligence (AI) cloud server is located. This is an interface and dependency with another organisation that affects the ISMS scope, as the auditee has to control the externally provided processes, products, and services that are relevant to the ISMS, and to implement appropriate contractual requirements related to information security12 The following options are not relevant or sufficient for verifying the scope of the ISMS:
The auditee has identified the resident's needs and expectations on the facility and environmental safety. This is an external issue and an interested party requirement, but it

does not affect the ISMS scope, as it is not related to information security12 The auditee has ISO 9001 certification. This is an indication of the auditee's quality management system, but it does not verify the scope of the ISMS, as it is not related to information security12 The auditee has identified the resident's needs and expectations on the comfort facility, medical professional's competence, and clean environment. These are external issues and interested party requirements, but they do not affect the ISMS scope, as they are not related to information security12 The auditee has identified the resident's needs and expectations on healthcare medical treatment services. These are external issues and interested party requirements, but they do not verify the scope of the ISMS, as they are not specific to information security12 The auditee is considering the purchase of a healthcare monitoring app from an external software company. This is a potential change that may affect the ISMS scope in the future, but it does not verify the current scope of the ISMS, as it is not yet implemented or controlled12 Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 160**
當涉及認證機構的多個辦事處時，必須確保什麼？
**A.**每個辦事處都與客戶簽訂了單獨的、具有法律效力的協議
**B.**一份具有法律效力的協議，涵蓋認證範圍內的所有站點
**C.**只有主辦公室與客戶簽訂了具有法律效力的協議
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:
A single legally enforceable agreement must cover all sites included in the certification scope to ensure:
Consistency in audit approach
Legal clarity between all parties
Global applicability for multinational companies
A . Incorrect:
Separate agreements for each office would create inconsistencies and legal complexities.
C . Incorrect:
All sites involved in certification must be covered by the agreement, not just the main office.
Relevant Standard Reference:

**QUESTION NO: 161**
場景 1：Fintive 是一家傑出的線上支付和保護解決方案安全提供者。 Fintive 於 1999 年由 Thomas Fin 在加州聖荷西創立，為線上營運、希望提高資訊安全、防止詐欺並保護 PII 等用戶資訊的公司提供服務。
Fintive的決策和營運流程以以往的案例為中心。他們收集客戶數據，根據情況進行分類並進行分析。該公司需要大量員工才能進行如此複雜的分析。然而，幾年後，協助進行此類分析的技術也取得了進展。現在，Fintive
正計劃使用現代工具聊天機器人來實現模式分析，以即時防止詐騙。該工具也將用於幫助改善

客戶服務。
這個最初的想法已傳達給軟體開發團隊，他們支持該想法並被分配從事該專案。他們開始將聊天機器人整合到現有系統中。此外，團隊也為聊天機器人設定了一個目標，即回答 85% 的聊天查詢。
聊天機器人成功整合後，該公司立即將其發布給客戶使用。
然而，聊天機器人似乎存在一些問題。
由於測試不足，並且在訓練階段缺乏向聊天機器人提供的樣本（在訓練階段，聊天機器人本應「學習」查詢模式），因此聊天機器人無法解決用戶查詢並提供正確的答案。此外，當聊天機器人收到無效輸入（例如奇怪的點圖案和特殊字元）時，它會向使用者發送隨機檔案。因此，聊天機器人無法正確回答客戶的查詢，而傳統的客戶支援因聊天查詢而不堪重負，因此無法幫助客戶解決他們的請求。
因此，Fintive 制定了軟體開發政策。該政策規定，無論軟體是內部開發還是外包，在作業系統上實施之前都將經過黑盒測試。
根據該場景，回答以下問題：
在訓練階段測試不充分且缺乏向 Fintive 聊天機器人提供的樣本被視為 1。
參考場景

**A.**威脅

**B.**漏洞

**C.**風險

***Answer:*** B

**QUESTION NO: 162**
場景 1：Fintive 是一家傑出的線上支付和保護解決方案安全提供者。 Fintive 於 1999 年由 Thomas Fin 在加州聖荷西創立，為線上營運、希望提高資訊安全、防止詐欺並保護 PII 等用戶資訊的公司提供服務。
Fintive的決策和營運流程以以往的案例為中心。他們收集客戶數據，根據情況進行分類並進行分析。該公司需要大量員工才能進行如此複雜的分析。然而，幾年後，協助進行此類分析的技術也取得了進展。現在，Fintive 正計劃使用現代工具聊天機器人來實現模式分析，以即時防止詐騙。該工具也將用於幫助改善客戶服務。
這個最初的想法已傳達給軟體開發團隊，他們支持該想法並被分配從事該專案。他們開始將聊天機器人整合到現有系統中。此外，團隊也為聊天機器人設定了一個目標，即回答 85% 的聊天查詢。
聊天機器人成功整合後，該公司立即將其發布給客戶使用。
然而，聊天機器人似乎存在一些問題。
由於測試不足，並且在訓練階段缺乏向聊天機器人提供的樣本（在訓練階段，聊天機器人本應「學習」查詢模式），因此聊天機器人無法解決用戶查詢並提供正確的答案。此外，當聊天機器人收到無效輸入（例如奇怪的點圖案和特殊字元）時，它會向使用者發送隨機檔案。因此，聊天機器人無法正確回答客戶的查詢，而傳統的客戶支援因聊天查詢而不堪重負，因此無法幫助客戶解決他們的請求。
因此，Fintive 制定了軟體開發政策。該政策規定，無論軟體是內部開發還是外包，在作業系統上實施之前都將經過黑盒測試。
使用黑盒測試代表什麼類型的安全控制？請參閱場景 1。

ACTUALTEST.COM

**A.**矯正與技術
**B.**偵探與管理
**C.**預防性與技術性
***Answer:*** C

**QUESTION NO: 163**
場景 3：Rebuildy
是一家位於泰國曼谷的建築公司，專門從事住宅建築的設計、建造和維護。為了確保敏感專案資料和客戶資訊的安全，Rebuildy 決定實施基於 ISO/IEC 27001 的資訊安全管理系統 (ISMS)。
ISMS 實施成果如下
* 資訊安全是透過應用一系列安全控制和製定政策、流程和程序來實現的。
* 安全控制是根據風險評估實施的，旨在消除風險或將風險降低到可接受的水平。
* 所有流程均基於計劃-執行-檢查-行動 (PDCA) 模型確保 ISMS 的持續改進。
*
資訊安全政策是根據最佳安全實務起草的安全手冊的一部分，因此，它不是一份獨立的文件。
* 資訊安全角色和職責已在每位員工的職位說明中明確說明
* 資訊安全管理系統的管理評審是依照計畫的時間間隔進行的。
Rebuildy
在經歷了兩次中期管理評審和一次年度內部審計後申請了認證。該前員工向審計團隊成員 Electra 提交了書面證據，Rebuildy 的主要客戶 Electra
也提交了有關相同問題的證據，審計員決定保留這份證據，而不是前員工的證據。審計團隊成員一直與 Electra
保持聯繫，直至審計完成，討論審計期間發現的不符合。伊萊克特拉提供了額外的證據來支持這些發現。
在審核開始時，審核小組對公司高階主管進行了訪談，討論了高階主管對 ISMS
實施的承諾等事項。從這些討論中獲得的證據都記錄在書面確認書中，用於確定 Rebuildy
是否符合 ISO/IEC 27001 的幾個條款。其中，發現以下不符合：
* 在公司的財務報告系統中偵測到了不當的使用者存取控制設定實例。
* 尚未建立獨立的資訊安全政策。相反，該公司使用根據最佳安全實踐起草的安全手冊。
在收到審計團隊的這些文件後，團隊負責人會見了 Rebuildy
的高層管理層，介紹了審計結果。審計小組報告了與財務報告系統和缺乏獨立資訊安全政策有關的調查結果。高階主管對調查結果表示不滿，並認為審計組長的行為不專業，暗示他們可能會要求更換組長。迫於壓力，審計組長決定與高階主管合作，淡化所發現的不符合項的重要性。因此，審計團隊負責人調整了報告以呈現更有利的觀點，從而歪曲了 Rebuildy
合規問題的真實程度。
根據上述情景，回答以下問題：
審計團隊是否遵守有關財務報告系統狀況的審計最佳實務？
**A.**是的，因為它超出了審計範圍
**B.**不，審核小組應該聯絡認證機構並報告情況
**C.**不，由於該行為的非法性質，審計小組應該退出審計
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:

The financial reporting system issue is a critical security concern, and the audit team should have reported the situation to the certification body for further action.
ISO 19011:2018 mandates auditors to escalate issues that impact compliance.
A . Incorrect:
Financial systems fall within ISMS scope if they contain sensitive data-it is not beyond the scope.
C . Incorrect:
Withdrawal is unnecessary unless legal violations prevent an effective audit.
Relevant Standard Reference:

**QUESTION NO: 164**
根據 ISO/IEC 27001，資訊安全管理系統旨在保護下列哪兩項？
**A.**資訊的可訪問性
**B.**訊息的真實性
**C.**資訊的機密性
**D.**資訊的一致性
**E.**資訊整合
**F.**資訊的完整性
***Answer:*** C,F
Explanation:
ISO/IEC 27001 focuses on the core principles of the CIA triad:
* Confidentiality: Ensuring information is accessible only to authorized individuals.
* Integrity: Maintaining the accuracy and completeness of information, protecting it from unauthorized modification.
* Availability: Information should be accessible to authorized users when needed (this is also important, but not one of the choices in this specific question).
Reference:
* ISO/IEC 27001:2022, Section 4.2 (Understanding the needs and expectations of interested parties): This section highlights the importance of determining relevant interested parties and their requirements related to information security, which includes addressing confidentiality, integrity, and availability.

**QUESTION NO: 165**
審核員應具備一定的知識和技能；而審計組長也應該具備一些額外的知識和技能。從下面的清單中，選擇僅適用於審核團隊領導的兩項。
**A.**計劃審核
**B.**瞭解並應用以風險為基礎的稽核方法
**C.**應用適當的取樣技術
**D.**有效利用提供給審計的資源
**E.**了解受審核方的文化和社會面
**F.**驗證所收集資訊的相關性和準確性
***Answer:*** A,D
Explanation:
According to the PECB Candidate Handbook1, audit team leaders should have the following

additional knowledge and skills compared to auditors:
* Plan the audit, including preparing the audit plan, assigning work to the audit team members and coordinating their activities
* Make effective use of resources provided to the audit, such as personnel, time, budget and equipment
* Manage the audit process, including leading the opening and closing meetings, directing the audit team, resolving conflicts and ensuring the audit objectives are achieved
* Review and approve the audit report and audit findings
* Communicate with the client and other interested parties throughout the audit

**QUESTION NO: 166**
下列哪兩個短語適用於與業務流程的計劃-實施-檢查-行動週期相關的「行動」？
**A.**審核流程
**B.**計劃變更
**C.**測量目標
**D.**重設目標
**E.**實現改進
**F.**驗證訓練
***Answer:*** D,E
Explanation:
The Act phase of the PDCA cycle is where the organisation takes actions to improve its processes and performance based on the results of the Check phase. This may involve resetting objectives to make them more realistic, achievable or challenging, or implementing changes to address the root causes of problems and achieve the desired outcomes. The Act phase is also where the organisation monitors the effects of the actions taken and evaluates their effectiveness and efficiency. The Act phase is important because it enables the organisation to learn from its experience and continually improve its ISMS. Reference: What is 'Plan, Do, Check, Act'? A framework for continuous improvement, PDCA in ISO27001 - Free guide to learn | Dr. Erdal Ozkaya, PECB Candidate Handbook ISO 27001 Lead Auditor (page 12)

**QUESTION NO: 167**
場景 6：Cyber ACrypt
是一家網路安全公司，透過提供反惡意軟體和設備安全、資產生命週期管理和設備加密來提供端點保護。為了根據 ISO/IEC 27001 驗證其 ISMS
並證明其對網路安全卓越的承諾，該公司經歷了由指定審計團隊負責人 John
領導的細緻的審計過程。
在接受審計任務後，John 立即組織了一次會議，概述了審計計劃和團隊角色。他們審查了 Cyber ACrypt
的文檔信息，包括資訊安全政策和操作程序，確保每一份文件都符合標準並具有標準化的格式，包括作者標識、生產日期、版本號和批准日期。這次徹底的檢查旨在確定持續改進和遵守 ISMS 要求。該文件對於審計團隊和 Cyber ACrypt
了解初步審計結果和需要關注的領域至關重要。
審計組也決定對主要相關方進行訪談。這項決定的目的是收集可靠的審計證據來驗證管理系統是否符合 ISO/IEC 27001 的要求。與 Cyber ACrypt

各個層級的相關方進行接觸為審計團隊提供了寶貴的觀點以及對 ISMS
的實施和有效性的理解。
第一階段審計報告揭露了值得關注的關鍵領域。適用性聲明 (SoA) 和 ISMS
政策在多個方面存在缺陷，包括風險評估不足、存取控制不充分以及缺乏定期政策審查。這促使 Cyber ACrypt
立即採取行動來解決這些缺陷。他們對戰略文件的快速回應和修改體現出了對實現合規的堅定承諾。
為了彌補審計團隊的網路安全知識差距而引入的技術專長在識別風險評估方法中的缺陷和審查網路架構方面發揮了關鍵作用。這包括評估防火牆、入侵偵測和預防系統以及其他網路安全措施，以及評估 Cyber ACrypt
如何偵測、回應和恢復外部和內部威脅。在約翰的監督下，技術專家將審計結果傳達給了 Cyber ACrypt
的代表。然而，審計小組發現，由於收取了被審計單位的諮詢費，該專家的客觀性可能受到影響。考慮到技術專家在審核過程中的行為，審核組長決定與認證機構討論這個問題。
根據上述情景，回答以下問題：
根據情境6，審計團隊負責人針對技術專家的行為所做的決定是否可以接受？
**A.**不，審計團隊負責人應該直接向高階主管報告問題
**B.**不，質疑專家的客觀性不是審核組長與認證機構討論此事的正當理由
**C.**是的，如果審核員對技術專家的客觀性有懷疑，他必須與認證機構討論他的顧慮
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct Answer:
ISO 17021-1:2015 Clause 5.2.4 requires auditors to report impartiality concerns.
The technical expert received consultancy fees from Cyber ACrypt, creating a conflict of interest.
The certification body must be informed to ensure audit integrity.
A . Incorrect:
Reporting to top management does not resolve certification body independence concerns.
B . Incorrect:
Impartiality is a critical concern in ISO/IEC 27001 certification.
Relevant Standard Reference:
ISO/IEC 17021-1:2015 Clause 5.2.4 (Ensuring Impartiality in Audits)

**QUESTION NO: 168**
您必須進行第三方虛擬審核。在開始進行審核之前，您需要告知受審核方以下哪兩個問題？
**A.**您將要求查看螢幕上的人的身分證。
**B.**您將為採訪的每個人拍照。
**C.**您將要求受訪的人事先說明他們的姓名和職位。
**D.**您將要求取得正在進行審核的房間的 360 度視圖。
**E.**除非允許，否則您不得記錄審核的任何部分。
**F.**您希望受審核方已評估與線上活動相關的所有風險。
***Answer:*** C,D
Explanation:

A third-party virtual audit is an external audit conducted by an independent certification body using remote technology such as video conferencing, screen sharing, and electronic document exchange. The purpose of a third-party virtual audit is to verify the conformity and effectiveness of the information security management system (ISMS) and to issue a certificate of compliance12 Before you start conducting the audit, you would need to inform the auditee about the following issues: 12 You will ask those being interviewed to state their name and position beforehand, i.e., to confirm their identity and role in the ISMS. This is to ensure that you are interviewing the relevant personnel and that they are authorized to provide information and evidence for the audit.
You will ask for a 360-degree view of the room where the audit is being carried out, i.e., to verify the physical and environmental security of the audit location. This is to ensure that there are no unauthorized persons or devices in the vicinity that could compromise the confidentiality, integrity, or availability of the information being audited.
The other issues are not relevant or appropriate for a third-party virtual audit, because:
You will ask to see the ID card of the person that is on the screen, i.e., to verify their identity. This is not necessary if you have already asked them to state their name and position beforehand, and if you have access to the auditee's organizational chart or staff directory. Asking to see the ID card could also be seen as intrusive or disrespectful by the auditee.
You will take photos of every person you interview, i.e., to document the audit process. This is not advisable as it could violate the privacy or consent of the auditee and the interviewees. Taking photos could also be seen as unprofessional or suspicious by the auditee. You should rely on the audit records and evidence provided by the auditee and the audit tool instead.
You will not record any part of the audit, unless permitted, i.e., to respect the auditee's preferences and rights. This is not a valid issue to inform the auditee about, as you should always record the audit for quality assurance and verification purposes. Recording the audit is also a requirement of the ISO/IEC 27001 standard and the certification body. You should inform the auditee that you will record the audit and obtain their consent before the audit begins.
You expect the auditee to have assessed all risks associated with online activities, i.e., to ensure the security of the audit process. This is not an issue to inform the auditee about, as it is part of the auditee's responsibility and obligation to have a risk assessment and treatment process for their ISMS. You should assess the auditee's risk management practices and controls during the audit, not before it.
Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 169**
Finnco 是一家認證機構的子公司，為某組織提供 ISMS
諮詢服務。考慮到這種情況，認證機構何時可以對該組織進行認證？
**A.**在這種情況下沒有時間限制
**B.** 認證機構可以在諮詢服務結束後立即對組織進行認證
**C.**如果自上次諮詢活動以來已過去至少兩年
***Answer:*** C

ISO/IEC 17021-1:2015 (Requirements for Certification Bodies) prohibits certification bodies from certifying organizations they have provided consultancy services to, unless a two-year separation period is maintained.
This prevents conflicts of interest and ensures independent certification audits.
A: Incorrect:
There is a strict time constraint to prevent certification bias.
B: Incorrect:
Certification cannot happen immediately after consulting services end, as this would create an independence conflict.
Relevant Standard Reference:
Explanation:
Comprehensive and Detailed In-Depth

**QUESTION NO: 170**
當您正在進行第三方監督審計時，審計團隊的另一位成員找到您並尋求澄清。他們被要求評估該組織對控制 5.7——威脅情報的應用。他們知道這是 2022 年版 ISO/IEC 27001 中引入的新控制措施之一，他們希望確保正確審查該控制措施。
他們準備了一份清單來協助他們進行審計，並希望您確認他們的計劃活動符合控制的要求。
下列哪三個選項代表有效的審計追蹤？
**A.**我將確定在產生威脅情報時是否使用了內部和外部資訊來源
**B.**我將確保將產生威脅情報的任務分配給組織的內部稽核團隊
**C.**我將確保組織的風險評估流程從有效的威脅情報開始
**D.**我將檢查該組織是否有完整記錄的威脅情報流程
**E.**我將檢查是否積極使用威脅情報來保護組織資訊資產的機密性、完整性和可用性
**F.**我將與高階主管交談，以確保所有員工都意識到報告威脅的重要性
**G.**我將確保採取適當措施，向高階主管通報目前威脅情報安排的有效性
**H.**我將檢視如何收集和評估與資訊安全威脅相關的資訊以產生威脅情報
***Answer:*** A,D,E
Explanation:
The options that represent valid audit trails for assessing the organisation's application of control 5.7 - Threat Intelligence, according to ISO/IEC 27001:2022, are:
Option A: I will determine whether internal and external sources of information are used in the production of threat intelligence. This is relevant because effective threat intelligence typically requires gathering information from multiple sources to be comprehensive.
Option D: I will check that the organisation has a fully documented threat intelligence process. Proper documentation is a core requirement in ISO standards to ensure processes are defined, implemented, and maintained consistently.
Option E: I will check that threat intelligence is actively used to protect the confidentiality, integrity, and availability of the organisation's information assets. This verifies that the output of threat intelligence is being used effectively within the organisation's information security practices.

**QUESTION NO: 171**
您正在一家提供醫療保健服務的住宅療養院進行 ISMS 審核。審核計畫的下一步是驗證業務連續性管理流程的資訊安全性。在審計過程中，您了解到

該組織啟動了其中一項業務連續性計劃
(BCP)，以確保護理服務在最近的大流行期間繼續進行。您要求服務經理解釋組織如何在業務連續性管理流程中管理資訊安全。
服務經理介紹了針對大流行的護理服務連續性計劃，並將流程總結如下：
停止接納任何新居民。
70%的行政人員和30%的醫護人員將在家工作。
定期對員工進行自我檢測，包括在來辦公室前 1 天提交陰性檢測報告。
安裝 ABC
的醫療保健行動應用程序，追蹤他們的足跡並出示綠色健康狀況二維碼以供現場檢查。
您詢問服務經理，當員工在家工作時，如何防止非相關家庭成員或利害關係人存取居民的個人資料。服務經理無法回答，並建議 IT 安全經理應提供協助。
您想進一步調查其他領域以收集更多審計證據。選擇三個不會出現在您的審核追蹤中的選項。
**A.**收集有關在中斷期間如何維護資訊安全協議的更多證據（與控制措施 A.5.29 相關）
**B.**收集更多證據，證明員工在家工作時僅使用免受惡意軟體侵害的 IT 裝置（與控制措施 A.8.7 相關）
**C.**透過訪談其他員工來收集更多證據，以確保他們意識到有時需要在家工作（與第 7.3 條相關）
**D.**收集更多有關如何以及何時測試業務連續性計劃的證據。（與控制措施 A.5.29 相關）
**E.**收集更多證據，說明組織如何確保所有員工定期進行新冠病毒檢測呈陽性（與控制措施 A.7.2 相關）
**F.**收集更多有關組織如何管理行動裝置上和遠端辦公期間的資訊安全的證據（與控制措施 A.6.7 相關）
**G.**收集更多有關組織如何進行業務風險評估的證據，以評估現有居民離開療養院的速度。（與第6條相關）
**H.**收集更多證據，了解組織提供哪些資源來支持在家工作的員工。（與第7.1條相關）
***Answer:*** E,G,H
Explanation:
According to ISO/IEC 27001:2022 clause 6.1, the organization must establish, implement and maintain an information security risk management process that includes the following activities:
establishing and maintaining information security risk criteria;
ensuring that repeated information security risk assessments produce consistent, valid and comparable results; identifying the information security risks; analyzing the information security risks; evaluating the information security risks; treating the information security risks; accepting the information security risks and the residual information security risks; communicating and consulting with stakeholders throughout the process; monitoring and reviewing the information security risks and the risk treatment plan.
According to control A.5.29, the organization must establish, document, implement and maintain processes, procedures and controls to ensure the required level of continuity for information security during a disruptive situation. The organization must also:
determine its requirements for information security and the continuity of information security management in adverse situations, e.g. during a crisis or disaster; establish, document, implement and maintain processes, procedures and controls to ensure the required level of continuity for information security during an adverse situation; verify the availability of

ACTUAL4TEST.COM

information processing facilities.
Therefore, the following options will not be in your audit trail, as they are not relevant to the information security risk management process or the information security continuity process:
E . Collect more evidence on how the organisation makes sure all staff periodically conduct a positive Covid test (Relevant to control A.7.2). This is not relevant to the information security aspects of business continuity management, as it is related to the health and safety of the staff, not the protection of information assets. Control A.7.2 is about screening of personnel prior to employment, not during employment.
G . Collect more evidence on how the organisation performs a business risk assessment to evaluate how fast the existing residents can be discharged from the nursing home. (Relevant to clause 6). This is not relevant to the information security aspects of business continuity management, as it is related to the operational and financial aspects of the business, not the identification and treatment of information security risks. Clause 6 is about the information security risk management process, not the business risk management process.
H . Collect more evidence on what resources the organisation provides to support the staff working from home. (Relevant to clause 7.1). This is not relevant to the information security aspects of business continuity management, as it is related to the general provision of resources for the ISMS, not the specific processes, procedures and controls to ensure the continuity of information security during a disruptive situation. Clause 7.1 is about determining and providing the resources needed for the establishment, implementation, maintenance and continual improvement of the ISMS, not the resources needed for the staff working from home.
Reference:
ISO/IEC 27001:2022, clauses 6.1, 7.1, and Annex A control A.5.29
[PECB Candidate Handbook ISO/IEC 27001 Lead Auditor], pages 14-15, 17, 22-23 ISO 27001:2022 Annex A Control 5.29 - What's New?
ISO 22301 Business Continuity Management System

**QUESTION NO: 172**
您正在國際物流組織的出貨部門進行 ISMS
審核，該組織為當地醫院和政府辦公室等大型組織提供運輸服務。包裹通常包含藥品、生物樣本以及護照和駕駛執照等文件。您注意到公司記錄顯示大量退貨，原因包括標籤地址錯誤，以及在 15% 的情況下，一個包裹的不同地址有兩個或多個標籤。您正在面試運輸經理 (SM)。
您：出貨前檢查過嗎？
SM：任何明顯損壞的物品都會在出貨前由值班人員移除，但利潤微薄，因此實施正式檢查流程並不經濟。
您：退貨後會採取什麼措施？
SM：這些合約大多價值相對較低，因此我們認為，簡單地重新列印標籤並重新發送單一包裹比實施調查更容易、更方便。
您因標籤流程缺乏控製而提出不符合 ISO 27001:2022 的要求。
在最後一次會議上，運輸經理向您道歉，他的評論可能被誤解了。他說，他沒有意識到有一個後台 IT
流程會自動檢查正確的標籤是否貼在正確的包裹上，否則包裹會在貼標籤時被彈出。他要求你撤回你不合格的行為。
選擇您作為審核組組長對運輸經理的要求做出的正確回應的三個選項。

**A.**通知運輸經理他的請求將包含在審核報告中
**B.**建議管理階層在審核員有更多時間時討論所提供的新資訊
**C.**通知運輸經理，不合格情況很輕微，應迅速糾正
**D.**請審核團隊成員說明他們認為應該發生什麼
**E.**告知他您的理解並撤回不符合項
**F.**感謝運輸經理的誠實，但建議撤回不合格項並不是正確的處理方式
**G.**建議運輸經理該不合格項必須成立，因為所獲得的證據非常昂貴
**H.**顯示不符合項是需要修正的更深層系統故障的證據
***Answer:*** A,B,F
Explanation:
A . Advise the Shipping Manager that his request will be included in the audit report. This is true because the audit report should document all the relevant information and evidence related to the audit, including any requests or objections raised by the auditee. The audit report should also provide the rationale for the audit conclusions and recommendations12.
B . Advise management that the new information provided will be discussed when the auditors have more time. This is true because the auditors should not make hasty decisions based on incomplete or unverified information. The auditors should review and evaluate the new information in a systematic and objective manner, and determine whether it affects the audit findings, nonconformities, or conclusions12.
F . Thank the Shipping Manager for his honesty but advise that withdrawing the nonconformity is not the right way to proceed. This is true because the auditors should acknowledge and appreciate the cooperation and transparency of the auditee, but also maintain their professional integrity and independence. The auditors should not withdraw a nonconformity unless they are satisfied that it was raised in error or that it has been effectively corrected and verified12.
Reference:
ISO 19011:2022 Guidelines for auditing management systems
ISO/IEC 17021-1:2022 Conformity assessment - Requirements for bodies providing audit and certification of management systems - Part 1: Requirements

**QUESTION NO: 173**
場景 8：苔絲
一個。 Malik 和 Michael
是一個由安全、合規以及業務規劃和策略領域的獨立且合格的專家組成的審計團隊。他們被指派到一家大型網頁設計公司Clastus進行認證審核。他們在進行審計時表現出了出色的職業道德，包括公正和客觀。這一次，Clastus 確信，如果獲得 ISO/IEC 27001
認證，他們將領先一步。
審計團隊負責人 Tessa 擁有審計專業知識，並且在 IT
相關問題、合規性和治理方面擁有非常成功的背景。馬利克擁有組織規劃和風險管理背景。他的專業知識依賴於對組織的安全控制及其風險承受能力的綜合和分析水平，以準確描述組織內部的風險水平 另一方面，Michael
是通過遵循嚴格的標準化程序進行控制評估的實際安全性的專家。
在執行所需的審計活動後，泰莎發起了一次審計團隊會議，他們分析了邁克爾的一項發現，以客觀、準確地就該問題做出決定。 Michael
遇到的問題是組織日常運作中的一個小問題，他認為這是由組織的一名 IT

技術人員造成的，因此，Tessa
會見了高層管理人員，並在他們詢問了責任人姓名後，告訴他們誰應該對這一問題負責，為了方便澄清和理解，Tessa 在審核的最後一天召開了結束會議。在這次會議上，她向 Clastus 管理層報告了發現的不符合情況。然而，Tessa 收到建議，避免在 Clastus 認證審核的審核報告中提供不必要的證據，確保報告保持簡潔並專注於關鍵發現。
根據審查的證據，審核小組起草了審核結論，並決定在授予認證之前必須對該組織的兩個領域進行審核。這些決定後來被提交給被審計方，但被審計方不接受調查結果並提議提供更多資訊。儘管受審計方提出了意見，但審計員已經決定接受認證建議，因此沒有接受補充資訊。被審計單位的高階主管堅持審計結論並不代表事實，但審計小組仍堅持他們的決定。
根據上述情景，回答以下問題：
根據審計小組的決定，克拉斯特斯下一步該採取什麼行動？

**A.**提交行動計劃

**B.**評估矯正措施

**C.**執行行動計畫的後續行動

***Answer:*** A

Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
ISO/IEC 27001:2022 Clause 10.1 (Improvement) requires organizations to submit action plans to address audit findings.
Clastus must document an action plan before corrective actions can be evaluated or followed up.
B . Incorrect:
Corrective actions can only be evaluated after action plans are submitted and implemented.
C . Incorrect:
Follow-up occurs after corrective actions have been executed and verified.
Relevant Standard Reference:

**QUESTION NO: 174**
當審核團隊的另一位成員向您尋求澄清時，您正在進行第三方監督審核。他們被要求評估組織對控制 5.7 - 威脅情報的應用。他們知道這是 2022 年版 ISO/IEC 中引入的新控制措施之一 27001，他們希望確保正確審核控制。
他們準備了一份清單來協助他們進行審核，並希望您確認他們計劃的活動符合控制要求。
下列哪三個選項代表有效的審計追蹤？

**A.**我將檢視組織的威脅情報流程，並確保對此進行完整記錄

**B.**我將與高階主管交談，以確保所有員工都意識到報告威脅的重要性

**C.**我將確保將產生威脅情報的任務分配給組織的內部稽核團隊

**D.**我將檢查是否積極使用威脅情報來保護組織資訊資產的機密性、完整性和可用性

**E.**我將確保組織的風險評估流程從有效的威脅情報開始

**F.**我將確定在威脅情報的生成中是否使用內部和外部資訊來源

**G.**我將回顧如何收集和評估與資訊安全威脅相關的資訊以產生威脅情報

**H.**我將確保採取適當措施，向最高管理階層通報目前威脅情報安排的有效性

***Answer:*** A,D,F

Explanation:

ACTUALTEST.COM

According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), control 5.7 requires an organization to establish and maintain a threat intelligence process to identify and evaluate information security threats that are relevant to its ISMS scope and objectives1. The organization should use internal and external sources of information, such as vulnerability databases, threat feeds, industry reports, etc., to produce threat intelligence that can be used to support risk assessment and treatment, as well as other information security activities1. Therefore, when auditing the organization's application of control 5.7, an ISMS auditor should verify that these aspects are met in accordance with the audit criteria.

Three options that represent valid audit trails for verifying control 5.7 are:

I will review the organisation's threat intelligence process and will ensure that this is fully documented: This option is valid because it can provide evidence of how the organization has established and maintained a threat intelligence process that is consistent with its ISMS scope and objectives. It can also verify that the process is documented according to clause 7.5 of ISO/IEC 27001:20221.

I will check that threat intelligence is actively used to protect the confidentiality, integrity and availability of the organisation's information assets: This option is valid because it can provide evidence of how the organization has used threat intelligence to support its risk assessment and treatment, as well as other information security activities, such as incident response, awareness, or monitoring. It can also verify that the organization has achieved its information security objectives according to clause 6.2 of ISO/IEC 27001:20221.

I will determine whether internal and external sources of information are used in the production of threat intelligence: This option is valid because it can provide evidence of how the organization has used various sources of information, such as vulnerability databases, threat feeds, industry reports, etc., to produce threat intelligence that is relevant and reliable. It can also verify that the organization has complied with the requirement of control 5.7 of ISO/IEC 27001:20221.

The other options are not valid audit trails for verifying control 5.7, as they are not related to the control or its requirements. For example:

I will speak to top management to make sure all staff are aware of the importance of reporting threats: This option is not valid because it does not provide evidence of how the organization has established and maintained a threat intelligence process or used threat intelligence to support its ISMS activities. It may be related to another control or requirement regarding information security awareness or communication, but not specifically to control 5.7.

I will ensure that the task of producing threat intelligence is assigned to the organisation s internal audit team: This option is not valid because it does not provide evidence of how the organization has established and maintained a threat intelligence process or used threat intelligence to support its ISMS activities. It may also contradict the requirement for auditor independence and objectivity, as recommended by ISO 19011:20182, which provides guidelines for auditing management systems.

I will ensure that the organisation's risk assessment process begins with effective threat intelligence: This option is not valid because it does not provide evidence of how the organization has established and maintained a threat intelligence process or used threat

intelligence to support its ISMS activities. It may also imply a prescriptive approach to risk assessment that is not consistent with ISO/IEC 27005:20183, which provides guidelines for information security risk management.
I will review how information relating to information security threats is collected and evaluated to produce threat intelligence: This option is not valid because it does not provide evidence of how the organization has established and maintained a threat intelligence process or used threat intelligence to support its ISMS activities. It may also be too vague or broad to be an effective audit trail, as it does not specify what criteria or methods are used for collecting and evaluating information.
I will ensure that appropriate measures have been introduced to inform top management as to the effectiveness of current threat intelligence arrangements: This option is not valid because it does not provide evidence of how the organization has established and maintained a threat intelligence process or used threat intelligence to support its ISMS activities. It may be related to another control or requirement regarding management review or performance evaluation, but not specifically to control 5.7.

**QUESTION NO: 175**
下列哪兩個是「不」涉及人際互動的審核方法的範例？
**A.**使用電話會議平台進行採訪
**B.**對受審核方的程序進行審查，為審核做準備
**C.**檢討受審核方對審核結果的回應
**D.**透過遠端存取被審核方伺服器分析數據
**E.**觀察遠端監控執行的工作
**F.**確認審核的日期和時間
***Answer:*** B,D
Explanation:
Audit methods are the techniques and procedures that auditors use to collect and evaluate audit evidence. Audit methods can be classified into two categories: those that involve human interaction and those that do not. Human interaction methods are those that require direct or indirect communication with the auditee or other relevant parties, such as interviews, questionnaires, surveys, observations, or walkthroughs. Non-human interaction methods are those that do not require any communication with the auditee or other parties, such as document reviews, data analysis, or remote surveillance.
Some examples of audit methods that do not involve human interaction are:
Performing a review of auditee's procedures in preparation for an audit: This method involves examining the auditee's documented information, such as policies, processes, records, or reports, to verify their adequacy and effectiveness in meeting the audit criteri a. The auditor does not need to interact with the auditee or anyone else to perform this method.
Analysing data by remotely accessing the auditee's server: This method involves accessing and processing the auditee's data, such as performance indicators, logs, metrics, or statistics, to verify their accuracy and reliability in meeting the audit criteria. The auditor does not need to interact with the auditee or anyone else to perform this method.
Reference:
ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) objectives and content from Quality.org and PECB ISO 19011:2018 Guidelines for auditing

ACTUAL4TEST.COM

management systems [Section 6.2.2]

**QUESTION NO: 176**
能夠證明所聲稱事件發生的資訊屬性。
**A.**電子連鎖信
**B.**誠信
**C.**可用性
**D.**輔助功能
***Answer:*** B
Explanation:
A property of information that has the ability to prove occurrence of a claimed event is integrity. Integrity is one of the three main objectives of information security, along with confidentiality and availability. Integrity ensures that information and systems are not corrupted, modified, or deleted by unauthorized actions or events. Integrity also implies that information and systems can be verified and validated as authentic and accurate. Electronic chain letters are not a property of information, but a type of spam or hoax message that may contain malicious or misleading content. Availability means that service should be accessible at the required time and usable only by the authorized entity. Accessibility is not a property of information, but a characteristic of usability that refers to how easy it is for users to access and interact with information and systems. Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 24. : [ISO/IEC 27001 Brochures | PECB], page 4. : [ISO/IEC 27001 LEAD AUDITOR - PECB], page 13.

**QUESTION NO: 177**
場景 8：苔絲
一個。 Malik 和 Michael
是一個由安全、合規以及業務規劃和策略領域的獨立且合格的專家組成的審計團隊。他們被指派到一家大型網頁設計公司Clastus進行認證審核。他們在進行審計時表現出了出色的職業道德，包括公正和客觀。這一次，Clastus 確信，如果獲得 ISO/IEC 27001
認證，他們將領先一步。
審計團隊負責人 Tessa 擁有審計專業知識，並且在 IT
相關問題、合規性和治理方面擁有非常成功的背景。馬利克擁有組織規劃和風險管理背景。他的專業知識依賴於對組織的安全控制及其風險承受能力的綜合和分析水平，以準確描述組織內部的風險水平 另一方面，Michael
是通過遵循嚴格的標準化程序進行控制評估的實際安全性的專家。
在執行所需的審計活動後，泰莎發起了一次審計團隊會議，他們分析了邁克爾的一項發現，以客觀、準確地就該問題做出決定。 Michael
遇到的問題是組織日常運作中的一個小問題，他認為這是由組織的一名 IT
技術人員造成的，因此，Tessa
會見了高層管理人員，並在他們詢問了責任人姓名後，告訴他們誰應該對這一問題負責，為了方便澄清和理解，Tessa 在審核的最後一天召開了結束會議。在這次會議上，她向 Clastus
管理層報告了發現的不符合情況。然而，Tessa 收到建議，避免在 Clastus
認證審核的審核報告中提供不必要的證據，確保報告保持簡潔並專注於關鍵發現。
根據審查的證據，審核小組起草了審核結論，並決定在授予認證之前必須對該組織的兩個領域進行審核。這些決定後來被提交給被審計方，但被審計方不接受調查結果並提議提供更多資訊

。儘管受審計方提出了意見，但審計員已經決定接受認證建議，因此沒有接受補充資訊。被審計單位的高階主管堅持審計結論並不代表事實，但審計小組仍堅持他們的決定。
根據上述情景，回答以下問題：
在分析了審計結論後，X公司接受了與發現的不符合項相關的風險，並決定不採取糾正措施。但他們的決定並未記錄在案。這可以接受嗎？
**A.**是的，受審計方的管理階層可以決定接受風險而不是實施糾正措施，並且無需記錄此類決定
**B.**否，受審核方接受風險而非實施糾正措施的決定應有理有據並記錄在案
**C.**否，受審核方必須針對審核期間記錄的所有觀察結果實施糾正措施
***Answer:*** B
Organizations are not required to mitigate every nonconformity but must justify their risk acceptance.
Relevant Standard Reference:
ISO/IEC 27001:2022 Clause 6.1.3 (Risk Treatment Documentation Requirements)
Explanation:
Comprehensive and Detailed In-Depth
B : Correct answer:
ISO/IEC 27001:2022 Clause 6.1.3 (Information Security Risk Treatment) requires that any decision to accept risk be documented and justified.
Failure to document this decision creates compliance and audit tracking gaps.
A : Incorrect:
Risk acceptance must always be documented for accountability.

**QUESTION NO: 178**
外部審計師收到了對研究開發公司進行 ISMS
審計的邀請。在接受之前，他們與被審計方的內部稽核師（他們的朋友）討論了先前的審計報告。這是可以接受的嗎？
**A.**不可以，外部審核員只能與認證機構討論被審核方之前的審核報告
**B.**是的，審核員可以在接受審核委託之前審查並討論先前的審核報告
**C.**不，審計師即使在決定是否接受審計委託時也應保持客觀性
***Answer:*** C
Explanation:
No, the auditor should uphold objectivity even when deciding whether to accept the audit mandate or not. Discussing previous audit reports with a friend who is an internal auditor at the auditee may compromise the external auditor's objectivity and independence.

**QUESTION NO: 179**
您是一位經驗豐富的 ISMS
審核團隊領導者。在進行第三方監督審核期間，您決定測試受審核方對 ISO/IEC 27001 風險管理要求的了解。
你問她一系列問題，答案要么是“那是真的”，要么是“那是假的”。她應該回答以下哪四項「這是真的」？
**A.**必須保留風險評估的結果
**B.**風險識別，用於確定資訊安全風險的嚴重程度
**C.**ISO/IEC 27001 提供了風險管理的概要方法

**D.**組織必須針對已識別的每個業務風險制定風險處理計劃
**E.**組織必須執行風險處理流程以消除其資訊安全風險
**F.**組織風險管理流程的初始階段應該是資訊安全風險評估
**G.**應每月進行一次風險評估
**H.**重大變化後應進行風險評估
***Answer:*** A,C,D,H
Explanation:
The following four statements are true according to ISO/IEC 27001's risk management requirements: 12 The results of risk assessments must be maintained. This is true because clause 8.2.3 of ISO/IEC 27001:2022 requires the organisation to retain documented information of the information security risk assessment process and the results12 ISO/IEC 27001 provides an outline approach for the management of risk. This is true because clause 6.1.2 of ISO/IEC 27001:2022 specifies the general steps for the information security risk management process, which include establishing the risk criteria, assessing the risks, treating the risks, and monitoring and reviewing the risks12 The organisation must produce a risk treatment plan for every business risk identified. This is true because clause 6.1.3 of ISO/IEC 27001:2022 requires the organisation to produce a risk treatment plan that defines the actions to be taken to address the unacceptable risks, the responsibilities, the expected dates, and the resources required12 Risk assessments should be undertaken following significant changes. This is true because clause 8.2.4 of ISO/IEC 27001:2022 requires the organisation to review and update the risk assessment at planned intervals or when significant changes occur12 The following four statements are false according to ISO/IEC 27001's risk management requirements:
Risk identification is used to determine the severity of an information security risk. This is false because risk identification is used to identify the assets, threats, vulnerabilities, and existing controls that are relevant to the information security risk management process. The severity of an information security risk is determined by the risk analysis, which evaluates the likelihood and impact of the risk scenarios12 The organisation must operate a risk treatment process to eliminate its information security risks. This is false because the organisation can choose from four options to treat its information security risks: avoid, transfer, mitigate, or accept. The organisation does not have to eliminate all its information security risks, but only those that are unacceptable according to its risk criteria12 The initial phase in an organisation's risk management process should be information security risk assessment. This is false because the initial phase in an organisation's risk management process should be establishing the risk management framework, which includes defining the risk management policy, objectives, scope, roles, responsibilities, and criteria. The information security risk assessment is the second phase in the risk management process12 Risks assessments should be undertaken at monthly intervals. This is false because there is no fixed frequency for conducting risk assessments in ISO/IEC 27001. The organisation should determine the appropriate intervals for reviewing and updating the risk assessment based on its risk appetite, risk profile, and operational context12 Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 180**
ISMS (1)----------幫助確定 (2)----------,
**A.**(1) 持續改進，(2) 矯正措施的有效性
**B.**問題 (1) 管理評審，(2) 持續改善的機會
**C.**(1) 內部審計，(2) ISMS 範圍
***Answer:*** B
Explanation:
Management review is a crucial component of an ISMS that helps determine opportunities for continual improvement. Through management review, an organization assesses the performance and effectiveness of its ISMS, including reviewing opportunities for improvements and the need for changes to the ISMS, including the security policy and security objectives.

**QUESTION NO: 181**
審計結果是根據審計標準對收集的審計證據進行評估的結果。評估以下潛在的審計證據格式並選擇可接受的兩種。
**A.**對測試結果進行未簽署的手寫更改
**B.**IT 經理的事實陳述
**C.**有關 IT 審核結果的記錄資訊
**D.**系統工程師的言論，無法驗證
**E.**觀察先前錄製的演示危險活動表現的視頻
**F.**IT 經理與系統工程師之間對話的錄音
***Answer:*** C,E
Explanation:
According to the ISO/IEC 27001 Lead Auditor exam preparation guide1, audit evidence can be in various formats, such as records, statements of fact, or other information that is relevant and verifiable. Audit evidence can be collected by means of interviews, observation, sampling, testing, or other techniques. However, not all formats of audit evidence are acceptable or reliable. For example, unsigned hand written changes to test results (A) are not verifiable and may indicate tampering or falsification. Statements by a system engineer that cannot be verified (D) are also not reliable and may be biased or inaccurate. An audio recording of a dialog between the IT manager and a system engineer (F) may not be relevant to the audit criteria or may violate the confidentiality or consent of the parties involved. A statement of facts by the IT manager (B) may be relevant and verifiable, but it is not sufficient as audit evidence unless it is supported by other sources of information. Therefore, the two acceptable formats of audit evidence are documented information on results of IT audits and observation of a previously recorded video demonstrating the performance of a hazardous activity (E), as they are relevant to the audit criteria and can be verified by other means.
Reference: 1: https://pecb.com/pdf/exam-preparation-guides/pecb-iso-iec-27001-lead-auditor-exam-preparation-guide.pdf (page 9)

**QUESTION NO: 182**
場景 3：Rebuildy
是一家位於泰國曼谷的建築公司，專門從事住宅建築的設計、建造和維護。為了確保敏感專案

資料和客戶資訊的安全，Rebuildy 決定實施基於 ISO/IEC 27001 的資訊安全管理系統 (ISMS)。
ISMS 實施成果如下
* 資訊安全是透過應用一系列安全控制和製定政策、流程和程序來實現的。
* 安全控制是根據風險評估實施的，旨在消除風險或將風險降低到可接受的水平。
* 所有流程均基於計劃-執行-檢查-行動 (PDCA) 模型確保 ISMS 的持續改進。
*
資訊安全政策是根據最佳安全實務起草的安全手冊的一部分，因此，它不是一份獨立的文件。
* 資訊安全角色和職責已在每位員工的職位說明中明確說明
* 資訊安全管理系統的管理評審是依照計畫的時間間隔進行的。
Rebuildy
在經歷了兩次中期管理評審和一次年度內部審計後申請了認證。該前員工向審計團隊成員 Electra 提交了書面證據，Rebuildy 的主要客戶 Electra
也提交了有關相同問題的證據，審計員決定保留這份證據，而不是前員工的證據。審計團隊成員一直與 Electra
保持聯繫，直至審計完成，討論審計期間發現的不符合。伊萊克特拉提供了額外的證據來支持這些發現。
在審核開始時，審核小組對公司高階主管進行了訪談，討論了高階主管對 ISMS 實施的承諾等事項。從這些討論中獲得的證據都記錄在書面確認書中，用於確定 Rebuildy 是否符合 ISO/IEC 27001 的幾個條款。其中，發現以下不符合：
* 在公司的財務報告系統中偵測到了不當的使用者存取控制設定實例。
* 尚未建立獨立的資訊安全政策。相反，該公司使用根據最佳安全實踐起草的安全手冊。
在收到審計團隊的這些文件後，團隊負責人會見了 Rebuildy 的高層管理層，介紹了審計結果。審計小組報告了與財務報告系統和缺乏獨立資訊安全政策有關的調查結果。高階主管對調查結果表示不滿，並認為審計組長的行為不專業，暗示他們可能會要求更換組長。迫於壓力，審計組長決定與高階主管合作，淡化所發現的不符合項的重要性。因此，審計團隊負責人調整了報告以呈現更有利的觀點，從而歪曲了 Rebuildy 合規問題的真實程度。
根據上述情景，回答以下問題：
根據情境 3 的最後一段，審計團隊負責人犯了什麼錯誤？

**A.** 一般疏忽

**B.** 嚴重疏忽

**C.** 詐欺

***Answer:*** C

The audit team leader knowingly falsified the audit report to downplay nonconformities. Fraud involves intentional deception or misrepresentation of information, making this a fraudulent act.
A: Ordinary negligence (Incorrect):
Ordinary negligence is a failure to exercise reasonable care, but this case involved intentional misconduct.
B: Gross negligence (Incorrect):
Gross negligence is extreme carelessness but does not involve deliberate misrepresentation.
Relevant Standard Reference:
Explanation:
Comprehensive and Detailed In-Depth

ACTUALTEST.COM

**QUESTION NO: 183**
在發生資訊安全事件時，應遵守系統使用者的角色和責任，但以下情況除外：
**A.**透過服務台發現後通報可疑或已知事件
**B.**必要時保留證據
**C.**如有需要，在調查期間與調查人員合作
**D.**讓所有員工了解資訊安全事件詳細信息
***Answer:*** D
Explanation:
The role and responsibility that system users should not observe in the event of an information security incident is D: make the information security incident details known to all employees. This is not a proper role or responsibility for system users, as it could cause unnecessary panic, confusion or speculation among employees who are not involved in the incident response process. It could also compromise the confidentiality and integrity of the incident information, which could be sensitive or confidential in nature. Making the information security incident details known to all employees could also violate the information security policies and procedures of the organization, which may require a certain level of discretion and confidentiality when dealing with incidents. The other roles and responsibilities are correct, as they describe what system users should do in the event of an information security incident, such as reporting the incident to the Servicedesk (A), preserving evidence if necessary (B), and cooperating with investigative personnel if needed . These roles and responsibilities help to ensure a quick, effective and orderly response to information security incidents. ISO/IEC 27001:2022 requires the organization to implement procedures for reporting and managing information security incidents (see clause A.16.1). Reference: CQI & IRCA Certified ISO/IEC 27001:2022 Lead Auditor Training Course, ISO/IEC 27001:2022 Information technology - Security techniques - Information security management systems - Requirements, What is Information Security Incident Management?

**QUESTION NO: 184**
您正在對位於歐洲的住宅進行 ISMS 審核
名為 ABC
的療養院提供醫療保健服務。您會發現所有療養院居民都戴著電子腕帶，用於監控他們的位置、心跳和血壓。您了解到，電子腕帶會自動將所有資料上傳到人工智慧（AI）雲端伺服器，供醫護人員進行健康監測和分析。
審核計畫的下一步是驗證高階管理人員是否已製定資訊安全策略和目標。
在審計過程中，你們發現以下審計證據。
將審核證據與 ISO/IEC 27001:2022 中的相應要求進行配對。

| Audit Evidence | ISO/IEC 27001:2022 Requirements |
|---|---|
| The top management has signed and approved the ISMS policy (Document reference ID: ISMS_L1_01, version 1.3), mobile device policy (Document reference ID: ISMS_L2_07, version 1, release 4), and information security objectives are linked to Annex A's information security control objectives. | |
| Testing on 5 medical staff's mobile phones, all mobile phones are pin code protected screen lock and the 15 digits IME (International Mobile Equipment Identity) are registered in the asset register (Document reference ID: ISMS_L4_01, version 2.1). | |
| Interview with IT staff (employee ID: NH-1268); he is well informed and understood the mobile device policy. You checked his mobile phone and found it is 6 digits pin code protected and NO resident's data is stored. | |
| Interview with human resource manager; sampling on medical staff's information security roles and responsibilities are assigned in the job description (Document reference ID: ISMS_L4_04, version 1.0). | |

*To complete the table click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable text from the options below. Alternatively, you may drag and drop each of the following ISO/IEC 27001 clauses to the correct statement.*

Clause 5.1 a | Clause 7.3 | A.8.1 | Clause 5.3

***Answer:***

| Audit Evidence | ISO/IEC 27001:2022 Requirements |
|---|---|
| The top management has signed and approved the ISMS policy (Document reference ID: ISMS_L1_01, version 1.3), mobile device policy (Document reference ID: ISMS_L2_07, version 1, release 4), and information security objectives are linked to Annex A's information security control objectives. | Clause 5.1 a |
| Testing on 5 medical staff's mobile phones, all mobile phones are pin code protected screen lock and the 15 digits IME (International Mobile Equipment Identity) are registered in the asset register (Document reference ID: ISMS_L4_01, version 2.1). | A.8.1 |
| Interview with IT staff (employee ID: NH-1268); he is well informed and understood the mobile device policy. You checked his mobile phone and found it is 6 digits pin code protected and NO resident's data is stored. | Clause 7.3 |
| Interview with human resource manager; sampling on medical staff's information security roles and responsibilities are assigned in the job description (Document reference ID: ISMS_L4_04, version 1.0). | Clause 5.3 |

*To complete the table click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable text from the options below. Alternatively, you may drag and drop each of the following ISO/IEC 27001 clauses to the correct statement.*

Clause 5.1 a | Clause 7.3 | A.8.1 | Clause 5.3

**QUESTION NO: 185**

對於組織和利害關係人來說，第三方認可的 ISO/IEC 27001:2022 資訊安全管理系統認證有哪兩個選項的好處？

**A.**第三方認可的認證表示組織符合相關方期望的法律和法規要求

**B.**第三方認可的認證表示組織的 ICT 產品受到保護並獲得認證

**C.**第三方認可的認證表示組織的管理系統已維護且有效

**D.**第三方認可的認證顯示該組織的管理系統採用了系統的資訊安全方法

**E.**第三方認可的認證確保組織獲得更多客戶

**F.**第三方認可的認證確保組織的 IT 系統免受外部幹擾

***Answer:*** C,D

Explanation:

Third-party accredited certification of information security management systems to ISO/IEC 27001:2022 provides assurance to organisations and interested parties that the organisation's management system is maintained and effective, meaning that it conforms to the requirements of the standard, meets the organisation's objectives and policies, and addresses the risks and opportunities related to information security. Third-party accredited certification also demonstrates that the organisation's management system adopted a systematic approach to information security, meaning that it follows the Plan-Do-Check-Act (PDCA) cycle, applies the risk-based thinking principle, and considers the context and needs of the organisation and its stakeholders

**QUESTION NO: 186**

您正在一家提供醫療保健服務的住宅療養院進行 ISMS 初始認證審核。審計計劃的下一步是召開末次會議。在最終審核小組會議上，身為審核組組長，您同意報告 2 項輕微不符合項和 1 項改進機會，如下：

**Cosmic Certifications Limited**

Summary of audit findings:

**Opportunities for Improvement (OI)**

| Item | Findings | Requirements | Follow-up |
|---|---|---|---|
| 1. | The organisation should improve the overall awareness of information security incident management responsibility and process. | Clause 7.4 and Control A.5.24 | N/A |

Nonconformities (NCs)

| Item | Findings | Grade | Requirements | Follow-up |
|---|---|---|---|---|
| 1. | During the audit on the outsourced process, sampling one of the outsourced service contracts with WeCare the medical device manufacturer found that ABC does not include personal data protection and legal compliance as part of the information security requirements in the contract. | Minor | Clause 4.2 and Control A.5.20 | Corrective actions are required. |
| 2. | During the audit on information security during the business continuity process, sampling one of the service continuity and recovery plans for the resident's healthy status monitoring service. The auditor found the recovery plan has not yet been tested. | Minor | Clause 8.1 and Control A.5.29 | Corrective actions are required. |

signed by *Audit Team Leader*

ACTUAL4TEST.COM

選擇您將在最後一次會議上向受審核方提供建議的審核專案經理的建議選項。

**A.**在您批准擬議的糾正措施計劃後建議進行認證

**B.**建議在 6 個月內進行全面的重新審核

**C.**建議在 3 個月內進行部分審核
**D.**建議可以在一年內的監督審核中結束調查結果
***Answer:*** C
Explanation:
* Minor Nonconformities: The identified nonconformities are minor, meaning they don't pose a significant risk to the information security management system (ISMS). They are likely to be easily rectified with focused corrective actions.
* Opportunity for Improvement: This is not a nonconformity but a suggestion for enhancing the ISMS. It doesn't require immediate corrective action but should be addressed in the organization's continual improvement efforts.
* Initial Certification: As this is an initial certification audit, the organization is expected to demonstrate its commitment to addressing any gaps identified. A partial audit allows for a focused follow-up on the specific areas of nonconformity, ensuring they have been adequately addressed.
Why other options are not suitable:
* A . Recommend certification after your approval of the proposed corrective action plan: While certification is the goal, it's premature to recommend it before verifying the effectiveness of the corrective actions.
* B . Recommend that a full scope re-audit is required within 6 months: This is too extensive for minor nonconformities. A full re-audit is usually reserved for major nonconformities or systemic issues.
* D . Recommend that the findings can be closed out at a surveillance audit in 1 year: This is too long a timeframe for addressing the nonconformities. Prompt corrective action is necessary to demonstrate commitment to the ISMS.

**QUESTION NO: 187**
當使用者在緩衝區中新增的資料超出其儲存容量所允許的數量時，資料處理工具就會崩潰。該事件是由於該工具無法綁定檢查數組而引起的。這是什麼樣的漏洞？
**A.**固有漏洞，因為無法綁定檢查數組是資料處理工具的特性
**B.**外在漏洞，因為無法綁定檢查陣列與外部因素有關
**C.**無，工具無法綁定檢查陣列不是漏洞，而是威脅
***Answer:*** A

**QUESTION NO: 188**
在與管理認證機構審核計畫的個人進行討論時，客戶組織的管理系統代表會要求指定特定審核員來進行認證審核。選擇以下選項中的兩個來了解管理審核計劃的個人應如何應對。
**A.**通知管理系統代表他的請求可以被接受
**B.**建議管理系統代表選擇其他認證機構
**C.**表明他的請求將被考慮，但可能不會被接受
**D.**建議請求認證機構管理層允許該請求
**E.**告知管理系統代表，審核團隊的選擇是審核專案經理需要根據可用資源做出的決定
***Answer:*** C,E
Explanation:
According to ISO/IEC 17021-1, which specifies the requirements for bodies providing audit

and certification of management systems, a certification body should ensure that its auditors are competent, impartial, and independent from the auditee organization2. Therefore, if a Management System Representative of a client organization asks for a specific auditor for the certification audit, the individual(s) managing the audit programme should respond in a way that does not compromise these principles or create any conflict of interest or undue influence2. Two possible ways to respond are to state that his request will be considered but may not be taken up, as there may be other factors that affect the auditor selection process; or to advise him that the audit team selection is a decision that the audit programme manager needs to make based on the resources available, such as auditor availability, competence, location, etc2. The other options are not suitable ways to respond in this situation. For example, advising him that his request can be accepted may raise doubts about the objectivity and credibility of the auditor and the certification body; suggesting that he chooses another certification body may imply that his request is unreasonable or unethical; and suggesting asking the certification body management to permit his request may suggest that there is room for negotiation or manipulation in auditor selection2. Reference: ISO/IEC 17021-1:2015 - Conformity assessment - Requirements for bodies providing audit an d certification of management systems - Part 1: Requirements

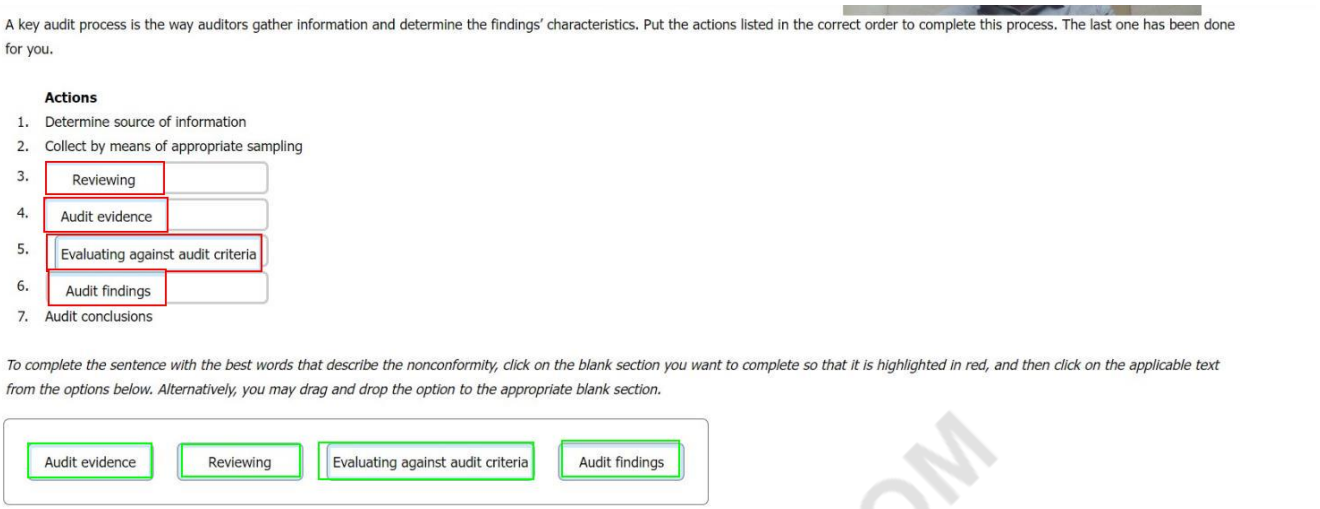
**QUESTION NO: 189**

**關鍵的審計流程是審計員收集資訊並確定調查結果特徵的方式。按正確的順序列出列出的操作以完成此過程。最後一項已為您完成。**




***Answer:***

ACTUAL4TEST.COM




**QUESTION NO: 190**
當應用於 ISO 19011 中所述的內部稽核計畫管理流程時，哪兩項活動與計畫-執行-檢查-行動循環的「檢查」階段一致？
**A.**保留內部審核記錄
**B.**定義每次內部審核的審核標準和範圍
**C.**更新內部審核計劃
**D.**建立基於風險的內部稽核計劃
**E.**進行內部審核
**F.**驗證內部稽核計畫的有效性
**G.**檢討內部稽核結果的趨勢
***Answer:*** F,G
Explanation:
The Check stage of the PDCA cycle involves monitoring and measuring the performance of the process and comparing it with the planned objectives and criteria. In the context of managing an internal audit programme, this stage includes verifying the effectiveness of the internal audit programme by evaluating whether it meets its objectives, scope, and criteria, and whether it is implemented in accordance with ISO 19011 guidelines1. It also includes reviewing the trends in internal audit results by analyzing the data collected from the audits, such as audit findings, nonconformities, corrective actions, opportunities for improvement, and customer feedback1. Reference: ISO 19011:2018 - Guidelines for auditing management systems

**QUESTION NO: 191**
您是經驗豐富的審核團隊領導，指導審核員進行培訓。
您的團隊目前正在對代表外部客戶儲存資料的組織進行第三方監督審核。接受培訓的審核員的任務是審查適用性聲明 (SoA) 中列出的並在現場實施的組織控制措施。
從以下內容中選擇您希望接受培訓的審核員審查的四項控制措施。
**A.**進出裝載區的通道
**B.**保密與保密協議
**C.**供應商協定中如何解決資訊安全問題
**D.**電源線和資料線如何進入建築物

ACTUAL4TEST.COM

**E.**在組織內部以及向其他組織傳輸訊息的規則
**F.**資訊資產清單的開發與維護
**G.**現場閉路電視和門禁系統的運行
**H.**組織的業務連續性安排
***Answer:*** B,C,E,F
Explanation:
According to the PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, the auditor in training should review the organisational controls that are related to the information security policy, the roles and responsibilities, the information classification, the information exchange, the supplier relationships, and the information asset management1. These controls are aligned with the ISO/IEC 27001 requirements for clauses 5, 7, 8.2, 8.3, and 8.42. The other controls (A, D, G, and H) are more relevant to the physical and environmental security, the communications security, or the business continuity management, which are not part of the organisational controls3. Reference: 1: PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, page 42, section 5.2.32: ISO/IEC 27001:2022, clauses 5, 7, 8.2, 8.3, and 8.43: ISO/IEC 27001:2022, clauses 8.1, 8.5, and 8.6.

**QUESTION NO: 192**
場景 2：Knight 是一家來自美國北加州的電子公司，開發電玩遊戲機。 Knight 在全球擁有 300 多名員工。在成立五週年之際，他們決定推出 G-Console，這是一款面向全球市場的新一代電玩遊戲機。 G-Console被認為是2021年的終極媒體機，將為玩家帶來最佳的遊戲體驗。
主機包將包括一副 VR 耳機、兩個
遊戲和其他禮物。
多年來，公司透過誠信、誠實和尊重客戶而建立了良好的聲譽。這種良好的聲譽是大多數熱衷遊戲玩家在Knight的G-console一上市就想擁有它的原因之一。
Knight 除了是一家非常以客戶為導向的公司之外，
也因其開發品質獲得了遊戲產業的廣泛認可。他們的價格比合理標準允許的要高一些。
儘管如此，對於 Knight
的大多數忠實客戶來說，這並不是一個問題，因為它們的品質是一流的。
作為世界頂級視訊遊戲機開發商之一，Knight 也經常成為惡意活動的焦點。該公司的 ISMS 已投入運作一年多了。 ISMS 範圍包括 Knight 的所有部門（財務和人力資源部門除外）。
最近，奈特的一些包含專有資訊的文件被駭客洩露。 Knight 的事件回應團隊 (IRT)
立即開始分析系統的每個部分以及事件的詳細資訊。
IRT 的第一個懷疑是 Knight
的員工使用了弱密碼，因此很容易被未經授權存取其帳戶的駭客破解。然而，在仔細調查該事件後，IRT 確定駭客透過擷取檔案傳輸協定 (FTP) 流量來存取帳戶。
FTP 是一種用於在帳戶之間傳輸檔案的網路協定。它使用明文密碼進行身份驗證。
受此資訊安全事件的影響，在IRT的建議下，Knight決定用Secure Shell (SSH)協定取代FTP，這樣任何捕獲流量的人都只能看到加密的資料。
在這些變化之後，奈特進行了風險評估，以驗證控制措施的實施是否已將類似事件的風險降至最低。該過程的結果得到了 ISMS
專案經理的批准，他聲稱實施新控制措施後的風險等級符合公司的風險接受程度。
根據該場景，回答以下問題：
根據情境 2，ISMS 範圍不適用於 Knight 的財務和人力資源部門。這是可以接受的嗎？

**A.**是的，ISMS 必須僅應用於可能直接影響資訊安全的流程和資產
**B.**是的，ISMS 範圍可以包括整個組織或僅包含組織內的特定部門
**C.**否，ISMS 範圍必須包括所有組織單位和流程
***Answer:*** B

**QUESTION NO: 193**
情境 6：Sinvestment
是一家提供家庭保險、商業保險和人壽保險的保險公司。該公司成立於北卡羅來納州，但最近在其他地區進行了擴張，包括歐洲和非洲。
Sinvestment
致力於遵守適用於其行業的法律法規，並防止任何資訊安全事件。他們實施了基於 ISO/IEC 27001 的 ISMS 並申請了 ISO/IEC 27001 認證。
認證機構指派兩名審核員進行審核。與Sinvestment簽訂保密協議後。他們開始了審計活動。
首先，他們審查了標準要求的文件，包括 ISMS
範圍聲明、資訊安全政策和內部稽核報告。審查過程並不容易，因為儘管 Sinvestment
表示他們已製定文件程序，但並非所有文件都具有相同的格式。
隨後，審計小組對Sinvestment的高階主管進行了多次訪談，以了解他們在ISMS實施中的作用。第一階段審計的所有活動都是遠端進行的，除了根據 Sinvestment
的要求在現場進行的文件資訊審查之外。
在此階段，審計人員發現沒有與資訊安全培訓和意識計劃相關的文件。被問及時，Sinvestment代表表示，公司已為所有員工提供資訊安全培訓課程。第一階段審計讓審計團隊對
Sinvestment 的營運和 ISMS 有了整體了解。
第二階段審核在第一階段審核三週後進行。審計小組觀察到，行銷部門（未包含在審計範圍內）沒有適當的程序來控制員工的存取權限。由於控制員工的存取權限是ISO/IEC
27001的要求之一，並且已包含在公司的資訊安全政策中，因此該問題包含在審計報告中。此外，在第二階段審計中，審計小組觀察到Sinvestment沒有記錄使用者活動日誌。
該公司的程序規定"記錄用戶活動的日誌應保留並定期審查"，但該公司沒有提供任何執行該程序的證據。
在所有審核活動中，審核員透過觀察、訪談、文件化資訊審查、分析和技術驗證來收集資訊和證據。對第一階段和第二階段的所有審核結果進行了分析，審核小組決定發布積極的認證建議。
根據上述場景，回答以下問題：
審計組依照Sinvestment的要求，現場審核了Sinvestment的文件資料。這是可以接受的嗎？
**A.**是的，Sinvestment有權要求在文件資訊審核期間任何文件不得帶離現場
**B.**不，Sinvestment 無法決定在哪裡進行文件審查，因為在第一階段審核之前簽署了保密協議
**C.**否，現場和場外活動的結合可能會對審核產生負面影響
***Answer:*** A
Explanation:
Yes, it is acceptable for Sinvestment to request that the review of documented information occur on-site. The company has the right to stipulate that no documents be carried off-site, especially to maintain control over sensitive information and ensure confidentiality, which aligns with the security controls expected in ISO/IEC 27001.

**QUESTION NO: 194**
您正在一家名為 ABC 的提供醫療保健服務的住宅療養院進行 ISMS

審核。您會發現所有療養院居民都戴著電子腕帶，用於監控他們的位置、心跳和血壓。您了解到，電子腕帶會自動將所有資料上傳到人工智慧（AI）雲端伺服器，供醫護人員進行健康監測和分析。
為了驗證 ISMS 的範圍，您採訪了管理系統代表 (MSR)，他解釋說 ISMS 範圍涵蓋外包資料中心。
選擇定義 ISMS 範圍內容的正確敘述之一。

**A.**ISMS 範圍不應涵蓋外部服務提供者，因為他們可能在遵守資訊安全政策和要求方面遇到困難

**B.**ISMS 範圍應考慮已發生的任何資訊安全問題以及任何利害關係人的要求

**C.**最有可能的 ISMS 範圍是涵蓋 IT 部門和外包資料中心

**D.**組織應僅遵循政府的建議，即法律和立法來定義 ISMS 範圍

***Answer:*** B

Explanation:
The correct statement which defines the content of the scope of the ISMS is that the ISMS scope should take any information security issues that have occurred and any interested parties' requirements into consideration. According to ISO/IEC 27001:2022, the scope of the ISMS should be determined by considering the internal and external issues, the requirements and expectations of interested parties, the interfaces and dependencies between the organisation and other parties, and the information security risks. The scope of the ISMS should also be aligned with the strategic direction of the organisation and be appropriate to its purpose and context. The scope of the ISMS should not be limited by the government's recommendation, nor exclude external service providers, nor be based on a single department or function, unless these are justified by the risk assessment and the needs and expectations of interested parties. Reference: = ISO/IEC 27001:2022, clause 4.3; PECB Candidate Handbook ISO 27001 Lead Auditor, page 15; ISO 27001 scope statement | How to set the scope of your ISMS - Advisera.

**QUESTION NO: 195**
下列哪一項關於組織 ISMS 中文件化資訊的敘述是不正確的？

**A.** 文件化資訊的目的在於指導 ISMS 操作並提供過程有效性的證據

**B.** 記錄資訊的收集本身就應該是一個目標

**C.** 記錄的資訊不應詳細且複雜，以確保完整性

***Answer:*** B

Explanation:
Comprehensive and Detailed In-Depth
ISO/IEC 27001:2022 Clause 7.5 (Documented Information) defines the role of documentation in an ISMS.
A . Correct Statement:
Documented information serves as a guideline for ISMS operations and provides audit evidence.
B . Incorrect Statement:
Collecting documented information is not a goal in itself.
The purpose of documentation is to support the ISMS and ensure compliance, not just to generate paperwork.
C . Correct Statement:

Documents should be clear and concise, avoiding unnecessary complexity while still being detailed enough to be useful.
Thus, documentation should be purposeful and functional, not just a bureaucratic requirement.
Relevant Standard Reference:

**QUESTION NO: 196**
場景七：Webvue。總部位於日本，是一家專門從事電腦軟體開發、支援和維護的技術公司。Webvue 提供跨各個技術領域和業務領域的解決方案。其旗艦服務是CloudWebvue，一個提供儲存、網路和虛擬運算服務的綜合雲端運算平台。專為企業和個人用戶設計。 CloudWebvue 以其靈活性、可擴展性和可靠性而聞名。
Webvue 決定僅將 CloudWebvue 納入其 ISO/IEC 27001 認證範圍。因此，第 1 階段和第 2 階段審計同時進行 Webvue
以其對資產保密的嚴格性而自豪，他們使用適當的加密控制來保護儲存在 CloudWebvue 中的資訊。任何機密級別的每條信息，無論是否供內部使用。受限的或機密的資訊首先用唯一的對應哈希值加密，然後儲存在雲端。肖恩。萊拉，山姆。和 Tin a。 Keith 是 IT 和資訊安全審計團隊中最有經驗的審計員，也是審計團隊的負責人。他的職責包括規劃審計和管理審計團隊。尚實踐生成的。在檢查了 Webvue
的加密政策後，他們得出結論，採訪中獲得的資訊是真實的。然而，由於該策略沒有解決加密金鑰的使用和壽命問題，因此加密金鑰仍在使用中。
依照 Webvue 和認證機構後來達成的協議，審計團隊選擇進行虛擬審計，專門專注於驗證 Webvue 是否符合 ISO/IEC 27001 的控制 8.11
資料屏蔽，以符合認證範圍和審計目標。他們檢查了 CloudWebvue 中保護資料所涉及的流程。重點關注公司如何遵守其政策和監管標準。作為此過程的一部分。審計團隊負責人 Keith 對相關文件和加密金鑰管理程序進行了截圖，以記錄和分析 Webvue 實踐的有效性。
Webvue 使用產生的測試資料用於測試目的。然而，根據與 QA 部門經理的訪談以及該部門使用的程序確定，有時會使用即時系統資料。在這樣的場景中，會產生大量數據，同時產生更準確的結果。測試資料受到保護和控制，這透過 Webvue 人員在審計期間執行的加密過程模擬得到驗證。儘管不在審計範圍之內，但安全培訓部門的不合規情況可能會對審計範圍內的流程產生影響，具體會影響 CloudWebvue 中的資料安全和加密實踐。因此，Keith將此發現納入審計報告中，並告知被審計方。
根據上述情景，回答以下問題：
根據情境 7，Keith 選擇將安全訓練部門納入審計報告是否適當？
**A.**是的，他應該將安全訓練部門納入審計報告
**B.**不，他應該在不告知被審計方所觀察到的情況的情況下將其納入
**C.**不，他不應該將其包括在內，而應該只向受審計方通報觀察到的情況
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
ISO 19011:2018 allows auditors to report significant issues that impact the audit scope, even if they arise outside the predefined scope.
Security Training Department nonconformities directly affected CloudWebvue's ISMS, justifying its inclusion in the audit report.

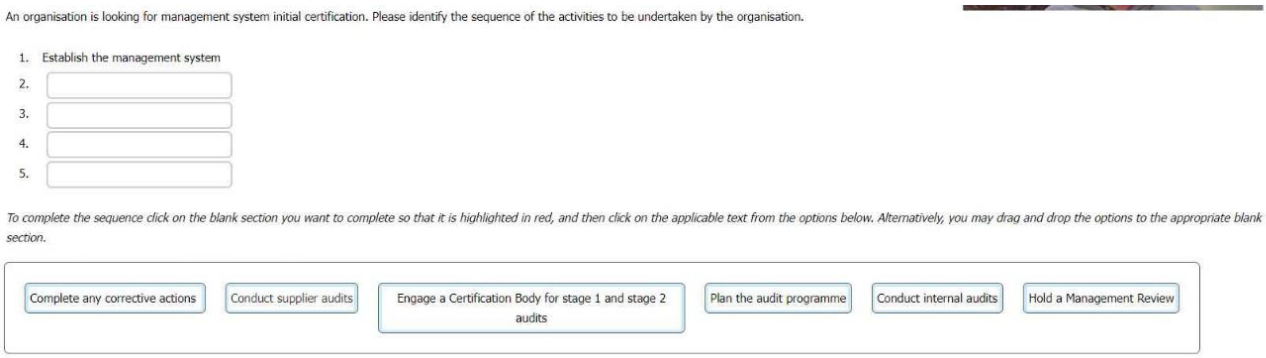
B . Incorrect:
Transparency is crucial in audits, and Keith correctly informed the auditee before reporting.
C . Incorrect:
Issues affecting ISMS implementation must be reported, as they pose risks to the certification scope.
Relevant Standard Reference:

**QUESTION NO: 197**
審計人員無法辨識 A 公司隱藏了不安全的網路架構。這是什麼類型的審計風險？
**A.**固有的
**B.**控制
**C.**檢測
***Answer:*** C
Explanation:
Detection risk refers to the risk that the auditor will not detect a material misstatement or significant issue within the organization's ISMS. In this case, the auditor's inability to identify Company A's insecure network architecture is a detection risk.

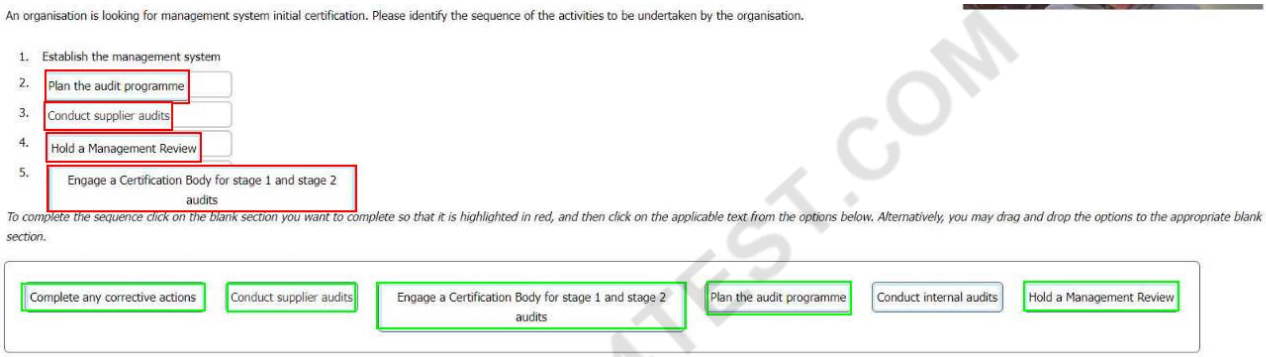
**QUESTION NO: 198**
哪種類型的審計要求被審計方和審計組在進行審計之前就遠端存取協議達成一致？
**A.**虛擬
**B.**內部
**C.**外部
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
Virtual audits require predefined remote access protocols to ensure secure, authorized connections for data review.
ISO 19011:2018 provides guidelines for virtual auditing security measures.
B . Incorrect:
Internal audits may use remote access, but agreement is not mandatory.
C . Incorrect:
External audits may involve remote access but do not require predefined agreements in all cases.
Relevant Standard Reference:

**QUESTION NO: 199**
某組織正在尋求管理系統初始認證。請確定組織將進行的活動的順序。
要完成序列，請按一下要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，您可以將選項拖曳到適當的空白部分。

ACTUAL4TEST.COM




***Answer:***




**QUESTION NO: 200**

當審核團隊的另一位成員向您尋求澄清時，您正在進行第三方監督審核。他們被要求評估組織對控制 5.7 - 威脅情報的應用。他們知道這是 2022 年版 ISO/IEC 中引入的新控制措施之一 27001，他們希望確保正確審核控制。

他們準備了一份清單來協助他們進行審核，並希望您確認他們計劃的活動符合控制要求。

下列哪三個選項代表有效的審計追蹤？

**A.**我將確保將產生威脅情報的任務分配給組織的內部稽核團隊

**B.**我將確保組織的風險評估流程從有效的威脅情報開始

**C.**我將與高階主管交談，以確保所有員工都意識到報告威脅的重要性

**D.**我將確保採取適當措施，向最高管理階層通報目前威脅情報安排的有效性

**E.**我將檢查該組織是否擁有完整記錄的威脅情報流程

**F.**我將檢查是否積極使用威脅情報來保護組織資訊資產的機密性、完整性和可用性

**G.**我將回顧如何收集和評估與資訊安全威脅相關的資訊以產生威脅情報

**H.**我將確定在威脅情報的生成中是否使用內部和外部資訊來源

***Answer:*** D,F,G

Explanation:

These three options represent valid audit trails for control 5.7, as they are aligned with the control's requirements and objectives. According to the web search results from my predefined tool, control 5.7 requires organisations to collect and analyse information relating to information security threats and use that information to take mitigation actions12. The control also specifies that threat intelligence should be relevant, perceptive, contextual, and actionable, and that it should be used to prevent, detect, or respond to threats34. Therefore, the auditor should verify how the organisation collects, analyses, and produces threat intelligence, how it uses threat intelligence to protect its information assets, and how it monitors and evaluates the effectiveness of its threat intelligence arrangements. The other

options are not valid audit trails, as they are either irrelevant, incorrect, or incomplete. For example:
* The task of producing threat intelligence is not assigned to the organisation's internal audit team, but to the person or team responsible for the ISMS, such as the information security manager or the information security committee5 .
* The organisation's risk assessment process does not begin with effective threat intelligence, but with the identification of the context, scope, and objectives of the ISMS . Threat intelligence is an input for the risk identification and analysis, but not the starting point of the risk assessment process.
* Speaking to top management to make sure all staff are aware of the importance of reporting threats is not sufficient to audit the control, as it does not address how the organisation collects, analyses, and produces threat intelligence, nor how it uses it to take mitigation actions. The auditor should also speak to the staff involved in the threat intelligence process, and review the relevant documents and records.
* Checking that the organisation has a fully documented threat intelligence process is not enough to audit the control, as it does not verify the implementation and effectiveness of the process. The auditor should also observe the process in action, and examine the outputs and outcomes of the process.
* Determining whether internal and external sources of information are used in the production of threat intelligence is a partial audit trail, as it only covers one aspect of the control. The auditor should also assess the quality, reliability, and relevance of the sources, and how the information is analysed and used.

**QUESTION NO: 201**
您是經驗豐富的 ISMS 審核團隊負責人，負責進行第三方監督訪問。
您注意到，儘管受審核方聲稱符合 ISO/IEC 27001:2022，但他們仍將改進稱為第 10.2 條（與 2013 年版一樣），而現在是 2022 年版中的第 10.1 條。您已確認它們符合標準中規定的所有 2022 年要求。
選擇您應該採取的操作之一。
**A.**注意審核報告中的問題
**B.**針對第 7.5.3 條提出不符合項 - 記錄資訊的控制
**C.**將其作為改進的機會
**D.**在閉幕會議上提出此事
***Answer:*** C
Explanation:
The correct action to take in this situation is to raise it as an opportunity for improvement. This is because the auditee is not violating any requirement of the standard, but rather using outdated terminology that does not reflect the current version of the standard. An opportunity for improvement is a suggestion for enhancing the performance or effectiveness of the ISMS1. It is not a nonconformity, which is a failure to fulfil a requirement2. Therefore, option B is incorrect. Option A is also incorrect, because noting the issue in the audit report without raising it as an opportunity for improvement would not provide any value or feedback to the auditee. Option D is also incorrect, because bringing the matter up at the closing meeting without documenting it as an opportunity for improvement would not ensure that the auditee takes any action to address it. Reference: 1: ISMS Auditing Guideline - ISO27000, page 11; 2:

ISO/IEC 27000:2022, 3.28; : ISMS Auditing Guideline - ISO27000; : ISO/IEC 27000:2022

**QUESTION NO: 202**
場景 6：Cyber ACrypt
是一家網路安全公司，透過提供反惡意軟體和設備安全、資產生命週期管理和設備加密來提供端點保護。為了根據 ISO/IEC 27001 驗證其 ISMS
並證明其對網路安全卓越的承諾，該公司經歷了由指定審計團隊負責人 John
領導的細緻的審計過程。
在接受審計任務後，John 立即組織了一次會議，概述了審計計劃和團隊角色。他們審查了 Cyber ACrypt
的文檔信息，包括資訊安全政策和操作程序，確保每一份文件都符合標準並具有標準化的格式，包括作者標識、生產日期、版本號和批准日期。這次徹底的檢查旨在確定持續改進和遵守 ISMS 要求。該文件對於審計團隊和 Cyber ACrypt
了解初步審計結果和需要關注的領域至關重要。
審計組也決定對主要相關方進行訪談。這項決定的目的是收集可靠的審計證據來驗證管理系統是否符合 ISO/IEC 27001 的要求。與 Cyber ACrypt
各個層級的相關方進行接觸為審計團隊提供了寶貴的觀點以及對 ISMS
的實施和有效性的理解。
第一階段審計報告揭露了值得關注的關鍵領域。適用性聲明 (SoA) 和 ISMS
政策在多個方面存在缺陷，包括風險評估不足、存取控制不充分以及缺乏定期政策審查。這促使 Cyber ACrypt
立即採取行動來解決這些缺陷。他們對戰略文件的快速回應和修改體現出了對實現合規的堅定承諾。
為了彌補審計團隊的網路安全知識差距而引入的技術專長在識別風險評估方法中的缺陷和審查網路架構方面發揮了關鍵作用。這包括評估防火牆、入侵偵測和預防系統以及其他網路安全措施，以及評估 Cyber ACrypt
如何偵測、回應和恢復外部和內部威脅。在約翰的監督下，技術專家將審計結果傳達給了 Cyber ACrypt
的代表。然而，審計小組發現，由於收取了被審計單位的諮詢費，該專家的客觀性可能受到影響。考慮到技術專家在審核過程中的行為，審核組長決定與認證機構討論這個問題。
根據上述情景，回答以下問題：
根據情境 6，第一階段審計的訪談目標是否由審計小組相應設定？
**A.**是的，訪談的目的是收集審核證據，以驗證管理系統是否符合 ISO/IEC 27001 要求
**B.**否，訪談的目的與管理系統的關鍵績效指標 (KPI) 不一致，從而降低了審核的有效性
**C.**不，面試的目的是確保充分了解受審核方面臨的挑戰
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
The primary goal of audit interviews is to validate compliance with ISO/IEC 27001.
ISO 19011:2018 states that interviews are a method to gather audit evidence.
B . Incorrect:
KPIs are relevant for performance measurement, but interviews focus on compliance validation.
C . Incorrect:

Understanding business challenges is secondary; the primary objective is ISO/IEC 27001 compliance verification.
Relevant Standard Reference:

**QUESTION NO: 203**
在分析審核結論後，X
公司決定接受與其中一項發現的不合格項相關的風險。他們聲稱無需採取糾正措施；然而，他們的決定並沒有記錄在案。這是可以接受的嗎？
**A.**是的，被審核方的管理階層可以決定接受風險而不是實施糾正措施，並且無需記錄此類決定
**B.**不，被審核方接受風險而不是實施糾正措施的決定應該有理由並記錄在案
**C.**否，受審核方必須對審核期間記錄的所有觀察結果實施糾正措施
***Answer:*** B
Explanation:
According to ISO/IEC 27001 standards, if the auditee decides to accept the risk instead of implementing corrective actions for a nonconformity, this decision should be justified and documented. Documenting such decisions is essential for maintaining the integrity of the ISMS and for demonstrating that the decision was made based on informed judgment.

**QUESTION NO: 204**
情境 4：SendPay
是一家金融公司，透過代理商和金融機構網路提供服務。他們的主要服務之一是在全球範圍內轉帳。 SendPay
作為一家新公司，致力於為客戶提供最優質的服務。由於該公司提供國際交易，因此要求客戶提供個人信息，例如身份、交易原因以及完成交易可能需要的其他詳細信息。因此，SendPay已實施安全措施來保護客戶的訊息，包括偵測、調查和回應可能出現的任何資訊安全威脅。他們對提供安全服務的承諾也體現在 ISMS 實施過程中，該公司投入了大量時間和資源。
去年，SendPay
推出了他們的數位平台，允許透過智慧型手機或筆記型電腦等電子設備進行貨幣交易，而無需支付額外費用。透過這個平台，SendPay
的客戶可以隨時隨地發送和接收資金。該數位平台幫助SendPay簡化了公司營運並進一步拓展了業務。當時SendPay正在外包其軟體業務，因此該專案是由外包公司的軟體開發團隊完成的。
該團隊還負責維護 SendPay 的技術基礎設施。
最近，該公司在實施 ISMS 近一年後申請了 ISO/IEC 27001
認證。他們與符合其標準的認證機構簽訂了合約。不久之後，認證機構任命了一個由四名審核員組成的團隊來審核 SendPay 的 ISMS。
審計過程中，發現以下情況：
1.外包軟體公司在未事先通知的情況下終止了與SendPay的合約。結果，SendPay
無法立即將服務恢復到內部，其營運中斷了五天。審計人員要求 SendPay
的代表提供證據，證明他們在合約終止的情況下有計劃遵循。這些代表沒有提供任何書面證據，但在接受審計時，他們告訴審計人員，SendPay的高層已經確定了另外兩家軟體開發公司，如果類似情況再次發生，可以立即提供服務。
2. 沒有證據顯示對外包給軟體開發公司的活動進行了監控。 SendPay
的代表再次告訴審計人員，他們定期與軟體開發公司溝通，並適當地告知可能發生的任何變更。

3.防火牆測試未發現異常狀況。審核員測試了防火牆配置，以確定這些服務提供的安全等級。他們使用資料包分析器來測試防火牆策略，這使他們能夠即時檢查發送或接收的資料包。
根據該場景，回答以下問題：
關於觀察到的第三種情況，審計人員自己測試了SendPay網路中實施的防火牆的配置。您如何描述這種情況？請參閱場景 4。
**A.**可接受的，需要技術證據來驗證技術流程的運作
**B.**不可接受，審核員應僅觀察系統或設備配置的測試，而不應自行測試系統
**C.**不可接受，審核期間不應測試防火牆配置，因為這可能會影響系統的運作
***Answer:*** A
Explanation:
It is acceptable and often necessary for auditors to test technical controls such as firewalls to validate the operation and effectiveness of these processes during an ISMS audit. This hands-on testing provides concrete, technical evidence of the security measures' performance.

**QUESTION NO: 205**
您是經驗豐富的審核團隊領導，指導審核員進行培訓。
您的團隊目前正在對代表外部客戶儲存資料的組織進行第三方監督審核。接受培訓的審核員的任務是審查適用性聲明 (SoA) 中列出的並在現場實施的實體控制措施。
從以下內容中選擇您希望接受培訓的審核員審查的四項控制措施。
**A.**進出裝載區的通道
**B.**電源線和資料線如何進入建築物
**C.**資訊安全意識、教育與培訓
**D.**對人員進行驗證檢查
**E.**資訊資產清單的開發與維護
**F.**現場閉路電視和門禁系統的運行
**G.**組織維護設備的安排
**H.**組織的業務連續性安排
***Answer:*** A,B,F,G
Explanation:
The four controls from the list that are related to PHYSICAL aspects of the ISMS are:
* Access to and from the loading bay
* How power and data cables enter the building
* The operation of the site CCTV and door control systems
* The organisation's arrangements for maintaining equipment
These controls are derived from the ISO 27001 Annex A, which provides a comprehensive list of information security controls that can be applied to an ISMS1. The other controls in the list are more related to ORGANIZATIONAL, LEGAL, or HUMAN aspects of the ISMS, which are also important, but not the focus of this question.
According to the ISMS Auditing Guideline2, the auditor in training should review the PHYSICAL controls by:
* Checking the SoA to identify the applicable controls and their implementation status
* Interviewing the relevant staff and management to verify their understanding and involvement in the controls

ACTUAL4TEST.COM

* Observing the physical and environmental conditions to confirm the existence and effectiveness of the controls
* Examining the relevant documents and records to validate the compliance and performance of the controls I hope this helps you prepare for the exam.

**QUESTION NO: 206**
選出最能完整描述審計結果的句子的單字。




***Answer:***




**QUESTION NO: 207**
下列哪一個選項是與人員管理相關的控制措施，旨在避免事件的發生？
**A.**組織定期為員工提供安全意識和培訓課程
**B.**在新部門整合到組織後，組織總是會檢視安全策略
**C.**組織定期進行使用者存取審查，以驗證只有授權員工才能存取機密資訊
***Answer:*** A
Explanation:
Regular security awareness and training sessions for employees are a control measure aimed at preventing security incidents by ensuring that personnel are aware of information security threats and concerns, and understand their roles and responsibilities in safeguarding organizational assets. This proactive approach is designed to educate employees on the importance of security practices and to avoid the occurrence of security incidents. Reference: = This answer is based on the principles of personnel security management as outlined in ISO/IEC 27001, particularly in Annex A.7 which deals with human resource security before, during, and after employment, and Annex A.9 which focuses on access control and ensuring that employees have access only to the information that is necessary for their job role

**QUESTION NO: 208**
您是一位經驗豐富的 ISMS
審核團隊負責人，正在與分配給您的審核團隊的正在接受培訓的審核員進行交談。您希望確保他們了解計劃-實施-檢查-行動週期的檢查階段對於資訊安全管理系統的運作的重要性。
您可以透過要求他選擇最能完成句子的單字來做到這一點：
要使用最佳單字完成句子，請按一下要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，您可以將該選項拖曳到適當的空白部分。




***Answer:***




Reference:
ISO/IEC 27001:2022 Information technology - Security techniques - Information securit y management systems - Requirements ISO/IEC 27003:2022 Information technology - Security techniques - Information security management systems - Guidance Assess | Definition of Assess by Merriam-Webster Regular | Definition of Regular by Merriam-Webster Suitability | Definition of Suitability by Merriam-Webster

**QUESTION NO: 209**
您是一位經驗豐富的 ISMS 審核員，目前正在為正在接受首次初始認證審核的 ISMS 審核員提供支援。她問您在審核組織的資訊安全目標時應該驗證什麼。您詢問她在審核清單中包含了哪些內容，她提供了以下答案。
對於 ISO/IEC 27001 的符合性，您會擔心以下哪三個答案：
2022 年？
**A.**我將檢查如何將每個資訊安全目標傳達給需要了解該目標的人員，以便實現該目標
**B.**我將檢查高階主管是否已確定本年度的資訊安全目標。如果沒有，我將檢查該任務是否已按計劃完成
**C.**我將檢查資訊安全目標是否寫在紙上，以便每個人都清楚需要實現什麼、如何實現以及何時實現
**D.**我將檢查是否有適當的流程來定期重新審視資訊安全目標，以便在情況需要時修改或取消這些目標
**E.**我將檢查是否已為每個目標設定完成日期，以及是否有任何目標缺少「實現」日期
**F.**我將檢查是否已確定實現每個目標所需的預算、人力和材料
**G.**我將檢查所有資訊安全目標是否都是可衡量的。如果它們不可衡量，組織將無法追蹤它們的進展
***Answer:*** B,C,E
Explanation:
According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), clause 6.2 requires an organization to establish information security

objectives at relevant functions and levels1. The objectives should be consistent with the information security policy; measurable (if practicable) or capable of being evaluated; monitored; communicated; updated as appropriate1. Therefore, when auditing an organization's information security objectives, an ISMS auditor should verify these aspects in accordance with the audit criteria.
Three responses from the ISMS auditor in training that would cause concern in relation to conformity with ISO/IEC 27001:2022 are:
I am going to check that top management have determined the Information Security objectives for the current year. If not, I will check that this task has been programmed to be completed: This response would cause concern because it implies that the auditor in training is not aware of the requirement to establish information security objectives at relevant functions and levels, not just at the top management level. It also implies that the auditor in training is willing to accept a delay or postponement in determining the information security objectives, which may affect the ISMS performance and effectiveness.
I am going to check that the Information Security objectives are written down on paper so that everyone is clear on what needs to be achieved, how it will be achieved, and by when it will be achieved: This response would cause concern because it implies that the auditor in training is not aware of the requirement to establish information security objectives that are measurable (if practicable) or capable of being evaluated, not just written down on paper. It also implies that the auditor in training is not aware of the flexibility and suitability of different media or formats for documenting and communicating information security objectives, such as electronic or digital records, posters, newsletters, etc.
I am going to check that a completion date has been set for each objective and that there are no objectives with missing 'achieve by' dates: This response would cause concern because it implies that the auditor in training is not aware of the requirement to establish information security objectives that are monitored, not just completed by a certain date. It also implies that the auditor in training is not aware of the possibility and necessity of updating information security objectives as appropriate, such as when changes occur in the internal or external context of the organization, or when new risks or opportunities arise.
The other responses from the ISMS auditor in training are acceptable and do not cause concern in relation to conformity with ISO/IEC 27001:2022. For example, checking how each Information Security objective has been communicated to those who need to be aware of it in order for the objective to be achieved is relevant to verifying the communication aspect of clause 6.2; checking that there is a process in place to periodically revisit Information Security objectives, with a view to amending or cancelling them if circumstances necessitate this is relevant to verifying the updating aspect of clause 6.2; checking that the necessary budget, manpower and materials to achieve each objective has been determined is relevant to verifying the planning aspect of clause 6.2; checking that all the Information Security objectives are measurable. If they are not measurable the organisation will not be able to track progress against them is relevant to verifying the measurability aspect of clause 6.2.
Reference: ISO/IEC 27001:2022 - Information technology - Security techniques - Informati on security management systems - Requirements

**QUESTION NO: 210**
完成第一階段並準備第二階段初步認證審核後，受審核方通知審核小組負責人，他們希望擴大審核範圍，以包括該組織最近收購的另外兩個場所。

考慮到這些訊息，您希望審計小組負責人採取什麼行動？
**A.**安排使用視訊會議平台完成兩個站點的遠端第一階段審核
**B.**增加第 2 階段審核的長度以包含額外的站點
**C.**通知被審核方審核組長接受請求
**D.**獲取有關其他站點的信息，以通知管理審核計劃的個人
***Answer:*** D
Explanation:
According to the PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, the audit team leader should obtain information about the additional sites to inform the individual(s) managing the audit programme, as this may affect the audit objectives, scope, criteria, duration, resources, and risks. The audit team leader should also review the audit plan and make any necessary adjustments in consultation with the auditee and the audit client1.
Reference: 1: PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, page 27, section 4.3.2.2.

**QUESTION NO: 211**
您正在一家提供醫療保健服務的住宅療養院執行 ISMS 審核，並審查軟體程式碼管理 (SCM) 系統。您在 SCM 上總共發現了 10 個使用者帳戶。
您確認其中一位用戶 Scott 已辭職 9 個月
前。 SCM 系統管理員確認 Scott 最後一次檢出原始碼是在 1
個月前。他正在安全區域使用本機網路的授權桌面之一。
您檢查用戶註銷程序，其中規定“經理必須確保在辭職批准後立即從相關ICT系統和/或設備註銷用戶帳戶和授權。”用戶Scott沒有註銷記錄。
IT 安全經理解釋說，Scott
辭職後每個月仍然會回到辦公室，提供原始碼維護的支援。這就是為什麼他在 SCM
上的帳戶仍然存在。
您想進一步調查其他領域以收集更多審計證據。選擇三個不是有效審計追蹤的選項。
**A.**收集更多關於如何定期審查存取控制以維護安全的證據（與控制措施 A.5.35 相關）
**B.**收集更多關於如何管理 Scott 從全職工作到兼職工作的轉變的證據（與控制措施 A.6.5 相關）
**C.**從新僱傭關係下人力資源部門進行的 Scott 背景核查中收集更多證據。（與控制 A.6.1 相關）
**D.**收集更多證據來證明 Scott 辭職的原因以及他的重新任職是否存在利益衝突。（與控制措施 A.5.3 相關）
**E.**收集更多有關 Scott 如何存取員工的桌面和本地網路的證據。（與控制 A.5.15 相關）
**F.**收集更多有關 Scott 如何存取安全區域的證據。（與控制 A.8.4 相關）
**G.**收集更多有關組織如何支付 Scott 原始碼維護支援服務費用的證據。（與控制 A.6.2 相關）
**H.**收集更多證據，了解 Scott 保存他查看的原始程式碼的位置以及如何保護它。（與控制 A.8.4 相關）
***Answer:*** B,D,G
Explanation:
The options B, D, and G are not valid audit trails because they are not directly related to the ISMS requirements or the audit criteria. They are more relevant to the human resource management or the contractual arrangements of the organization, which are outside the

scope of the ISMS audit. The other options are valid audit trails because they can provide evidence of how the organization implements and maintains the ISMS controls related to access control, secure areas, and information security aspects of business continuity management. Reference:
PECB Candidate Handbook ISO/IEC 27001 Lead Auditor, page 16, section 4.2.1 ISO/IEC 27001:2013, clauses A.5.3, A.5.15, A.5.35, A.6.1, A.6.2, A.6.5, A.8.4, A.17.1 ISO 19011:2018, clause 6.2.2

**QUESTION NO: 212**
在第三方認證審核期間，受審核方會提供您問題清單。下列哪四項構成 ISO/IEC 27001:2022 管理系統背景下的「外部」問題？
**A.**為因應高通膨而提高利率
**B.**因政府政策改變而導致補助金減少
**C.**訓練支出削減導致員工能力水準低下
**D.**因管理不善導致缺勤增加
**E.**人口老化導致勞動成本上升
**F.**由於政府制裁而無法購買原料
**G.**由於員工假期減少，士氣低落
**H.**與過時的生產設備有關的生產率下降
***Answer:*** A,B,E,F
Explanation:
According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), clause 4.1 requires an organization to determine external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended outcomes of its ISMS2. External issues are those that originate from outside the organization, such as legal, regulatory, cultural, social, political, economic, natural and competitive factors2. Internal issues are those that originate from within the organization, such as governance, structure, roles and responsibilities, policies, objectives, culture, capabilities, resources and information systems2. Therefore, based on this definition, four examples of external issues in the context of a management system to ISO/IEC 27001:2022 are a rise in interest rates in response to high inflation (which affects the economic environment of the organization), a reduction in grants as a result of a change in government policy (which affects the political and legal environment of the organization), higher labour costs as a result of an aging population (which affects the social and demographic environment of the organization), and inability to source raw materials due to government sanctions (which affects the trade and supply environment of the organization)2. The other options are examples of internal issues, as they originate from within the organization or its activities. For example, poor levels of staff competence as a result of cuts in training expenditure (which affects the capabilities and resources of the organization), increased absenteeism as a result of poor management (which affects the culture and performance of the organization), poor morale as a result of staff holidays being reduced (which affects the motivation and satisfaction of the organization's personnel), and a fall in productivity linked to outdated production equipment (which affects the efficiency and quality of the organization's processes)2. Reference:
ISO/IEC 27001:2022 - Information technology - Security techniques - Information securi

ACTUAL4TEST.COM

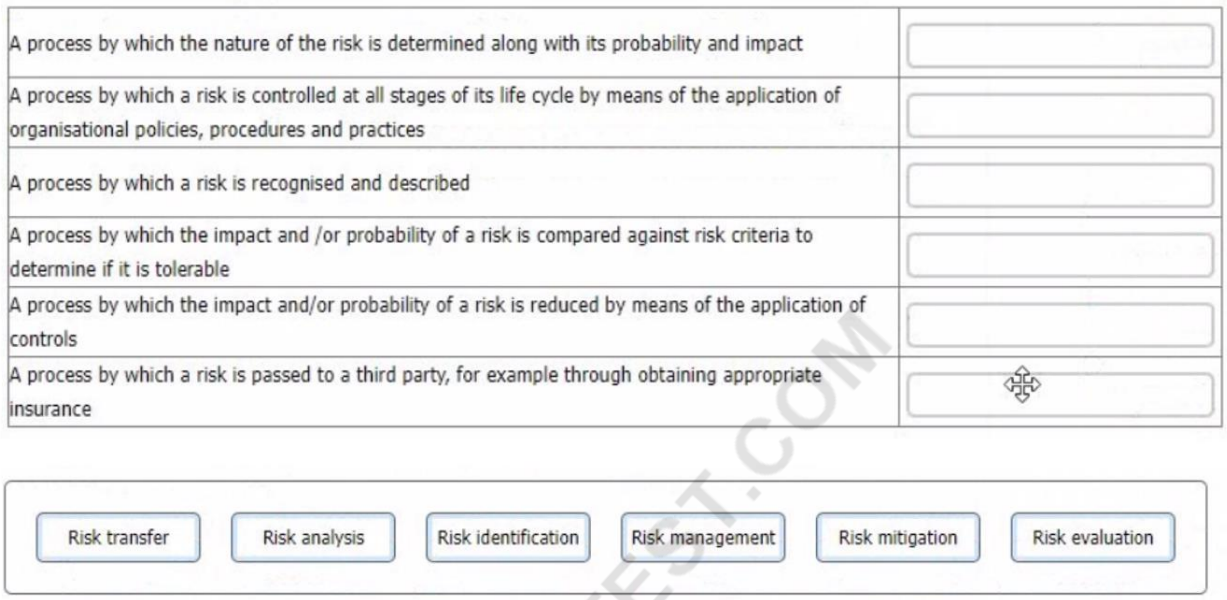
ty management systems - Requirements

**QUESTION NO: 213**
下列哪兩個短語適用於「審計目標」？
**A.**審核持續時間
**B.**確定一致性
**C.**檢查法律合規性
**D.**審核員能力
**E.**修改管理政策
**F.**如果需要，確定改進的機會
***Answer:*** B,F
Explanation:
The audit objectives are the purpose and scope of an audit, as defined by the audit client and the auditor. According to the ISO/IEC 27001 standard, the audit objectives for an ISMS audit may include determining the extent of conformity of the ISMS with the audit criteria, evaluating the ability of the ISMS to ensure the organization meets its information security objectives, and identifying potential areas for improvement of the ISMS12. Reference: = 1: PECB Candidate Handbook - ISO/IEC 27001 Lead Auditor, page 192: ISO/IEC 27007:2011 Information technology - Security techniques - Guidelines for information security managemen t systems auditing, clause 4.2.1.

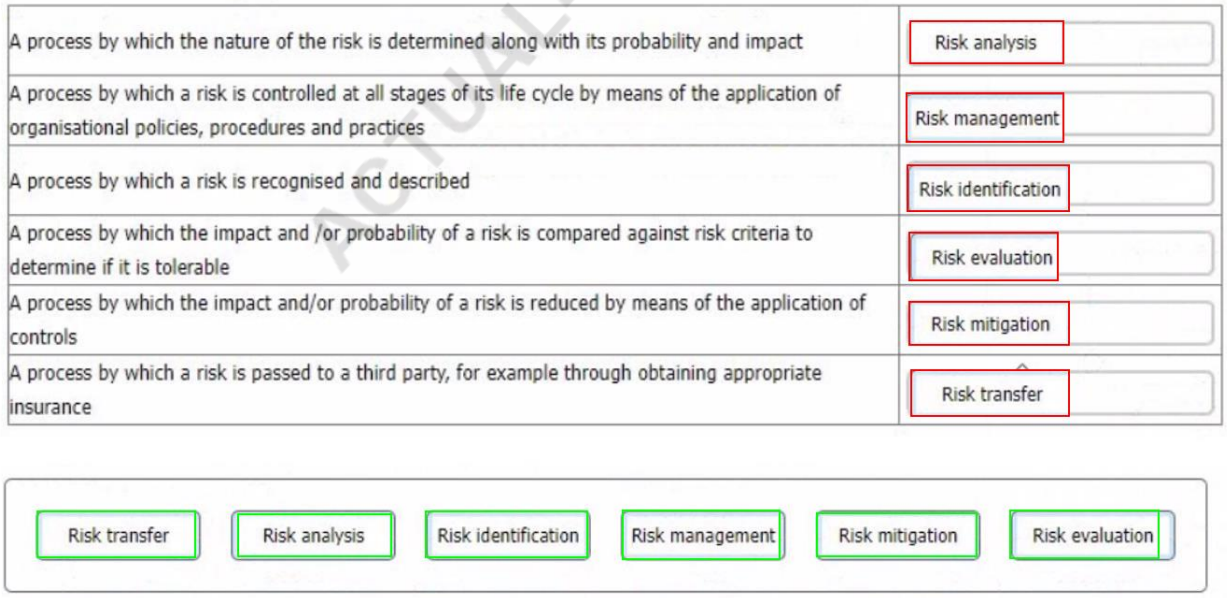
**QUESTION NO: 214**
您正在國際物流組織的出貨部門進行 ISMS
審核，該組織為當地醫院和政府辦公室等大型組織提供運輸服務。包裹通常包含藥品、生物樣本以及護照和駕駛執照等文件。您注意到公司記錄顯示大量退貨，原因包括標籤地址錯誤，以及在 15% 的情況下，一個包裹的不同地址有兩個或多個標籤。您正在面試運輸經理 (SM)。
您：出貨前檢查過嗎？
SM：任何明顯損壞的物品都會在出貨前由值班人員移除，但利潤微薄，因此實施正式檢查流程並不經濟。
您：退貨後會採取什麼措施？
SM：這些合約大多價值相對較低，因此我們認為，簡單地重新列印標籤並重新發送單一包裹比實施調查更容易、更方便。
您提出不符合項。參考該場景，您希望受審核方在進行後續審核時實施下列哪三項附件 A 控制措施？
**A.**5.11 資產返還
**B.**5.13 資訊標籤
**C.**5.3 職責分離
**D.**5.32 智慧財產權
**E.**5.34 隱私與個人識別資訊 (PII) 的保護
**F.**5.6 與特殊利益團體的聯繫
**G.**6.3 資訊安全意識、教育與培訓
**H.**6.4 紀律程序
***Answer:*** B,E,G
Explanation:

The three Annex A controls that you would expect the auditee to have implemented when you conduct the follow-up audit are:
B . 5.13 Labelling of information
E . 5.34 Privacy and protection of personal identifiable information (PII) G . 6.3 Information security awareness, education, and training B . This control requires the organisation to label information assets in accordance with the information classification scheme, and to handle them accordingly12. This control is relevant for the auditee because it could help them to avoid misaddressing labels and sending parcels to wrong destinations, which could compromise the confidentiality, integrity, and availability of the information assets. By labelling the information assets correctly, the auditee could also ensure that they are delivered to the intended recipients and that they are protected from unauthorized access, use, or disclosure.
E . This control requires the organisation to protect the privacy and the rights of individuals whose personal identifiable information (PII) is processed by the organisation, and to comply with the applicable legal and contractual obligations13. This control is relevant for the auditee because it could help them to prevent the unauthorized use of residents' personal data by a supplier, which could violate the privacy and the rights of the residents and their family members, and expose the auditee to legal and reputational risks. By protecting the PII of the residents and their family members, the auditee could also enhance their trust and satisfaction, and avoid complaints and disputes.
G . This control requires the organisation to ensure that all employees and contractors are aware of the information security policy, their roles and responsibilities, and the relevant information security procedures and controls14. This control is relevant for the auditee because it could help them to improve the information security culture and behaviour of their staff, and to reduce the human errors and negligence that could lead to information security incidents. By providing information security awareness, education, and training to their staff, the auditee could also increase their competence and performance, and ensure the effectiveness and efficiency of the information security processes and controls.
Reference:
1: ISO/IEC 27001:2022 - Information technology - Security techniques - Information securi ty management systems - Requirements, Annex A 2: ISO/IEC 27002:2022 - Informatio n technology - Security techniques - Code of practice for information security controls, claus e 8.2.1 3: ISO/IEC 27002:2022 - Information technology - Security techniques - Code of practice for information security controls, clause 18.1.4 4: ISO/IEC 27002:2022 - Information technology - Security techniques - Code of practice for information securit y controls, clause 7.2.2

**QUESTION NO: 215**
您是一位經驗豐富的 ISMS
審核團隊領導，為審核員提供培訓指導。他們對風險流程的理解不清楚，並要求您向他們提供下面詳細介紹的每個流程的範例。
將提供的每項描述與下列風險管理流程之一相符。
要填寫表格，請按一下要填寫的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，您可以將每個選項拖曳到適當的空白部分。




***Answer:***




Reference:
ISO/IEC 27001:2022 Information technology - Security techniques - Information securit y management systems - Requirements ISO/IEC 27005:2022 Information technology - Security techniques - Information security risk management

**QUESTION NO: 216**
為什麼在初次接觸時要考慮重要性？
**A.**確定審核持續時間
**B.**合理保證審核能夠成功完成
**C.**定義最小化偵測風險的流程
***Answer:*** B
Explanation:
Materiality should be considered during the initial contact to obtain reasonable assurance that

the audit can be successfully completed. Determining materiality helps establish the threshold for the significance of audit findings, ensuring that the audit focuses on substantial issues that could impact the audit conclusions.

**QUESTION NO: 217**
在第三方認證審核的背景下，有效的溝通非常重要。選擇包含有關審核上下文中通訊的正確答案的選項。
**A.**在審核期間，每位審核員應定期向受審核方和審核客戶傳達任何疑慮
**B.**審核期間，審核組長負責溝通
**C.**審核小組與受審核方之間的正式溝通管道可以在首次會議期間建立
**D.**無須建立正式的溝通安排，因為受審核方可以在審核期間隨時與審核員進行溝通
***Answer:*** C
Explanation:
In the context of a third-party certification audit, it is very important to have effective communication between the audit team and the auditee. The formal communication channels, such as the names and contact details of the audit team members, the auditee representatives, the audit client and any other relevant parties, can be established during the opening meeting. This helps to ensure that the audit objectives, scope, criteria, methods, schedule and any other arrangements are clearly understood and agreed by all parties. It also facilitates the exchange of information, feedback, requests, concerns and complaints during the audit process. Reference: = ISO 19011:2022, clause 6.4.2; PECB Candidate Handbook ISO 27001 Lead Auditor, page 25.

**QUESTION NO: 218**
您是 ISMS
審核員，正在對電信供應商進行第三方監督審核。您位於設備暫存室，網路交換器在傳送給客戶之前已預先編程。您注意到，最近未通過初始設定測試並被退回重新編程的交換器數量顯著增加。
你問首席測試員為什麼，她說，「這是最近 ISMS
升級的結果」。在升級之前，每個技術人員都有自己的硬拷貝工作說明。現在，我團隊的八名成員必須共用兩台筆記型電腦才能在線上存取客戶的設定說明。這些延誤給技術人員帶來了壓力，導致更多錯誤。
僅根據上述訊息，ISO/IEC 27001:2022 的哪一條條款最適合提出不合格項？選擇一個。
**A.**第 10.2 條 - 不合格與糾正措施
**B.**第 7.2 條 - 能力
**C.**第 7.5 條 - 記錄資訊
**D.**第 8.1 條 - 營運規劃與控制
***Answer:*** D

**QUESTION NO: 219**
您正在一家提供醫療保健服務的住宅療養院進行 ISMS
審核。審核計畫的下一步是驗證資訊安全事件管理流程。 IT
安全經理介紹了資訊安全事件管理程序，並解釋該流程基於 ISO/IEC 27035-1:2016。
您查看該文件並注意到一條聲明「任何資訊安全弱點、事件和事故應在識別後 1
小時內報告給聯絡人

(PoC)」。在訪問員工時，您發現大家對「弱點、事件、事件」意義的理解有差異。
您從事件追蹤系統中抽取過去 6 個月的事件報告記錄樣本，總結結果如下表所示。

| Type of report | Description | Resolution/Recovery Actions | Resolution/ Recovery Time |
|---|---|---|---|
| Information security weakness, report ID: 056 | The human resources manager's mobile phone was hacked by ransomware, asking for $1000 to unlock (decrypt) the data | IT department suggests the person shall pay the ransom to unlock the phone. No further action is needed. | 24 hours |
| Information security weakness, report ID: 078 | The medical staff's company mobile phone (with patient data) was hacked by ransomware, asking for $5000 to unlock (decrypt) the data | IT department suggests the company shall pay the ransom to unlock the company phone. No further action is needed. | 24 hours |
| Information security event, report ID: 090 | The cloud server does not respond and healthcare monitoring stops for 8 hours. | IT department reboots the cloud server remotely. No further action is needed. | 24 hours |
| Information security incident, report ID: 012 | The cloud server does not respond and healthcare monitoring stops for 48 hours. | IT department reboots thencloud server remotely. No further action is needed. | 24 hours |

您想進一步調查其他領域以收集更多審計證據。選擇兩個不會出現在您的審核追蹤中的選項。
**A.**透過訪問更多員工了解他們對報告流程的理解來收集更多證據。
（與控制措施 A.6.8 相關）
**B.**收集更多關於公司如何以及何時支付贖金以解鎖公司手機和資料（即信用卡和銀行轉帳）的證據。（與控制措施 A.5.26 相關）
**C.**收集更多有關人力資源經理如何以及何時支付贖金以解鎖個人行動資料（即信用卡和銀行轉帳）的證據。（與控制措施 A.5.26 相關）
**D.**收集更多有關組織如何確定事件恢復時間的證據。（與控制措施 A.5.27 相關）
**E.**收集更多證據，說明組織如何確定事件發生後無需採取進一步行動。（與控制措施 A.5.26 相關）
**F.**收集更多有關事件恢復程序的證據。（與控制措施 A.5.26 相關）
***Answer:*** B,C
Explanation:
* C . Collect more evidence on how and when the Human Resources manager pays the ransom fee to unlock personal mobile data, i.e., credit card, and bank transfer. (Relevant to control A.5.26) This is not relevant to the audit of the organization's incident management process. The HR manager's personal phone and how they handle a ransomware attack on it falls outside the scope of the ISMS audit. The organization is not responsible for personal devices.
* B . Collect more evidence on how and when the company pays the ransom fee to unlock the company's mobile phone and data, i.e., credit card, and bank transfer. (Relevant to control A.5.26) While seemingly relevant, this focuses on the method of payment for the ransom. The core issue is the organization paying the ransom at all, which is generally not best practice in incident response. The audit should focus on why this decision was made

and if alternative solutions were considered (e.g., data backups, device wiping and restoration).
Why the other options ARE relevant:
* A . Collect more evidence by interviewing more staff about their understanding of the reporting process. (Relevant to control A.6.8) This directly addresses the identified discrepancy in understanding "weakness, event, and incident," which is crucial for proper incident reporting.
* D . Collect more evidence on how the organisation determined the incident recovery time. (Relevant to control A.5.27) This investigates the basis for the 24-hour recovery time, which seems arbitrary and may not be appropriate for all incidents.
* E . Collect more evidence on how the organization determined no further action was needed after the incident. (Relevant to control A.5.26) This probes the adequacy of the incident response, especially the lack of preventative measures after paying the ransom.
* F . Collect more evidence on the incident recovery procedures. (Relevant to control A.5.26) This examines the actual procedures to assess their effectiveness and alignment with best practices.

**QUESTION NO: 220**
您正在 ABC Healthcare Services 的療養院執行 ISO 27001 ISMS 監督審核。 ABC 使用由供應商 WeCare
設計和維護的醫療保健行動應用程式來監控居民的健康狀況。在審核過程中，您了解到90%的居民家庭成員每週都會透過電子郵件和簡訊定期收到WeCare的醫療器材廣告。 ABC 與 WeCare
之間的服務協議禁止供應商使用居民的個人資料。美國廣播公司已收到許多居民及其家人的投訴。
服務經理表示，這些投訴作為資訊安全事件進行了調查，發現這些投訴是合理的。
已根據不合格和糾正措施管理程序規劃並實施糾正措施。
您寫了一份不合格項“ABC 未能遵守與居民及其家庭成員的個人資料相關的資訊安全控制 A.5.34（隱私和 PII 保護）。供應商 WeCare
使用居民的個人資訊向家庭成員。”從列出的糾正和糾正措施中選擇您希望 ABC 針對不合格項採取的三個選項。
**A.**ABC 要求 ISMS 顧問測試 ABC Healthcare 行動應用程式以防範網路犯罪。
**B.**ABC 取消與 WeCare 的服務協定。
**C.**ABC 確認資訊安全控制 A.5.34 包含在適用性聲明 (SoA) 中。
**D.**ABC 停止使用 ABC Healthcare 行動應用程式。
**E.**ABC 為所有供應商引入了資訊安全績效背景調查。
**F.**ABC 定期監控涉及第三方的所有適用法律和合約要求的遵守情況。
**G.**ABC 對 WeCare 違反合約採取法律行動。
**H.**ABC 對所有員工進行維護資訊安全協定重要性的訓練。
***Answer:*** B,E,F
Explanation:
The three options of the corrections and corrective actions listed that you would expect ABC to make in response to the nonconformity are:
B . ABC cancels the service agreement with WeCare.
E . ABC introduces background checks on information security performance for all suppliers.

F . ABC periodically monitors compliance with all applicable legislation and contractual requirements involving third parties.
B . This option is a possible correction and corrective action that ABC could take to address the nonconformity. A correction is the action taken to eliminate a detected nonconformity, while a corrective action is the action taken to eliminate the cause of a nonconformity and to prevent its recurrence1. By cancelling the service agreement with WeCare, ABC could stop the unauthorized use of residents' personal data and protect their privacy and rights. This could also prevent further complaints and legal issues from the residents and their family members. However, this option may also have some drawbacks, such as the loss of a service provider, the need to find an alternative solution, and the potential impact on the residents' well-being.
E . This option is a possible corrective action that ABC could take to address the nonconformity. By introducing background checks on information security performance for all suppliers, ABC could ensure that they select and work with reliable and trustworthy partners who respect the confidentiality, integrity, and availability of the information they handle. This could also help ABC to comply with information security control A.15.1.1 (Information security policy for supplier relationships), which requires the organisation to agree and document information security requirements for mitigating the risks associated with supplier access to the organisation's assets2.
F . This option is a possible corrective action that ABC could take to address the nonconformity. By periodically monitoring compliance with all applicable legislation and contractual requirements involving third parties, ABC could verify that the suppliers are fulfilling their obligations and responsibilities regarding information security. This could also help ABC to comply with information security control A.18.1.1 (Identification of applicable legislation and contractual requirements), which requires the organisation to identify, document, and keep up to date the relevant legislative, regulatory, contractual, and other requirements to which the organisation is subject3.
Reference:
1: ISO 27000:2018 - Information technology - Security techniques - Information securi ty management systems - Overview and vocabulary, clause 3.9 and 3.10 2: ISO/IEC 27001:2022 - Information technology - Security techniques - Information security manageme nt systems - Requirements, Annex A, control A.15.1.1 3: ISO/IEC 27001:2022 - Informatio n technology - Security techniques - Information security management systems - Requirements, Annex A, control A.18.1.1

**QUESTION NO: 221**
場景 9：Techmanic 是一家比利時公司，成立於 1995 年，目前在布魯塞爾運作。它提供 IT 諮詢、軟體設計和硬體/軟體服務，包括部署和維護。該公司服務於公共服務、金融、電信、能源、醫療保健和教育等行業。作為一家以客戶為中心的公司，它優先考慮建立牢固的客戶關係並引領安全實踐。
Techmanic 已獲得 ISO/IEC 27001
認證一年，並對此認證感到自豪。在認證審核期間，審核員發現其 ISMS 實施上存在一些不一致之處。由於觀察到的情況並不影響其 ISMS 實現預期結果的能力，因此在審計師遠端跟進根本原因分析和糾正措施後，Techmanic 獲得了認證。的遵守情況。認識持續改進的價值並從過去的評估中學習。 Techmanic 實施了審查先前的監督審計報告的做法。這種積極主動的方法不僅有助於識別和解決潛在的不

合格情況，而且還旨在簡化 IT 諮詢領域的重新認證流程。
監督審核期間，發現了多處不符合項。 ISMS 繼續滿足 ISO/IEC 27001*s
的要求，但根據內部稽核員的報告，Techmanic
未能解決與託管服務相關的不符合問題。此外，內部稽核報告存在多處不一致之處，這使人們對內部稽核師在託管服務審計過程中的獨立性產生了質疑。基於此，延期認證未獲核准。因此。 Techmanic 請求轉移到另一個認證機構。同時，該公司向客戶發布聲明稱，ISO/IEC 27001 認證涵蓋 IT 服務以及託管服務。
根據上述情景，回答以下問題：
內部稽核員是否負責跟進外部稽核所製定的行動計畫？
**A.**否，內部審核員應跟進針對內部審核導致的不符合項而提交的行動計劃
**B.**是的，只有在外部審核期間發現輕微不符合項時
**C.**是的，內部稽核員應跟進內部和外部審計期間提交的行動計劃
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct answer:
Internal auditors focus on internal audit nonconformities, while external auditors oversee external audit follow-ups.
B . Incorrect:
Minor nonconformities do not change the role of internal auditors.
C . Incorrect:
Internal auditors do not follow up on external audit findings-this is the certification body's responsibility.
Relevant Standard Reference:
ISO/IEC 27001:2022 Clause 9.2.2 (Internal Audit Responsibilities)

**QUESTION NO: 222**
您會在某些實體資產上看到藍色貼紙。這意味著什麼？
**A.**資產非常重要，其故障會影響整個組織
**B.**帶有藍色貼紙的資產應始終保持空調狀態
**C.**資產非常關鍵，其故障將影響組織中小組/專案的工作
**D.**資產至關重要，影響力僅限於員工
***Answer:*** C
Explanation:
You see a blue color sticker on certain physical assets. This signifies that the asset is high critical and its failure will affect a group/s/project's work in the organization. A blue color sticker is a type of label that indicates the level of criticality of an asset, which is a measure of how important an asset is for the organization's operations and objectives. A high critical asset is an asset that has a significant impact on the organization's activities, and its loss or damage would cause major disruption or loss of service. A blue color sticker also implies that the asset requires a high level of protection and security, and should be handled with care.
Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 36. : [ISO/IEC 27001 Brochures | PECB], page 6.

**QUESTION NO: 223**

場景 3：Rebuildy
是一家位於泰國曼谷的建築公司，專門從事住宅建築的設計、建造和維護。為了確保敏感專案資料和客戶資訊的安全，Rebuildy 決定實施基於 ISO/IEC 27001 的資訊安全管理系統 (ISMS)。
ISMS 實施成果如下
* 資訊安全是透過應用一系列安全控制和製定政策、流程和程序來實現的。
* 安全控制是根據風險評估實施的，旨在消除風險或將風險降低到可接受的水平。
* 所有流程均基於計劃-執行-檢查-行動 (PDCA) 模型確保 ISMS 的持續改進。
*
資訊安全政策是根據最佳安全實務起草的安全手冊的一部分，因此，它不是一份獨立的文件。
* 資訊安全角色和職責已在每位員工的職位說明中明確說明
* 資訊安全管理系統的管理評審是依照計畫的時間間隔進行的。
Rebuildy
在經歷了兩次中期管理評審和一次年度內部審計後申請了認證。該前員工向審計團隊成員 Electra 提交了書面證據，Rebuildy 的主要客戶 Electra
也提交了有關相同問題的證據，審計員決定保留這份證據，而不是前員工的證據。審計團隊成員一直與 Electra
保持聯繫，直至審計完成，討論審計期間發現的不符合。伊萊克特拉提供了額外的證據來支持這些發現。
在審核開始時，審核小組對公司高階主管進行了訪談，討論了高階主管對 ISMS
實施的承諾等事項。從這些討論中獲得的證據都記錄在書面確認書中，用於確定 Rebuildy 是否符合 ISO/IEC 27001 的幾個條款。其中，發現以下不符合：
* 在公司的財務報告系統中偵測到了不當的使用者存取控制設定實例。
* 尚未建立獨立的資訊安全政策。相反，該公司使用根據最佳安全實踐起草的安全手冊。
在收到審計團隊的這些文件後，團隊負責人會見了 Rebuildy
的高層管理層，介紹了審計結果。審計小組報告了與財務報告系統和缺乏獨立資訊安全政策有關的調查結果。高階主管對調查結果表示不滿，並認為審計組長的行為不專業，暗示他們可能會要求更換組長。迫於壓力，審計組長決定與高階主管合作，淡化所發現的不符合項的重要性。因此，審計團隊負責人調整了報告以呈現更有利的觀點，從而歪曲了 Rebuildy
合規問題的真實程度。
根據上述情景，回答以下問題：
審計師是否可以優先保留 Electra 提供的證據，而不是前員工提供的證據？
**A.**不，因為來自前員工的證據總是比來自客戶的證據更可靠
**B.**不，兩個證據來源都應保留並平等評估
**C.**是的，因為客戶具有獨立身份，因此來自客戶的證據被認為更可靠
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer: ISO 19011:2018 (Guidelines for Auditing Management Systems) states Both sources should have been retained, reviewed, and verified rather than selectively prioritizing one over the other.
A . Incorrect:
A former employee may have insider knowledge, but their credibility must be verified-it is not inherently more reliable.
C . Incorrect:

While a client is independent, their evidence is not automatically more credible than a former employee's.
Relevant Standard Reference:

**QUESTION NO: 224**
情境 4：SendPay
是一家金融公司，透過代理商和金融機構網路提供服務。他們的主要服務之一是在全球範圍內轉帳。 SendPay
作為一家新公司，致力於為客戶提供最優質的服務。由於該公司提供國際交易，因此要求客戶提供個人信息，例如身份、交易原因以及完成交易可能需要的其他詳細信息。因此，SendPay已實施安全措施來保護客戶的訊息，包括偵測、調查和回應可能出現的任何資訊安全威脅。他們對提供安全服務的承諾也體現在 ISMS 實施過程中，該公司投入了大量時間和資源。
去年，SendPay
推出了他們的數位平台，允許透過智慧型手機或筆記型電腦等電子設備進行貨幣交易，而無需支付額外費用。透過這個平台，SendPay
的客戶可以隨時隨地發送和接收資金。該數位平台幫助SendPay簡化了公司營運並進一步拓展了業務。當時SendPay正在外包其軟體業務，因此該專案是由外包公司的軟體開發團隊完成的。
該團隊還負責維護 SendPay 的技術基礎設施。
最近，該公司在實施 ISMS 近一年後申請了 ISO/IEC 27001
認證。他們與符合其標準的認證機構簽訂了合約。不久之後，認證機構任命了一個由四名審核員組成的團隊來審核 SendPay 的 ISMS。
審計過程中，發現以下情況：
1.外包軟體公司在未事先通知的情況下終止了與SendPay的合約。結果，SendPay
無法立即將服務恢復到內部，其營運中斷了五天。審計人員要求 SendPay
的代表提供證據，證明他們在合約終止的情況下有計劃遵循。這些代表沒有提供任何書面證據，但在接受審計時，他們告訴審計人員，SendPay的高層已經確定了另外兩家軟體開發公司，如果類似情況再次發生，可以立即提供服務。
2. 沒有證據顯示對外包給軟體開發公司的活動進行了監控。 SendPay
的代表再次告訴審計人員，他們定期與軟體開發公司溝通，並適當地告知可能發生的任何變更。
3.防火牆測試未發現異常狀況。審核員測試了防火牆配置，以確定這些服務提供的安全等級。他們使用資料包分析器來測試防火牆策略，這使他們能夠即時檢查發送或接收的資料包。
根據該場景，回答以下問題：
根據情境 4，審計人員要求提供有關外包業務監控過程的文件證據。這說明什麼？
**A.**審核員表現出專業懷疑態度
**B.**審計人員洩漏了外包業務的機密性
**C.**審計師根據基於風險的方法評估了證據
***Answer:*** A
Explanation:
Based on the provided scenario, the auditors' request for documentary evidence regarding the monitoring process of outsourced operations indicates that the auditors demonstrated professional skepticism. This is because professional skepticism involves a critical assessment of audit evidence and includes a questioning mind and a careful evaluation of the information provided by the auditee123.

Professional skepticism is an essential part of the auditing process, especially in the context of ISO/IEC 27001, which requires auditors to systematically examine an organization's information security risks, including the management of outsourced processes4. The auditors' request for evidence suggests that they were not satisfied with verbal assurances alone and sought to verify that SendPay had a formal, documented process for monitoring outsourced activities, which is a requirement for maintaining an effective Information Security Management System (ISMS)5.

**QUESTION NO: 225**
您是經驗豐富的 ISMS
審核團隊領導，指導審核員進行培訓。她詢問您審核報告中不合格項的分級。您決定透過詢問她以下哪四個陳述是正確的來測試她的知識。
**A.**重大不符合項目可能需要現場跟進
**B.**不合格項必須僅使用術語「嚴重」或「輕微」進行分級
**C.**解決重大不合格問題所採取的行動通常比解決輕微不合格問題所採取的行動更為實質性
**D.**非常輕微的不符合項應重新評級為改進機會
**E.**幾個輕微不符合項可以歸為一個主要不符合項
**F.**不合格品的分級必須在首次會議上向受審核方解釋
**G.**受審核方始終負責確定不合格品的分級標準
**H.**可以將不合格項分級以表示其重要性
***Answer:*** A,C,E,H
Explanation:
The four statements that are true are:
* Major nonconformities may be subject to on-site follow up
* The action taken to address major nonconformities is typically more substantial than the action taken to address minor nonconformities
* Several minor nonconformities can be grouped into a major nonconformity
* Nonconformities may be graded to indicate their significance
According to ISO 19011:2018, a nonconformity is the non-fulfilment of a requirement1. Nonconformities may be graded to indicate their significance, based on the criteria established by the audit programme or the audit client2. The grading of nonconformities may use different terms or levels, such as major, minor, critical, etc., depending on the nature and context of the audit3. However, some common definitions of major and minor nonconformities are:
* A major nonconformity is a nonconformity that affects the ability of the management system to achieve its intended results, or that represents a significant breakdown of the management system4. Major nonconformities may require immediate corrective action and on-site follow up by the auditor to verify their closure5.
* A minor nonconformity is a nonconformity that does not affect the ability of the management system to achieve its intended results, or that represents an isolated lapse of the management system4. Minor nonconformities may require corrective action within a specified time frame and off-site verification by the auditor to confirm their closure5.
The action taken to address nonconformities depends on the severity and impact of the nonconformity, and the risk of recurrence or escalation. Typically, the action taken to address major nonconformities is more substantial than the action taken to address minor

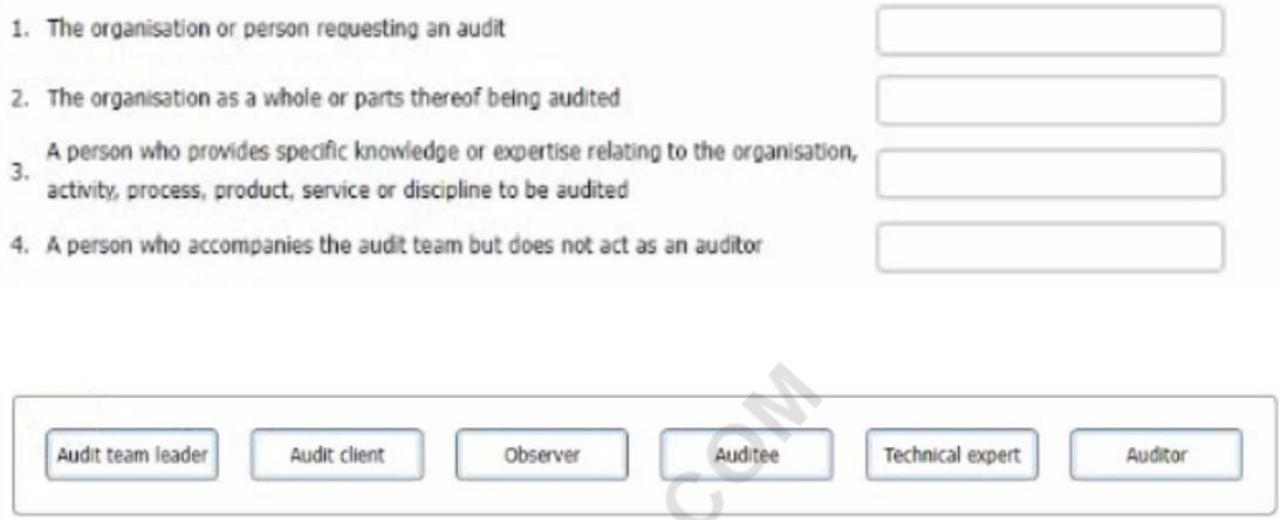
nonconformities, as it may involve identifying and eliminating the root cause of the problem, implementing preventive measures, and monitoring the effectiveness of the solution.
Several minor nonconformities can be grouped into a major nonconformity if they are related to the same requirement, process, or area, and if they indicate a systemic failure or a significant risk to the management system. The auditor should use professional judgment and evidence-based approach to decide whether to group or report nonconformities individually.
The other statements are false, based on the guidance of ISO 19011:2018. For example:
* Option B is false, because nonconformities can be graded using different terms or levels, depending on the criteria established by the audit programme or the audit client2. The terms 'major' and 'minor' are not mandatory or universal, but rather examples of possible grading levels3.
* Option D is false, because very minor nonconformities should not be re-graded as opportunities for improvement, but rather reported as nonconformities, as they still represent a non-fulfilment of a requirement1. An opportunity for improvement is a suggestion for enhancing the performance or effectiveness of the management system, but it is not a nonconformity or a requirement.
* Option F is false, because the grading of nonconformities does not have to be explained to the auditee at the opening meeting, but rather at the closing meeting, where the audit findings and conclusions are presented and discussed. The opening meeting is intended to provide an overview of the audit objectives, scope, criteria, and methods, and to confirm the audit arrangements and logistics.
* Option G is false, because the auditee is not always responsible for determining the criteria for grading nonconformities, but rather the audit programme or the audit client, in consultation with the auditee and other relevant parties2. The auditee is responsible for taking corrective action to address the nonconformities, and for providing evidence of their completion and effectiveness.

**QUESTION NO: 226**
場景9：UpNet是一家網路公司，已通過ISO/IEC 27001認證。
自從獲得 ISO/IEC 27001 認證以來，該公司的認可度大幅提高。此認證證實了 UpNefs 營運的成熟性及其符合廣泛認可和接受的標準。
但認證之後一切還沒結束。 UpNet 透過進行內部稽核不斷審查和增強其安全控制以及 ISMS 的整體有效性和效率。高階主管不願意聘請全職內部稽核團隊，因此決定將內部稽核職能外包。這種形式的內部稽核確保了獨立性、客觀性，並且在 ISMS 的持續改進方面發揮諮詢作用。
在初次認證審核後不久，該公司創建了一個專門從事數據和儲存產品的新部門。他們提供針對資料中心和基於軟體的網路設備（例如網路虛擬化和網路安全設備）進行最佳化的路由器和交換器。這導致 ISMS 認證範圍內已涵蓋的其他部門的營運發生變化。
所以。 UpNet
啟動了風險評估流程和內部稽核。根據內部審計結果，公司確認了現有和新流程和控制的有效性和效率。
由於新部門符合 ISO/IEC 27001 要求，最高管理層決定將其納入認證範圍。
UpNet宣布取得ISO/IEC 27001認證，認證範圍涵蓋全公司。
在初次認證審核一年後，認證機構對 UpNefs ISMS 進行了另一次審核。
此次審核旨在確定 UpNefs ISMS 是否符合指定的 ISO/IEC 27001 要求，並確保 ISMS 持續改善。審核小組確認，經過認證的 ISMS

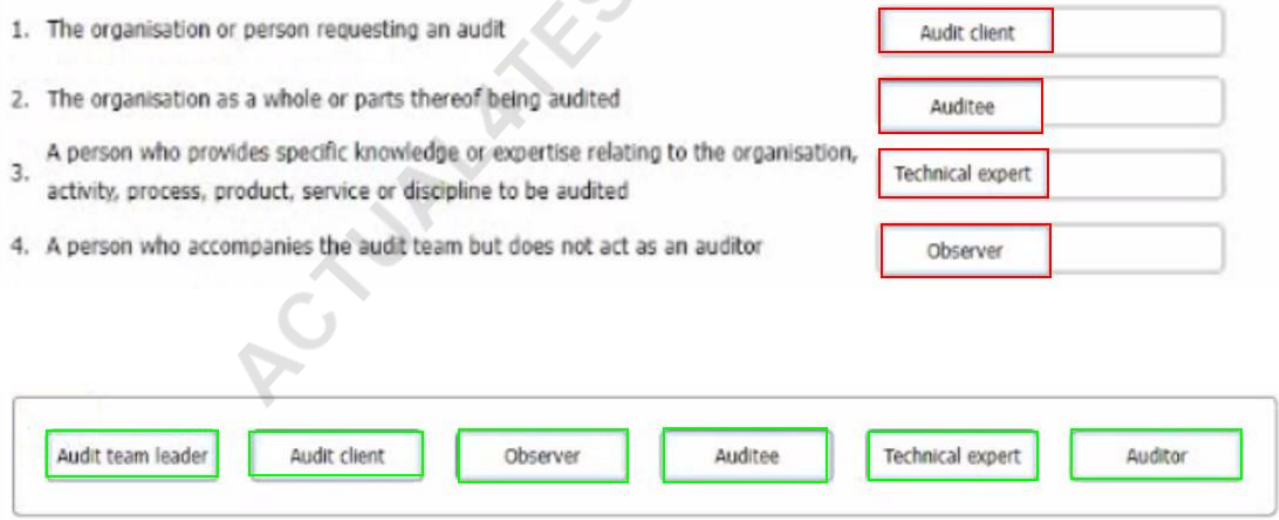
繼續符合標準的要求。儘管如此，新部門對管理體系的治理產生了重大影響。此外，認證機構並未獲悉任何變更。因此，UpNefs認證被暫停。
根據上述場景，回答以下問題：
UpNet 確保內部稽核的獨立性、客觀性和諮詢活動。這個動作可以接受嗎？
**A.**是的，因為內部稽核具有諮詢作用
**B.**否，因為內部審核應獨立於被審核的活動
**C.**否，因為內部稽核功能已外包
***Answer:*** A

**QUESTION NO: 227**
場景 2：Knight 是一家來自美國北加州的電子公司，開發電玩遊戲機。 Knight 在全球擁有 300 多名員工。在成立五週年之際，他們決定推出 G-
Console，這是一款面向全球市場的新一代電玩遊戲機。 G-
Console被認為是2021年的終極媒體機，將為玩家帶來最佳的遊戲體驗。
主機包將包括一副 VR 耳機、兩個
遊戲和其他禮物。
多年來，公司透過誠信、誠實和尊重客戶而建立了良好的聲譽。這種良好的聲譽是大多數熱衷遊戲玩家在Knight的G-console一上市就想擁有它的原因之一。
Knight 除了是一家非常以客戶為導向的公司之外，
也因其開發品質獲得了遊戲產業的廣泛認可。他們的價格比合理標準允許的要高一些。
儘管如此，對於 Knight
的大多數忠實客戶來說，這並不是一個問題，因為它們的品質是一流的。
作為世界頂級視訊遊戲機開發商之一，Knight 也經常成為惡意活動的焦點。該公司的 ISMS 已投入運作一年多了。 ISMS 範圍包括 Knight 的所有部門（財務和人力資源部門除外）。
最近，奈特的一些包含專有資訊的文件被駭客洩露。 Knight 的事件回應團隊 (IRT)
立即開始分析系統的每個部分以及事件的詳細資訊。
IRT 的第一個懷疑是 Knight
的員工使用了弱密碼，因此很容易被未經授權存取其帳戶的駭客破解。然而，在仔細調查該事件後，IRT 確定駭客透過擷取檔案傳輸協定 (FTP) 流量來存取帳戶。
FTP 是一種用於在帳戶之間傳輸檔案的網路協定。它使用明文密碼進行身份驗證。
受此資訊安全事件的影響，在IRT的建議下，Knight決定用Secure Shell
(SSH)協定取代FTP，這樣任何捕獲流量的人都只能看到加密的資料。
在這些變化之後，奈特進行了風險評估，以驗證控制措施的實施是否已將類似事件的風險降至最低。該過程的結果得到了 ISMS
專案經理的批准，他聲稱實施新控制措施後的風險等級符合公司的風險接受程度。
根據該場景，回答以下問題：
FTP 使用明文密碼進行驗證。這是一個 FTP：
**A.**漏洞
**B.**風險
**C.**威脅
***Answer:*** A

**QUESTION NO: 228**
請將角色與以下描述配對：




***Answer:***




To complete the table click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable test from the options below. Alternatively, you may drag and drop each option to the appropriate blank section.
Reference:
[ISO 19011:2022 Guidelines for auditing management systems]
[ISO/IEC 17021-1:2022 Conformity assessment - Requirements for bodies providing audit and certification of management systems - Part 1: Requirements]

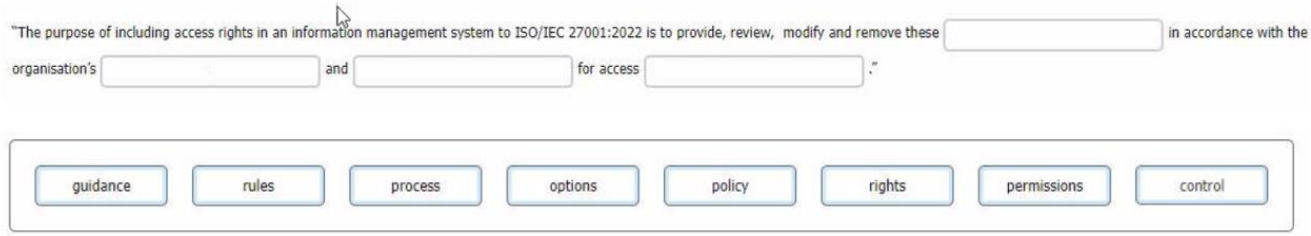
**QUESTION NO: 229**
下列哪一項關於資訊安全威脅和漏洞的敘述是不正確的？
**A.**脆弱性可以是內在的，也可以是外在的，與資產的特徵或外在因素有關
**B.**威脅必須利用漏洞對資訊的機密性、完整性和/或可用性產生負面影響
**C.**無論相應的威脅為何，所有漏洞都需要立即實施控制
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Incorrect Statement - Not all vulnerabilities require immediate remediation. Risk

assessment determines whether controls are necessary. Some vulnerabilities pose low risks and may not need urgent fixes.
A . Correct Statement - Vulnerabilities can be intrinsic (inherent flaws) or extrinsic (caused by external misconfigurations).
B . Correct Statement - Threats must exploit vulnerabilities to cause harm.
This aligns with ISO/IEC 27001:2022 Annex A Control A.8.8 (Management of Technical Vulnerabilities).

**QUESTION NO: 230**
場景3：NightCore是一家總部位於美國的跨國科技公司，專注於電子商務、雲端運算、數位串流媒體和人工智慧。在實施資訊安全管理系統 (ISMS) 8
個多月後，他們聘請了認證機構進行第三方審核，以獲得 ISO/IEC 27001 認證。
認證機構成立了一個由七名審核員組成的團隊。傑克是最有經驗的審核員，被任命為審核組組長。多年來，他獲得了許多知名認證，例如 ISO/IEC 27001 首席審核員、CISA、CISSP 和 CISM。
Jack 透過研究和評估 NightCore 實施的每項資訊安全要求和控制，對 ISMS
審查的每個階段進行了全面分析。在第二階段審核期間。傑克發現了一些不合格項。在將購買的軟體許可證發票數量與軟體庫存進行比較後，傑克發現該公司的許多電腦一直在使用非法版本的軟體。他決定要求高階主管對這項違規行為做出解釋，看看他們是否意識到這一點。他的下一步是審計 NightCore 的 IT 部門。高層指派 NightCore 的系統管理員 Tom 擔任指導，陪伴 Jack 和稽核團隊了解系統和數位資產基礎設施的內部運作。
在採訪財務部的一名成員時，審計人員發現該公司最近向其一名顧問進行了一些不尋常的大額交易。收集有關交易的所有必要詳細資訊後。傑克決定直接訪問高階主管。
在討論第一個不合格項時，高階主管告訴傑克，他們願意決定使用複製軟體而不是原始軟體，因為它更便宜。 Jack向NightCore的高層解釋說，使用非法版本的軟體違反了ISO/IEC 27001和國家法律法規的要求。然而，他們似乎對此感到滿意。
在審計幾個月後，Jack 將他在審計期間收集的一些 NightCore 資訊出售給了 NightCore 的競爭對手，以獲取巨額資金。
根據該場景，回答以下問題：
根據審核原則，Jack是否應該就第二次不合格問題聯繫認證機構？
請參閱場景 3。
**A.**是的，審核員應聯繫認證機構的道德委員會成員以獲得有關此類情況的建議
**B.**是的，審核員應將此類情況傳達給認證機構；但是，不應通知最高管理階層
**C.**不，可能表示金融犯罪的情況不是 ISMS 審核的重點
***Answer:*** B
Explanation:
Yes, Jack should communicate such situations to the certification body. It is essential for auditors to report potential nonconformities and ethical breaches to the certification body to maintain the integrity and credibility of the audit process, without necessarily informing top management of these steps.

**QUESTION NO: 231**
身為 ISMS
審核小組組長，您正在代表一家線上零售商對一家國際物流公司進行第二方審核。在審核期間，您的一名團隊成員報告了與 ISO/IEC 27001:2022 附錄 A 的控制措施

5.18（存取權限）相關的不合格項。她發現證據表明，刪除過去 3 個月內離開的 20 名人員的伺服器存取協議需要長達 1 週的時間，而政策要求在他們離開後 24 小時內刪除存取權限。
用最好的單字填寫句子，勾選要填寫的空白部分，使其以紅色突出顯示，然後從下面的選項中點擊適用的文字。或者，您可以將該選項拖曳到適當的空白部分。




***Answer:***




**QUESTION NO: 232**
下列哪兩個短語是與第一方審核相關的「目標」？
**A.**應用國際標準
**B.**為認證機構準備審核報告
**C.**確認管理系統的範圍準確
**D.**按時完成審核
**E.**應用監理要求
**F.**更新管理策略
***Answer:*** C,F
Explanation:
A first-party audit is an internal audit conducted by the organization itself or by an external party on its behalf. The objectives of a first-party audit are to: 12 Confirm the scope of the management system is accurate, i.e., it covers all the processes, activities, locations, and functions that are relevant to the information security objectives and requirements of the organization.
Update the management policy, i.e., review and revise the policy statement, roles and responsibilities, and objectives and targets of the information security management system (ISMS) based on the audit findings and feedback.
The other phrases are not objectives of a first-party audit, but rather:
Apply international standards: This is a requirement for the ISMS, not an objective of the audit. The ISMS must conform to the ISO/IEC 27001 standard and any other applicable standards or regulations12 Prepare the audit report for the certification body: This is an activity of a third-party audit, not a first-party audit. A third-party audit is an external audit conducted by an independent certification body to verify the conformity and effectiveness of the ISMS and to issue a certificate of compliance12 Complete the audit on time: This is a performance indicator, not an objective of the audit. The audit should be completed within the

ACTUAL4TEST.COM

planned time frame and budget, but this is not the primary purpose of the audit12 Apply regulatory requirements: This is also a requirement for the ISMS, not an objective of the audit. The ISMS must comply with the legal and contractual obligations of the organization regarding information security12 Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 233**
場景 7：Lawsy 是一家領先的律師事務所，在新澤西州和紐約市設有辦公室。它擁有 50 多名律師，為商業法、智慧財產權、銀行和金融服務領域的客戶提供完善的法律服務。他們相信，由於他們致力於實施資訊安全最佳實踐並跟上技術發展的步伐，他們在市場上佔據了有利的地位。
Lawsy 已經嚴格實施、評估和進行 ISMS 內部審核兩年了。
現在，他們已向知名且值得信賴的認證機構ISMA申請ISO/IEC 27001認證。
在第一階段審核期間，審核小組審查了實施過程中所建立的所有 ISMS 文件。
他們還審查和評估了管理審查和內部審計的記錄。
Lawsy
提交了證據記錄，表明在必要時對不合格項採取了糾正措施，因此審核組約談了內部審核員。
訪談透過提供對內部稽核計畫和程序的詳細了解，驗證了內部稽核的充分性和頻率。
審計小組繼續驗證戰略文件，包括資訊安全政策和風險評估標準。在資訊安全政策審查期間，團隊注意到描述治理框架（即資訊安全政策）的記錄資訊與程序之間存在不一致。
儘管允許員工將筆記型電腦帶到工作場所之外，但 Lawsy
並沒有製定有關在這種情況下使用筆記型電腦的程序。此政策僅提供有關筆記型電腦使用的一般資訊。該公司依靠員工的常識來保護筆記型電腦中儲存的資訊的機密性和完整性。該問題已記錄在第一階段審計報告中。
完成第一階段審核後，審核組長準備了審核計劃，其中規定了審核目標、範圍、標準和程序。
在第二階段審核期間，審核小組約談了資安經理，資安經理起草了資訊安全政策。他透過指出 Lawsy
每三個月舉辦一次強制性資訊安全培訓和意識課程來證明第一階段中確定的問題的合理性。
面談後，審核小組檢查了 15 份員工培訓記錄（共 50 份），得出的結論是 Lawsy 符合 ISO/IEC 27001
有關培訓和意識的要求。為了支持這個結論，他們影印了檢查過的員工訓練記錄。
根據上述場景，回答以下問題：
Lawsy
缺乏關於在工作場所之外使用筆記型電腦的程序，它依賴員工的常識來保護筆記型電腦中儲存的資訊的機密性。這提出：

**A.**異常

**B.**不合格項

**C.**一致性

***Answer:*** B

Explanation:
Lawsy's lack of specific procedures for the use of laptops outside the workplace, despite allowing such use, represents a nonconformity. ISO/IEC 27001 requires that security controls and management processes be clearly defined, documented, and implemented. Relying

solely on employees' common knowledge does not fulfill the standard's requirements for managing information security risks associated with mobile and teleworking.

**QUESTION NO: 234**
在管理系統審核的背景下，請確定收集和驗證資訊的典型流程的順序。第一個已經為你完成了。




***Answer:***

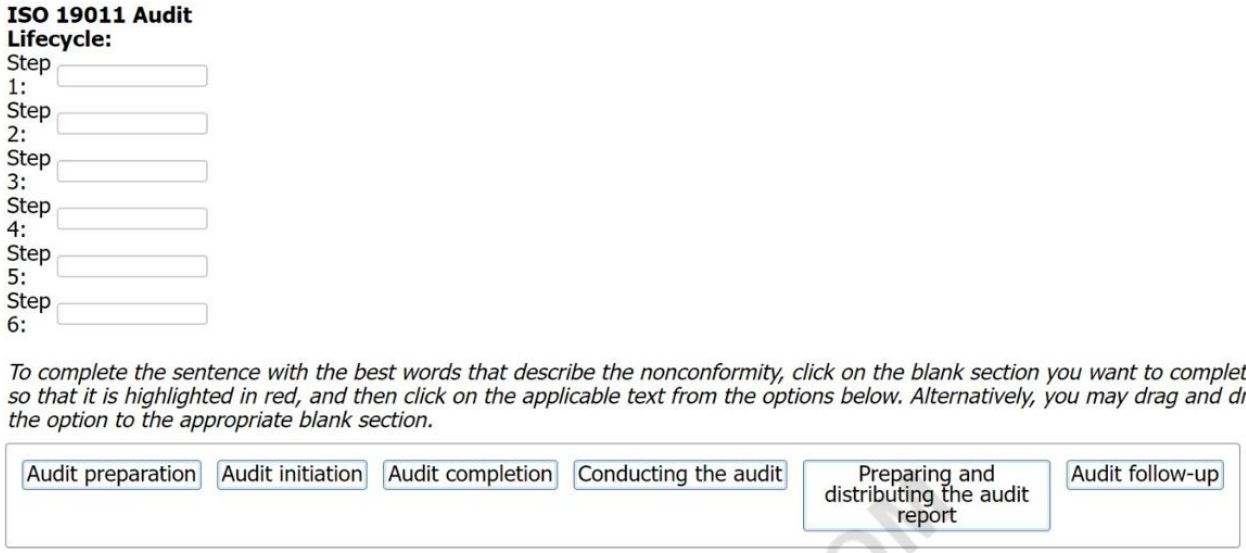



**QUESTION NO: 235**
您是一位經驗豐富的 ISMS 審核員，在一家提供 ICT
回收服務的組織中進行第三方監督審核。公司不再需要的ICT設備由組織處理。它要么被重新調試並重複使用，要么被安全銷毀。
您注意到房間角落的長凳上有兩台伺服器。兩者都貼有伺服器名稱、IP
位址和管理員密碼的貼圖。您向 ICT
經理詢問這些物品，他告訴您這些物品是昨天從一位老客戶那裡收到的一批貨物的一部分。
您應該採取哪一項行動？
**A.**請受審核方移除標籤，然後繼續審核
**B.**請 ICT 經理記錄資訊安全事件並啟動資訊安全事件管理流程
**C.**記下審核結果並檢查處理與客戶 IT 安全相關的進貨的流程
**D.**針對控制措施 5.31「法律、法規、監管和合約要求」提出不符合項
**E.**針對控制措施
8.20「網路安全」提出不符合項（應保護、管理和控製網路和網路設備，以保護系統和應用程

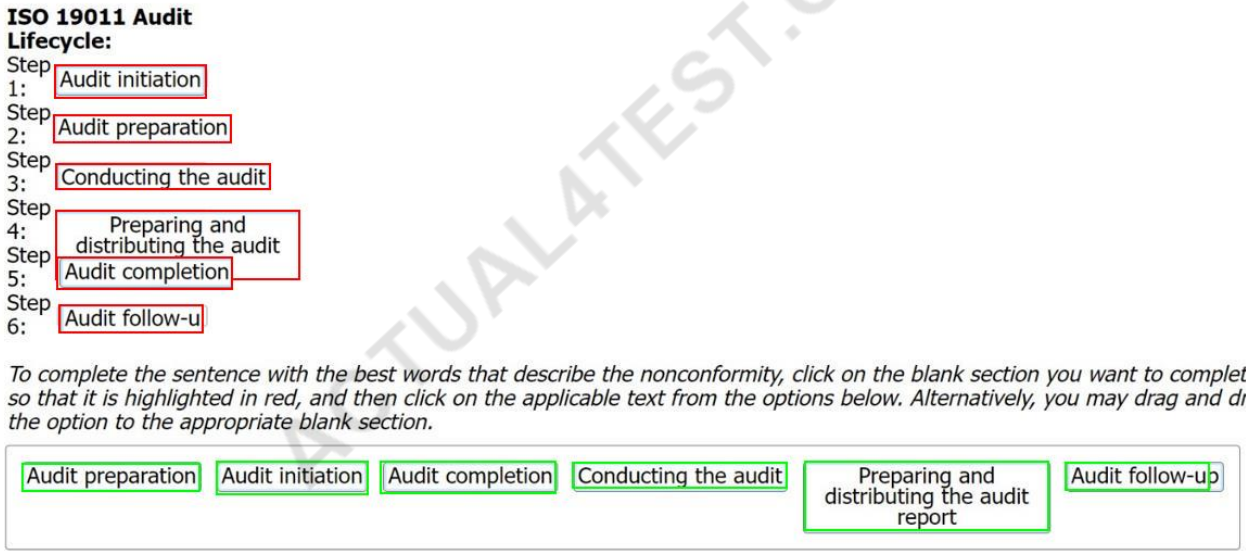
ACTUAL4TEST.COM

式中的資訊）
**F.**記錄您在審核結果中看到的內容，但不採取進一步行動
***Answer:*** C

**QUESTION NO: 236**
審核生命週期描述了進行單獨審核的 ISO 19011
流程。將審核生命週期的步驟拖曳到正確的順序中。




***Answer:***




**QUESTION NO: 237**
您正在對客戶的 ISMS
進行第三方監督審核。您目前位於資料中心的安全儲存區域，組織的客戶可以暫時定位進出站點的設備。該設備包含在上鎖的櫃子內，每個櫃子都分配給一個特定的客戶端。
你用眼角的餘光發現儲藏區外門附近有動靜。隨後是一聲巨響。你問導遊發生了什麼事。他們告訴您，最近的高降雨量導致當地河流水位上升，並導致老鼠氾濫。發出噪音的是專門的害蟲控制致暈裝置被觸發。你檢查角落的裝置，發現裡面有一隻一動也不動的大老鼠。
接下來應該採取哪三項行動？

ACTUAL4TEST.COM

**A.**不採取進一步行動。這是 ISMS 審核，而非環境管理系統審核
**B.**調查害蟲侵擾是否是已識別的風險，如果是，則應採取哪些風險處理措施
**C.**確定大量降雨是否對資料中心營運產生其他影響，例如
基礎設施損壞、客戶訪問問題、調用業務連續性安排
**D.**針對控制 7.4 實體安全監控提出不符合項
**E.**針對控制 7.2 實體條目提出不符合項
**F.**與指南核實他們打算啟動組織的資訊安全事件流程
**G.**檢查客戶機櫃是否有嚙齒動物進入的跡象，並將您的發現記錄為審計證據
**H.**協助導遊人道處置老鼠並重置設備
***Answer:*** B,C,F
Explanation:
The appropriate actions to take next are to investigate whether pest infestation is an identified risk and if so, what risk treatment is to be applied, to determine whether the high levels of rainfall have had other impacts on data centre operations, and to check with the guide that they intend to initiate the organisation's information security incident process. These actions are relevant to the ISMS audit objectives and criteria, as they relate to the organisation's risk assessment and treatment, security performance, and incident management processes. The other actions are either not within the scope of the ISMS audit, not required by the ISO/IEC 27001 standard, or not the responsibility of the auditor.
Reference: PECB Candidate Handbook1, page 21-22; ISO/IEC 27001:2022 (en)2, clauses 6.1, 8.2, 9.1, and 10.2.

**QUESTION NO: 238**
檢查以下陳述並確定哪兩項是錯誤的：
**A.**獲準進行現場審核的審核員不需要進行虛擬審核的額外培訓，因為所需的技能沒有顯著差異
**B.**在虛擬審核之前進行技術檢查可以提高審核的有效性和效率
**C.**出於保密和安全考慮，虛擬審核期間的螢幕共享是審核團隊審查受審核方文件的一種方法
**D.**在虛擬審核期間，強烈建議參與面談的受審核方保持網路攝影機處於啟用狀態
**E.**分配給第三方審核的天數取決於受審核方的空閒時間
**F.**選擇現場、虛擬或組合審核應考慮歷史績效和先前的審核結果
***Answer:*** A,E
Explanation:
A: Auditors approved for conducting onsite audits do require additional training for virtual audits to ensure they are competent in using the technology and tools required for conducting audits remotely12.
E: The number of days assigned to a third-party audit is not determined by the auditee's availability, but rather by factors such as the size and complexity of the organization, the scope of the audit, and the requirements of the certification body34.

**QUESTION NO: 239**
您是一位經驗豐富的 ISMS 內部稽核師。
當 IT
經理找到您並要求您協助修改公司的適用性聲明時，您剛剛完成了組織的預定資訊安全審核。IT 經理正在嘗試將基於 ISO/IEC 27001:2013 的適用性聲明更新為與 ISO/IEC 27001:2022

中的 4 個控制主題（組織控制、人員控制、實體控制、技術控制）一致的聲明。
IT
經理對控制權的重新分配感到滿意，但以下情況除外。他詢問您以下每個控制類別應出現在哪四個控制類別下。

How would you respond? Match the control description to the category.

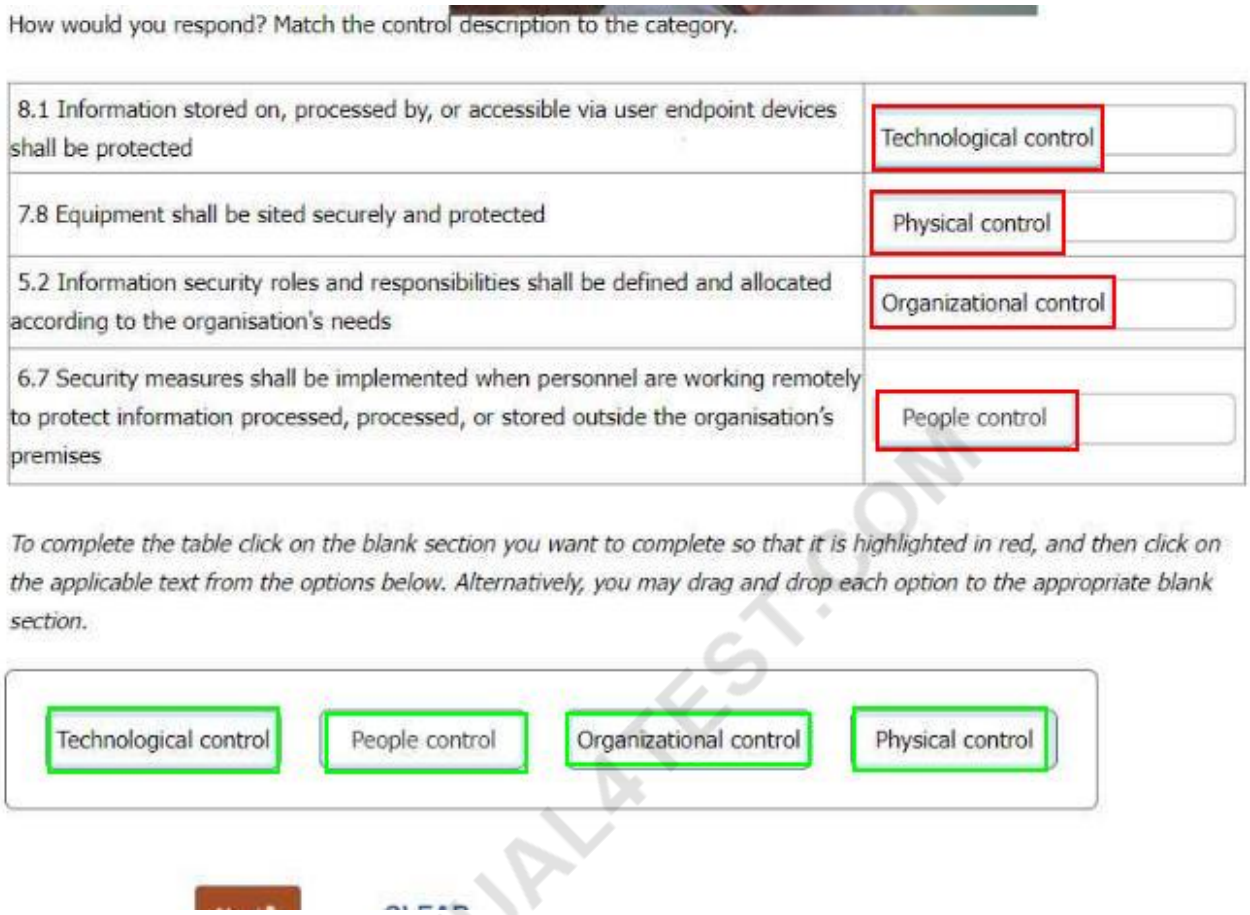
| | |
|---|---|
| 8.1 Information stored on, processed by, or accessible via user endpoint devices shall be protected | |
| 7.8 Equipment shall be sited securely and protected | |
| 5.2 Information security roles and responsibilities shall be defined and allocated according to the organisation's needs | |
| 6.7 Security measures shall be implemented when personnel are working remotely to protect information processed, processed, or stored outside the organisation's premises | |

*To complete the table click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable text from the options below. Alternatively, you may drag and drop each option to the appropriate blank section.*

Technological control | People control | Organizational control | Physical control

ACTUALTEST.COM

***Answer:***




**QUESTION NO: 240**

場景 4：Branding
是一家行銷公司，與美國一些最著名的公司合作。降低內部成本。兩年多來，Branding 已將軟體開發和 IT 幫助台營運外包給
Techvology。技術學。配備必要的專業知識，管理品牌的軟體、網路和硬體需求。 Branding 已實施資訊安全管理系統 (ISMS) 並獲得了 ISO/IEC 27001
認證，表明其致力於維護高標準的資訊安全。它積極對技術進行審計，以確保其外包業務的安全性符合 ISO/IEC 27001 認證要求。
在上次審計期間。品牌的審計團隊定義了要審計的流程和審計計畫。他們採用了基於證據的方法，特別是考慮到 Techvology 在過去一年中報告的兩起資訊安全事件。所有方面。
此外，審計也對Techvology用於管理其外包業務和其他組織的治理流程進行了嚴格的評估。此步驟對於品牌推廣至關重要，可以驗證是否有適當的控制和監督機制來減輕與外包安排相關的潛在風險。
審計員對 Techvology 各級人員進行了採訪，並分析了事件解決記錄。此外，Techvology 還提供了記錄作為證據，證明他們為員工開展了事件管理意識會議。根據收集到的信息，他們預測這兩起資訊安全事件都是由人員不稱職造成的。因此，審計人員要求查看涉事員工的人事檔案，以審查其能力的證據，例如相關經驗、證書和參與培訓的記錄。
Branding
的審計員對所獲得的證據的有效性進行了嚴格評估，並對可能與收到的記錄資訊的可靠性相矛盾或質疑的證據保持警惕。在對 Techvology
進行審計期間，審計員堅持這種方法，嚴格評估事件解決記錄，並對不同級別和職能的員工進行徹底的訪談。他們不只把 Techvology
代表的話當作事實；相反，他們尋求具體的證據來支持代表們對事件管理流程的主張。

根據上述情景，回答以下問題：
根據場景4，審計人員收集了哪些類型的審計證據來決定資訊安全事件的來源？
**A.**口頭和書面證據
**B.** 確認與技術證據
**C.** 分析與數學證據
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct answer:
Auditors conducted interviews (verbal evidence) and analyzed incident resolution records, employee training logs, and governance policies (documentary evidence).
ISO 19011:2018 (Clause 6.4.7) states that audit evidence can be verbal, documented, observed, or analytical.
B . Incorrect:
Confirmative evidence involves third-party validation, which was not explicitly mentioned.
C . Incorrect:
Mathematical analysis was not conducted in this audit.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.4.7 (Audit Evidence Collection Methods)

**QUESTION NO: 241**
您是一位經驗豐富的 ISMS 審核團隊領導者。您正在向一類品質管理系統審核員介紹 ISO/IEC 27001:2022，這些審核員正在尋求再培訓，以便能夠執行資訊安全管理系統審核。
您問他們資訊安全管理系統尋求保留下列哪些資訊特徵？
他們應該提供哪三個答案？
**A.**清晰度
**B.**輔助功能
**C.**完整性
**D.**重要性
**E.**可用性
**F.**保密性
**G.**誠信
**H.**效率
***Answer:*** E,F,G
Explanation:
These three characteristics are the fundamental properties of information security, as defined by the ISO/IEC 27000 standard, which provides the overview and vocabulary of information security, cybersecurity, and privacy protection12. They are also the basis for the information security objectives and controls of the ISO/IEC 27001 standard, which specifies the requirements for establishing, implementing, maintaining, and continually improving an information security management system34. The definitions of these characteristics are as follows12:
* Availability: The property of being accessible and usable upon demand by an authorized entity.

ACTUAL4TEST.COM

* Confidentiality: The property that information is not made available or disclosed to unauthorized individuals, entities, or processes.
* Integrity: The property of safeguarding the accuracy and completeness of information and processing methods.
The other characteristics listed in the question, such as clarity, accessibility, completeness, importance, and efficiency, are not directly related to information security, although they may be relevant for other aspects of information management, such as quality, usability, or performance.

**QUESTION NO: 242**
場景 8：苔絲
一個。 Malik 和 Michael
是一個由安全、合規以及業務規劃和策略領域的獨立且合格的專家組成的審計團隊。他們被指派到一家大型網頁設計公司Clastus進行認證審核。他們在進行審計時表現出了出色的職業道德，包括公正和客觀。這一次，Clastus 確信，如果獲得 ISO/IEC 27001
認證，他們將領先一步。
審計團隊負責人 Tessa 擁有審計專業知識，並且在 IT
相關問題、合規性和治理方面擁有非常成功的背景。馬利克擁有組織規劃和風險管理背景。他的專業知識依賴於對組織的安全控制及其風險承受能力的綜合和分析水平，以準確描述組織內部的風險水平 另一方面，Michael
是通過遵循嚴格的標準化程序進行控制評估的實際安全性的專家。
在執行所需的審計活動後，泰莎發起了一次審計團隊會議，他們分析了邁克爾的一項發現，以客觀、準確地就該問題做出決定。 Michael
遇到的問題是組織日常運作中的一個小問題，他認為這是由組織的一名 IT
技術人員造成的，因此，Tessa
會見了高層管理人員，並在他們詢問了責任人姓名後，告訴他們誰應該對這一問題負責，為了方便澄清和理解，Tessa 在審核的最後一天召開了結束會議。在這次會議上，她向 Clastus
管理層報告了發現的不符合情況。然而，Tessa 收到建議，避免在 Clastus
認證審核的審核報告中提供不必要的證據，確保報告保持簡潔並專注於關鍵發現。
根據審查的證據，審核小組起草了審核結論，並決定在授予認證之前必須對該組織的兩個領域進行審核。這些決定後來被提交給被審計方，但被審計方不接受調查結果並提議提供更多資訊。儘管受審計方提出了意見，但審計員已經決定接受認證建議，因此沒有接受補充資訊。被審計單位的高階主管堅持審計結論並不代表事實，但審計小組仍堅持他們的決定。
根據上述情景，回答以下問題：
末次會議是否依要求進行了？
**A.**是的，末次會議在審計的最後一天舉行
**B.**不，應在審計結論起草後進行
**C.**不，應該在現場審核後幾週進行
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct answer:
ISO 19011:2018 requires that closing meetings occur at the end of the audit to present findings to the auditee.
B . Incorrect:

Audit conclusions can be drafted later, but the closing meeting must still happen immediately post-audit.
C . Incorrect:
Delaying the closing meeting beyond the audit timeline is improper.
Relevant Standard Reference:

**QUESTION NO: 243**
完成第一階段並準備第二階段初步認證審核後，受審核方通知審核小組負責人，他們希望擴大審核範圍，以包括該組織最近收購的另外兩個場所。
考慮到這些訊息，您希望審計小組負責人採取什麼行動？
**A.**增加第 2 階段審核的長度以包含額外的站點
**B.**取得附加網站的資訊以通知認證機構
**C.**安排使用視訊會議平台完成兩個站點的遠端第一階段審核
**D.**通知審核方可以接受請求，但必須重複完整的第一階段審核
***Answer:*** B
Explanation:
According to ISO/IEC 17021-1, which specifies the requirements for bodies providing audit and certification of management systems, a certification body should establish criteria for determining audit time and audit team composition based on factors such as the scope of certification, size and complexity of the organization, risks associated with its activities, etc2. Therefore, if an auditee requests to extend the audit scope to include two additional sites after completing Stage 1 of an initial certification audit, the audit team leader should obtain information about the additional sites to inform the certification body, so that they can review and approve the change in scope and adjust the audit time and audit team accordingly2. The other options are not appropriate actions for the audit team leader to take in this situation. For example, increasing the length of the Stage 2 audit to include the extra sites without informing the certification body may violate their procedures and policies; arranging to complete a remote Stage 1 audit of the two sites using a video conferencing platform may not be feasible or effective depending on the nature and location of the sites; and informing the auditee that the request can be accepted but a full Stage 1 audit must be repeated may not be necessary or reasonable if there are no significant changes in the auditee's ISMS since Stage 12. Reference: ISO/IEC 17021-1:2015 - Conformity assessment - Requirements fo r bodies providing audit and certification of management systems - Part 1: Requirements

**QUESTION NO: 244**
您正在一家名為 ABC 的提供醫療保健服務的住宅療養院進行 ISMS
審核。您會發現所有療養院居民都戴著電子腕帶，用於監控他們的位置、心跳和血壓。您了解到，電子腕帶會自動將所有資料上傳到人工智慧（AI）雲端伺服器，供醫護人員進行健康監測和分析。
為了驗證 ISMS 的範圍，您採訪了管理系統代表 (MSR)，他解釋說 ISMS
範圍涵蓋外包資料中心。
為 ISO/IEC 27001:2022 與 ISMS 範圍驗證直接相關的條款和/或控制選擇四個選項。
**A.**控制措施 5.3 組織角色、職責與權限
**B.**第 4.2 條了解相關方的需求與期望
**C.**控制措施 5.3 法律、法規、監管和合約要求

**D.**控制措施 6.3 資訊安全意識、教育與培訓
**E.**第 5.2 條政策
**F.**條款 4.1 了解組織及其背景
**G.**控制措施 7.6 在安全區域工作
**H.**第 4.3 條決定資訊安全管理系統的範圍
***Answer:*** B,E,F,H
Explanation:
B . This clause requires the organisation to determine the interested parties that are relevant to the ISMS, and the requirements of these interested parties12. This clause is relevant to the verification of the scope of the ISMS because it helps the organisation to identify the stakeholders that have an influence or an interest in the information security of the organisation, such as customers, suppliers, regulators, employees, etc. The organisation should also consider the needs and expectations of these interested parties when defining the scope of the ISMS, and ensure that they are met and communicated.
E . This clause requires the organisation to establish an information security policy that provides the framework for setting the information security objectives and guiding the information security activities13. This clause is relevant to the verification of the scope of the ISMS because it helps the organisation to define the direction and principles of the ISMS, and to align them with the strategic goals and context of the organisation. The information security policy should also be consistent with the scope of the ISMS, and should be communicated and understood within the organisation and by relevant interested parties.
F . This clause requires the organisation to determine the internal and external issues that are relevant to the purpose and the context of the organisation, and that affect its ability to achieve the intended outcomes of the ISMS14. This clause is relevant to the verification of the scope of the ISMS because it helps the organisation to understand the factors and conditions that influence the information security of the organisation, such as the legal, technological, social, economic, environmental, etc. The organisation should also monitor and review these issues, and consider them when defining the scope of the ISMS.
H . This clause requires the organisation to determine the boundaries and applicability of the ISMS to establish its scope15. This clause is relevant to the verification of the scope of the ISMS because it helps the organisation to describe the information and processes that are included in the ISMS, and to document the scope in a clear and concise manner. The organisation should also consider the issues, requirements, and interfaces identified in clauses 4.1, 4.2, and 4.3 when determining the scope of the ISMS, and ensure that the scope is appropriate to the nature and scale of the organisation.
Reference:
1: PECB Candidate Handbook - ISO 27001 Lead Auditor, page 17 2: ISO/IEC 27001:2022 - Information technology - Security techniques - Information security management system s - Requirements, clause 4.2 3: ISO/IEC 27001:2022 - Information technology - Securi ty techniques - Information security management systems - Requirements, clause 5.2 4 : ISO/IEC 27001:2022 - Information technology - Security techniques - Information securi ty management systems - Requirements, clause 4.1 5: ISO/IEC 27001:2022 - Informatio n technology - Security techniques - Information security management systems - Requirements, clause 4.3

**QUESTION NO: 245**
您正在一家提供醫療保健服務的住宅療養院 (ABC) 進行 ISMS 審核。審核計劃的下一步是驗證 ABC
醫療保健行動應用程式開發、支援和生命週期流程的資訊安全性。在審核過程中，您了解到該組織將行動應用程式開發外包給了一家具有 CMMI 5 級、ITSM（ISO/IEC 20000-1)、BCMS (ISO 22301) 和 ISMS (ISO/IEC 27001) 認證。
IT經理介紹了軟體安全管理流程，並將流程總結如下：
行動應用程式開發至少應採用「設計安全」和「預設安全」原則。應具備以下個人資料保護安全功能：
存取控制。
個人資料加密，即高階加密標準（AES）演算法，金鑰長度：256位元；個人資料假名化。
已檢查漏洞，無安全後門
您採樣最新的行動應用測試報告，詳細資訊如下：

| Target of Test: ABC's healthcare mobile app, version 1 | Test results | Test summary |
|---|---|---|
| Security test | | |
| Personal data encryption | Fail | Not able to perform the encryption. |
| Personal data pseudonymisation | Fail | Not able to perform the pseudonymisation. |
| Final approval: | | |
| by: *Service Manager* | | signed |

ACTUAL4TEST.COM

您詢問 IT
經理，為什麼組織仍在使用行動應用程序，而個人資料加密和假名化測試卻失敗了。此外，服務經理是否有權批准測試。
IT經理解釋說，根據軟體安全管理程序，測試結果應由他批准。
加密和假名功能失敗的原因是這些功能嚴重降低了系統和服務效能。需要額外 150%
的資源來滿足這一點。服務經理同意存取控制足夠好並且可以接受。這就是服務經理簽署批准書的原因。
您正在準備審計結果。選擇正確的選項。
**A.**不存在不合格項 (NC)。服務經理做出了繼續提供服務的正確決定。
（與第 8.1 條相關，控制措施 A.8.30）
**B.**存在不合格項 (NC)。組織和開發人員不執行驗收測試。
（與第 8.1 條相關，控制措施 A.8.29）
**C.**存在不合格項 (NC)。組織和開發人員執行的安全測試失敗。
（與第 8.1 條相關，控制措施 A.8.29）
**D.**存在不合格項 (NC)。服務管理員不遵守軟體安全管理程序。（與第 8.1 條相關，控制措施 A.8.30）
***Answer:*** D
Explanation:
The correct option is D. There is a nonconformity (NC). The Service Manager does not comply with the software security management procedure. (Relevant to clause 8.1, control A.8.30). The IT Manager should have approved the test results according to the software

security management procedure, not the Service Manager. The Service Manager's decision to accept the failed security tests also violates the "security-by-design" and "security-by-default" principles that the organization adopted. The other options are either incorrect or irrelevant. The organization and developer did perform acceptance tests, but they failed (B, C). The Service Manager's decision to continue the service does not justify the nonconformity (A). Reference: 1: ISO/IEC 27001:2022, Information technology - Security techniques - Information security management systems - Requirements, Clause 8.1 \n2: PECB Certified ISO/IEC 27001 Lead Auditor Exam Preparation Guide, Domain 5: Conducting an ISO/IEC 27001 audit

**QUESTION NO: 246**
情境 5：Data Grid Inc.
是一家知名公司，為整個資訊科技基礎設施提供安全服務。它提供網路安全軟體，包括端點安全、防火牆和防毒軟體。二十年來，Data Grid Inc.
透過先進的產品和服務幫助多家公司保護其網路安全。 Data Grid Inc.
在資訊和網路安全領域享有盛譽，決定獲得 ISO/IEC 27001
認證，以更好地保護其內部和客戶資產並獲得競爭優勢。
Data Grid Inc. 任命了審計團隊，該團隊同意審計任務的條款。此外，Data Grid Inc.明確了審核範圍，明確了審核標準，並建議在五天內結束審核。由於Data Grid Inc.員工人數眾多，流程複雜，審計小組拒絕了Data Grid Inc.在五天內進行審計的提議。 Data Grid
Inc.堅稱他們計劃在五天內完成審核，因此雙方同意在規定的時間內進行審核。審計小組遵循基於風險的審計方法。
為了獲得主要業務流程和控制的概述，審計團隊存取了流程描述和組織圖表。他們無法對 IT 風險和控制進行更深入的分析，因為他們對 IT
基礎架構和應用程式的存取受到限制。然而，審計小組表示，Data Grid Inc. 的 ISMS 出現重大缺陷的風險很低，因為該公司的大部分流程都是自動化的。因此，他們透過詢問 Data Grid Inc. 的代表以下問題來評估 ISMS 整體上符合標準要求：
*如何定義和指派 IT 和 IT 控制的職責？
*Data Grid Inc. 如何評估控制措施是否達到了預期效果？
*Data Grid Inc. 採取了哪些控制措施來保護操作環境和資料免受惡意軟體的侵害？
*是否實施了與防火牆相關的控制？
Data Grid Inc. 的代表提供了充分且適當的證據來解決所有這些問題。
審計組長起草審計結論並向Data Grid Inc. 的最高管理階層報告。
儘管審核員推薦Data Grid Inc.進行認證，但Data Grid Inc.與認證機構之間在審核目標方面產生了誤解。 Data Grid Inc.
表示，儘管審計目標包括確定潛在改進的領域，但審計團隊並未提供此類資訊。
根據該場景，回答以下問題：
根據情境 5，審核團隊不同意 Data Grid Inc. 針對 ISMS 審核提出的審核持續時間。您如何描述這樣的情況？
**A.**可以接受，如果審核員認為審核持續時間不夠，他們有權反對，甚至拒絕審核授權
**B.**不可接受，審核持續時間由受審核方定義，審核員無法更改
**C.**不可接受，一旦接受審核委託，審核持續時間就無法更改
***Answer:*** A
Explanation:

Auditors have the authority to object or even refuse an audit mandate if they believe that the audit duration proposed by the auditee is not sufficient to thoroughly assess the ISMS. It is crucial for the audit to be comprehensive enough to cover all necessary aspects of the system, ensuring its effectiveness and compliance.

**QUESTION NO: 247**
審核員使用抽樣來確保記錄資訊安全事件的事件日誌得到維護和定期審查。抽樣基於審計目標，而樣本選擇過程基於機率論。使用什麼類型的抽樣？
**A.**統計抽樣
**B.**基於判斷的取樣
**C.**系統抽樣
***Answer:*** A
Explanation:
The use of probability theory in the sample selection process indicates that "statistical sampling" was used. Statistical sampling allows auditors to make inferences about the population based on the properties of the sample, relying on the principles of probability to select representative elements.

**QUESTION NO: 248**
場景 3：Rebuildy
是一家位於泰國曼谷的建築公司，專門從事住宅建築的設計、建造和維護。為了確保敏感專案資料和客戶資訊的安全，Rebuildy 決定實施基於 ISO/IEC 27001 的資訊安全管理系統 (ISMS)。
ISMS 實施成果如下
* 資訊安全是透過應用一系列安全控制和製定政策、流程和程序來實現的。
* 安全控制是根據風險評估實施的，旨在消除風險或將風險降低到可接受的水平。
* 所有流程均基於計劃-執行-檢查-行動 (PDCA) 模型確保 ISMS 的持續改進。
*
資訊安全政策是根據最佳安全實務起草的安全手冊的一部分，因此，它不是一份獨立的文件。
* 資訊安全角色和職責已在每位員工的職位說明中明確說明
* 資訊安全管理系統的管理評審是依照計畫的時間間隔進行的。
Rebuildy
在經歷了兩次中期管理評審和一次年度內部審計後申請了認證。該前員工向審計團隊成員 Electra 提交了書面證據，Rebuildy 的主要客戶 Electra
也提交了有關相同問題的證據，審計員決定保留這份證據，而不是前員工的證據。審計團隊成員一直與 Electra
保持聯繫，直至審計完成，討論審計期間發現的不符合。伊萊克特拉提供了額外的證據來支持這些發現。
在審核開始時，審核小組對公司高階主管進行了訪談，討論了高階主管對 ISMS
實施的承諾等事項。從這些討論中獲得的證據都記錄在書面確認書中，用於確定 Rebuildy
是否符合 ISO/IEC 27001 的幾個條款。其中，發現以下不符合：
* 在公司的財務報告系統中偵測到了不當的使用者存取控制設定實例。
* 尚未建立獨立的資訊安全政策。相反，該公司使用根據最佳安全實踐起草的安全手冊。
在收到審計團隊的這些文件後，團隊負責人會見了 Rebuildy
的高層管理層，介紹了審計結果。審計小組報告了與財務報告系統和缺乏獨立資訊安全政策有

關的調查結果。高階主管對調查結果表示不滿，並認為審計組長的行為不專業，暗示他們可能會要求更換組長。迫於壓力，審計組長決定與高階主管合作，淡化所發現的不符合項的重要性。因此，審計團隊負責人調整了報告以呈現更有利的觀點，從而歪曲了 Rebuildy 合規問題的真實程度。
根據上述情景，回答以下問題：
情境 3 中所描述的哪一種行為顯示審計組長違反了獨立性原則？
**A.**審計組長與高階主管討論了審計結論後，發來了一份有利的報告
**B.**審計團隊在審計報告中納入了前員工的證據，但沒有透露來源
**C.**審計團隊負責人向前員工透露了有關 Rebuildy 的機密信息
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
Independence is compromised when an auditor alters audit findings under pressure.
The audit team leader misrepresented compliance, violating ISO 19011's principles of objectivity and integrity.
B . Incorrect:
Including anonymous evidence in an audit report is acceptable as long as it is verified.
C . Incorrect:
While revealing confidential information would be unethical, it was not mentioned in the scenario.
Relevant Standard Reference:

**QUESTION NO: 249**
a----------
的職責包括促進審核活動、維護後勤、確保遵守健康和安全政策以及代表受審核方見證審核過程。
**A.**內部稽核員
**B.**觀察者
**C.**指南
***Answer:*** C
Explanation:
The responsibilities described fit those of a "guide." A guide in an audit context is typically someone from the auditee's organization who facilitates audit activities, manages logistics, ensures compliance with health and safety policies, and may also witness the audit process, assisting the audit team.

**QUESTION NO: 250**
我們在 ACT 中做什麼 - 來自 PDCA 循環
**A.**採取行動持續監控流程績效
**B.**採取行動持續改善流程績效
**C.**採取行動持續監控流程績效
**D.**採取行動不斷提升人員績效
***Answer:*** B

ACTUAL4TEST.COM

Explanation:
In the Act phase of the PDCA cycle, the process is reviewed and evaluated based on the results from the Check phase. The actions taken in this phase aim to continually improve the process performance by addressing the root causes of problems, implementing corrective and preventive actions, and updating the process documentation1. Reference: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) | CQI | IRCA

**QUESTION NO: 251**
誰可以存取高度機密的文件？
**A.**有業務需要了解的員工
**B.**有業務須知的承包商
**C.**簽署 NDA 的員工有業務須知
**D.**指定具有核准存取權限並已簽署 NDA 的非員工
***Answer:*** A
Explanation:
According to ISO/IEC 27001:2022, clause 8.2.1, the organization shall ensure that access to information and information processing facilities is limited to authorized users based on the access control policy and in accordance with the business requirements of access control2. Therefore, only employees with a business need-to-know are allowed to access highly confidential files, and not contractors, non-employees or employees with signed NDA. Reference: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) | CQI | IRCA

**QUESTION NO: 252**
一個組織正在評估其 ISMS
中不同流程的重要性。它正在評估與人員、第三方服務和一般費用相關的直接費用。公司主要考慮哪些重要性因素？
**A.**營運成本
**B.**流程的成本
**C.**錯誤或不合規的潛在成本
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:
The organization is focusing on direct costs associated with running specific processes. "Personnel, third-party services, and general fees" refer to operational costs of specific processes, not overall business operations.
A . Incorrect:
Cost of operations refers to the total business expenses, not individual processes.
C . Incorrect:
Potential cost of errors relates to risk assessment and impact analysis, not direct expenses.
Relevant Standard Reference:

**QUESTION NO: 253**
場景七：Webvue。總部位於日本，是一家專門從事電腦軟體開發、支援和維護的技術公司。

Webvue 提供跨各個技術領域和業務領域的解決方案。其旗艦服務是 CloudWebvue，一個提供儲存、網路和虛擬運算服務的綜合雲端運算平台。專為企業和個人用戶設計。 CloudWebvue 以其靈活性、可擴展性和可靠性而聞名。
Webvue 決定僅將 CloudWebvue 納入其 ISO/IEC 27001 認證範圍。因此，第 1 階段和第 2 階段審計同時進行 Webvue
以其對資產保密的嚴格性而自豪，他們使用適當的加密控制來保護儲存在 CloudWebvue 中的資訊。任何機密級別的每條信息，無論是否供內部使用。受限的或機密的資訊首先用唯一的對應哈希值加密，然後儲存在雲端。肖恩。萊拉，山姆。和 Tin a。 Keith 是 IT 和資訊安全審計團隊中最有經驗的審計員，也是審計團隊的負責人。他的職責包括規劃審計和管理審計團隊。尚實踐生成的。在檢查了 Webvue 的加密政策後，他們得出結論，採訪中獲得的資訊是真實的。然而，由於該策略沒有解決加密金鑰的使用和壽命問題，因此加密金鑰仍在使用中。
依照 Webvue 和認證機構後來達成的協議，審計團隊選擇進行虛擬審計，專門專注於驗證 Webvue 是否符合 ISO/IEC 27001 的控制 8.11
資料屏蔽，以符合認證範圍和審計目標。他們檢查了 CloudWebvue 中保護資料所涉及的流程。重點關注公司如何遵守其政策和監管標準。作為此過程的一部分。審計團隊負責人 Keith 對相關文件和加密金鑰管理程序進行了截圖，以記錄和分析 Webvue 實踐的有效性。
Webvue 使用產生的測試資料用於測試目的。然而，根據與 QA 部門經理的訪談以及該部門使用的程序確定，有時會使用即時系統資料。在這樣的場景中，會產生大量數據，同時產生更準確的結果。測試資料受到保護和控制，這透過 Webvue 人員在審計期間執行的加密過程模擬得到驗證。儘管不在審計範圍之內，但安全培訓部門的不合規情況可能會對審計範圍內的流程產生影響，具體會影響 CloudWebvue 中的資料安全和加密實踐。因此，Keith將此發現納入審計報告中，並告知被審計方。
根據上述情景，回答以下問題：
根據場景 7，哪一種稽核程序用來驗證測試資料的使用是否符合要求？

**A.**記錄資訊審查

**B.**確證

**C.**技術驗證

***Answer:*** C

Explanation:
Comprehensive and Detailed In-Depth
C . Correct Answer:
Technical verification involves directly testing or simulating controls.
Webvue's personnel simulated the encryption process, confirming test data security measures.
A . Incorrect:
Document review is passive, while technical verification is active and includes real-time assessments.
B . Incorrect:
Corroboration is about cross-checking information, whereas technical verification tests controls in practice.
Relevant Standard Reference:

**QUESTION NO: 254**

場景 8：苔絲
一個。 Malik 和 Michael
是一個由安全、合規以及業務規劃和策略領域的獨立且合格的專家組成的審計團隊。他們被指派到一家大型網頁設計公司Clastus進行認證審核。他們在進行審計時表現出了出色的職業道德，包括公正和客觀。這一次，Clastus 確信，如果獲得 ISO/IEC 27001
認證，他們將領先一步。
審計團隊負責人 Tessa 擁有審計專業知識，並且在 IT
相關問題、合規性和治理方面擁有非常成功的背景。馬利克擁有組織規劃和風險管理背景。他的專業知識依賴於對組織的安全控制及其風險承受能力的綜合和分析水平，以準確描述組織內部的風險水平 另一方面，Michael
是通過遵循嚴格的標準化程序進行控制評估的實際安全性的專家。
在執行所需的審計活動後，泰莎發起了一次審計團隊會議，他們分析了邁克爾的一項發現，以客觀、準確地就該問題做出決定。 Michael
遇到的問題是組織日常運作中的一個小問題，他認為這是由組織的一名 IT
技術人員造成的，因此，Tessa
會見了高層管理人員，並在他們詢問了責任人姓名後，告訴他們誰應該對這一問題負責，為了方便澄清和理解，Tessa 在審核的最後一天召開了結束會議。在這次會議上，她向 Clastus
管理層報告了發現的不符合情況。然而，Tessa 收到建議，避免在 Clastus
認證審核的審核報告中提供不必要的證據，確保報告保持簡潔並專注於關鍵發現。
根據審查的證據，審核小組起草了審核結論，並決定在授予認證之前必須對該組織的兩個領域進行審核。這些決定後來被提交給被審計方，但被審計方不接受調查結果並提議提供更多資訊。儘管受審計方提出了意見，但審計員已經決定接受認證建議，因此沒有接受補充資訊。被審計單位的高階主管堅持審計結論並不代表事實，但審計小組仍堅持他們的決定。
根據上述情景，回答以下問題：
審計小組沒有接受Clastus的補充訊息，因為他們已經提出了認證建議。這可以接受嗎？
**A.**是的，一旦審核團隊決定認證建議，他們就不能接受任何其他信息
**B.**否，如果受審核方不同意認證建議，可以提供更多信息
**C.**不，審核員不應在認證建議決定中考慮與受審核方討論後產生的修訂
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct answer:
ISO 19011:2018 (Guidelines for Auditing) requires auditors to consider all relevant evidence before making a final recommendation.
Clastus has the right to present additional evidence if they disagree with findings.
A . Incorrect:
Certification recommendations should remain open to valid new evidence until officially finalized.
C . Incorrect:
Auditors must consider revisions if they provide relevant clarification or evidence.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.6.3 (Handling Disputes and Additional Evidence in Audits)

**QUESTION NO: 255**
所有資訊資產的可接受使用均被禁止，但以下情況除外：

**A.**電子連鎖信
**B.**透過電子郵件將副本發送給非必要讀者
**C.**經過主管/TL 許可的公司範圍內的電子郵件。
**D.**帶有非常大附件或發送給大量收件者的郵件。
***Answer:*** C
Explanation:
The only option that is not prohibited in acceptable use of information assets is C: company-wide e-mails with supervisor/TL permission. This option implies that the sender has obtained the necessary authorization from their supervisor or team leader to send an e-mail to all employees in the organization. This could be done for legitimate business purposes, such as announcing important news, events or updates that are relevant to everyone. However, this option should still be used sparingly and responsibly, as it could cause unnecessary disruption or annoyance to the recipients if abused or misused. The other options are prohibited in acceptable use of information assets, as they could violate the information security policies and procedures of the organization, as well as waste resources and bandwidth. Electronic chain letters (A) are messages that urge recipients to forward them to multiple other people, often with false or misleading claims or promises. They are considered spam and could contain malicious links or attachments that could compromise information security. E-mail copies to non-essential readers (B) are messages that are sent to recipients who do not need to receive them or have no interest in them. They are considered unnecessary and could clutter the inbox and distract the recipients from more important messages. Messages with very large attachments or to a large number of recipients (D) are messages that consume a lot of network resources and could affect the performance or availability of the information systems. They could also exceed the storage capacity or quota limits of the recipients' mailboxes and cause problems for them. ISO/IEC 27001:2022 requires the organization to implement rules for acceptable use of assets (see clause A.8.1.3). Reference: CQI & IRCA Certified ISO/IEC 27001:2022 Lead Auditor Training Course, ISO/IEC 27001:2022 Information technology - Security techniques - Informatio n security management systems - Requirements, What is Acceptable Use?

**QUESTION NO: 256**
預測分析如何幫助審計師識別潛在風險？
**A.**透過提供即時財務數據分析
**B.**根據趨勢預測未來結果
**C.**透過組織來自各種來源的數據
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B: Correct Answer:
Predictive analytics uses historical data, machine learning, and statistical models to predict future risk events.
It identifies patterns in security incidents, financial trends, and operational failures to anticipate risks before they occur.
A: Incorrect:
Real-time analysis is part of monitoring, but predictive analytics focuses on forecasting risks,

not just real-time reporting.
C: Incorrect:
Data organization is essential but does not involve forecasting risks.
Relevant Standard Reference:
ISO 31000:2018 (Risk Management - Guidelines on Using Data Analytics in Risk Assessment)

**QUESTION NO: 257**
您是審核小組組長，對電信服務供應商進行第三方監督審核。您已將審核組織的資訊安全目標的責任分配給審核團隊的初級成員。在他們開始評估之前，您可以問他們以下問題來檢查他們對 ISO 要求的理解
/IEC 27001:2022。
資訊安全目標必須符合下列哪四項標準？
**A.**必須適當地溝通
**B.**它們必須作為記錄資訊提供
**C.**必須始終對其進行測量
**D.**必須始終對其進行監控
**E.**必須每年進行審核
**F.**它們必須清晰明確
**G.**它們必須符合 IS 政策
**H.**它們必須是可實現的
***Answer:*** A,B,G,H
Explanation:
According to ISO/IEC 27001:2022, clause 6.2, information security objectives are the specific results that an organisation intends to achieve with its information security management system (ISMS). The standard specifies that information security objectives must fulfil the following criteria:
They must be communicated appropriately (A): The organisation must ensure that the relevant internal and external parties are informed about the information security objectives and their roles and responsibilities in achieving them. This can help to create awareness, commitment, and accountability for information security. This criterion is related to clause 6.2.2 of ISO/IEC 27001:2022.
They must be available as documented information (B): The organisation must maintain and retain documented information on the information security objectives, including their scope, level, indicators, and time frame. This can help to provide evidence, traceability, and consistency for information security. This criterion is related to clause 6.2.1 of ISO/IEC 27001:2022.
They must be consistent with the IS Policy (G): The organisation must ensure that the information security objectives are aligned with the information security policy, which is the top-level statement of the organisation's intentions and direction for information security. This can help to support the strategic objectives and the context of the organisation. This criterion is related to clause 5.2 of ISO/IEC 27001:2022.
They must be achievable (H): The organisation must ensure that the information security objectives are realistic and attainable, considering the available resources, capabilities, and constraints. This can help to avoid setting unrealistic or unfeasible expectations and to

ACTUAL4TEST.COM

monitor and measure the progress and performance of information security. This criterion is related to clause 6.2.1 of ISO/IEC 27001:2022.
Reference:
ISO/IEC 27001:2022, Information technology - Security techniques - Information securit y management systems - Requirements1 PECB Candidate Handbook ISO/IEC 27001 Lead Auditor2 ISO 27001:2022 Lead Auditor - PECB3 ISO 27001:2022 certified ISMS lead auditor - Jisc4 ISO/IEC 27001:2022 Lead Auditor Transition Training Course5 ISO 27001 - Information Security Lead Auditor Course - PwC Training Academy6

**QUESTION NO: 258**
您正在國際物流組織的出貨部門進行資訊安全管理系統審核，該組織為當地醫院和政府辦公室等大型組織提供運輸服務。
包裹通常包含藥品、生物樣本以及護照和駕駛執照等文件。
您注意到公司記錄顯示大量退貨，原因包括標籤地址錯誤，以及在 15% 的情況下，一個包裹的不同地址有兩個或多個標籤。您正在面試運輸經理 (SM)。
您：出貨前檢查過嗎？
SM：任何明顯損壞的物品都會在出貨前由值班人員移除，但利潤微薄，因此實施正式檢查流程並不經濟。
您：退貨後會採取什麼措施？
SM：這些合約大多價值相對較低，因此我們認為，簡單地重新列印標籤並重新發送單一包裹比實施調查更容易、更方便。
您提出了不符合 ISO 27001:2022 第 8.1 條的要求。
以下哪一項最能描述您發現的不合格項？
**A.**組織沒有經過批准的流程來確保滿足資料保護的服務要求和監管要求。記錄顯示，15%的退回包裹已更正了收件人的另一方資訊（可能包括敏感的醫療資訊或政府部門通訊資訊），但沒有足夠的操作方法來滿足資訊安全要求。
**B.**組織沒有適當的審核流程來確保滿足資料保護的服務要求和監管要求。記錄顯示，15% 的退回包裹中包含不準確的資訊（可能包括敏感的醫療資訊或政府部門通訊資訊），且沒有足夠的操作規則來滿足資訊安全要求。
**C.**組織沒有有效的流程來確保滿足資料保護的服務要求和監管要求。記錄顯示，15% 的退回包裹向收件人洩露了供另一方使用的資訊（可能包括敏感的醫療資訊或政府部門通訊資訊），而沒有足夠的操作控制來滿足資訊安全要求。
**D.**組織沒有有效的流程來確保滿足資料保護的服務要求和監管要求。記錄顯示，15% 的退回包裹包含向收件人另一方提供的詳細資訊（可能包括敏感的醫療資訊或政府部門通訊資訊），但沒有足夠的操作程序來滿足資訊安全要求。
**E.**組織沒有有效的流程來確保滿足資料保護的服務要求和監管要求。記錄顯示，15% 的退回包裹包含受保護的資訊（可能包括敏感的醫療資訊或政府部門通訊資訊），但沒有足夠的操作流程來滿足資訊安全要求。
***Answer:*** C
Explanation:
The non-conformity you have identified relates to the organization's failure to implement adequate operational controls to ensure that service and regulatory requirements for data protection are met. This situation is particularly critical given the nature of the items being shipped, which include sensitive medical information and government documents. The fact that 15% of returned parcels have labels for different addresses, potentially exposing

sensitive information to incorrect recipients, underscores the lack of effective information security practices.
The best description of the non-conformity, based on the details provided and the requirements of ISO/IEC 27001:2022, particularly clause 8.1 which deals with operational planning and control, would be:
C . The organisation does not have an effective process in place that ensures service requirements and regulatory requirements for data protection are met. Records show that 15% of returned parcels have disclosed information intended for another party to the recipient (which may include sensitive medical information or government department communications) without adequate operational controls to meet information security requirements.
This option accurately captures the essence of the non-conformity by highlighting the lack of effective operational controls to protect sensitive information, leading to potential unauthorized disclosure of information intended for another party. This is a direct violation of information security management principles, particularly those related to the protection of confidentiality and integrity of information as mandated by ISO/IEC 27001:2022.

**QUESTION NO: 259**
下列哪一項最能描述第二階段審核的目的？
**A.**檢查組織是否遵守法律
**B.**確保審核計畫得到執行
**C.**評估管理系統的實施情況
**D.**了解組織的流程
***Answer:*** C
Explanation:
The purpose of a Stage 2 audit is to evaluate the implementation of the management system, in this case, the ISMS, according to the requirements of ISO/IEC 27001:2022 and the organisation's own policies and procedures. The Stage 2 audit involves collecting evidence of the effectiveness and performance of the ISMS, as well as verifying the conformity and suitability of the organisation's controls. The Stage 2 audit also assesses the organisation's ability to achieve its information security objectives and to manage information security risks.
Reference: = ISO/IEC 27006:2022, clause 9.2.2.2; PECB Candidate Handbook ISO 27001 Lead Auditor, page 28.

**QUESTION NO: 260**
您正在進行 ISMS
審核。審計計劃的下一步是驗證組織的資訊安全風險處理計劃是否已製定並正確實施。您決定採訪 IT 安全經理。
您：能否請您解釋一下組織是如何進行資訊安全風險評估和處理流程的？
IT 安全經理：我們遵循資訊安全風險管理程序，產生風險處理計劃。
旁白：您回顧了第 123
號風險處理計劃，該計劃涉及計劃安裝電子（隱形）圍欄，以提高療養院的物理安全。您發現風險處理計劃已獲得 IT 安全經理的批准。
您：誰要為實體安全風險負責？
IT 安全經理：設施經理負責實體安全風險。

IT部門幫助他們監控警報。授權設施經理批准123號風險處理計畫的預算。
您：123號風險處置預案實施後，還有哪些資訊安全風險殘留？
IT安全經理：據我了解，目前還沒有關於殘留資訊安全風險接受的資訊。
您準備您的審計結果。為場景中合理的發現選擇三個選項。
**A.**不合格（NC） - 風險處理實施後，應更新殘餘資訊安全風險的接受資訊。第 6.1.3.f 條
**B.**有一個改進機會 (OI)，可以對週邊圍欄進行安全檢查
**C.**一旦安裝了電子（隱形）圍欄，就有改進的機會（OI）。
居民人身安全得到改善
**D.**不合格 (NC) - 最高管理階層必須確保 ISMS 所需的資源可用。第 5.1.c 條
**E.**不合格 (NC) - IT 安全經理應該意識到並理解他的權限和責任範圍。第7.3條
**F.**不合格 (NC) - 組織應提供持續改善 ISMS 所需的資源。第 7.1 條
**G.**不合格 (NC) - 第 123 號風險處理計畫應由風險負責人（在本例中為設施經理）批准。第 6.1.3.f 條
**H.**採用最先進的技術作為持續改進流程的一部分是良好的做法
***Answer:*** A,E,G
Explanation:
The three options for findings that are justified in the scenario are:
* Nonconformity (NC) - The information for the acceptance of residual information security risks should be updated after the risk treatment is implemented. Clause 6.1.3.f
* Nonconformity (NC) - The IT security manager should be aware of and understand his authority and area of responsibility. Clause 7.3
* Nonconformity (NC) - The risk treatment plan No. 123 should be approved by the risk owner, the Facility Manager in this case. Clause 6.1.3.f According to ISO/IEC 27001:2022, clause 6.1.3.f, the organisation must retain documented information that includes the information for the acceptance of residual information security risks, and the approval of the risk treatment plan by the risk owner1. Therefore, option A and G are justified as nonconformities, because the organisation failed to update the information for the acceptance of residual risks, and the risk treatment plan was approved by the IT security manager, who is not the risk owner. According to ISO/IEC 27001:2022, clause 7.3, the organisation must ensure that the persons assigned to perform the roles and responsibilities for the ISMS are competent, and are aware of the consequences of not conforming to the ISMS requirements2. Therefore, option E is justified as a nonconformity, because the IT security manager, who is responsible for the information security risk management process, was not aware of his authority and area of responsibility.
The other options are not justified as findings, because they are either irrelevant or incorrect. For example:
* Option B is irrelevant, because it is not related to the information security risk treatment plan No. 123, which is the focus of the audit.
* Option C is incorrect, because it is not an opportunity for improvement, but rather a benefit of the risk treatment plan No. 123, which is already implemented.
* Option D is incorrect, because it is not a nonconformity, but rather a requirement for the organisation to provide the resources needed for the ISMS, which is not the same as the resources needed for the risk treatment plan No. 123.
* Option F is incorrect, because it is not a nonconformity, but rather a requirement for the

organisation to provide the resources needed for the continual improvement of the ISMS, which is not the same as the resources needed for the risk treatment plan No. 123.
* Option H is irrelevant, because it is not a finding, but rather a good practice, which is not the objective of the audit.

**QUESTION NO: 261**
審核員需要與受審核方進行有效溝通。因此，他們的個人行為是確保審計成功所需的關鍵特徵。以下是其特徵和相關的簡要描述。將特徵與描述相符。

| Descriptions | Auditor's characteristics |
|---|---|
| Actively observing surroundings/activities | |
| Fair, truthful, sincere, honest, discreet | |
| Persistent and focused on objectives | |
| Willing to learn from situations | |
| Tactful in dealing with individuals | |
| Aware of and able to understand situations | |

*To complete the table click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable text from the options below. Alternatively, you may drag and drop each option to the appropriate blank section.*

Tenacious | Ethical | Diplomatic | Observant | Perceptive | Open to improvement

***Answer:***

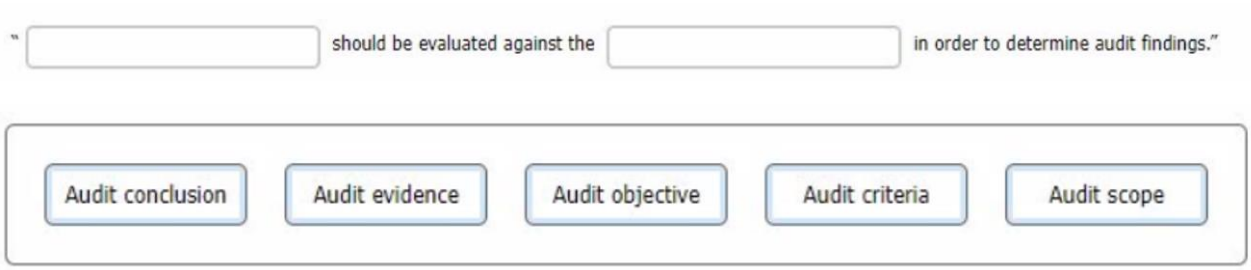
| Descriptions | Auditor's characteristics |
|---|---|
| Actively observing surroundings/activities | Observant |
| Fair, truthful, sincere, honest, discreet | Ethical |
| Persistent and focused on objectives | Tenacious |
| Willing to learn from situations | Open to improvement |
| Tactful in dealing with individuals | Diplomatic |
| Aware of and able to understand situations | Perceptive |

*To complete the table click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable text from the options below. Alternatively, you may drag and drop each option to the appropriate blank section.*

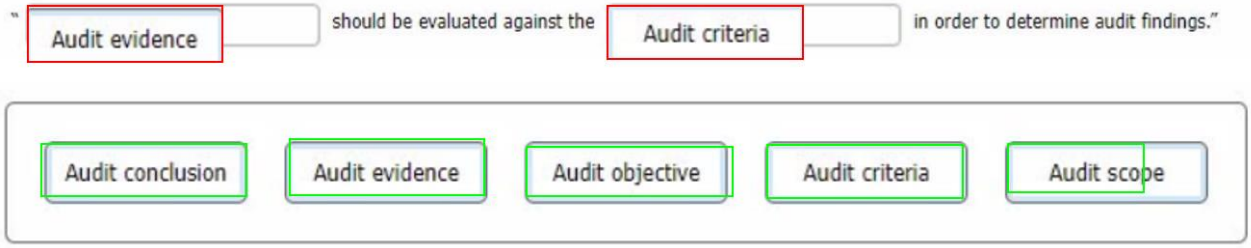
Tenacious | Ethical | Diplomatic | Observant | Perceptive | Open to improvement

ACTUAL4TEST.COM

**QUESTION NO: 262**
關於產生審計結果，請選擇最能完成以下句子的單字。
要使用最佳單字完成句子，請按一下要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，您可以將該選項拖曳到適當的空白部分。




***Answer:***




Reference:
ISO 19011:2022 Guidelines for auditing management systems
ISO/IEC 27001:2022 Information technology - Security techniques - Information securit y management systems - Requirements Components of Audit Findings - The Institute o f Internal Auditors

**QUESTION NO: 263**
資訊階段
**A.**創造、演化、維護、使用、處置
**B.**建立、使用、處置、維護、演變
**C.**建立、分發、使用、維護、處置
**D.**建立、分發、維護、處置、使用
***Answer:*** C
Explanation:
The stages of information are creation, distribution, use, maintenance, and disposition. These are the phases that information goes through during its lifecycle, from the moment it is generated to the moment it is destroyed or archived. Each stage of information has different security requirements and risks, and should be managed accordingly. Creation, evolution, maintenance, use, and disposition are not the correct stages of information, as evolution is not a distinct stage, but a process that can occur in any stage. Creation, use, disposition, maintenance, and evolution are not the correct stages of information, as they are not in the right order. Creation, distribution, maintenance, disposition, and use are not the correct stages of information, as they are not in the right order. Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 32. : [ISO/IEC 27001 LEAD AUDITOR - PECB], page 12.

**QUESTION NO: 264**
您是一位經驗豐富的 ISMS
審核團隊負責人，目前正在對新客戶進行第三方初始認證審核，使用 ISO/IEC 27001：2022 作為標準。

ACTUAL4TEST.COM

這是為期兩天的審計的第二天下午，您正要開始撰寫審計報告。到目前為止還沒有發現任何不符合項，而且您和您的團隊對該網站和組織的資訊安全管理系統印象深刻。
此時，您的團隊中的一名成員找到您並告訴您，她無法完成對領導力和承諾的評估，因為她花了太長時間審查變更計劃。
針對此訊息，您將採取下列哪一種行動？
**A.**向客戶道歉並告訴他們您將稍後回來審查領導能力和承諾。
**B.**向客戶建議，如果他們準備將您的回程航班升級為頭等艙，您將明天在自己的時間內審核領導力和承諾。
**C.**告知受審計方和審計客戶目前無法做出積極的建議。
**D.**通知受審核方需要終止並重新安排認證審核。
**E.**聯絡管理審計計劃的個人並尋求他們的許可，在審計報告中記錄積極的建議。
**F.**聯絡您的總部並等待他們關於如何進行的進一步指示。
**G.**鑑於未發現任何不符合項，且組織的整體印象良好，請在審核報告中記錄積極的認證建議。
***Answer:*** C
Review the audit plan and client availabilities to determine whether there is any opportunity for another member of your team to pick up this task before the closing meeting.
Explanation:
Leadership and commitment is a key requirement of ISO/IEC 27001:2022, as it establishes the top management's role and responsibility in establishing, implementing, maintaining, and continually improving the ISMS. Without assessing this aspect, the audit team cannot conclude that the ISMS is effective and conforms to the standard. Therefore, the audit team leader should advise the auditee and audit client that it is not possible to make a positive recommendation at this point, and explain the reason and the implications. The audit team leader should also consult with the certification body and the audit programme manager on the next steps, such as extending the audit duration, conducting a follow-up audit, or issuing a conditional certification, depending on the certification body's policy and the audit client's agreement. Reference: = ISO/IEC 27001:2022, clause 5, Leadership PECB Candidate Handbook ISO 27001 Lead Auditor, page 19, Audit Process PECB Candidate Handbook ISO 27001 Lead Auditor, page 22, Audit Report PECB Candidate Handbook ISO 27001 Lead Auditor, page 23, Audit Conclusion and Recommendation

**QUESTION NO: 265**
管理體系審核的目的是？選擇1
**A.**評估組織管理系統的績效
**B.**提升組織管理系統的績效
**C.**管理組織管理系統的績效
**D.**研究組織管理系統的績效
***Answer:*** A
Explanation:
A management system audit is a systematic, independent and documented process for obtaining objective evidence and evaluating it objectively to determine the extent to which the audit criteria are fulfilled. The audit criteria are a set of requirements that may include policies, procedures, standards, regulations, etc. The purpose of a management system audit is to evaluate the performance of an organisation's management system in terms of its

effectiveness, efficiency, compliance, and improvement. A management system audit can also identify strengths, weaknesses, opportunities, and risks of the management system and provide recommendations for improvement.

**QUESTION NO: 266**
審核員在確定 (2)-------- 時應考慮 (1)--------
**A.**（1）標準要求。（二）審核標準
**B.**(1) 稽核風險，(2) 稽核目標
**C.**(1) 與違法行為相關的處罰，(2) 重要性
***Answer:*** B
Explanation:
The auditor should consider "audit risks" when determining the "audit objectives." Understanding the risks associated with the audit helps define the objectives clearly, ensuring that the audit focuses on the most significant areas of concern, aligns with the audit scope, and adequately addresses the risks identified.

**QUESTION NO: 267**
在審計的哪個階段，審計師會決定需要審計的關鍵流程並根據重要性決定優先順序？
**A.**初次接觸
**B.**第一階段審計
**C.**第二階段審計
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:
The Stage 1 audit (preliminary assessment) focuses on understanding the organization and its processes, identifying key areas for in-depth auditing in Stage 2.
Materiality-based prioritization occurs in Stage 1 to ensure the Stage 2 audit focuses on critical areas.
A . Incorrect:
Initial contact is only for scheduling and preliminary discussions.
C . Incorrect:
By Stage 2, the key areas should already be identified and the focus is on detailed auditing.
Relevant Standard Reference:

**QUESTION NO: 268**
下列哪兩項敘述是正確的？
**A.**實施 ISMS 的好處主要來自於資訊安全風險的降低
**B.**認證 ISMS 的好處是獲得政府機構的合同
**C.**ISMS 的目的在於應用風險管理流程來維護資訊安全
**D.**ISMS 的目的在於證明符合監管要求
***Answer:*** A,C
Explanation:
The benefits of implementing an ISMS are not limited to a reduction in information security

risks, but also include improved business performance, customer satisfaction, legal compliance, and stakeholder confidence. The benefit of certifying an ISMS is not only to obtain contracts from governmental institutions, but also to demonstrate the organisation's commitment to information security to other potential customers, partners, and regulators. The purpose of an ISMS is to apply a risk management process for preserving information security, which means identifying, analysing, evaluating, treating, monitoring, and reviewing the information security risks that the organisation faces. The purpose of an ISMS is not to demonstrate compliance with regulatory requirements, but rather to ensure that the organisation meets its own information security objectives and obligations.
Reference:
ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) objectives and content from Quality.org and PECB ISO/IEC 27001:2013 Information technology - Security techniques - Information security management systems - Requirements [Section 0.1 ] and [Section 1]

**QUESTION NO: 269**
下列哪兩個是「確實」涉及人際互動的審核方法的範例？
**A.**對程序進行獨立審查以準備審核
**B.**檢討受審核方對審核結果的回應
**C.**透過遠端存取被審核方的伺服器來分析數據
**D.**觀察遠端監控執行的工作
**E.**透過遠端存取被審核方伺服器分析數據
***Answer:*** A,B
Explanation:
Audit methods are techniques used by auditors to obtain audit evidence. Audit methods can be classified into two categories: those that involve human interaction and those that do not2. Audit methods that involve human interaction require direct communication between the auditor and the auditee or other relevant parties, such as interviews, questionnaires, surveys, meetings, etc. Audit methods that do not involve human interaction rely on observation, inspection, measurement, testing, sampling, analysis, etc., without requiring any verbal or written exchange2. Therefore, performing an independent review of procedures in preparation for an audit and reviewing the auditee's response to an audit finding are examples of audit methods that involve human interaction, as they require reading and evaluating documents provided by the auditee or other sources. On the other hand, analysing data by remotely accessing the auditee's server and observing work performed by remote surveillance are examples of audit methods that do not involve human interaction, as they do not require any direct communication with the auditee or other parties. Reference: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) | CQI | IRCA

**QUESTION NO: 270**
在第二階段審核的開幕會議上，客戶組織的總經理邀請審核團隊觀看 45 分鐘的新公司影片。審核組長應做出下列哪兩項回應？
**A.**建議總經理審計團隊必須遵守計畫的時間表
**B.**說明審核組長將在開幕會議後留下來代表團隊觀看視頻
**C.**邀請總經理當晚到審計師下榻的飯店參觀。

**D.**建議可以在茶歇期間觀看該視頻
**E.**說明審核小組將在稍後對觀看做出決定
**F.**通知總經理審計團隊同意他的請求
***Answer:*** A,D
Explanation:
According to ISO 19011:2018, which provides guidelines for auditing management systems, an opening meeting is a formal communication between the audit team and the auditee at the start of an audit1. The purpose of the opening meeting is to confirm the audit objectives, scope and criteria, introduce the audit team and their roles, confirm the audit plan and logistics, explain the audit methods and procedures, and establish the communication channels1. Therefore, if the Managing Director of the client organization invites the audit team to view a new company video lasting 45 minutes during the opening meeting of a Stage 2 audit, the audit team leader should respond in a way that does not compromise the effectiveness and efficiency of the audit or create any misunderstanding or conflict with the auditee. Two possible ways to respond are to advise the Managing Director that the audit team has to keep to the planned schedule, as there may be limited time and resources available for the audit; or to suggest that the video could be viewed during a refreshment break, if it is relevant and useful for the audit and does not interfere with other audit activities1. The other options are not appropriate responses for the audit team leader to make in this situation. For example, stating that the audit team leader will stay behind after the opening meeting to view the video on behalf of the team may imply that the video is not important or relevant for the rest of the audit team; inviting the Managing Director to the auditors' hotel for a viewing that evening may create an impression of bias or favouritism; stating that the audit team will make a decision on the viewing at a later time may be vague or indecisive; and advising the Managing Director that the audit team agrees to his request may result in wasting valuable audit time or losing focus on the audit objectives1. Reference: ISO 19011:2018 - Guidelines for auditing management systems

**QUESTION NO: 271**
場景 8：苔絲
一個。 Malik 和 Michael
是一個由安全、合規以及業務規劃和策略領域的獨立且合格的專家組成的審計團隊。他們被指派到一家大型網頁設計公司Clastus進行認證審核。他們在進行審計時表現出了出色的職業道德，包括公正和客觀。這一次，Clastus 確信，如果獲得 ISO/IEC 27001
認證，他們將領先一步。
審計團隊負責人 Tessa 擁有審計專業知識，並且在 IT
相關問題、合規性和治理方面擁有非常成功的背景。馬利克擁有組織規劃和風險管理背景。他的專業知識依賴於對組織的安全控制及其風險承受能力的綜合和分析水平，以準確描述組織內部的風險水平 另一方面，Michael
是通過遵循嚴格的標準化程序進行控制評估的實際安全性的專家。
在執行所需的審計活動後，泰莎發起了一次審計團隊會議，他們分析了邁克爾的一項發現，以客觀、準確地就該問題做出決定。 Michael
遇到的問題是組織日常運作中的一個小問題，他認為這是由組織的一名 IT
技術人員造成的，因此，Tessa
會見了高層管理人員，並在他們詢問了責任人姓名後，告訴他們誰應該對這一問題負責，為了

方便澄清和理解，Tessa 在審核的最後一天召開了結束會議。在這次會議上，她向 Clastus 管理層報告了發現的不符合情況。然而，Tessa 收到建議，避免在 Clastus 認證審核的審核報告中提供不必要的證據，確保報告保持簡潔並專注於關鍵發現。
根據審查的證據，審核小組起草了審核結論，並決定在授予認證之前必須對該組織的兩個領域進行審核。這些決定後來被提交給被審計方，但被審計方不接受調查結果並提議提供更多資訊。儘管受審計方提出了意見，但審計員已經決定接受認證建議，因此沒有接受補充資訊。被審計單位的高階主管堅持審計結論並不代表事實，但審計小組仍堅持他們的決定。
根據上述情景，回答以下問題：
誰主要負責審計報告的編制和內容？

**A.**審計團隊負責人

**B.**審計團隊成員

**C.**認證機構

***Answer:*** A

Explanation:
Comprehensive and Detailed In-Depth
A . Correct answer:
ISO 19011:2018 states that the audit team leader is responsible for compiling and finalizing the audit report.
B . Incorrect:
Team members contribute findings, but the leader ensures finalization.
C . Incorrect:
The certification body reviews but does not prepare the report.
Relevant Standard Reference:

**QUESTION NO: 272**

場景 8：苔絲
一個。 Malik 和 Michael
是一個由安全、合規以及業務規劃和策略領域的獨立且合格的專家組成的審計團隊。他們被指派到一家大型網頁設計公司Clastus進行認證審核。他們在進行審計時表現出了出色的職業道德，包括公正和客觀。這一次，Clastus 確信，如果獲得 ISO/IEC 27001 認證，他們將領先一步。
審計團隊負責人 Tessa 擁有審計專業知識，並且在 IT 相關問題、合規性和治理方面擁有非常成功的背景。馬利克擁有組織規劃和風險管理背景。他的專業知識依賴於對組織的安全控制及其風險承受能力的綜合和分析水平，以準確描述組織內部的風險水平 另一方面，Michael 是通過遵循嚴格的標準化程序進行控制評估的實際安全性的專家。
在執行所需的審計活動後，泰莎發起了一次審計團隊會議，他們分析了邁克爾的一項發現，以客觀、準確地就該問題做出決定。 Michael 遇到的問題是組織日常運作中的一個小問題，他認為這是由組織的一名 IT 技術人員造成的，因此，Tessa 會見了高層管理人員，並在他們詢問了責任人姓名後，告訴他們誰應該對這一問題負責，為了
方便澄清和理解，Tessa 在審核的最後一天召開了結束會議。在這次會議上，她向 Clastus 管理層報告了發現的不符合情況。然而，Tessa 收到建議，避免在 Clastus 認證審核的審核報告中提供不必要的證據，確保報告保持簡潔並專注於關鍵發現。
根據審查的證據，審核小組起草了審核結論，並決定在授予認證之前必須對該組織的兩個領域

進行審核。這些決定後來被提交給被審計方，但被審計方不接受調查結果並提議提供更多資訊。儘管受審計方提出了意見，但審計員已經決定接受認證建議，因此沒有接受補充資訊。被審計單位的高階主管堅持審計結論並不代表事實，但審計小組仍堅持他們的決定。
根據上述情景，回答以下問題：
建議 Tessa 避免在 Clastus 認證審核的審核報告中提供不必要的證據。推薦這個嗎？
**A.**是的，以避免包含可能危及審計機密性的信息
**B.**是的，為了簡化報告以便於更好地理解
**C.**否，為了確保考慮並處理所有相關證據
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct answer:
ISO 19011:2018 requires audit reports to include all relevant evidence supporting audit conclusions.
Omitting evidence for conciseness undermines transparency and credibility.
A . Incorrect:
Audit confidentiality is protected through controlled access, not by omitting evidence.
B . Incorrect:
Clarity is important, but not at the expense of completeness.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.7 (Audit Reporting Best Practices)

**QUESTION NO: 273**
您是一位經驗豐富的 ISMS
審核團隊負責人，負責對專門從事機密文件和可移動媒體安全處置的組織進行第三方認證審核。文件和媒體都被軍用級設備粉碎，因此無法重建原始文件。
審核進展順利，距離末次會議還有 30
分鐘，您正要開始撰寫審核報告。此時，組織的一名員工敲響了您的門，詢問是否可以與您交談。他們告訴您，當事情變得繁忙時，她的經理會告訴她使用較低等級的工業碎紙機，因為該組織擁有更多此類碎紙機並且運行速度更快。受審核方沒有告知您這些機器的存在或使用情況。
選擇三個選項來決定您應如何回應此訊息。
**A.**向管理審核計劃的個人建議您在認證之前進行進一步審核的任何建議
**B.**取消審核報告的製作，轉而審查組織與其客戶的合同，以確定他們是否允許使用較低等級的機器
**C.**根據已發現的其他信息，考慮是否需要在 4 週內進行後續審核
**D.**什麼都不做。所有審核均基於樣本，您採集的樣本不包括較低等級機器的計劃審查
**E.**延長認證審核持續時間，以騰出更多時間來審核較低等級機器的使用情況
**F.**由於組織尚未公開其流程，因此提出不符合 8.1 營運規劃與控制的要求
**G.**與受審核方核實在某些情況下是否使用了較低等級的機器
***Answer:*** A,C,G
Explanation:
According to ISO/IEC 27001:2022 clause 8.1, the organization must plan, implement and control the processes needed to meet the information security requirements, and to

implement the actions determined in clause 6.1. The organization must also ensure that the outsourced processes are controlled or influenced. According to control A.5.24, the organization must establish and maintain an information security incident management process that includes reporting information security events and weaknesses. Therefore, the use of lower grade machines for the secure disposal of confidential documents and media could pose a significant information security risk and a potential breach of contract with the clients. The auditor should respond to this information by:
A . Advising the individual managing the audit programme of any recommendation by you to conduct a further audit prior to certification. This is in accordance with ISO/IEC 27006:2022 clause 7.4.3, which states that the audit team leader shall report to the certification body any situation that may significantly affect the audit conclusions or the certification decision, and propose any necessary changes to the audit plan.
C . Considering the need for a subsequent audit within 4 weeks based on the additional information that has come to light. This is in accordance with ISO/IEC 27006:2022 clause 7.5.2, which states that the audit team leader shall review the audit findings and any other appropriate information collected during the audit to determine the audit conclusions, and to identify any need for a subsequent audit.
G . Verifying with the auditee that lower grade machines are used in certain circumstances. This is in accordance with ISO/IEC 27006:2022 clause 7.4.2, which states that the audit team leader shall ensure that the audit is conducted in accordance with the audit plan, and that any changes to the plan are agreed upon and documented.
The other options are not appropriate responses, as they either ignore the information, exceed the scope of the audit, or prematurely raise a nonconformity without sufficient evidence. For example:
B . Cancelling the production of the audit report and instead reviewing the organization's contracts with its clients to determine whether they have permitted the use of lower grade machines. This is not a suitable response, as it would delay the audit process and the certification decision, and it would involve reviewing documents that are outside the scope of the ISMS audit. The auditor should focus on verifying the information security risk assessment and treatment process, and the information security incident management process, as they relate to the use of lower grade machines.
D . Doing nothing. All audits are based on a sample and the sample you took did not include a planned review of the lower grade machines. This is not a suitable response, as it would disregard a significant information security risk and a potential nonconformity that could affect the audit conclusions and the certification decision. The auditor should follow up on the information provided by the employee and verify its validity and impact.
E . Extending the certification audit duration to create additional time to audit the use of the lower grade machines. This is not a suitable response, as it would disrupt the audit schedule and the availability of the audit team and the auditee. The auditor should report the situation to the certification body and propose any necessary changes to the audit plan, such as conducting a subsequent audit.
F . Raising a nonconformity against 8.1 Operational Planning and Control as the organization has not been open about its processes. This is not a suitable response, as it would be based on a single source of information that has not been verified or corroborated. The auditor should collect sufficient and appropriate audit evidence to support any nonconformity, and

ACTUALTEST.COM

should also consider the root cause and the severity of the nonconformity.
Reference:
ISO/IEC 27001:2022, clauses 8.1 and Annex A control A.5.24
ISO/IEC 27006:2022, clauses 7.4.2, 7.4.3, and 7.5.2
[PECB Candidate Handbook ISO/IEC 27001 Lead Auditor], pages 18-19, 23-24 A Step-by-Step Guide to Conducting an ISO 27001 Internal Audit ISO 27001 - Annex A.16: Information Security Incident Management

**QUESTION NO: 274**
場景
5：Cobt。位於倫敦的保險公司，提供各種商業、工業和人壽保險解決方案。近年來，Cobt 的客戶數量大幅增加。由於需要處理大量數據，該公司認為通過 ISO/IEC 27001 認證將為資訊安全帶來許多好處，並表明其對持續改進的承諾。儘管該公司擅長進行定期風險評估，但實施 ISMS
會為其日常營運帶來重大變化。在風險評估過程中，發現了一種風險，即組織的內部控制機制未能發現或預防重大缺陷。
公司遵循一套方法論來實施 ISMS，並在僅僅幾個月後就建立了可運行的
ISMS。分配了審核團隊成員的職責。
Sarah 承認，儘管 Cobt
通過提供多樣化的商業和保險解決方案實現了顯著擴張，但它仍然依賴於一些手動流程。
，特別是關於被審計方的可用性和合作以及獲取證據的管道。在本案中，Cobt的拒絕引發了人們對審計的完整性及其提供合理保證的能力的質疑。針對這些情況，Sarah決定在簽署認證協議之前退出審核，並將她的決定告知了Cobt和認證機構。做出這項決定是為了確保遵守審計原則並保持透明度，突顯了她始終如一地堅持這些原則的承諾。
根據上述情景，回答以下問題：
Cobt 在上次風險評估中發現了哪種類型的風險？
**A.**固有風險
**B.**控制風險
**C.**偵測風險
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
Detection Risk (Correct Answer) - Detection risk occurs when control mechanisms fail to identify significant defects or errors. Cobt identified that major defects were not detected or prevented by internal controls, making detection risk the correct answer.
Inherent Risk refers to the likelihood of a security event occurring without considering any controls. The scenario mentions control failures, not natural risks, so this is incorrect.
Control Risk is the risk of controls failing to prevent a risk. However, the scenario specifically mentions that the defects were not detected, making detection risk the more precise answer.
Relevant Standard Reference:

**QUESTION NO: 275**
為了驗證是否符合 ISO/IEC 27001 附錄 A 控制措施 8.15
記錄，審核小組驗證了伺服器日誌樣本，以確定它們是否可以編輯或刪除。使用了哪種審計程序？

**A.**分析
**B.**取樣
**C.**觀察
***Answer:*** A
Explanation:
The audit procedure used here is "analysis." The audit team analyzed server logs to verify if they can be edited or deleted, focusing on evaluating the logs' properties and the controls over their manipulation to ensure they comply with ISO/IEC 27001 requirements.

**QUESTION NO: 276**
當審計員使用基於機率的抽樣進行事件日誌審查時，使用了哪種類型的抽樣？
**A.**統計抽樣
**B.** 基於判斷的抽樣
**C.** 多地點抽樣
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
Statistical sampling follows probability theory and ensures objective selection.
ISO 19011:2018 supports statistical sampling for unbiased audit conclusions.
B . Incorrect:
Judgment-based sampling is subjective, not probability-based.
C . Incorrect:
Multi-site sampling applies to organizations with multiple locations.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.4.9 (Using Statistical Sampling for Audits)

**QUESTION NO: 277**
三名審核員被指派到 X 公司進行認證審核。這可以接受嗎？
**A.** 利益衝突的情況是要求更換審計師的正當理由
**B.**不可以，受審計方只有在提出正當理由的情況下才可以要求更換審計員，例如不專業的行為或存在實際利益衝突的情況
**C.**不可以，受審計方不能要求更換審計員
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:
ISO/IEC 17021-1 (Conformity assessment - Requirements for bodies providing audit and certification of management systems) states that the auditee may request a replacement of an auditor only for valid reasons.
A former employee of the company serving as an auditor presents a potential conflict of interest (real or perceived).
Therefore, Company X's request is valid.
A . Incorrect:

ACTUAL4TEST.COM

While a conflict of interest is a valid reason, the replacement must be based on an objective, justified claim, and not just personal preference.
C . Incorrect:
Auditees can request an auditor's replacement, but only under justified circumstances.
Relevant Standard Reference:
ISO/IEC 17021-1:2015 Clause 9.1.3 (Impartiality and Objectivity of Auditors)

**QUESTION NO: 278**
在測試的基礎上實施計劃 - 這屬於 PDCA 的哪一部分
**A.**計劃
**B.**執行
**C.**行動
**D.**檢查
***Answer:*** B
Explanation:
The PDCA cycle is a four-step method for managing and improving processes. The steps are Plan, Do, Check, and Act. In the Plan phase, the objectives and scope of the process are defined, and the resources and activities are planned. In the Do phase, the process is implemented on a test basis, and the results are recorded and analyzed1. Reference:
ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) | CQI | IRCA

**QUESTION NO: 279**
場景 9：Techmanic 是一家比利時公司，成立於 1995 年，目前在布魯塞爾運作。它提供 IT 諮詢、軟體設計和硬體/軟體服務，包括部署和維護。該公司服務於公共服務、金融、電信、能源、醫療保健和教育等行業。作為一家以客戶為中心的公司，它優先考慮建立牢固的客戶關係並引領安全實踐。
Techmanic 已獲得 ISO/IEC 27001
認證一年，並對此認證感到自豪。在認證審核期間，審核員發現其 ISMS
實施上存在一些不一致之處。由於觀察到的情況並不影響其 ISMS
實現預期結果的能力，因此在審計師遠端跟進根本原因分析和糾正措施後，Techmanic
獲得了認證。的遵守情況。認識持續改進的價值並從過去的評估中學習。 Techmanic
實施了審查先前的監督審計報告的做法。這種積極主動的方法不僅有助於識別和解決潛在的不合格情況，而且還旨在簡化 IT 諮詢領域的重新認證流程。
監督審核期間，發現了多處不符合項。 ISMS 繼續滿足 ISO/IEC 27001*s
的要求，但根據內部稽核員的報告，Techmanic
未能解決與託管服務相關的不符合問題。此外，內部稽核報告存在多處不一致之處，這使人們對內部稽核師在託管服務審計過程中的獨立性產生了質疑。基於此，延期認證未獲核准。因此。 Techmanic 請求轉移到另一個認證機構。同時，該公司向客戶發布聲明稱，ISO/IEC 27001 認證涵蓋 IT 服務以及託管服務。
根據上述情景，回答以下問題：
根據情境9，審計員決定在監督審計期間進行延伸審計。您如何定義這種情況？
**A.**可以接受，因為在監督審核期間進行了擴展審核
**B.**不可接受，因為審計員無法批准延期審計
**C.**不可接受，因為擴展審核僅在初次認證審核的第二年後進行
***Answer:*** A

Explanation:
Comprehensive and Detailed In-Depth
A . Correct answer:
ISO/IEC 17021-1 allows extension audits to be conducted alongside surveillance audits. This reduces redundancy and cost while maintaining compliance.
B . Incorrect:
Certification bodies have the authority to approve extension audits.
C . Incorrect:
Extensions are not restricted to the second year-they can occur at any time during the certification cycle.
Relevant Standard Reference:

**QUESTION NO: 280**
場景3：NightCore是一家總部位於美國的跨國科技公司，專注於電子商務、雲端運算、數位串流媒體和人工智慧。在實施資訊安全管理系統 (ISMS) 8
個多月後，他們聘請了認證機構進行第三方審核，以獲得 ISO/IEC 27001 認證。
認證機構成立了一個由七名審核員組成的團隊。傑克是最有經驗的審核員，被任命為審核組組長。多年來，他獲得了許多知名認證，例如 ISO/IEC 27001 首席審核員、CISA、CISSP 和 CISM。
Jack 透過研究和評估 NightCore 實施的每項資訊安全要求和控制，對 ISMS
審查的每個階段進行了全面分析。在第二階段審核期間。傑克發現了一些不合格項。在將購買的軟體許可證發票數量與軟體庫存進行比較後，傑克發現該公司的許多電腦一直在使用非法版本的軟體。他決定要求高階主管對這項違規行為做出解釋，看看他們是否意識到這一點。他的下一步是審計 NightCore 的 IT 部門。高層指派 NightCore 的系統管理員 Tom 擔任指導，陪伴 Jack 和稽核團隊了解系統和數位資產基礎設施的內部運作。
在採訪財務部的一名成員時，審計人員發現該公司最近向其一名顧問進行了一些不尋常的大額交易。收集有關交易的所有必要詳細資訊後。傑克決定直接訪問高階主管。
在討論第一個不合格項時，高階主管告訴傑克，他們願意決定使用複製軟體而不是原始軟體，因為它更便宜。 Jack向NightCore的高層解釋說，使用非法版本的軟體違反了ISO/IEC 27001和國家法律法規的要求。然而，他們似乎對此感到滿意。
在審計幾個月後，Jack 將他在審計期間收集的一些 NightCore 資訊出售給了 NightCore 的競爭對手，以獲取巨額資金。
根據該場景，回答以下問題：
根據情境 3。
**A.**附件 A 5.1 資訊安全政策
**B.**附件 A 5.10 資訊及其他相關資產的可接受使用
**C.**附件 A 5.32 智慧財產權
***Answer:*** C
Explanation:
By using illegal versions of software, NightCore ignored the control about intellectual property rights under Annex A.8.1.1 of ISO/IEC 27001, which requires the protection of organizational records to include intellectual property and personal information held in the form of data or software.

**QUESTION NO: 281**

您正在一家受 ABC 監管、提供醫療保健服務的住宅療養院進行 ISMS 審核。
審核計畫的下一步是驗證持續改善流程的有效性。在審計過程中，您了解到大多數居民家庭成員（90%）每週都會透過ABC的醫療保健行動應用程式透過電子郵件和簡訊收到一次WeCare醫療器材促銷廣告。他們均不同意將所收集的個人資料用於與ABC
簽署的服務協議上（或行銷或除護理和醫療之外的任何其他目的）。的資訊」個人資訊給不相關的第三方，他們已提出投訴。
服務經理表示，所有這些投訴均已被視為不合格，並且已根據不合格和糾正管理程序規劃和實施糾正措施。糾正措施包括立即停止與醫療設備製造商 WeCare
的合作，要求他們刪除收到的所有個人數據，並向所有居民及其家人發送道歉電子郵件。
您正在準備審計結果。選擇一項正確的發現選項。

**A.**不符合：ABC未遵守與居民家庭成員簽署的醫療服務協議

**B.**無不符合：我想收集更多有關組織如何定義管理系統範圍的證據，並了解它們是否涵蓋 WeCare 醫療器材製造

**C.**無不合格情況：服務經理實施了糾正措施，客戶服務代表評估所實施的糾正措施的有效性

**D.**不合格：管理評審未考慮居民家庭成員的回饋

***Answer:*** A

Explanation:
According to ISO 27001:2022 clause 8.1.4, the organisation shall ensure that externally provided processes, products or services that are relevant to the information security management system are controlled. This includes implementing appropriate contractual requirements related to information security with external providers, such as customers who send ICT equipment for reclamation12 In this case, ABC is a residential nursing home that provides healthcare services to its residents and collects their personal data and their family members' personal data. ABC has a signed service agreement with the residents' family members that states that the collected personal data will not be used for marketing or any other purposes than nursing and medical care. However, ABC has violated this contractual requirement by sharing the personal data with WeCare, a medical device manufacturer, who has used the data to send promotional advertisements to the residents' family members via email and SMS. This has caused dissatisfaction and complaints from the residents' family members, who have a strong reason to believe that ABC is leaking their personal information to a non-relevant third party.
Therefore, the audit finding is a nonconformity with clause 8.1.4 of ISO 27001:2022, as ABC has failed to control the externally provided processes, products or services that are relevant to the information security management system, and has breached the contractual requirements related to information security with its customers. The fact that ABC has taken corrective actions to stop working with WeCare and to apologise to the customers does not eliminate the nonconformity, but only mitigates its consequences. The nonconformity still needs to be recorded, evaluated, and reviewed for effectiveness and improvement.
Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 282**
設想：

Northstorm
是一家線上零售商店，提供獨特的復古和現代配件。它最初進入了一個小型市場，但隨著整個電子商務格局的發展而逐漸發展壯大。 Northstorm
專門在線上工作，確保高效的付款處理、庫存管理、行銷工具和出貨訂單。它採用優先排序來接收、補貨和運送其最受歡迎的產品。
Northstorm
傳統上透過託管其網站並完全控制其基礎架構（包括硬體、軟體和資料管理）來管理其 IT 營運。然而，由於缺乏響應的基礎設施，這種方法阻礙了其發展。為了增強其電子商務和支付系統，Northstorm
選擇擴展其內部資料中心，並在三個月內分兩個階段完成擴建。最初，該公司升級了其核心伺服器、銷售點、訂購、計費、資料庫和備份系統。第二階段涉及改善郵件、付款和網路功能。此外，在此階段，Northstorm 採用了針對個人識別資訊 (PII) 控制者和 PII
處理者的國際標準，以確保其資料處理實務安全並符合全球法規。
儘管進行了擴張，但 Northstorm
升級後的資料中心仍未能滿足其不斷變化的業務需求。這種不足導致了一些新的挑戰，包括訂單優先事項問題。客戶報告未收到優先訂單，且公司難以迅速回應。這主要是因為主伺服器無法處理來自 YouDecide 的訂單，YouDecide
是一款旨在優先處理訂單和模擬客戶互動的應用程式。該應用程式依賴先進的演算法，與升級期間安裝的新作業系統（OS）不相容。
面對緊急的兼容性問題，Northstorm
在沒有經過適當驗證的情況下迅速修補了應用程序，導致安裝了受損版本。這次安全漏洞導致主伺服器受到影響，該公司的網站離線一週。認識到需要更可靠的解決方案，該公司決定將其網站託管外包給電子商務提供者。該公司簽署了有關產品所有權的保密協議，並在過渡之前對使用者存取權限進行了徹底審查，以增強安全性。
下列哪一項是基於場景 1 的預防控制？

**A.**使用根據先驗知識對訂單進行優先排序的應用程序

**B.**簽署保密協議

**C.**擴大內部資料中心的容量

***Answer:*** B

Explanation:

Comprehensive and Detailed In-Depth

A preventive control is a security measure implemented to prevent security incidents or risks from occurring. It proactively protects information systems and mitigates potential threats.

A . Using an application that prioritized orders based on its prior knowledge - This is an operational enhancement but not a security control. It improves efficiency but does not directly prevent security breaches or risks.

B . Signing a confidentiality agreement - This is a preventive control because it ensures that sensitive business information remains protected from unauthorized disclosure before transitioning to an outsourced service provider. It mitigates the risk of intellectual property theft or data misuse by legally binding the parties to confidentiality.

C . Expanding the capacity of the in-house data center - This is a corrective or operational control, as it addresses the issue of insufficient infrastructure but does not prevent security-related threats.

**QUESTION NO: 283**

ACTUAL4TEST.COM

場景 2：Knight 是一家來自美國北加州的電子公司，開發電玩遊戲機。 Knight 在全球擁有 300 多名員工。在成立五週年之際，他們決定推出 G-
Console，這是一款面向全球市場的新一代電玩遊戲機。 G-
Console被認為是2021年的終極媒體機，將為玩家帶來最佳的遊戲體驗。
主機包將包括一副 VR 耳機、兩個
遊戲和其他禮物。
多年來，公司透過誠信、誠實和尊重客戶而建立了良好的聲譽。這種良好的聲譽是大多數熱衷遊戲玩家在Knight的G-console一上市就想擁有它的原因之一。
Knight 除了是一家非常以客戶為導向的公司之外，
也因其開發品質獲得了遊戲產業的廣泛認可。他們的價格比合理標準允許的要高一些。
儘管如此，對於 Knight
的大多數忠實客戶來說，這並不是一個問題，因為它們的品質是一流的。
作為世界頂級視訊遊戲機開發商之一，Knight 也經常成為惡意活動的焦點。該公司的 ISMS 已投入運作一年多了。 ISMS 範圍包括 Knight 的所有部門（財務和人力資源部門除外）。
最近，奈特的一些包含專有資訊的文件被駭客洩露。 Knight 的事件回應團隊 (IRT)
立即開始分析系統的每個部分以及事件的詳細資訊。
IRT 的第一個懷疑是 Knight
的員工使用了弱密碼，因此很容易被未經授權存取其帳戶的駭客破解。然而，在仔細調查該事件後，IRT 確定駭客透過擷取檔案傳輸協定 (FTP) 流量來存取帳戶。
FTP 是一種用於在帳戶之間傳輸檔案的網路協定。它使用明文密碼進行身份驗證。
受此資訊安全事件的影響，在IRT的建議下，Knight決定用Secure Shell
(SSH)協定取代FTP，這樣任何捕獲流量的人都只能看到加密的資料。
在這些變化之後，奈特進行了風險評估，以驗證控制措施的實施是否已將類似事件的風險降至最低。該過程的結果得到了 ISMS
專案經理的批准，他聲稱實施新控制措施後的風險等級符合公司的風險接受程度。
根據該場景，回答以下問題：
基於場景 2，Knight 決定用 Secure Shell (SSH) 協定取代
FTP。在這種情況下是否應該更新適用性聲明 (SoA)？

**A.**不，使用 SSH 協定不是 ISO/IEC 27001 要求；且；因此，不需要包含在 SoA 中

**B.**否，因為只有在新增控制項時才應更新 SoA，而不是在取消舊控制項時更新 SoA

**C.**是的，新控制的實施應該合理並包含在 SoA 中

***Answer:*** C

Explanation:

The Statement of Applicability (SoA) is a core document within an ISMS that outlines the security controls an organization implements. When a new control, such as the SSH protocol, is implemented, it should be included in the SoA to reflect the current state of the ISMS. The SoA should be updated to justify the inclusion of the new control and to document how it is implemented within the organization12. Reference: = This guidance is based on the best practices for maintaining the SoA as per ISO/IEC 27001, which requires the SoA to be a living document that accurately reflects the security controls in use by the organization

**QUESTION NO: 284**

哪一項最能描述保留與組織的資訊安全管理系統 (ISMS) 相關的記錄資訊的目的？

**A.**確保所有工人都遵守既定程序。

**B.**表示遵守法律要求。

**C.**向第三方審核員展示客觀證據。
**D.**在必要的範圍內，確信流程已按計劃進行。
***Answer:*** D
Explanation:
The purpose of retaining documented information related to the ISMS of an organisation is to the extent necessary, to have confidence that the processes have been carried out as planned. This means that the documented information provides evidence of the conformity and effectiveness of the ISMS, as well as the achievement of the information security objectives and the continual improvement of the ISMS. Documented information also supports the analysis and evaluation of the ISMS performance and the identification of opportunities for improvement. Reference: = ISO/IEC 27001:2022, clause 7.5.1; PECB Candidate Handbook ISO 27001 Lead Auditor, page 17.

**QUESTION NO: 285**
填空
當應用程式自動更新時，組織不會檢查更新版本的原始程式碼。因此，該應用程式可能會受到未經授權的修改。這顯示 _____ 可能會影響訊息 _____
**A.**威脅，（2）保密性
**B.**風險，（2）可用性
**C.**脆弱性，（2）完整性
***Answer:*** C

**QUESTION NO: 286**
下列哪一個是定性證據的例子？
**A.**外部組織的資訊安全專家記錄的入侵檢測測試結果
**B.**對受審核組織自 ISMS 實施之日起起草的不合格報告進行定義的樣本分析
**C.**與資訊安全人員面談，驗證資訊安全流程是否符合標準要求
***Answer:*** C
Explanation:
Qualitative evidence in an audit typically involves observations, interviews, and reviews that provide insights into the processes and compliance through subjective but informed assessments. An interview with information security personnel to validate compliance with the standard requirements is an example of qualitative evidence, where the quality and effectiveness of processes are assessed based on expert judgments rather than measurable metrics.

**QUESTION NO: 287**
您是 ISMS 審計團隊負責人，負責在客戶的資料中心進行後續審計。
現場兩天后，您得出結論，在促使進行後續審核的最初 12 項輕微不符合項和 1 項重大不符合項中，只有 1 項輕微不符合項仍未解決。
選擇您可以採取的動作的四個選項。
**A.**在一項未解決的輕微不合格項被清除後，預約另一次現場後續審核以對其進行審查
**B.**建議下次監督審核時處理未解決的輕微不符合項
**C.**告知受審核方您將安排線上審核來處理突出的不合格項

ACTUALTEST.COM

**D.**記下所取得的進展，但保持審核開放，直到所有糾正措施都被清除
**E.**與受審核方/審核客戶同意如何清除剩餘的不合格項、何時以及如何驗證其清除
**F.**建議管理審核計畫的個人就突出的不合格項所做的任何決定
**G.**建議暫停該組織的認證，因為該組織未能在商定的時間內實施商定的糾正措施和糾正措施
**H.**結束後續審核，因為組織已證明其致力於清除提出的不合格項

***Answer:*** B,E,F,H

Explanation:

According to ISO 19011:2018, which provides guidelines for auditing management systems, clause 6.7 requires the audit team leader to conduct a follow-up audit to verify the implementation and effectiveness of the corrective actions taken by the auditee in response to the nonconformities identified during a previous audit1. The follow-up audit should be conducted in accordance with the same principles and processes as the initial audit, and should result in a conclusion on the status of the nonconformities and any remaining issues1. Therefore, when conducting a follow-up audit, an ISMS auditor should consider the following actions:

Recommend that the outstanding minor nonconformity is dealt with at the next surveillance audit: This action is appropriate because it reflects the fact that the auditee has cleared most of the nonconformities, including the major one, and only one minor nonconformity remains outstanding. A minor nonconformity is defined as a failure to achieve one or more requirements of ISO/IEC 27001:2022 or a situation which raises significant doubt about the ability of an ISMS process to achieve its intended output, but does not affect its overall effectiveness or conformity2. Therefore, this finding does not prevent or preclude the continuation of certification, as long as it is addressed by appropriate corrective actions within a reasonable time frame. The auditor should recommend that the outstanding minor nonconformity is dealt with at the next surveillance audit, which is a regular audit conducted by the certification body to confirm the ongoing conformity and effectiveness of an ISMS3.

Agree with the auditee/audit client how the remaining nonconformity will be cleared, by when, and how its clearance will be verified: This action is appropriate because it reflects the fact that the auditee has demonstrated commitment and capability to implement corrective actions for the nonconformities identified during the previous audit. The auditor should agree with the auditee/audit client on a realistic, achievable, and effective corrective action plan for the remaining nonconformity, including a clear deadline and verification method. The auditor should also document this agreement in the follow-up audit report1.

Advise the individual managing the audit programme of any decision taken regarding the outstanding nonconformity: This action is appropriate because it reflects the fact that the auditor has followed a systematic and consistent approach to conducting and reporting the follow-up audit. The auditor should advise the individual managing the audit programme of any decision taken regarding the outstanding nonconformity, such as recommending its closure at the next surveillance audit or agreeing on a corrective action plan with the auditee/audit client. The auditor should also provide sufficient information and evidence to support their decision1.

Close the follow-up audit as the organisation has demonstrated it is committed to clearing the nonconformities raised: This action is appropriate because it reflects the fact that the organisation has achieved satisfactory results in the follow-up audit. The auditor should close the follow-up audit as the organisation has demonstrated it is committed to clearing the

nonconformities raised by implementing effective corrective actions for most of them and agreeing on a plan for the remaining one. The auditor should also communicate the follow-up audit conclusion to the auditee/audit client and other relevant parties1.

**QUESTION NO: 288**

場景 6：Cyber ACrypt
是一家網路安全公司，透過提供反惡意軟體和設備安全、資產生命週期管理和設備加密來提供端點保護。為了根據 ISO/IEC 27001 驗證其 ISMS
並證明其對網路安全卓越的承諾，該公司經歷了由指定審計團隊負責人 John
領導的細緻的審計過程。
在接受審計任務後，John 立即組織了一次會議，概述了審計計劃和團隊角色。他們審查了 Cyber ACrypt
的文檔信息，包括資訊安全政策和操作程序，確保每一份文件都符合標準並具有標準化的格式，包括作者標識、生產日期、版本號和批准日期。這次徹底的檢查旨在確定持續改進和遵守 ISMS 要求。該文件對於審計團隊和 Cyber ACrypt
了解初步審計結果和需要關注的領域至關重要。
審計組也決定對主要相關方進行訪談。這項決定的目的是收集可靠的審計證據來驗證管理系統是否符合 ISO/IEC 27001 的要求。與 Cyber ACrypt
各個層級的相關方進行接觸為審計團隊提供了寶貴的觀點以及對 ISMS
的實施和有效性的理解。
第一階段審計報告揭露了值得關注的關鍵領域。適用性聲明 (SoA) 和 ISMS
政策在多個方面存在缺陷，包括風險評估不足、存取控制不充分以及缺乏定期政策審查。這促使 Cyber ACrypt
立即採取行動來解決這些缺陷。他們對戰略文件的快速回應和修改體現出了對實現合規的堅定承諾。
為了彌補審計團隊的網路安全知識差距而引入的技術專長在識別風險評估方法中的缺陷和審查網路架構方面發揮了關鍵作用。這包括評估防火牆、入侵偵測和預防系統以及其他網路安全措施，以及評估 Cyber ACrypt
如何偵測、回應和恢復外部和內部威脅。在約翰的監督下，技術專家將審計結果傳達給了 Cyber ACrypt
的代表。然而，審計小組發現，由於收取了被審計單位的諮詢費，該專家的客觀性可能受到影響。考慮到技術專家在審核過程中的行為，審核組長決定與認證機構討論這個問題。
根據上述情景，回答以下問題：
哪些用於評估文件資訊的標準尚未經過審計團隊的驗證？（參考場景6）

**A.**記錄資訊的內容

**B.** 記錄資訊的格式

**C.** 管理文件資訊的程序

***Answer:*** C

Explanation:
Comprehensive and Detailed In-Depth
C . Correct Answer:
Scenario 6 states that the audit team reviewed the content and format of the documents but does not mention an evaluation of the document management procedure.
ISO/IEC 27001 requires that procedures for managing documented information be reviewed.
A . Incorrect:

The content of documents was reviewed for compliance with ISO/IEC 27001 clauses.
B . Incorrect:
The audit team confirmed that all documents were in a standardized format.
Relevant Standard Reference:
ISO/IEC 27001:2022 Clause 7.5 (Documented Information Requirements)

**QUESTION NO: 289**
您正在 ABC Healthcare Services 的療養院執行 ISO 27001 ISMS 監督審核。 ABC 使用由供應商 WeCare
設計和維護的醫療保健行動應用程式來監控居民的健康狀況。在審計過程中，您了解到90%的居民家庭成員每週一次透過電子郵件和簡訊定期收到WeCare的醫療器材廣告。 ABC 與 WeCare
之間的服務協議禁止供應商使用居民的個人資料。美國廣播公司已收到許多居民及其家人的投訴。
服務經理表示，這些投訴作為資訊安全事件進行了調查，發現這些投訴是合理的。已根據不合格和糾正措施管理程序規劃並實施糾正措施。
您寫了一份不合格項“ABC 未能遵守與居民及其家庭成員的個人資料相關的資訊安全控制 A.5.34（隱私和 PII 保護）。供應商 WeCare
使用居民的個人資訊向家庭成員”，從列出的糾正和糾正措施中選擇您希望ABC 針對不合格項採取的三個選項
**A.**ABC 確認資訊安全控制 A.5.34 包含在適用性聲明 (SoA) 中
**B.**服務經理提供不合格原因分析的證據以及 ABC 如何評估已實施的糾正措施的有效性
**C.**農行指示全體員工遵守與居民家屬簽署的醫療服務協議
**D.**ABC 進行管理審查，以考慮居民家庭成員的回饋
**E.**ABC
需要收集更多關於組織如何定義管理系統範圍的證據，並找出他們是否涵蓋醫療設備製造商 WeCare
**F.**ABC 識別並檢查是否遵守涉及第三方的所有適用法律和合約要求
**G.**服務經理實施糾正措施，客戶服務代表評估所實施糾正措施的有效性
**H.**ABC
在對不符合項採取行動之前需要收集更多證據，說明資訊安全風險評估與已識別的不符合項之間的關係
***Answer:*** B,F,G
Explanation:
According to the ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) course, the following corrections and corrective actions are expected from ABC in response to the nonconformity:
B . The Service Manager provides evidence of analysis of the cause of nonconformity and how the ABC evaluates the effectiveness of implemented corrective actions. This is part of the requirement of clause 10.1 of ISO/IEC 27001:2022, which states that the organization shall determine the causes of nonconformities and evaluate the need for action to ensure that they do not recur or occur elsewhere12. The organization shall also evaluate the effectiveness of any corrective actions taken12.
F . ABC identifies and checks compliance with all applicable legislation and contractual requirements involving third parties. This is part of the requirement of clause 4.2 of ISO/IEC

27001:2022, which states that the organization shall determine the external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended outcome(s) of its information security management system12. This includes the legal and contractual requirements related to the information security aspects of the organization's activities, products and services12.
G . The Service Manager implements the corrective actions and Customer Service Representatives evaluate the effectiveness of implemented corrective actions. This is part of the requirement of clause 10.1 of ISO/IEC 27001:2022, which states that the organization shall implement any action needed and retain documented information as evidence of the results of any action taken12. The organization shall also monitor, measure, analyze and evaluate the information security performance and the effectiveness of the information security management system12.
Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) course, CQI and IRCA Certified Training, 1
2: ISO/IEC 27001 Lead Auditor Training Course, PECB, 2

**QUESTION NO: 290**
定性證據和定量證據的主要差異是什麼？
**A.**定性證據源自於與確定審計標準有關的樣本分析，而定量證據源自於不可量化資訊的分析
**B.**定性證據著重於評估流程或控制是否符合稽核標準，而定量證據旨在確定運作中的流程是否功能齊全且有效
**C.**定性證據用於對整個總體進行估計，而定量證據則著重於評估某個流程是否符合標準要求
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:
Qualitative evidence assesses whether processes comply with audit criteria based on descriptive, observational, and interview-based data.
Quantitative evidence uses numerical data (e.g., metrics, statistics, or performance indicators) to assess if a process is functional and effective.
A . Incorrect:
Qualitative evidence is not limited to sampling and quantitative evidence is based on measurable data.
C . Incorrect:
Qualitative evidence does not estimate populations; it is subjective and descriptive.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.4.7 (Types of Audit Evidence: Qualitative vs. Quantitative)

**QUESTION NO: 291**
場景 7：Lawsy 是一家領先的律師事務所，在新澤西州和紐約市設有辦公室。它擁有 50 多名律師，為商業法、智慧財產權、銀行和金融服務領域的客戶提供完善的法律服務。他們相信，由於他們致力於實施資訊安全最佳實踐並跟上技術發展的步伐，他們在市場上佔據了有利的地位。
Lawsy 已經嚴格實施、評估和進行 ISMS 內部審核兩年了。

ACTUAL4TEST.COM

現在，他們已向知名且值得信賴的認證機構ISMA申請ISO/IEC 27001認證。
在第一階段審核期間，審核小組審查了實施過程中所建立的所有 ISMS 文件。
他們還審查和評估了管理審查和內部審計的記錄。
Lawsy
提交了證據記錄，表明在必要時對不合格項採取了糾正措施，因此審核組約談了內部審核員。
訪談透過提供對內部稽核計畫和程序的詳細了解，驗證了內部稽核的充分性和頻率。
審計小組繼續驗證戰略文件，包括資訊安全政策和風險評估標準。在資訊安全政策審查期間，團隊注意到描述治理框架（即資訊安全政策）的記錄資訊與程序之間存在不一致。
儘管允許員工將筆記型電腦帶到工作場所之外，但 Lawsy
並沒有製定有關在這種情況下使用筆記型電腦的程序。此政策僅提供有關筆記型電腦使用的一般資訊。該公司依靠員工的常識來保護筆記型電腦中儲存的資訊的機密性和完整性。該問題已記錄在第一階段審計報告中。
完成第一階段審核後，審核組長準備了審核計劃，其中闡述了審核目標、範圍、標準和程序。
在第二階段審核期間，審核小組約談了資安經理，資安經理起草了資訊安全政策。他透過指出
Lawsy
每三個月舉辦一次強制性資訊安全培訓和意識課程來證明第一階段中確定的問題的合理性。
面談後，審核小組檢查了 15 份員工培訓記錄（共 50 份），得出的結論是 Lawsy 符合
ISO/IEC 27001
有關培訓和意識的要求。為了支持這個結論，他們影印了檢查過的員工訓練記錄。
根據上述場景，回答以下問題：
根據情境 7，Lawsy 在開始第二階段審核之前該做什麼？

**A.**第一階段審核的審核結果進行品質審核

**B.**定義可以組合哪些審核測試計畫來驗證合規性

**C.**與認證機構審核並確認審核計劃

***Answer:*** C

Explanation:
Prior to the initiation of stage 2 audit, Lawsy should review and confirm the audit plan with the certification body. This ensures that both parties agree on the objectives, scope, and procedures for the stage 2 audit, thus aligning expectations and facilitating a smoother audit process.

**QUESTION NO: 292**
CMM 代表什麼？

**A.**能力成熟度矩陣

**B.**能力成熟度矩陣

**C.**能力成熟度模型

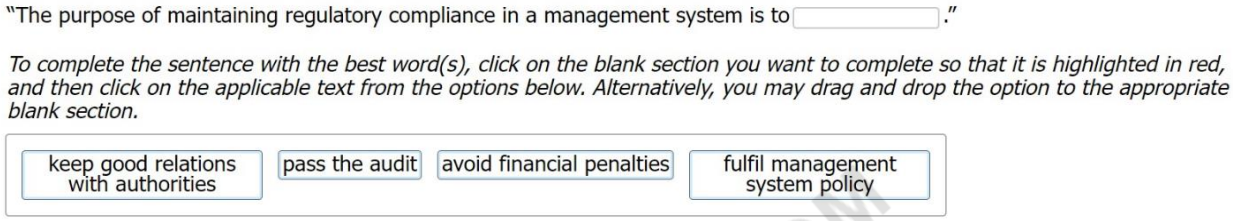
**D.**有能力的成熟模型

***Answer:*** C

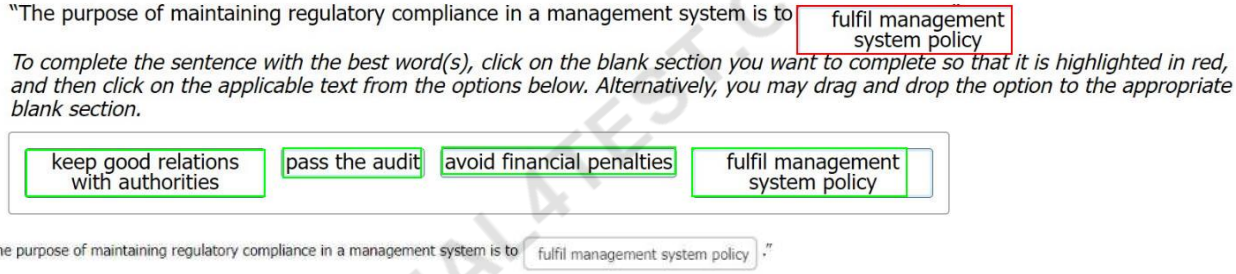
Explanation:
Capability Maturity Model (CMM) is a framework that describes the key elements of an effective software process. It defines five levels of maturity for software development organizations, from initial to optimized. The CMM helps organizations to assess their current level of process capability and identify the areas for improvement1. Reference: ISO/IEC 27001:2022 Lead Auditor - IECB

ACTUAL4TEST.COM

**QUESTION NO: 293**
選出最能完成句子的單字：
「在管理系統中維護法規遵從性的目的是要用最好的單字完成句子，請點擊要完成的空白部分，使其以紅色突出顯示，然後點擊來自的適用文字或者，您可以將選項拖放到對應的空白部分。




***Answer:***




**QUESTION NO: 294**
場景 2：
Clinic 成立於 20 世紀 90
年代，是一家專門治療心臟相關疾病和複雜外科手術的醫療器材公司。該公司總部位於歐洲，為患者和醫療保健專業人士提供服務。診所收集患者數據以客製化治療方案、監測結果並改善設備功能。為了增強資料安全性和建立信任，Clinic 正在實施基於 ISO/IEC 27001
的資訊安全管理系統 (ISMS)。
診所僅透過考慮內部問題、介面、內部和外包活動之間的依賴關係以及相關方的期望來確定其 ISMS 的範圍。此範圍已仔細記錄並可供查閱。在定義其 ISMS 時，Clinic
選擇專注於關鍵部門內的關鍵流程，例如研發、病患資料管理和客戶支援。
儘管最初面臨挑戰，Clinic 仍然致力於實施
ISMS，並根據其獨特需求量身定制安全控制。專案團隊從 ISO/IEC 27001 中排除了某些附件 A
控制，同時加入了額外的特定產業控制以增強安全性。該團隊根據內部和外部因素評估了這些控制的適用性，最終制定了全面的適用性聲明
(SoA)，詳細說明了控制選擇和實施背後的理由。
隨著認證準備工作的進展，被任命為團隊負責人的 Brian
採用了自我導向的風險評估方法來識別和評估公司的策略問題和安全實踐。這種積極主動的方法確保診所的風險評估與其目標和使命保持一致。
根據場景 2，診所 ISMS 的範圍是否確定正確？
**A.**不，診所也應該考慮外部問題
**B.**是的，診所 ISMS 的範圍已正確確定
**C.**不，診所也應將排除內容及其理由納入其 ISMS 範圍
***Answer:*** A
Explanation:

Comprehensive and Detailed In-Depth
A . Correct Answer: ISO/IEC 27001 Clause 4.1 (Understanding the Organization and Its The scenario states that Clinic only considered internal issues but did not assess external factors, such as regulatory requirements, industry standards, or cybersecurity threats.
B . Incorrect: The scope is not fully correct because external factors were not considered.
C . Incorrect: Justifying exclusions is necessary in the SoA, not in the ISMS scope statement.

**QUESTION NO: 295**
下列哪兩個短語適用於與業務流程的計劃-執行-檢查-行動週期相關的「計劃」？
**A.**保留文檔
**B.**保留文檔
**C.**組織變更
**D.**設定目標
**E.**訓練人員
**F.**提供ICT資產
***Answer:*** D,E
Explanation:
The Plan-Do-Check-Act (PDCA) cycle is a four-step method for implementing and improving processes, products, or services. The "plan" phase involves establishing the objectives and processes necessary to deliver the desired results. This may include setting SMART goals, identifying resources, defining roles and responsibilities, conducting risk assessments, and developing plans for training, communication, and monitoring.
Reference:
ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) objectives and content from Quality.org and PECB ISO 19011:2018 Guidelines for auditing management systems [Section 5.3.1]

**QUESTION NO: 296**
情境 4：SendPay
是一家金融公司，透過代理商和金融機構網路提供服務。他們的主要服務之一是在全球範圍內轉帳。 SendPay
作為一家新公司，致力於為客戶提供最優質的服務。由於該公司提供國際交易，因此要求客戶提供個人信息，例如身份、交易原因以及完成交易可能需要的其他詳細信息。因此，SendPay已實施安全措施來保護客戶的訊息，包括偵測、調查和回應可能出現的任何資訊安全威脅。他們對提供安全服務的承諾也體現在 ISMS 實施過程中，該公司投入了大量時間和資源。
去年，SendPay
推出了他們的數位平台，允許透過智慧型手機或筆記型電腦等電子設備進行貨幣交易，而無需支付額外費用。透過這個平台，SendPay
的客戶可以隨時隨地發送和接收資金。該數位平台幫助SendPay簡化了公司營運並進一步拓展了業務。當時SendPay正在外包其軟體業務，因此該專案是由外包公司的軟體開發團隊完成的。
該團隊還負責維護 SendPay 的技術基礎設施。
最近，該公司在實施 ISMS 近一年後申請了 ISO/IEC 27001
認證。他們與符合其標準的認證機構簽訂了合約。不久之後，認證機構任命了一個由四名審核員組成的團隊來審核 SendPay 的 ISMS。

ACTUAL4TEST.COM

審計過程中，發現以下情況：
1.外包軟體公司在未事先通知的情況下終止了與SendPay的合約。結果，SendPay無法立即將服務恢復到內部，其營運中斷了五天。審計人員要求 SendPay的代表提供證據，證明他們在合約終止的情況下有計劃遵循。這些代表沒有提供任何書面證據，但在接受審計時，他們告訴審計人員，SendPay的高層已經確定了另外兩家軟體開發公司，如果類似情況再次發生，可以立即提供服務。
2. 沒有證據顯示對外包給軟體開發公司的活動進行了監控。 SendPay的代表再次告訴審計人員，他們定期與軟體開發公司溝通，並適當地告知可能發生的任何變更。
3.防火牆測試未發現異常狀況。審核員測試了防火牆配置，以確定這些服務提供的安全等級。他們使用資料包分析器來測試防火牆策略，這使他們能夠即時檢查發送或接收的資料包。
根據該場景，回答以下問題：
為什麼SendPay在合約終止後無法恢復內部服務？請參閱場景 4。
**A.**因為SendPay沒有監控外包軟體營運的技術基礎設施
**B.**因為 SendPay 缺乏全面的業務連續性計劃，存在合約終止的潛在影響
**C.**因為外包軟體公司在沒有事先通知的情況下終止了與SendPay的合約
***Answer:*** B
Explanation:
SendPay's inability to restore their services immediately after the contract termination indicates a lack of a comprehensive business continuity plan that addresses the potential impacts of such terminations. This oversight can result in significant operational disruptions, as observed.

**QUESTION NO: 297**
場景
5：Cobt。位於倫敦的保險公司，提供各種商業、工業和人壽保險解決方案。近年來，Cobt的客戶數量大幅增加。由於需要處理大量數據，該公司認為通過 ISO/IEC 27001認證將為資訊安全帶來許多好處，並表明其對持續改進的承諾。儘管該公司擅長進行定期風險評估，但實施 ISMS會為其日常營運帶來重大變化。在風險評估過程中，發現了一種風險，即組織的內部控制機制未能發現或預防重大缺陷。
公司遵循一套方法論來實施 ISMS，並在僅僅幾個月後就建立了可運行的ISMS。分配了審核團隊成員的職責。
Sarah 承認，儘管 Cobt通過提供多樣化的商業和保險解決方案實現了顯著擴張，但它仍然依賴於一些手動流程。，特別是關於被審計方的可用性和合作以及獲取證據的管道。在本案中，Cobt的拒絕引發了人們對審計的完整性及其提供合理保證的能力的質疑。針對這些情況，Sarah決定在簽署認證協議之前退出審核，並將她的決定告知了Cobt和認證機構。做出這項決定是為了確保遵守審計原則並保持透明度，突顯了她始終如一地堅持這些原則的承諾。
根據上述情景，回答以下問題：
根據情境 5，Cobt表示審計計畫沒有正確反映他們最近對審計範圍所做的變更。在這種情況下莎拉該怎麼辦？
**A.**根據 Cobt 的要求更改審計計劃，因為範圍應該反映要審計活動的狀態和重要性
**B.**繼續以初始範圍進行審計，因為只有當所採用的技術最近發生變化時，Cobt才能要求更改審計範圍

**C.**僅當 Cobt、Sarah 和認證機構同意審核範圍的變更時才更改審核計劃

***Answer:*** C

Explanation:

Comprehensive and Detailed In-Depth

C . Correct Answer: Changes to the audit scope must be approved by the auditee, the A . Incorrect: The audit schedule cannot be changed solely at Cobt's request-approval is required.

B . Incorrect: Audit scope is not limited to technological changes but includes organizational and procedural changes as well.

Relevant Standard Reference:

ISO 19011:2018 Clause 5.5.2 (Determining the Audit Scope and Schedule)

**QUESTION NO: 298**

場景 6：Cyber ACrypt
是一家網路安全公司，透過提供反惡意軟體和設備安全、資產生命週期管理和設備加密來提供端點保護。為了根據 ISO/IEC 27001 驗證其 ISMS
並證明其對網路安全卓越的承諾，該公司經歷了由指定審計團隊負責人 John
領導的細緻的審計過程。
在接受審計任務後，John 立即組織了一次會議，概述了審計計劃和團隊角色。他們審查了 Cyber ACrypt
的文檔信息，包括資訊安全政策和操作程序，確保每一份文件都符合標準並具有標準化的格式，包括作者標識、生產日期、版本號和批准日期。這次徹底的檢查旨在確定持續改進和遵守 ISMS 要求。該文件對於審計團隊和 Cyber ACrypt
了解初步審計結果和需要關注的領域至關重要。
審計組也決定對主要相關方進行訪談。這項決定的目的是收集可靠的審計證據來驗證管理系統是否符合 ISO/IEC 27001 的要求。與 Cyber ACrypt
各個層級的相關方進行接觸為審計團隊提供了寶貴的觀點以及對 ISMS
的實施和有效性的理解。
第一階段審計報告揭露了值得關注的關鍵領域。適用性聲明 (SoA) 和 ISMS
政策在多個方面存在缺陷，包括風險評估不足、存取控制不充分以及缺乏定期政策審查。這促使 Cyber ACrypt
立即採取行動來解決這些缺陷。他們對戰略文件的快速回應和修改體現出了對實現合規的堅定承諾。
為了彌補審計團隊的網路安全知識差距而引入的技術專長在識別風險評估方法中的缺陷和審查網路架構方面發揮了關鍵作用。這包括評估防火牆、入侵偵測和預防系統以及其他網路安全措施，以及評估 Cyber ACrypt
如何偵測、回應和恢復外部和內部威脅。在約翰的監督下，技術專家將審計結果傳達給了 Cyber ACrypt
的代表。然而，審計小組發現，由於收取了被審計單位的諮詢費，該專家的客觀性可能受到影響。考慮到技術專家在審核過程中的行為，審核組長決定與認證機構討論這個問題。
根據上述情景，回答以下問題：
根據場景 6，Cyber ACrypt 在第 1 階段審計報告之後修改了 SoA 和 ISMS
政策。您如何定義這種情況？

**A.**不可接受，一旦外部審核通過第 1 階段，SoA 和 ISMS 政策就無法修改

**B.**可接受，應糾正第二階段審核期間導致重大不符合的情況

**C.**在提交最終審計報告之前，可以對 SoA 和 ISMS 政策進行可接受的微小修改

***Answer:*** B

Explanation:

Comprehensive and Detailed In-Depth

B . Correct Answer:

Stage 1 audits identify gaps and allow the organization to correct major nonconformities before Stage 2 certification.

ISO/IEC 27006 requires organizations to address major nonconformities before proceeding to Stage 2.

A . Incorrect:

Organizations are allowed to correct nonconformities identified in Stage 1.

C . Incorrect:

Major changes must be addressed, not just minor modifications.

Relevant Standard Reference:

ISO/IEC 27006:2020 Clause 9.2.3 (Stage 1 and Stage 2 Audit Process)

**QUESTION NO: 299**

下列哪一種情況代表威脅？

**A.**員工使用其合法憑證存取未經授權的文件

**B.**某組織未能為其雲端服務實施多因素身份驗證 (MFA)

**C.**網路攻擊者利用組織防火牆軟體中的零日漏洞入侵網絡

***Answer:*** C

Explanation:

Comprehensive and Detailed In-Depth

C . Correct Answer - This is a Threat. A cyberattack exploiting a zero-day vulnerability is an active security threat, as it causes harm to the organization.

A . Employee accessing unauthorized files is a vulnerability (insider risk) rather than an external threat.

B . Lack of MFA is a security weakness (vulnerability), not a threat.

**QUESTION NO: 300**

組織 A 的審核員對供應商 B 進行審核。

**A.**與 A 中的其他相關經理分享調查結果

**B.**與 B 的資安經理分享調查結果

**C.**與 A 的供應商評估團隊分享調查結果

**D.**與 B 的其他客戶分享調查結果

**E.**與 B 的認證機構分享調查結果

**F.**與 B 中的其他相關經理分享調查結果

***Answer:*** A,D

Explanation:

According to the PECB Candidate Handbook1, one of the principles of auditing is confidentiality, which means that auditors should respect the confidentiality of information obtained during the audit and not disclose it to unauthorized parties. The handbook also states that auditors should only report audit results to those who have a legitimate need to

know, such as the client, the auditee, and the certification body. Therefore, sharing the findings with other relevant managers in A or B's other customers would be a breach of confidentiality, as they are not directly involved in the audit process or the information security management system of B.
Sharing the findings with B's Information Security Manager or other relevant managers in B would be appropriate, as they are part of the auditee organization and responsible for the implementation and improvement of the ISMS. Sharing the findings with A's supplier evaluation team or B's certification body would also be acceptable, as they have a legitimate need to know the audit results for the purpose of supplier selection or certification, respectively. Reference: 1: PECB Candidate Handbook - ISO 27001 Lead Auditor, pages 7-8
.

**QUESTION NO: 301**
您收到一封電子郵件，要求您發送姓名、電子郵件和密碼等訊息，才能繼續使用您的電子郵件帳戶。如果您不發送此類訊息，您的電子郵件帳戶將被停用。這個場景呈現了什麼？
**A.**人員類型的漏洞
**B.**未經授權的威脅行為類型
**C.**威脅訊息類型的妥協
***Answer:*** B
Explanation:
The scenario described is a classic example of a phishing attack, which is a type of social engineering threat where attackers masquerade as a trustworthy entity in an electronic communication. The goal is to trick individuals into providing sensitive information. This represents an unauthorized action type of threat because it involves an attacker attempting to gain unauthorized access to personal information. Reference: = This understanding of phishing as a threat is consistent with the principles of information security management systems and is supported by resources that describe phishing attacks and their prevention

**QUESTION NO: 302**
認證機構在決定授予認證時不需要審核報告中的下列哪一項結論？
**A.**組織針對重大不合格項採取的糾正措施已被接受。
**B.**組織完全遵守適用於資訊安全管理系統的所有法律和其他要求。
**C.**解決與輕微不合格項相關的糾正措施的計劃已被接受
**D.**已符合認證範圍
***Answer:*** B
Explanation:
The conclusion in the audit report that is not required by the certification body when deciding to grant certification is that the organisation fully complies with all legal and other requirements applicable to the ISMS. This is because the certification body does not have the authority or the responsibility to verify the legal compliance of the organisation, as this is outside the scope of ISO/IEC 27001:2022. The certification body only evaluates the conformity of the organisation's ISMS with the requirements of the standard, which include the establishment of a process to identify and evaluate the legal and other requirements that are relevant to the ISMS. The organisation is responsible for ensuring its own legal compliance and for providing evidence of such compliance to the certification body if

requested. Reference: = ISO/IEC 27001:2022, clause 6.1.3; ISO/IEC 27006:2022, clause 9.2.2.4; PECB Candidate Handbook ISO 27001 Lead Auditor, page 29.

**QUESTION NO: 303**
情境 5：Data Grid Inc.
是一家知名公司，為整個資訊科技基礎設施提供安全服務。它提供網路安全軟體，包括端點安全、防火牆和防毒軟體。二十年來，Data Grid Inc.
透過先進的產品和服務幫助多家公司保護其網路安全。 Data Grid Inc.
在資訊和網路安全領域享有盛譽，決定獲得 ISO/IEC 27001
認證，以更好地保護其內部和客戶資產並獲得競爭優勢。
Data Grid Inc. 任命了審計團隊，該團隊同意審計任務的條款。此外，Data Grid Inc.明確了審核範圍，明確了審核標準，並建議在五天內結束審核。由於Data Grid Inc.員工人數眾多，流程複雜，審計小組拒絕了Data Grid Inc.在五天內進行審計的提議。 Data Grid
Inc.堅稱他們計劃在五天內完成審核，因此雙方同意在規定的時間內進行審核。審計小組遵循基於風險的審計方法。
為了獲得主要業務流程和控制的概述，審計團隊存取了流程描述和組織圖表。他們無法對 IT 風險和控制進行更深入的分析，因為他們對 IT
基礎架構和應用程式的存取受到限制。然而，審計小組表示，Data Grid Inc. 的 ISMS 出現重大缺陷的風險很低，因為該公司的大部分流程都是自動化的。因此，他們透過詢問 Data Grid Inc. 的代表以下問題來評估 ISMS 整體上符合標準要求：
*如何定義和指派 IT 和 IT 控制的職責？
*Data Grid Inc. 如何評估控制措施是否達到了預期效果？
*Data Grid Inc. 採取了哪些控制措施來保護操作環境和資料免受惡意軟體的侵害？
*是否實施了與防火牆相關的控制？
Data Grid Inc. 的代表提供了充分且適當的證據來解決所有這些問題。
審計組長起草審計結論並向Data Grid Inc. 的最高管理階層報告。
儘管審核員推薦Data Grid Inc.進行認證，但Data Grid Inc.與認證機構之間在審核目標方面產生了誤解。 Data Grid Inc.
表示，儘管審計目標包括確定潛在改進的領域，但審計團隊並未提供此類資訊。
根據該場景，回答以下問題：
如何避免認證機構和 Data Grid Inc. 之間產生誤解？
請參閱場景 5。
**A.**驗證審核報價
**B.**簽署認證協議
**C.**定義審核計劃
***Answer:*** B
Explanation:
Signing the certification agreement, which should clearly outline the audit objectives, scope, and responsibilities, would help prevent misunderstandings between the certification body and Data Grid Inc. A well-defined agreement ensures both parties have a clear understanding of what the audit will entail and what outputs are expected.

**QUESTION NO: 304**
資料完整性意味著

**A.**資料的準確性和完整性
**B.**資料應始終可見
**C.**資料只能由適當的人存取
***Answer:*** A
Explanation:
Integrity of data means accuracy and completeness of the data. Integrity is one of the three main objectives of information security, along with confidentiality and availability. Integrity ensures that information and systems are not corrupted, modified, or deleted by unauthorized actions or events. Data should be viewable at all times is not related to integrity, but to availability. Data should be accessed by only the right people is not related to integrity, but to confidentiality. Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 24. : [ISO/IEC 27001 Brochures | PECB], page 4.

**QUESTION NO: 305**
進行外部審核後，審核員決定內部審核員將追蹤糾正措施的實施情況，直到下一次監督審核。這是可以接受的嗎？
**A.**否，只有外部審核員應在審核完成後跟進糾正措施的實施情況
**B.**是的，如果外部稽核師無法完成，內部稽核師可以驗證糾正措施的實施情況
**C.**是的，內部稽核師可以追蹤糾正措施的實施情況，直到外部審計師在監督審計期間進行驗證為止
***Answer:*** C
Explanation:
Yes, it is acceptable for the internal auditor to follow-up on the implementation of corrective actions until verified by the external auditor during the next surveillance audit. This practice supports continuous improvement and ensures that corrective actions are effectively implemented and maintained over time.

**QUESTION NO: 306**
場景9：UpNet是一家網路公司，已通過ISO/IEC 27001認證。
自從獲得 ISO/IEC 27001 認證以來，該公司的認可度大幅提高。此認證證實了 UpNefs 營運的成熟性及其符合廣泛認可和接受的標準。
但認證之後一切還沒結束。 UpNet 透過進行內部稽核不斷審查和增強其安全控制以及 ISMS 的整體有效性和效率。高階主管不願意聘請全職內部稽核團隊，因此決定將內部稽核職能外包。這種形式的內部稽核確保了獨立性、客觀性，並且在 ISMS 的持續改進方面發揮諮詢作用。
在初次認證審核後不久，該公司創建了一個專門從事數據和儲存產品的新部門。他們提供針對資料中心和基於軟體的網路設備（例如網路虛擬化和網路安全設備）進行最佳化的路由器和交換器。這導致 ISMS 認證範圍內已涵蓋的其他部門的營運發生變化。
所以。 UpNet
啟動了風險評估流程和內部稽核。根據內部審計結果，公司確認了現有和新流程和控制的有效性和效率。
由於新部門符合 ISO/IEC 27001 要求，最高管理層決定將其納入認證範圍。
UpNet宣布取得ISO/IEC 27001認證，認證範圍涵蓋全公司。
在初次認證審核一年後，認證機構對 UpNefs ISMS 進行了另一次審核。
此次審核旨在確定 UpNefs ISMS 是否符合指定的 ISO/IEC 27001 要求，並確保 ISMS 持續改善。審核小組確認，經過認證的 ISMS

繼續符合標準的要求。儘管如此，新部門對管理體系的治理產生了重大影響。此外，認證機構並未獲悉任何變更。因此，UpNefs認證被暫停。
根據上述場景，回答以下問題：
UpNet宣布ISMS認證範圍涵蓋整個公司，確保新部門也符合ISO/IEC 27001要求。您如何對場景 9 所示的情況進行分類？
**A.**不可接受，延期審核應由內部審核員而非最高管理階層批准
**B.**不可接受，UpNet 應在發佈公告之前請求並批准延期審核
**C.**可接受，內部稽核確認了現有和新流程和控制的有效性和效率
***Answer:*** B

**QUESTION NO: 307**
您正在療養院進行 ISMS 審核，療養院的住戶總是戴著電子腕帶來監測他們的位置、心跳和血壓。腕帶會自動將這些資料上傳到雲端伺服器，供工作人員進行醫療保健監控和分析。
您現在希望驗證最高管理層是否已製定資訊安全策略和目標。您正在對行動裝置策略進行抽樣，並確定該策略的安全目標是「確保遠端辦公和行動裝置使用的安全」。
禁止個人行動裝置連接至療養院網路、處理和儲存居民資料。
本公司在ISMS範圍內的行動裝置應在資產登記冊中登記。
本公司的行動裝置應實施或啟用實體保護，即密碼保護的螢幕鎖定/解鎖、臉部或指紋解鎖裝置。
本公司的行動裝置應定期備份。
若要驗證行動裝置策略和目標是否已實施且有效，請為稽核追蹤選擇三個選項。
**A.**與接待人員面談，確保在進入療養院之前檢查所有訪客和員工的行李
**B.**查看訪客登記簿，確保任何訪客都不能在療養院內攜帶個人手機
**C.**查看內部審核報告以確保 IT 部門已接受審核
**D.**檢查資產註冊以確保所有個人行動裝置已註冊
**E.**從值班醫護人員處抽取部分行動設備，並與資產登記冊驗證行動裝置資訊
**F.**檢查資產註冊以確保所有公司的行動裝置已註冊
**G.**採訪設備供應商，確保他們了解 ISMS 政策
**H.**與高階主管面談，核實他們參與制定資訊安全政策和資訊安全目標的情況
***Answer:*** C,E,F
Explanation:
According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), clause 5.2 requires top management to establish an information security policy that provides the framework for setting information security objectives1. Clause 6.2 requires top management to ensure that the information security objectives are established at relevant functions and levels1. Therefore, when verifying that the information security policy and objectives have been established by top management, an ISMS auditor should review relevant documents and records that demonstrate top management's involvement and commitment.
To verify that the mobile device policy and objectives are implemented and effective, an ISMS auditor should review relevant documents and records that demonstrate how the policy and objectives are communicated, monitored, measured, analyzed, and evaluated. The

auditor should also sample and verify the implementation of the controls that are stated in the policy.
Three options for the audit trail that are relevant to verifying the mobile device policy and objectives are:
Review the internal audit report to make sure the IT department has been audited: This option is relevant because it can provide evidence of how the IT department, which is responsible for managing the mobile devices and their security, has been evaluated for its conformity and effectiveness in implementing the mobile device policy and objectives. The internal audit report can also reveal any nonconformities, corrective actions, or opportunities for improvement related to the mobile device policy and objectives.
Sampling some mobile devices from on-duty medical staff and validate the mobile device information with the asset register: This option is relevant because it can provide evidence of how the mobile devices that are used by the medical staff, who are involved in processing and storing residents' data, are registered in the asset register and have physical protection enabled. This can verify the implementation and effectiveness of two of the controls that are stated in the mobile device policy.
Review the asset register to make sure all company's mobile devices are registered: This option is relevant because it can provide evidence of how the company's mobile devices that are within the ISMS scope are identified and accounted for. This can verify the implementation and effectiveness of one of the controls that are stated in the mobile device policy.
The other options for the audit trail are not relevant to verifying the mobile device policy and objectives, as they are not related to the policy or objectives or their implementation or effectiveness. For example:
Interview the reception personnel to make sure all visitor and employee bags are checked before entering the nursing home: This option is not relevant because it does not provide evidence of how the mobile device policy and objectives are implemented or effective. It may be related to another policy or objective regarding physical security or access control, but not specifically to mobile devices.
Review visitors' register book to make sure no visitor can have their personal mobile phone in the nursing home: This option is not relevant because it does not provide evidence of how the mobile device policy and objectives are implemented or effective. It may be related to another policy or objective regarding information security awareness or compliance, but not specifically to mobile devices.
Interview the supplier of the devices to make sure they are aware of the ISMS policy: This option is not relevant because it does not provide evidence of how the mobile device policy and objectives are implemented or effective. It may be related to another policy or objective regarding information security within supplier relationships, but not specifically to mobile devices.
Interview top management to verify their involvement in establishing the information security policy and the information security objectives: This option is not relevant because it does not provide evidence of how the mobile device policy and objectives are implemented or effective. It may be related to verifying that the information security policy and objectives have been established by top management, but not specifically to mobile devices.

**QUESTION NO: 308**

ACTUALTEST.COM

以下是保護您的密碼的準則，但以下情況除外：
**A.**不同公司係統安全存取不要使用相同的密碼
**B.**不要與任何人分享密碼
**C.**為了方便回憶，公司和個人帳號使用相同的密碼
**D.**首次登入時變更暫時密碼
***Answer:*** B,C
Explanation:
The following are guidelines to protect your password, except for easy recall use the same password for company and personal accounts; do not share passwords with anyone. Using the same password for company and personal accounts is not a guideline to protect your password, as it increases the risk of compromising your password if one of your accounts is hacked or breached. You should use different and unique passwords for each account, and change them regularly. Sharing passwords with anyone is not a guideline to protect your password, as it reduces the security and accountability of your password. You should keep your password confidential and never disclose it to anyone, even if they claim to be authorized or trustworthy. Don't use the same password for various company system security access is a guideline to protect your password, as it prevents unauthorized access or misuse of your password if one of the systems is compromised or breached. You should use different and complex passwords for each system, and follow the password policies and standards of the organization. Change a temporary password on first log-on is a guideline to protect your password, as it prevents unauthorized access or misuse of your password if the temporary password is intercepted or leaked. You should change the temporary password to a personal and secure password as soon as possible, and avoid using default or predictable passwords.
Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 43. : [ISO/IEC 27001 LEAD AUDITOR - PECB], page 15.

**QUESTION NO: 309**
審核組組長決定聘請技術專家作為審核小組的一部分，這樣他們就可以填補審核組成員知識的潛在空白。在這種情況下，審計組長應該考慮什麼？
**A.**讓技術專家在需要時做出與審核流程相關的決定
**B.**技術專家應直接與認證機構而不是審核員討論他們的擔憂
**C.**技術專家只能透過審核小組成員之一向受審核方傳達其審核結果
***Answer:*** C
Explanation:
The technical expert can communicate their audit findings to the auditee only through one of the audit team members. This ensures that communications remain coordinated and that the audit team maintains control over the audit process.

**QUESTION NO: 310**
場景9：UpNet是一家網路公司，已通過ISO/IEC 27001認證。
自從獲得 ISO/IEC 27001 認證以來，該公司的認可度大幅提高。此認證證實了 UpNefs 營運的成熟性及其符合廣泛認可和接受的標準。
但認證之後一切還沒結束。 UpNet 透過進行內部稽核不斷審查和增強其安全控制以及 ISMS 的整體有效性和效率。高階主管不願意聘請全職內部稽核團隊，因此決定將內部稽核職能外包。這種形式的內部稽核確保了獨立性、客觀性，並且在 ISMS 的持續改進方面發揮諮詢作用。

在初次認證審核後不久，該公司創建了一個專門從事數據和儲存產品的新部門。他們提供針對資料中心和基於軟體的網路設備（例如網路虛擬化和網路安全設備）進行最佳化的路由器和交換器。這導致 ISMS 認證範圍內已涵蓋的其他部門的營運發生變化。
所以。 UpNet
啟動了風險評估流程和內部稽核。根據內部審計結果，公司確認了現有和新流程和控制的有效性和效率。
由於新部門符合 ISO/IEC 27001 要求，最高管理層決定將其納入認證範圍。
UpNet宣布取得ISO/IEC 27001認證，認證範圍涵蓋全公司。
在初次認證審核一年後，認證機構對 UpNefs ISMS 進行了另一次審核。
此次審核旨在確定 UpNefs ISMS 是否符合指定的 ISO/IEC 27001 要求，並確保 ISMS 持續改善。審核小組確認，經過認證的 ISMS
繼續符合標準的要求。儘管如此，新部門對管理體系的治理產生了重大影響。此外，認證機構並未獲悉任何變更。因此，UpNefs認證被暫停。
根據上述場景，回答以下問題：
場景 9 最後一段說明了什麼類型的審計？

**A.**監督審核

**B.**內部稽核

**C.**重新認證審核

***Answer:*** A

**QUESTION NO: 311**
ISMS的標準定義是什麼？

**A.**是一種資訊安全系統方法，旨在實現實施、建立、審查、營運和維護組織聲譽的業務目標。

**B.**公司範圍內的業務目標，以實現建立、實施、營運、監控、審查、維護和改進的資訊安全意識

**C.**基於專案的方法，用於實現建立、實施、營運、監控、審查、維護和改進組織資訊安全的業務目標

**D.**用於建立、實施、操作、監控、審查、維護和改進組織的資訊安全以實現業務目標的系統方法。

***Answer:*** D
Explanation:
The standard definition of ISMS is a systematic approach for establishing, implementing, operating, monitoring, reviewing, maintaining and improving an organization's information security to achieve business objectives. This definition is given in clause 3.17 of ISO/IEC 27001:2022, and it describes the main components and purpose of an ISMS. An ISMS is not a project-based approach, as it is an ongoing process that requires continual improvement. An ISMS is not a company wide business objective, as it is a management system that supports the organization's objectives. An ISMS is not an information security systematic approach, as it is a broader concept that encompasses the organization's context, risks, controls, and performance. Reference: : CQI & IRCA ISO 27001:2022 Lead Auditor Course Handbook, page 15. : ISO/IEC 27001:2022, clause 3.17.

**QUESTION NO: 312**
設想：
Northstorm

是一家線上零售商店，提供獨特的復古和現代配件。它最初進入了一個小型市場，但隨著整個電子商務格局的發展而逐漸發展壯大。 Northstorm
專門在線上工作，確保高效的付款處理、庫存管理、行銷工具和出貨訂單。它採用優先排序來接收、補貨和運送其最受歡迎的產品。
Northstorm
傳統上透過託管其網站並完全控制其基礎架構（包括硬體、軟體和資料管理）來管理其 IT 營運。然而，由於缺乏響應的基礎設施，這種方法阻礙了其發展。為了增強其電子商務和支付系統，Northstorm
選擇擴展其內部資料中心，並在三個月內分兩個階段完成擴建。最初，該公司升級了其核心伺服器、銷售點、訂購、計費、資料庫和備份系統。第二階段涉及改善郵件、付款和網路功能。此外，在此階段，Northstorm 採用了針對個人識別資訊 (PII) 控制者和 PII
處理者的國際標準，以確保其資料處理實務安全並符合全球法規。
儘管進行了擴張，但 Northstorm
升級後的資料中心仍未能滿足其不斷變化的業務需求。這種不足導致了一些新的挑戰，包括訂單優先事項問題。客戶報告未收到優先訂單，且公司難以迅速回應。這主要是因為主伺服器無法處理來自 YouDecide 的訂單，YouDecide
是一款旨在優先處理訂單和模擬客戶互動的應用程式。該應用程式依賴先進的演算法，與升級期間安裝的新作業系統（OS）不相容。
面對緊急的兼容性問題，Northstorm
在沒有經過適當驗證的情況下迅速修補了應用程序，導致安裝了受損版本。這次安全漏洞導致主伺服器受到影響，該公司的網站離線一週。認識到需要更可靠的解決方案，該公司決定將其網站託管外包給電子商務提供者。該公司簽署了有關產品所有權的保密協議，並在過渡之前對使用者存取權限進行了徹底審查，以增強安全性。
根據場景 1，Northstorm 審查了使用者的存取權限。這種安全控制的類型和功能是什麼？

**A.**偵探與行政

**B.**修正與管理

**C.**法律與技術

***Answer:*** A

Explanation:
Comprehensive and Detailed In-Depth
Security controls can be classified by type (administrative, technical, physical) and function (preventive, detective, corrective).
A . Detective and administrative - Correct Answer. Reviewing access rights is an administrative control because it involves procedural security measures (such as policy enforcement and auditing). It is also a detective control because it helps identify inappropriate or unauthorized access by auditing and verifying user permissions.
B . Corrective and managerial - Incorrect because reviewing user access rights does not correct an issue but rather detects potential unauthorized access. It is also administrative, not managerial.
C . Legal and technical - Incorrect because reviewing user access rights is an administrative policy-based action, not a legal or technical control.

**QUESTION NO: 313**
下列哪兩個選項不參與第一方審核？

**A.**認證機構審核員

**B.**來自認證機構的審核小組
**C.**經過CQI及IRCA認證的審核員
**D.**諮詢機構的審核員
**E.**接受過 CQI 和 IRCA 計畫訓練的審核員
**F.**在組織中接受過訓練的審核員
***Answer:*** A,B
Explanation:
A first-party audit is an internal audit in which the organization's own staff or contractors check the conformity and effectiveness of the ISMS. A certification body auditor and an audit team from an accreditation body are external auditors who conduct audits for the purpose of certification or accreditation. They do not participate in a first-party audit, but rather in a third-party audit. Reference: First & Second Party Audits - operational services, The ISO 27001 Audit Process | Blog | OneTrust, The ISO 27001 Audit Process | A Beginner's Guide - IAS USA

**QUESTION NO: 314**
場景 1：Fintive 是一家傑出的線上支付和保護解決方案安全提供者。 Fintive 於 1999 年由 Thomas Fin 在加州聖荷西創立，為線上營運、希望提高資訊安全、防止詐欺並保護 PII 等用戶資訊的公司提供服務。
Fintive的決策和營運流程以以往的案例為中心。他們收集客戶數據，根據情況進行分類並進行分析。該公司需要大量員工才能進行如此複雜的分析。然而，幾年後，協助進行此類分析的技術也取得了進展。現在，Fintive
正計劃使用現代工具聊天機器人來實現模式分析，以即時防止詐騙。該工具也將用於幫助改善客戶服務。
這個最初的想法已傳達給軟體開發團隊，他們支持該想法並被分配從事該專案。他們開始將聊天機器人整合到現有系統中。此外，團隊也為聊天機器人設定了一個目標，即回答 85% 的聊天查詢。
聊天機器人成功整合後，該公司立即將其發布給客戶使用。
然而，聊天機器人似乎存在一些問題。
由於測試不足，並且在訓練階段缺乏向聊天機器人提供的樣本（在訓練階段，聊天機器人本應「學習」查詢模式），因此聊天機器人無法解決用戶查詢並提供正確的答案。此外，當聊天機器人收到無效輸入（例如奇怪的點圖案和特殊字元）時，它會向使用者發送隨機檔案。因此，聊天機器人無法正確回答客戶的查詢，而傳統的客戶支援因聊天查詢而不堪重負，因此無法幫助客戶解決他們的請求。
因此，Fintive
制定了軟體開發政策。該政策規定，無論軟體是內部開發還是外包，在作業系統上實施之前都將經過黑盒測試。
根據該場景，回答以下問題：
根據場景 1，聊天機器人無法正確回答客戶的詢問。本案影響了資訊安全的哪些原則？
**A.**可用性
**B.**誠信
**C.**保密性
***Answer:*** B

**QUESTION NO: 315**

您正在一家提供醫療保健服務的住宅療養院進行 ISMS
審核。審核計畫的下一步是驗證資訊安全事件管理流程。 IT
安全經理介紹了資訊安全事件管理程序（文件參考 ID：ISMS_L2_16，版本
4），並解釋此流程基於 ISO/IEC 27035-1:2016。
您查看該文件並注意到一條聲明「任何資訊安全弱點、事件和事故應在識別後 1
小時內報告給聯絡人
(PoC)」。在訪問員工時，您發現大家對「弱點、事件、事件」意義的理解有差異。
IT安全經理解釋說，6個月前舉辦了一次線上「資訊安全應對」培訓研討會。所有受訪者均參與並通過了報告練習和課程評估。
您正在準備審計結果。選擇兩個正確的選項。
**A.**存在不合格項 (NC)。資訊安全事件培訓失敗。這不符合第 7.2 條和控制措施 A.6.3。
**B.**存在不合格項
(NC)。事件管理報告流程的術語不明確，員工對「弱點、事件和事件」意義的誤解證明了這一點。這不符合第 9.1 條和控制措施 A.5.24。
**C.**還有改進的機會 (OFI)。提高資訊安全事件訓練效果。這與第 7.2 條和控制措施 A.6.3
相關。
**D.**有改進的機會 (OFI)。報告資訊安全弱點、事件和事件。這與第 9.1 條和控制措施 A.5.24
有關。
**E.**沒有不合格項。資訊安全處置訓練卓有成效。這符合第 7.2 條和控制措施 A.6.3。
**F.**沒有不合格項。報告資訊安全弱點、事件和事故。
這符合第 9.1 條和控制措施 A.5.24。

***Answer:*** B,C

Explanation:

According to ISO/IEC 27001:2022 clause 7.2, the organization must ensure that the persons doing work under its control are aware of the information security policy, their contribution to the effectiveness of the ISMS, the implications of not conforming to the ISMS requirements, and the benefits of improved information security performance. The organization must also provide information security awareness education and training to its personnel and relevant interested parties. According to control A.6.3, the organization must ensure that all employees and contractors are made aware of the information security incident management procedures and their expected roles and responsibilities. Therefore, an opportunity for improvement (OFI) can be identified if the information security incident training effectiveness can be improved, as evidenced by the differences in the understanding of the meaning of "weakness, event, and incident" among the staff.

According to ISO/IEC 27001:2022 clause 9.1, the organization must monitor, measure, analyze and evaluate the information security performance and the effectiveness of the ISMS. The organization must also retain appropriate documented information as evidence of the monitoring and measurement results. According to control A.5.24, the organization must establish and maintain an information security incident management process that includes the following activities:

* reporting information security events and weaknesses;
* assessing and deciding on information security events;
* responding to information security incidents;
* learning from information security incidents;
* collecting evidence and disclosing information.

Therefore, a nonconformity (NC) can be identified if the terminology of the incident management reporting process is unclear, as evidenced by the staff misunderstanding of the meaning of "weakness, event, and incident". This could lead to inconsistent or inaccurate reporting, assessment, response, learning, and disclosure of information security incidents, which could affect the information security performance and the effectiveness of the ISMS.
Reference:
* ISO/IEC 27001:2022, clauses 7.2, 9.1, and Annex A controls A.5.24 and A.6.3
* [PECB Candidate Handbook ISO/IEC 27001 Lead Auditor], pages 15-16, 18-19, 22-23
* ISO/IEC 27035-1:2016, clauses 4, 5, 6, 7, and 8
* ISO 27001 - Annex A.16: Information Security Incident Management
* ISO 27001:2022 Annex A Control 5.24 - What's New?

**QUESTION NO: 316**
管理審核計畫的個人負責下列哪兩項行動？
**A.**確定審核計畫所需的資源
**B.**審核期間與受審核方溝通
**C.**確定適用於每次審核的法律要求
**D.**柯平向認證機構通報了審核計畫的進度
**E.**定義單獨審核的目標、範圍和標準
**F.**定義單獨審核的計劃
***Answer:*** A,D
Explanation:
Establishing the audit programme objectives, scope and criteria
Determining the resources necessary for the audit programme, such as the audit team members, the budget, the time, the tools, etc.
Selecting and appointing the audit team leaders and auditors
Reviewing and approving the audit plans and arrangements
Ensuring the effective communication and coordination among the audit programme stakeholders, such as the auditors, the auditees, the certification bodies, the accreditation bodies, etc.
Keeping informed the accreditation body on the progress of the audit programme, especially in case of any significant changes, issues, or nonconformities Monitoring and reviewing the performance and results of the audit programme and the audit teams Evaluating the feedback and satisfaction of the auditees and other interested parties Identifying and implementing the opportunities for improvement of the audit programme The individual(s) managing the audit programme are not responsible for the following tasks, which are delegated to the audit team leaders or the auditors12:
Communicating with the auditee during the audit, such as conducting the opening and closing meetings, resolving any audit-related problems, reporting any audit findings, etc.
Determining the legal requirements applicable to each audit, such as the confidentiality, the impartiality, the consent, the liability, etc.
Defining the objectives, scope and criteria for an individual audit, which are derived from the audit programme and agreed with the auditee Defining the plan of an individual audit, which includes the audit schedule, the audit activities, the audit methods, the audit documents, etc.
Reference:

ACTUALTEST.COM

ISO 19011:2018 - Guidelines for auditing management systems
PECB Candidate Handbook ISO 27001 Lead Auditor, pages 19-20

**QUESTION NO: 317**
場景七：Webvue。總部位於日本，是一家專門從事電腦軟體開發、支援和維護的技術公司。Webvue 提供跨各個技術領域和業務領域的解決方案。其旗艦服務是CloudWebvue，一個提供儲存、網路和虛擬運算服務的綜合雲端運算平台。專為企業和個人用戶設計。 CloudWebvue 以其靈活性、可擴展性和可靠性而聞名。
Webvue 決定僅將 CloudWebvue 納入其 ISO/IEC 27001 認證範圍。因此，第 1 階段和第 2 階段審計同時進行 Webvue
以其對資產保密的嚴格性而自豪，他們使用適當的加密控制來保護儲存在 CloudWebvue 中的資訊。任何機密級別的每條信息，無論是否供內部使用。受限的或機密的資訊首先用唯一的對應哈希值加密，然後儲存在雲端。肖恩。萊拉，山姆。和 Tin a。 Keith 是 IT 和資訊安全審計團隊中最有經驗的審計員，也是審計團隊的負責人。他的職責包括規劃審計和管理審計團隊。尚實踐生成的。在檢查了 Webvue
的加密政策後，他們得出結論，採訪中獲得的資訊是真實的。然而，由於該策略沒有解決加密金鑰的使用和壽命問題，因此加密金鑰仍在使用中。
依照 Webvue 和認證機構後來達成的協議，審計團隊選擇進行虛擬審計，專門專注於驗證 Webvue 是否符合 ISO/IEC 27001 的控制 8.11
資料屏蔽，以符合認證範圍和審計目標。他們檢查了 CloudWebvue
中保護資料所涉及的流程。重點關注公司如何遵守其政策和監管標準。作為此過程的一部分。審計團隊負責人 Keith 對相關文件和加密金鑰管理程序進行了截圖，以記錄和分析 Webvue 實踐的有效性。
Webvue 使用產生的測試資料用於測試目的。然而，根據與 QA
部門經理的訪談以及該部門使用的程序確定，有時會使用即時系統資料。在這樣的場景中，會產生大量數據，同時產生更準確的結果。測試資料受到保護和控制，這透過 Webvue
人員在審計期間執行的加密過程模擬得到驗證。儘管不在審計範圍之內，但安全培訓部門的不合規情況可能會對審計範圍內的流程產生影響，具體會影響 CloudWebvue
中的資料安全和加密實踐。因此，Keith將此發現納入審計報告中，並告知被審計方。
根據上述情景，回答以下問題：
根據場景 7，審計團隊檢查了 Webvue
的加密策略，以對訪談期間獲得的資訊獲得合理保證。使用了哪種類型的審計程序？

**A.**觀察

**B.**確證

**C.**評估

***Answer:*** B

Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:
Corroboration is the process of validating verbal statements with documented evidence.
ISO 19011:2018 emphasizes cross-verification of audit evidence to ensure accuracy.
A . Incorrect:
Observation involves witnessing real-time processes, but here, the audit team compared interview data with documentation.
C . Incorrect:

Evaluation assesses compliance with criteria, but corroboration focuses on evidence validation.
Relevant Standard Reference:
ISO 19011:2018 Clause 6.4.7 (Corroboration of Audit Evidence)

**QUESTION NO: 318**
場景 9：Techmanic 是一家比利時公司，成立於 1995 年，目前在布魯塞爾運作。它提供 IT 諮詢、軟體設計和硬體/軟體服務，包括部署和維護。該公司服務於公共服務、金融、電信、能源、醫療保健和教育等行業。作為一家以客戶為中心的公司，它優先考慮建立牢固的客戶關係並引領安全實踐。
Techmanic 已獲得 ISO/IEC 27001
認證一年，並對此認證感到自豪。在認證審核期間，審核員發現其 ISMS
實施上存在一些不一致之處。由於觀察到的情況並不影響其 ISMS
實現預期結果的能力，因此在審計師遠端跟進根本原因分析和糾正措施後，Techmanic
獲得了認證。的遵守情況。認識持續改進的價值並從過去的評估中學習。 Techmanic
實施了審查先前的監督審計報告的做法。這種積極主動的方法不僅有助於識別和解決潛在的不合格情況，而且還旨在簡化 IT 諮詢領域的重新認證流程。
監督審核期間，發現了多處不符合項。 ISMS 繼續滿足 ISO/IEC 27001*s
的要求，但根據內部稽核員的報告，Techmanic
未能解決與託管服務相關的不符合問題。此外，內部稽核報告存在多處不一致之處，這使人們對內部稽核師在託管服務審計過程中的獨立性產生了質疑。基於此，延期認證未獲核准。因此。 Techmanic 請求轉移到另一個認證機構。同時，該公司向客戶發布聲明稱，ISO/IEC 27001 認證涵蓋 IT 服務以及託管服務。
根據上述情景，回答以下問題：
針對 Techmanic 認證應該採取什麼行動？
**A.**暫停認證，因為他們在認證範圍之外使用該認證
**B.**由於未能解決與託管服務相關的不合規問題，因此撤銷認證
**C.**由於未獲得擴充認證，因此轉移認證
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct answer:
Techmanic misrepresented its certification scope, which is a violation of ISO certification rules.
Suspension allows time for corrective action before withdrawal is considered.
B . Incorrect:
Certification withdrawal is only necessary if corrective actions fail after suspension.
C . Incorrect:
Transfer does not resolve misrepresentation issues.
Relevant Standard Reference:

**QUESTION NO: 319**
場景 9：Techmanic 是一家比利時公司，成立於 1995 年，目前在布魯塞爾運作。它提供 IT 諮詢、軟體設計和硬體/軟體服務，包括部署和維護。該公司服務於公共服務、金融、電信、能源、醫療保健和教育等行業。作為一家以客戶為中心的公司，它優先考慮建立牢固的客戶關

係並引領安全實踐。
Techmanic 已獲得 ISO/IEC 27001
認證一年，並對此認證感到自豪。在認證審核期間，審核員發現其 ISMS
實施上存在一些不一致之處。由於觀察到的情況並不影響其 ISMS
實現預期結果的能力，因此在審計師遠端跟進根本原因分析和糾正措施後，Techmanic
獲得了認證。的遵守情況。認識持續改進的價值並從過去的評估中學習。 Techmanic
實施了審查先前的監督審計報告的做法。這種積極主動的方法不僅有助於識別和解決潛在的不合格情況，而且還旨在簡化 IT 諮詢領域的重新認證流程。
監督審核期間，發現了多處不符合項。 ISMS 繼續滿足 ISO/IEC 27001*s
的要求，但根據內部稽核員的報告，Techmanic
未能解決與託管服務相關的不符合問題。此外，內部稽核報告存在多處不一致之處，這使人們對內部稽核師在託管服務審計過程中的獨立性產生了質疑。基於此，延期認證未獲核准。因此。 Techmanic 請求轉移到另一個認證機構。同時，該公司向客戶發布聲明稱，ISO/IEC 27001 認證涵蓋 IT 服務以及託管服務。
根據上述情景，回答以下問題：
審核員在遠端跟進糾正措施後，建議對 Techmanic 進行認證。這可以接受嗎？
**A.**是的，由於發現了輕微的不符合情況，審核員可以遠端跟進行動計劃
**B.**否，必須進行審計跟進，因為審計報告包含不符合項
**C.**否，由於已要求延期，因此必須在現場進行審計跟進
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct answer:
Remote follow-ups are acceptable for minor nonconformities, as long as auditors can verify corrective actions.
ISO/IEC 17021-1:2015 allows remote follow-ups when the effectiveness of corrective actions can be demonstrated.
B . Incorrect:
Follow-ups are required, but remote verification is acceptable for minor issues.
C . Incorrect:
An on-site follow-up is not mandatory unless major nonconformities are present.
Relevant Standard Reference:

**QUESTION NO: 320**
您是一位審核小組組長，剛完成了對行動電信供應商的第三方審核。您正在準備審計報告，並即將完成標題為「保密」的部分。
您團隊中受訓的審核員會詢問您是否在任何情況下可以將機密報告發佈給第三方。
以下哪四個答案是錯的？
**A.**雖然我們建議客戶該報告是保密的，但如果我們認為合理，我們可以決定將其發佈給第三方。我們總是事後告訴客戶
**B.**報告可以發佈給第三方，但必須經過審計客戶的明確事先批准
**C.**在任何情況下都不能將報告發佈給第三方。機密意味著機密，洩漏該文件將構成違反信任
**D.**起始立場始終是第三方沒有自動存取審核報告的權利
**E.**如果第三方已獲得我們揭露報告的法律通知，那麼我們必須這樣做。在所有此類情況下，我們都會向審核客戶以及受審核方（如適用）提供建議

**F.**審核機構僱用的任何審核員都可以存取審核報告
**G.**我們的保密義務並不是永遠持續的。作為認證機構，我們可以決定將報告保密多久。此後，第三方可以透過提出主題存取請求來存取它們
**H.**分包審核員被視為保密方面的第三方，因此通常受保密協議的約束
***Answer:*** A,F,G,H
Explanation:
The audit report is a confidential document that contains sensitive information about the auditee's ISMS and its performance. The audit team has a duty to protect the confidentiality of the audit report and only disclose it to authorized parties, such as the audit client, the certification body, and the accreditation body. Therefore, the following responses are false:
A: The audit team cannot decide to release the report to third parties without the consent of the audit client, as this would breach the confidentiality agreement and the audit code of conduct. The audit team should always inform the audit client before disclosing the report to any third party, and obtain their explicit, prior approval.
F: Not every auditor employed by the auditing organization can access the audit report, as this would violate the principle of need-to-know. Only auditors who are involved in the audit process, such as the audit team leader, the audit team members, the audit programme manager, and the certification decision maker, can access the audit report. Other auditors who are not related to the audit have no legitimate reason to access the report, and should be prevented from doing so by appropriate security measures.
G: The duty of confidentiality does not expire after a certain period of time, as this would compromise the trust and integrity of the audit process. The audit report remains confidential indefinitely, unless there is a legal or contractual obligation to disclose it, or the audit client agrees to release it. Third parties cannot access the audit report by making a subject access request, as this would infringe the privacy and data protection rights of the audit client and the auditee.
H: Subcontracted auditors are not considered to be third parties regarding confidentiality, as they are part of the audit team and have a contractual relationship with the auditing organization. Subcontracted auditors are typically bound by the same confidentiality agreement and audit code of conduct as the employed auditors, and have the same rights and responsibilities to access and protect the audit report.
Reference:
ISO/IEC 27001:2022, clause 9.2, Internal audit
ISO/IEC 27006:2015, clause 7.2.3, Confidentiality
PECB Candidate Handbook ISO 27001 Lead Auditor, page 22, Audit Report
PECB Candidate Handbook ISO 27001 Lead Auditor, page 24, Audit Code of Conduct

**QUESTION NO: 321**
您正在一家提供醫療保健服務的住宅療養院 (ABC) 進行 ISMS 審核。審核計劃的下一步是驗證 ABC
醫療保健行動應用程式開發、支援和生命週期流程的資訊安全性。在審核過程中，您了解到該組織將行動應用程式開發外包給了一家擁有CMMI Level 5、ITSM（ISO/IEC 20000-1）、BCMS（ISO
22301）和
通過 ISMS (ISO/IEC 27001) 認證。

IT經理介紹了軟體安全管理流程，並將流程總結如下：
行動應用程式開發至少應採用「設計安全」和「預設安全」原則。
應具備以下個人資料保護安全功能：
存取控制。
個人資料加密，即高階加密標準（AES）演算法，金鑰長度：256位元；個人資料假名化。
已檢查漏洞，無安全後門
您採樣最新的行動應用測試報告，詳細資訊如下：

| Target of Test: ABC's healthcare mobile app, version 1 | Test results | Test summary |
|---|---|---|
| Security test | | |
| Personal data encryption | Fail | Not able to perform the encryption. |
| Personal data pseudonymisation | Fail | Not able to perform the pseudonymisation. |
| Final approval: | | |
| by: *Service Manager* | | signed |

IT經理解釋說，根據軟體安全管理程序，測試結果應由他批准。加密和假名功能失敗的原因是這些功能嚴重降低了系統和服務效能。需要額外 150%
的資源來滿足這一點。服務經理同意存取控制足夠好並且可以接受。這就是服務經理簽署批准書的原因。
您正在準備審計結果。選擇正確的選項。
**A.**存在不合格項 (NC)。組織和開發人員不執行驗收測試。
（與第 8.1 條相關，控制措施 A.8.29）
**B.**存在不合格項 (NC)。組織和開發人員執行的安全測試失敗。
（與第 8.1 條相關，控制措施 A.8.29）
**C.**存在不合格項 (NC)。服務管理員不遵守軟體安全管理程序。（與第 8.1 條相關，控制措施 A.8.30）
**D.**不存在不合格項 (NC)。服務經理做出了繼續提供服務的正確決定。
（與第 8.1 條相關，控制措施 A.8.30）
***Answer:*** C

**QUESTION NO: 322**
場景 3：Rebuildy
是一家位於泰國曼谷的建築公司，專門從事住宅建築的設計、建造和維護。為了確保敏感專案資料和客戶資訊的安全，Rebuildy 決定實施基於 ISO/IEC 27001 的資訊安全管理系統 (ISMS)。
ISMS 實施成果如下
* 資訊安全是透過應用一系列安全控制和製定政策、流程和程序來實現的。
* 安全控制是根據風險評估實施的，旨在消除風險或將風險降低到可接受的水平。
* 所有流程均基於計劃-執行-檢查-行動 (PDCA) 模型確保 ISMS 的持續改進。
*
資訊安全政策是根據最佳安全實務起草的安全手冊的一部分，因此，它不是一份獨立的文件。

* 資訊安全角色和職責已在每位員工的職位說明中明確說明
* 資訊安全管理系統的管理評審是依照計畫的時間間隔進行的。
Rebuildy
在經歷了兩次中期管理評審和一次年度內部審計後申請了認證。該前員工向審計團隊成員 Electra 提交了書面證據，Rebuildy 的主要客戶 Electra
也提交了有關相同問題的證據，審計員決定保留這份證據，而不是前員工的證據。審計團隊成員一直與 Electra
保持聯繫，直至審計完成，討論審計期間發現的不符合。伊萊克特拉提供了額外的證據來支持這些發現。
在審核開始時，審核小組對公司高階主管進行了訪談，討論了高階主管對 ISMS
實施的承諾等事項。從這些討論中獲得的證據都記錄在書面確認書中，用於確定 Rebuildy
是否符合 ISO/IEC 27001 的幾個條款。其中，發現以下不符合：
* 在公司的財務報告系統中偵測到了不當的使用者存取控制設定實例。
* 尚未建立獨立的資訊安全政策。相反，該公司使用根據最佳安全實踐起草的安全手冊。
在收到審計團隊的這些文件後，團隊負責人會見了 Rebuildy
的高層管理層，介紹了審計結果。審計小組報告了與財務報告系統和缺乏獨立資訊安全政策有關的調查結果。高階主管對調查結果表示不滿，並認為審計組長的行為不專業，暗示他們可能會要求更換組長。迫於壓力，審計組長決定與高階主管合作，淡化所發現的不符合項的重要性。因此，審計團隊負責人調整了報告以呈現更有利的觀點，從而歪曲了 Rebuildy
合規問題的真實程度。
根據上述情景，回答以下問題：
根據情境 3，稽核團隊使用從高階主管訪談中獲得的資訊來確定 Rebuildy 是否符合 ISO/IEC 27001 的幾項條款。這可以接受嗎？

**A.**不，審計團隊應該只使用政策和程序等書面證據來確定是否符合要求

**B.**是的，審計小組透過最高管理層的書面確認獲得了口頭證據，可用於確定是否符合標準

**C.**是的，與高階主管的訪談是最可靠的審計證據形式，可用於確定是否符合標準，而無需進一步驗證

***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:
Audit evidence can come from interviews, observations, and documentation.
Verbal evidence from top management is acceptable if documented and confirmed in writing.
A . Incorrect:
ISO 19011 allows verbal evidence as long as it is substantiated.
C . Incorrect:
Interviews alone are not sufficient-additional verification is required.
Relevant Standard Reference:

**QUESTION NO: 323**
管理審核計畫的個人負責下列哪六項行動？

**A.**選擇審核團隊

**B.**保留審核結果的記錄資訊

**C.**定義單獨審核的目標、範圍和標準

**D.**定義單獨審核的計劃

**E.**確定審核計劃的範圍
**F.**建立審核計劃
**G.**確定審核計畫所需的資源
**H.**審核期間與受審核方的溝通
***Answer:*** A,B,C,D,E,F
Explanation:
According to ISO 19011:2018, which provides guidelines for auditing management systems, an audit programme is a set of one or more audits planned for a specific time frame and directed towards a specific purpose1. The individual(s) managing the audit programme are responsible for establishing, implementing and maintaining the audit programme in accordance with the organization's policies and objectives1. This includes defining the extent of the audit programme based on strategic direction, risks and opportunities; establishing the audit programme by defining its objectives, scope and criteria; determining the resources necessary for the audit programme; selecting competent auditors and assigning them to appropriate audits; defining the objectives, scope and criteria for each individual audit; defining the plan of each individual audit; retaining documented information of the audit results; reviewing and improving the performance of the audit programme1. Therefore, these six actions are part of the responsibilities of the individual(s) managing the audit programme. The other option, communicating with the auditee during the audit, is not a responsibility of the individual(s) managing the audit programme, but rather a responsibility of the audit team leader1. Reference: ISO 19011:2018 - Guidelines for auditing management systems

**QUESTION NO: 324**
應根據審計標準審查下列哪一項以確定審計結果？
**A.**審核結論
**B.**審計證據
**C.**審核目標
**D.**審核範圍
***Answer:*** B
Explanation:
* Audit Findings: These are the results of evaluating collected audit evidence against the predetermined audit criteria.
* Audit Evidence: Objective, verifiable information gathered through interviews, observations, document reviews, etc., that supports the audit findings.
* Audit Criteria: The standards, policies, procedures, or requirements of the ISMS that are used as benchmarks for the audit.
The Process: Auditors compare collected audit evidence against the audit criteria to determine whether there is conformity or nonconformity, leading them to generate audit findings.
Reference:
* ISO/IEC 27001:2022, Section 9.2 (Internal Audit): Discusses the process of gathering audit evidence and documenting nonconformities (which form a basis for audit findings).

**QUESTION NO: 325**
您正在準備審計結果。選擇兩個正確的選項。

**A.**還有改進的機會 (OFI)。可以提高iLiirmation安全事件訓練的有效性。這與第 7.2 條和控制措施 A.6.3 相關。
**B.**沒有不合格項。報告資訊安全弱點、事件和事故。
這符合第 9.1 條和控制措施 A.5.24。
**C.**沒有不合格項。已進行資訊安全處理培訓，並評估其有效性。這符合第 7.2 條和控制措施 A.6.3。
**D.**存在不合格項
(NC)。根據抽樣訪談結果，沒有受訪者能夠描述事件管理程序報告流程，包括人員的角色和職責。這不符合第 9.1 條和控制措施 A.5.24。
**E.**存在不合格項 (NC)。資訊安全事件培訓失敗。這不符合第 7.2 條和控制措施 A.6.3。
**F.**有改進的機會 (OFI)。報告資訊安全弱點、事件和缺陷。這與第 9.1 條和控制措施 A.5.24 有關。
***Answer:*** A,D
Explanation:
According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), clause 7.2 requires an organization to determine the necessary competence of persons doing work under its control that affects its ISMS performance, and to provide training or take other actions to acquire or maintain the necessary competence1. Control A.6.3 requires an organization to ensure that all employees and contractors are aware of information security threats and concerns, their responsibilities and liabilities, and are equipped to support organizational policies and procedures in this respect2. Therefore, if an ISMS auditor finds that the information security incident training effectiveness can be improved, this indicates an opportunity for improvement (OFI) that is relevant to clause 7.2 and control A.6.3.
According to ISO/IEC 27001:2022, clause 9.1 requires an organization to monitor, measure, analyze and evaluate its ISMS performance and effectiveness1. Control A.5.24 requires an organization to define and apply procedures for reporting information security events and weaknesses2. Therefore, if an ISMS auditor finds that based on sampling interview results, none of the interviewees were able to describe the incident management procedure reporting process including the role and responsibilities of personnel, this indicates a nonconformity (NC) that is not conforming with clause 9.1 and control A.5.24.
The other options are not correct options for preparing the audit findings based on the given information. For example, there is no nonconformance if the information security weaknesses, events, and incidents are reported, as this conforms with clause 9.1 and control A.5.24; there is no nonconformance if the information security handling training has performed, and its effectiveness was evaluated, as this conforms with clause 7.2 and control A.6.3; there is no nonconformity if the information security incident training has failed, as this may not necessarily indicate a lack of conformity with clause 7.2 or control A.6.3; there is no opportunity for improvement if the information security weaknesses, events, and incidents are reported, as this is already conforming with clause 9.1 and control A.5.24. Reference: ISO/IEC 27001:2022 - Information technology - Security techniques - Information securi ty management systems - Requirements, ISO/IEC 27002:2013 - Information technology - Security techniques - Code of practice for information security controls

**QUESTION NO: 326**
在涉及多個審計組的聯合審計中，每個審計通常會指定多少名審計組長？
**A.**每次審計都配有一名審計組長，無論涉及多少個審計組
**B.**每個審計團隊都任命自己的審計團隊負責人
**C.**聯合審計中沒有指定審計組長
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
Joint audits involve multiple teams but require only one designated audit team leader to ensure:
Consistent audit methodology
Coordination among teams
Unified reporting structure
B . Incorrect:
While each team may have a coordinator, there is only one main leader responsible for the audit.
C . Incorrect:
ISO 19011 mandates the presence of a designated audit team leader in all audits.
Relevant Standard Reference:

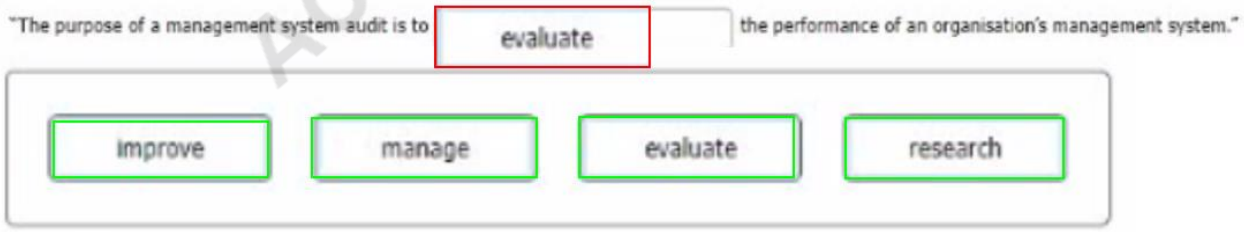
**QUESTION NO: 327**
情境 6：Sinvestment
是一家提供家庭保險、商業保險和人壽保險的保險公司。該公司成立於北卡羅來納州，但最近在其他地區進行了擴張，包括歐洲和非洲。
Sinvestment
致力於遵守適用於其行業的法律法規，並防止任何資訊安全事件。他們實施了基於 ISO/IEC 27001 的 ISMS 並申請了 ISO/IEC 27001 認證。
認證機構指派兩名審核員進行審核。與Sinvestment簽訂保密協議後。他們開始了審計活動。
首先，他們審查了標準要求的文件，包括 ISMS
範圍聲明、資訊安全政策和內部稽核報告。審查過程並不容易，因為儘管 Sinvestment
表示他們已製定文件程序，但並非所有文件都具有相同的格式。
隨後，審計小組對Sinvestment的高階主管進行了多次訪談，以了解他們在ISMS實施中的作用。第一階段審計的所有活動都是遠端進行的，除了根據 Sinvestment
的要求在現場進行的文件資訊審查之外。
在此階段，審計人員發現沒有與資訊安全培訓和意識計劃相關的文件。被問及時，Sinvestment代表表示，公司已為所有員工提供資訊安全培訓課程。第一階段審計讓審計團隊對 Sinvestment 的營運和 ISMS 有了整體了解。
第二階段審核在第一階段審核三週後進行。審計小組觀察到，行銷部門（未包含在審計範圍內）沒有適當的程序來控制員工的存取權限。由於控制員工的存取權限是ISO/IEC 27001的要求之一，並且已包含在公司的資訊安全政策中，因此該問題包含在審計報告中。此外，在第二階段審計中，審計小組觀察到Sinvestment沒有記錄使用者活動日誌。
該公司的程序規定“記錄用戶活動的日誌應保留並定期審查”，但該公司沒有提供任何執行該程序的證據。
在所有審核活動中，審核員透過觀察、訪談、文件化資訊審查、分析和技術驗證來收集資訊和

證據。對第一階段和第二階段的所有審核結果進行了分析，審核小組決定發布積極的認證建議。
根據ISO/IEC
27001要求，公司是否需要提供執行有關記錄使用者活動的日誌程式的證據？請參閱場景 6。
**A.**是的，記錄使用者活動的事件日誌必須保存並定期審查
**B.**否，因為該流程的實施不是標準的要求
**C.**否，本公司僅建議實施此程序
***Answer:*** A
Explanation:
Yes, according to ISO/IEC 27001, the company needs to provide evidence of the implementation of procedures regarding the logging of user activities. This requirement is essential to ensure that events are recorded and regularly reviewed, supporting the detection and prevention of security incidents.

**QUESTION NO: 328**
從以下選項中選擇一個最能完成句子的單字：
要用單字完成句子，請點擊要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中點擊應用程式文字。或者，您可以將該選項拖曳到適當的空白部分。




***Answer:***




**QUESTION NO: 329**
您是一位經驗豐富的 ISMS 審核員，在一家提供 ICT
回收服務的組織中進行第三方監督審核。公司不再需要的ICT設備由組織處理。它要么被重新調試並重複使用，要么被安全地銷毀。
您注意到房間角落的長凳上有兩台伺服器。兩者的項目上都貼有伺服器名稱、IP
位址和管理員密碼的貼圖。您向 ICT
經理詢問這些物品，他告訴您這些物品是昨天從一位老客戶那裡收到的一批貨物的一部分。
您應該採取哪一項行動？
**A.**請 ICT 經理記錄資訊安全事件並啟動資訊安全事件管理流程
**B.**注意審核結果並檢查處理與客戶 IT 安全相關的進貨的流程
**C.**記錄您在審核結果中看到的內容，但不採取進一步行動
**D.**針對控制提出不符合項 5.31 法律、法規、監管和合約要求'

**E.**針對控制措施
8.20「網路安全」提出不符合項（應保護、管理和控製網路和網路設備，以保護系統和應用程式中的資訊）
**F.**要求被審核方移除標籤，然後繼續審核

***Answer:*** B

Explanation:
According to ISO 27001:2022 clause 8.1.4, the organisation shall ensure that externally provided processes, products or services that are relevant to the information security management system are controlled. This includes implementing appropriate contractual requirements related to information security with external providers, such as customers who send ICT equipment for reclamation12 In this case, the organisation offers ICT reclamation services, which involves processing customer ICT equipment that may contain sensitive or confidential information. The organisation should have a process in place to ensure that the customer ICT equipment is handled securely and in accordance with the customer's information security requirements. The process should include steps such as verifying the customer's identity and authorisation, checking the inventory and condition of the equipment, removing or destroying any labels or stickers that contain information about the equipment or the customer, wiping or erasing any data stored on the equipment, and documenting the actions taken and the results achieved12 The fact that the auditor noticed two servers on a bench with stickers that reveal the server's name, IP address and admin password indicates that the process for dealing with incoming shipments relating to customer IT security is not effective or not followed. This could pose a risk of unauthorised access, disclosure, or modification of the customer's information or systems. Therefore, the auditor should note the audit finding and check the process for dealing with incoming shipments relating to customer IT security, and determine whether there is a nonconformity with clause 8.1.4 of ISO 27001:202212 The other actions are not appropriate for the following reasons:
A . Asking the ICT Manager to record an information security incident and initiate the information security incident management process is not appropriate because this is not an information security incident that affects the organisation's own information or systems. An information security incident is defined as a single or a series of unwanted or unexpected information security events that have a significant probability of compromising business operations and threatening information security12 In this case, the information security event affects the customer's information or systems, not the organisation's. Therefore, the organisation should follow the process for dealing with incoming shipments relating to customer IT security, not the process for information security incident management.
C . Recording what the auditor has seen in the audit findings, but taking no further action is not appropriate because this would not address the root cause or the impact of the issue. The auditor has a responsibility to verify the effectiveness and compliance of the organisation's information security management system, and to report any nonconformities or opportunities for improvement12 Therefore, the auditor should check the process for dealing with incoming shipments relating to customer IT security, and determine whether there is a nonconformity with clause 8.1.4 of ISO 27001:2022.
D . Raising a nonconformity against control 5.31 Legal, statutory, regulatory and contractual requirements is not appropriate because this control is not relevant to the issue. Control 5.31 requires the organisation to identify and comply with the legal, statutory, regulatory and

contractual requirements that are applicable to the information security management system12 In this case, the issue is not about the organisation's compliance with the legal, statutory, regulatory and contractual requirements, but about the organisation's control of the externally provided processes, products or services that are relevant to the information security management system. Therefore, the auditor should check the process for dealing with incoming shipments relating to customer IT security, and determine whether there is a nonconformity with clause 8.1.4 of ISO 27001:2022.
E . Raising a nonconformity against control 8.20 'network security' (networks and network devices shall be secured, managed and controlled to protect information in systems and applications) is not appropriate because this control is not relevant to the issue. Control 8.20 requires the organisation to secure, manage and control its own networks and network devices to protect the information in its systems and applications12 In this case, the issue is not about the organisation's network security, but about the organisation's control of the externally provided processes, products or services that are relevant to the information security management system. Therefore, the auditor should check the process for dealing with incoming shipments relating to customer IT security, and determine whether there is a nonconformity with clause 8.1.4 of ISO 27001:2022.
F . Asking the auditee to remove the labels, then carry on with the audit is not appropriate because this would not address the root cause or the impact of the issue. The auditor should not interfere with the auditee's operations or suggest corrective actions during the audit, as this would compromise the auditor's objectivity and impartiality12 The auditor should check the process for dealing with incoming shipments relating to customer IT security, and determine whether there is a nonconformity with clause 8.1.4 of ISO 27001:2022.
Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 330**
Finnco 是一家認證機構的子公司，為組織提供 ISMS 諮詢服務。
考慮到這種情況，認證機構什麼時候可以對組織進行認證？
**A.**這種情況下沒有時間限制
**B.**任何時候都不會，因為這會帶來利益衝突
**C.**如果自上次諮詢活動以來已經過了至少兩年
***Answer:*** B
Explanation:
A certification body cannot certify an organization if it has provided consultancy services to that organization. This situation presents a conflict of interest, as the certification body is required to maintain impartiality and objectivity. The ISO/IEC 17021-1 standard, which sets out requirements for bodies providing audit and certification of management systems, specifies that providing both services to the same client is incompatible.

**QUESTION NO: 331**
網路釣魚屬於什麼類型的資訊安全事件？
**A.**私人事件

**B.**破解者/駭客攻擊
**C.**技術漏洞
**D.**法律事件
***Answer:*** B
Explanation:
Phishing is a type of information security incident that falls under the category of cracker/hacker attacks. Phishing is a form of fraud that uses deceptive emails or other messages to trick recipients into revealing sensitive information, such as passwords, credit card numbers, bank account details, etc. Phishing emails often impersonate legitimate organizations or individuals and create a sense of urgency or curiosity to lure the victims into clicking on malicious links, opening malicious attachments or providing personal information. Phishing is a common and serious threat to information security, as it can lead to identity theft, financial loss, data breach, malware infection or other damages. ISO/IEC 27001:2022 requires the organization to implement awareness and training programs to make users aware of the risks of social engineering attacks, such as phishing, and how to avoid them (see clause A.7.2.2). Reference: CQI & IRCA Certified ISO/IEC 27001:2022 Lead Auditor Training Course, ISO/IEC 27001:2022 Information technology - Security techniques - Information security management systems - Requirements, What is Phishing?

**QUESTION NO: 332**
您有一份客戶設計文件的硬拷貝，想要處理掉。你會怎麼辦
**A.**將其丟進任何垃圾箱
**B.**使用粉碎機將其粉碎
**C.**將其交給辦公室男孩以將其重新用於其他目的
**D.**環境友善並且重複使用它來編寫
***Answer:*** B
Explanation:
The best way to dispose of a hard copy of a customer design document is to shred it using a shredder. This is because shredding ensures that the document is destroyed and cannot be reconstructed or accessed by unauthorized persons. A customer design document may contain sensitive or confidential information that could cause harm or damage to the customer or the organization if disclosed. Therefore, it is important to protect the confidentiality and integrity of the document until it is securely disposed of. Throwing it in any dustbin, giving it to the office boy to reuse it for other purposes, or reusing it for writing are not secure ways of disposing of the document, as they could expose the document to unauthorized access, theft, loss or damage. ISO/IEC 27001:2022 requires the organization to implement procedures for the secure disposal of media containing information (see clause A.8.3.2). Reference: CQI & IRCA Certified ISO/IEC 27001:2022 Lead Auditor Training Course, ISO/IEC 27001:2022 Information technology - Security techniques - Informatio n security management systems - Requirements, What is Secure Disposal?

**QUESTION NO: 333**
情境 8：EsBank 自 9 月起為愛沙尼亞銀行業提供銀行和金融解決方案
2010年，該公司在全國擁有30家分行和100多台ATM機。
EsBank

在高度監管的行業中運營，必須遵守許多有關資料安全和隱私的法律和法規。他們需要透過實施技術和非技術控制來管理整個營運的資訊安全。 EsBank 決定實施基於 ISO/IEC 的 ISMS 27001，因為它提供了更好的安全性、更多的風險控制以及符合法律法規的關鍵要求。
在成功實施 ISMS 九個月後，EsBank 決定由獨立認證機構根據 ISO/IEC 27001 對其 ISMS 進行認證。
第一階段和第二階段審核是共同進行的，發現了一些不符合項。第一個不合格之處與 EsBank 的資訊標籤有關。該公司有資訊分類方案，但沒有資訊標籤程序。因此，需要相同保護等級的文件將被貼上不同的標籤（有時為機密，有時為敏感）。
考慮到所有文件也以電子方式存儲，不合格情況也影響了媒體處理。審計小組透過抽樣得出結論，200 個可移動媒體中有 50
個儲存了被錯誤分類為機密的敏感資訊。根據資訊分類方案，允許將機密資訊儲存在可移動媒體中，而嚴格禁止儲存敏感資訊。這標誌著另一個不合格之處。
他們起草了不合格報告，並與 EsBank
代表討論了審計結論，代表同意在兩個月內針對發現的不合格問題提交行動計劃。
EsBank
接受了審計組組長提出的解決方案。他們根據實體和電子格式的分類方案起草了資訊標籤程序，解決了不合格問題。可移動媒體程式也基於此程式進行了更新。
審計完成兩週後，EsBank
提交了總體行動計畫。在那裡，他們解決了檢測到的不合格問題以及採取的糾正措施，但沒有包括有關受影響的系統、控製或操作的任何詳細資訊。審核小組評估了該行動計劃並得出結論，該計劃將解決不合格問題。然而，EsBank 收到了不利的認證建議。
根據上述場景，回答以下問題：
根據情境
8，審核小組評估了行動計畫並得出結論，該計畫將解決檢測到的不符合項。這是可以接受的嗎？

**A.**是的。審核小組必須評估行動計畫並驗證其是否適合糾正檢測到的不合格項

**B.**是，前提是 EsBank
之前已經驗證了行動計劃的有效性，並告知審核團隊該行動計劃允許糾正不合格項

**C.**否，被審核方應驗證行動計畫是否允許糾正不合格項並消除根本原因

***Answer:*** A

**QUESTION NO: 334**
您正在作為審核組組長進行您的第一次第三方 ISMS
監督審核。您目前與審核團隊的另一位成員一起在被審核方的資料中心。
您目前所在的大房間被分成幾個較小的房間，每個房間的門上都有一個數位密碼鎖和刷卡器。
您注意到兩個外部承包商使用中心接待台提供的刷卡和組合號碼進入客戶的套房進行授權的電氣維修。
您前往接待處並要求查看客戶套房的門禁記錄。這表示只刷了一張卡。你問接待員，他們回答說：“是的，這是一個常見問題。我們要求每個人都刷卡，但尤其是承包商，一個人往往會刷卡，而其他人只是'尾隨'進來”，但我們知道他們是誰接待處簽到。
根據上述情況，您現在會採取下列哪一項行動？

**A.**不採取任何行動。無論有什麼建議，承包商都將始終以這種方式行事

**B.**由於尚未與供應商就資訊安全要求達成一致，因此針對控制措施
A.5.20「解決供應商關係中的資訊安全問題」提出不符合項

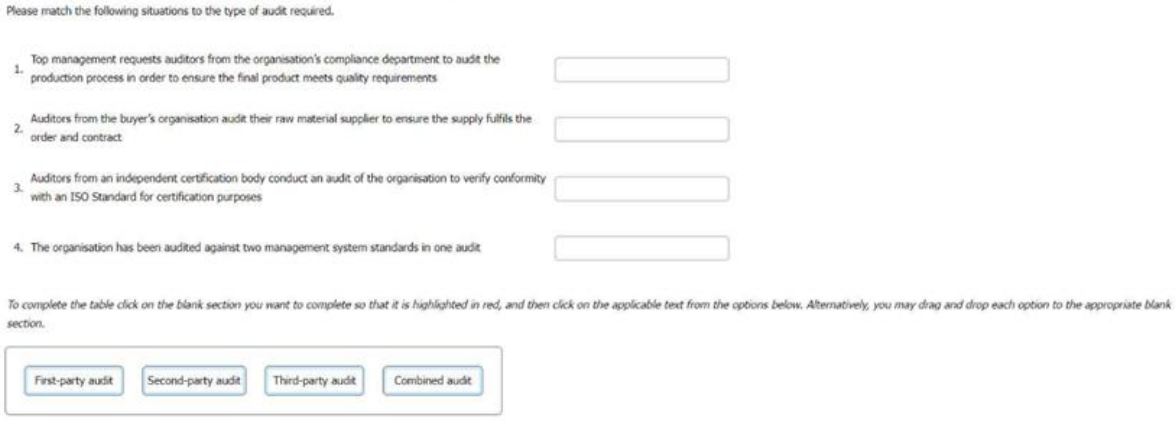
**C.**針對控制

A.7.6「在安全區域工作」提出不符合項，因為尚未定義在安全區域工作的安全措施
**D.**確定是否有任何額外的有效安排來驗證個人對安全區域（例如閉路電視）的存取權限
**E.**提供改進機會，承包商在訪問安全設施時必須始終有人陪同
**F.**提供改進機會，在接待處設置大型標牌，提醒每個需要進入的人必須始終使用刷卡
**G.**由於安全區域未充分保護，因此針對控制 A.7.2「物理進入」提出不符合項
**H.**告訴組織他們必須寫信給承包商，提醒他們需要適當使用門禁卡
***Answer:*** G
Explanation:
According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), control A.7.2 requires an organization to implement appropriate physical entry controls to prevent unauthorized access to secure areas1. The organization should define and document the criteria for granting and revoking access rights to secure areas, and should monitor and record the use of such access rights1. Therefore, when auditing the organization's application of control A.7.2, an ISMS auditor should verify that these aspects are met in accordance with the audit criteria.
Based on the scenario above, the auditor should raise a nonconformity against control A.7.2, as the secure area is not adequately protected from unauthorized access. The auditor should provide the following evidence and justification for the nonconformity:
Evidence: The auditor observed two external contractors using a swipe card and combination number provided by the centre's reception desk to gain access to a client's suite to carry out authorized electrical repairs. The auditor checked the door access record for the client's suite and found that only one card was swiped. The auditor asked the receptionist and was told that it was a common problem that contractors tend to swipe one card and tailgate their way in, but they were known from the reception sign-in.
Justification: This evidence indicates that the organization has not implemented appropriate physical entry controls to prevent unauthorized access to secure areas, as required by control A.7.2. The organization has not defined and documented the criteria for granting and revoking access rights to secure areas, as there is no verification or authorization process for providing swipe cards and combination numbers to external contractors. The organization has not monitored and recorded the use of access rights to secure areas, as there is no mechanism to ensure that each individual swipes their card and enters their combination number before entering a secure area. The organization has relied on the reception sign-in as a means of identification, which is not sufficient or reliable for ensuring information security.
The other options are not valid actions for auditing control A.7.2, as they are not related to the control or its requirements, or they are not appropriate or effective for addressing the nonconformity. For example:
Take no action: This option is not valid because it implies that the auditor ignores or accepts the nonconformity, which is contrary to the audit principles and objectives of ISO 19011:20182, which provides guidelines for auditing management systems.
Raise a nonconformity against control A.5.20 'addressing information security in supplier relationships' as information security requirements have not been agreed upon with the supplier: This option is not valid because it does not address the root cause of the nonconformity, which is related to physical entry controls, not supplier relationships. Control

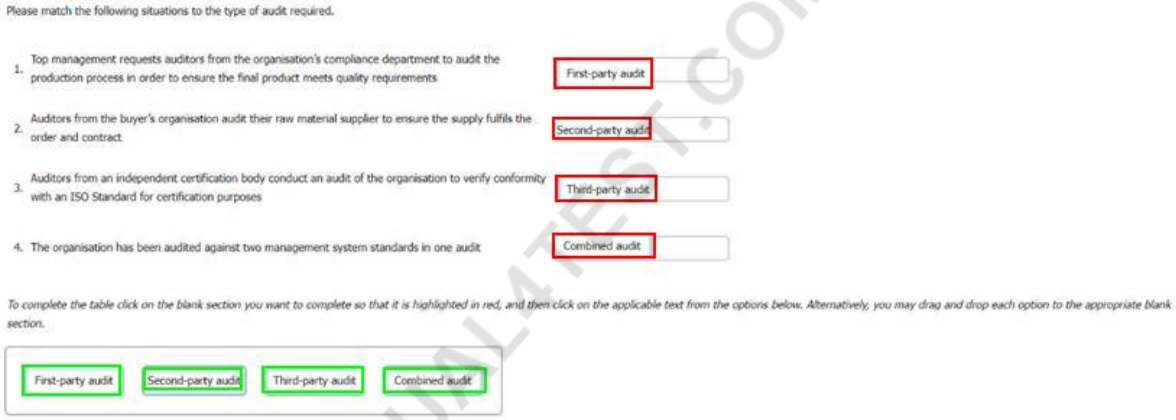
A.5.20 requires an organization to agree on information security requirements with suppliers that may access, process, store, communicate or provide IT infrastructure components for its information assets1. While this control may be relevant for ensuring information security in supplier relationships, it does not address the issue of unauthorized access to secure areas by external contractors.
Raise a nonconformity against control A.7.6 'working in secure areas' as security measures for working in secure areas have not been defined: This option is not valid because it does not address the root cause of the nonconformity, which is related to physical entry controls, not working in secure areas. Control A.7.6 requires an organization to define and apply security measures for working in secure areas1. While this control may be relevant for ensuring information security when working in secure areas, it does not address the issue of unauthorized access to secure areas by external contractors.
Determine whether any additional effective arrangements are in place to verify individual access to secure areas e.g. CCTV: This option is not valid because it does not address or resolve the nonconformity, but rather attempts to find alternative or compensating controls that may mitigate its impact or likelihood. While additional arrangements such as CCTV may be useful for verifying individual access to secure areas, they do not replace or substitute the requirement for appropriate physical entry controls as specified by control A.7.2.
Raise an opportunity for improvement that contractors must be accompanied at all times when accessing secure facilities: This option is not valid because it does not address or resolve the nonconformity, but rather suggests a possible improvement action that may prevent or reduce its recurrence or severity. While accompanying contractors at all times when accessing secure facilities may be a good practice for ensuring information security, it does not replace or substitute the requirement for appropriate physical entry controls as specified by control A.7.2.
Raise an opportunity for improvement to have a large sign in reception reminding everyone requiring access must use their swipe card at all times: This option is not valid because it does not address or resolve the nonconformity, but rather suggests a possible improvement action that may increase awareness or compliance with the existing controls. While having a large sign in reception reminding everyone requiring access must use their swipe card at all times may be a helpful reminder for ensuring information security, it does not replace or substitute the requirement for appropriate physical entry controls as specified by control A.7.2.
Tell the organisation they must write to their contractors, reminding them of the need to use access cards appropriately: This option is not valid because it does not address or resolve the nonconformity, but rather instructs the organization to take a corrective action that may not be effective or sufficient for ensuring information security. While writing to contractors, reminding them of the need to use access cards appropriately may be a communication measure for ensuring information security, it does not replace or substitute the requirement for appropriate physical entry controls as specified by control A.7.2.

**QUESTION NO: 335**
請將以下情況與所需的審核類型相符。

ACTUALTEST.COM




***Answer:***




ACTUAL4TEST.COM

**QUESTION NO: 336**
下列哪一項最能描述第二階段第三方審核的主要目的？
**A.**確定認證準備狀況
**B.**檢查組織是否遵守法律
**C.**辨識不符合標準的情況
**D.**了解組織的管理體系
***Answer:*** C
Explanation:
The main purpose of a Stage 2 third-party audit is to evaluate the implementation and effectiveness of the organisation's management system and to identify any nonconformances against the requirements of the standard12. The other options are either the objectives of a Stage 1 audit (A, D) or a specific aspect of the audit scope (B). Reference: 1: ISO/IEC 27006:2022, Information technology - Security techniques - Requirements for bodies providin g audit and certification of information security management systems, Clause 9.2 \n2: PECB Certified ISO/IEC 27001 Lead Auditor Exam Preparation Guide, Domain 4: Preparing an ISO/IEC 27001 audit

**QUESTION NO: 337**
大數據等新科技的使用對審計有何影響？

**A.**它提出了新的挑戰，例如，結合結構化和非結構化數據
**B.**透過使審核員能夠收集更高品質的審核證據來提高審核質量
**C.**它會造成嚴重中斷，例如，引入對於傳統資料庫管理工具處理來說太大或太複雜的數據
***Answer:*** A
Explanation:
The use of new technologies such as big data presents new challenges in auditing, particularly the issue of combining structured and unstructured data. Big data environments often include diverse data sets that auditors need to understand and interpret, which requires new skills and approaches to ensure effective and comprehensive audit coverage.

**QUESTION NO: 338**
一家行銷機構已經制定了其風險評估方法作為 ISMS 實施的一部分。這可以接受嗎？
**A.**是的，可以使用任何符合 ISO/IEC 27001 要求的風險評估方法
**B.**是的，但前提是風險評估方法與公認的風險評估方法一致
**C.**不，實施 ISMS 時應使用 ISO/IEC 27001 提供的風險評估方法
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
ISO/IEC 27001 does not prescribe a specific risk assessment methodology but instead provides general requirements for risk assessment. Organizations are free to develop their own risk assessment methods, as long as they:
Identify risks and impacts on information security.
Define risk criteria for evaluating risks.
Implement risk treatment plans based on the organization's context.
A . Correct Answer:
ISO/IEC 27001 Clause 6.1.2 (Information Security Risk Assessment) states that organizations may define their own risk assessment methodology.
This approach must be systematic, measurable, and aligned with business objectives.
B . Incorrect:
Organizations are not required to use a recognized methodology like OCTAVE, MEHARI, or EBIOS, as long as their approach meets ISO requirements.
C . Incorrect:
ISO/IEC 27001 does not mandate a specific risk assessment method, only that a consistent and structured approach is used.
Relevant Standard Reference:
ISO/IEC 27001:2022 Clause 6.1.2 (Information Security Risk Assessment Process)

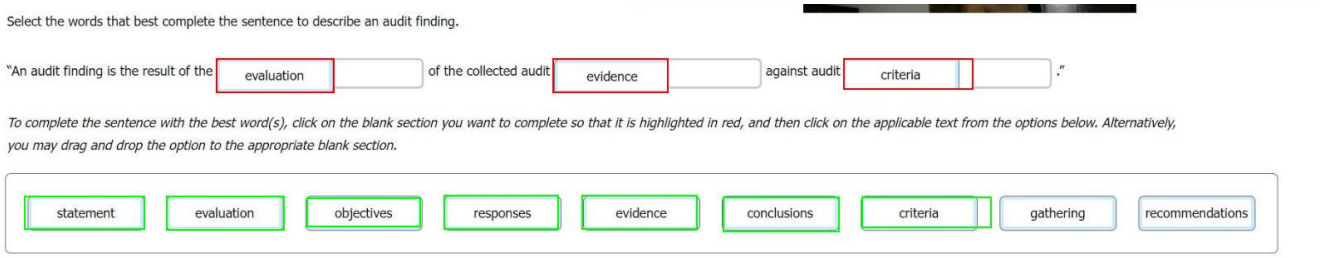
**QUESTION NO: 339**
Select the words that best complete the sentence to describe an audit finding.

"An audit finding is the result of the [ ] of the collected audit [ ] against audit [ ]."

*To complete the sentence with the best word(s), click on the blank section you want to complete so that it is highlighted in red, and then click on the applicable text from the options below. Alternatively, you may drag and drop the option to the appropriate blank section.*

| statement | evaluation | objectives | responses | evidence | conclusions | criteria | gathering | recommendations |
|---|---|---|---|---|---|---|---|---|

***Answer:***




**QUESTION NO: 340**

場景 7：Lawsy 是一家領先的律師事務所，在新澤西州和紐約市設有辦公室。它擁有 50 多名律師，為商業法、智慧財產權、銀行和金融服務領域的客戶提供完善的法律服務。他們相信，由於他們致力於實施資訊安全最佳實踐並跟上技術發展的步伐，他們在市場上佔據了有利的地位。

Lawsy 已經嚴格實施、評估和進行 ISMS 內部審核兩年了。

現在，他們已向知名且值得信賴的認證機構ISMA申請ISO/IEC 27001認證。

在第一階段審核期間，審核小組審查了實施過程中所建立的所有 ISMS 文件。

他們還審查和評估了管理審查和內部審計的記錄。

Lawsy

提交了證據記錄，表明在必要時對不合格項採取了糾正措施，因此審核組約談了內部審核員。

訪談透過提供對內部稽核計畫和程序的詳細了解，驗證了內部稽核的充分性和頻率。

審計小組繼續驗證戰略文件，包括資訊安全政策和風險評估標準。在資訊安全政策審查期間，團隊注意到描述治理框架（即資訊安全政策）的記錄資訊與程序之間存在不一致。

儘管允許員工將筆記型電腦帶到工作場所之外，但 Lawsy

並沒有製定有關在這種情況下使用筆記型電腦的程序。此政策僅提供有關筆記型電腦使用的一般資訊。該公司依靠員工的常識來保護筆記型電腦中儲存的資訊的機密性和完整性。該問題已記錄在第一階段審計報告中。

完成第一階段審核後，審核組長準備了審核計劃，其中規定了審核目標、範圍、標準和程序。

在第二階段審核期間，審核小組約談了資安經理，資安經理起草了資訊安全政策。他透過指出 Lawsy

每三個月舉辦一次強制性資訊安全培訓和意識課程來證明第一階段中確定的問題的合理性。

面談後，審核小組檢查了 15 份員工培訓記錄（共 50 份），得出的結論是 Lawsy 符合 ISO/IEC 27001

有關培訓和意識的要求。為了支持這個結論，他們影印了檢查過的員工訓練記錄。

根據上述場景，回答以下問題：

審核員是否應在審核完成後將員工訓練記錄的副本存檔？請參閱場景 7。

**A.**否，文件副本通常不會儲存為審核記錄

**B.**是的，如審計協議中所述，審計員擁有文件副本

**C.**是的，審核期間產生的所有文件化資訊應保留為審核記錄

***Answer:*** A

Explanation:

No, copies of files are not generally kept as audit records unless specifically required and agreed upon in the audit plan. Audit records typically include notes and observations made by auditors, not copies of the auditee's files, unless these are essential and explicitly allowed by the auditee.

**QUESTION NO: 341**
場景 2：
Clinic 成立於 20 世紀 90
年代，是一家專門治療心臟相關疾病和複雜外科手術的醫療器材公司。該公司總部位於歐洲，為患者和醫療保健專業人士提供服務。診所收集患者數據以客製化治療方案、監測結果並改善設備功能。為了增強資料安全性和建立信任，Clinic 正在實施基於 ISO/IEC 27001
的資訊安全管理系統 (ISMS)。
診所僅透過考慮內部問題、介面、內部和外包活動之間的依賴關係以及相關方的期望來確定其 ISMS 的範圍。此範圍已仔細記錄並可供查閱。在定義其 ISMS 時，Clinic
選擇專注於關鍵部門內的關鍵流程，例如研發、病患資料管理和客戶支援。
儘管最初面臨挑戰，Clinic 仍然致力於實施
ISMS，並根據其獨特需求量身定制安全控制。專案團隊從 ISO/IEC 27001 中排除了某些附件 A
控制，同時加入了額外的特定產業控制以增強安全性。該團隊根據內部和外部因素評估了這些控制的適用性，最終制定了全面的適用性聲明
(SoA)，詳細說明了控制選擇和實施背後的理由。
隨著認證準備工作的進展，被任命為團隊負責人的 Brian
採用了自我導向的風險評估方法來識別和評估公司的策略問題和安全實踐。這種積極主動的方法確保診所的風險評估與其目標和使命保持一致。
基於場景2，診所初步確定了其資訊安全目標，然後進行了風險評估。這可以接受嗎？
**A.**是的，因為可以稍後調整目標以適應風險評估結果
**B.**不，因為風險評估應僅在目標完全實現後進行
**C.**不，必須根據 ISO/IEC 27001 的要求，建立資訊安全目標，並考慮風險評估結果
***Answer:*** C
Explanation:
Comprehensive and Detailed In-Depth
C . Correct Answer: ISO/IEC 27001 Clause 6.2 (Information Security Objectives and Planning A . Incorrect: While objectives can be revised, they must be initially established based on risk assessment findings.
B . Incorrect: Objectives should be set after risk assessment, but security objectives are not dependent on full implementation.

**QUESTION NO: 342**
您正在一家提供醫療保健服務的住宅療養院進行 ISMS
審核。審核計畫的下一步是驗證業務連續性管理流程的資訊安全性。
在審計過程中，您了解到該組織啟動了其中一項業務連續性計劃
(BCP)，以確保護理服務在最近的大流行期間繼續進行。您要求服務經理解釋組織如何在業務連續性管理流程中管理資訊安全。
服務經理提出針對大流行的護理服務連續性計劃，並將流程總結如下：
停止接納任何新居民。
70%的行政人員和30%的醫護人員將在家工作。
定期員工自我檢測，包括在來辦公室前 1 天提交陰性檢測報告。
安裝 ABC
的醫療保健行動應用程序，追蹤他們的足跡並出示綠色健康狀況二維碼以供現場檢查。
您詢問服務經理，當員工在家工作時，如何防止非相關家庭成員或利害關係人存取居民的個人

資料。服務經理無法回答，並建議安全經理應提供協助。
您想要進一步調查其他領域以收集更多審計證據 選擇將在您的審計追蹤中的三個選項。
**A.**收集更多有關組織如何管理行動裝置上和遠端辦公期間的資訊安全的證據（與控制措施 A.6.7 相關）
**B.**透過訪問更多員工來了解他們對在家工作的感受，收集更多證據。（與第4.2條相關）
**C.**收集更多證據，了解組織提供哪些資源來支持在家工作的員工。（與第7.1條相關）
**D.**收集更多有關組織如何進行業務風險評估的證據，以評估現有居民離開療養院的速度。（與第6條相關）
**E.**收集更多有關如何以及何時測試業務連續性廣域網路的證據。（與控制措施 A.5.29 相關）
**F.**收集更多證據，說明組織如何確保只有檢測結果為陰性的員工才能進入組織（與控制措施 A.7.2 相關）
***Answer:*** A,E,F
Explanation:
According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), control A.5.29 requires an organization to establish and maintain a business continuity management process to ensure the continued availability of information and information systems at the required level following disruptive incidents1. The organization should identify and prioritize critical information assets and processes, assess the risks and impacts of disruptive incidents, develop and implement business continuity plans (BCPs), test and review the BCPs, and ensure that relevant parties are aware of their roles and responsibilities1. Therefore, when verifying the information security of the business continuity management process, an ISMS auditor should verify that these aspects are met in accordance with the audit criteria.
Three options that will be in the audit trail for verifying control A.5.29 are:
Collect more evidence on how the organisation manages information security on mobile devices and during teleworking (Relevant to control A.6.7): This option is relevant because it can provide evidence of how the organization has implemented appropriate controls to protect the confidentiality, integrity and availability of information and information systems when staff work from home using mobile devices, such as laptops, tablets or smartphones. This is related to control A.6.7, which requires an organization to establish a policy and procedures for teleworking and use of mobile devices1.
Collect more evidence on how and when the Business Continuity Plan has been tested (Relevant to control A.5.29): This option is relevant because it can provide evidence of how the organization has tested and reviewed the BCPs to ensure their effectiveness and suitability for different scenarios, such as a pandemic. This is related to control A.5.29, which requires an organization to test and review the BCPs at planned intervals or when significant changes occur1.
Collect more evidence on how the organisation makes sure only staff with a negative test result can enter the organisation (Relevant to control A.7.2): This option is relevant because it can provide evidence of how the organization has implemented appropriate controls to prevent or reduce the risk of infection or transmission of diseases among staff or residents, such as requiring regular staff self-testing and using a health status app. This is related to control A.7.2, which requires an organization to ensure that all employees and contractors

are aware of information security threats and concerns, their responsibilities and liabilities, and are equipped to support organizational policies and procedures in this respect1.
The other options are not relevant to verifying control A.5.29, as they are not related to the control or its requirements. For example:
Collect more evidence by interviewing more staff about their feeling about working from home (Relevant to clause 4.2): This option is not relevant because it does not provide evidence of how the organization has established and maintained a business continuity management process or ensured the continued availability of information and information systems following disruptive incidents. It may be related to clause 4.2, which requires an organization to understand the needs and expectations of interested parties, but not specifically to control A.5.29.
Collect more evidence on what resources the organisation provides to support the staff working from home (Relevant to clause 7.1): This option is not relevant because it does not provide evidence of how the organization has established and maintained a business continuity management process or ensured the continued availability of information and information systems following disruptive incidents. It may be related to clause 7.1, which requires an organization to determine and provide the resources needed for its ISMS, but not specifically to control A.5.29.
Collect more evidence on how the organisation performs a business risk assessment to evaluate how fast the existing residents can be discharged from the nursing home (Relevant to clause 6): This option is not relevant because it does not provide evidence of how the organization has established and maintained a business continuity management process or ensured the continued availability of information and information systems following disruptive incidents. It may be related to clause 6, which requires an organization to plan actions to address risks and opportunities for its ISMS, but not specifically to control A.5.29.

**QUESTION NO: 343**
情境 4：SendPay
是一家金融公司，透過代理商和金融機構網路提供服務。他們的主要服務之一是在全球範圍內轉帳。 SendPay
作為一家新公司，致力於為客戶提供最優質的服務。由於該公司提供國際交易，因此要求客戶提供個人信息，例如身份、交易原因以及完成交易可能需要的其他詳細信息。因此，SendPay 已實施安全措施來保護客戶的訊息，包括偵測、調查和回應可能出現的任何資訊安全威脅。他們對提供安全服務的承諾也體現在 ISMS 實施過程中，該公司投入了大量時間和資源。
去年，SendPay
推出了他們的數位平台，允許透過智慧型手機或筆記型電腦等電子設備進行貨幣交易，而無需支付額外費用。透過這個平台，SendPay
的客戶可以隨時隨地發送和接收資金。該數位平台幫助SendPay簡化了公司營運並進一步拓展了業務。當時SendPay正在外包其軟體業務，因此該專案是由外包公司的軟體開發團隊完成的。
該團隊還負責維護 SendPay 的技術基礎設施。
最近，該公司在實施 ISMS 近一年後申請了 ISO/IEC 27001
認證。他們與符合其標準的認證機構簽訂了合約。不久之後，認證機構任命了一個由四名審核員組成的團隊來審核 SendPay 的 ISMS。
審計過程中，發現以下情況：
1.外包軟體公司在未事先通知的情況下終止了與SendPay的合約。結果，SendPay

無法立即將服務恢復到內部，其營運中斷了五天。審計人員要求 SendPay
的代表提供證據，證明他們在合約終止的情況下有計劃遵循。這些代表沒有提供任何書面證據，但在接受審計時，他們告訴審計人員，SendPay的高層已經確定了另外兩家軟體開發公司，如果類似情況再次發生，可以立即提供服務。
2. 沒有證據顯示對外包給軟體開發公司的活動進行了監控。 SendPay
的代表再次告訴審計人員，他們定期與軟體開發公司溝通，並適當地告知可能發生的任何變更。
3.防火牆測試未發現異常狀況。審核員測試了防火牆配置，以確定這些服務提供的安全等級。他們使用資料包分析器來測試防火牆策略，這使他們能夠即時檢查發送或接收的資料包。
根據該場景，回答以下問題：
您如何評估所獲得的與外包業務監控流程相關的證據？請參閱場景 4。

**A.**無關緊要，監控外包作業不是標準的要求

**B.**不可靠。 SendPay 僅提供了有關其外包業務監控的口頭證據

**C.**SendPay 代表的適當且充分的口頭確認表明他們知道必須監控外包操作

***Answer:*** B

Explanation:

The evidence provided by SendPay, which is solely verbal confirmation about the monitoring of outsourced operations, is not considered reliable under ISO/IEC 27001. The standard requires documented evidence to support claims of effective monitoring and control over outsourced processes.

**QUESTION NO: 344**

您詢問 IT
經理，為什麼組織仍在使用行動應用程序，而個人資料加密和假名化測試卻失敗了。此外，服務經理是否有權批准測試。
IT經理解釋說，根據軟體安全管理程序，測試結果應由他批准。加密和假名功能失敗的原因是這些功能嚴重降低了系統和服務效能。需要額外 150%
的資源來滿足這一點。服務經理同意存取控制足夠好並且可以接受。這就是服務經理簽署批准書的原因。
您正在準備審計結果。選擇正確的選項。

**A.**存在不合格項 (NC)。組織和開發人員不執行驗收測試。
（與第 8.1 條相關，控制措施 A.8.29）

**B.**存在不合格項 (NC)。服務管理員不遵守軟體安全管理程序。（與第 8.1 條相關，控制措施 A.8.30）

**C.**存在不合格項 (NC)。組織和開發人員執行的安全測試失敗。
（與第 8.1 條相關，控制措施 A.8.29）

**D.**不存在不合格項 (NC)。服務經理做出了繼續提供服務的正確決定。
（與第 8.1 條相關，控制措施 A.8.30）

***Answer:*** B

Explanation:

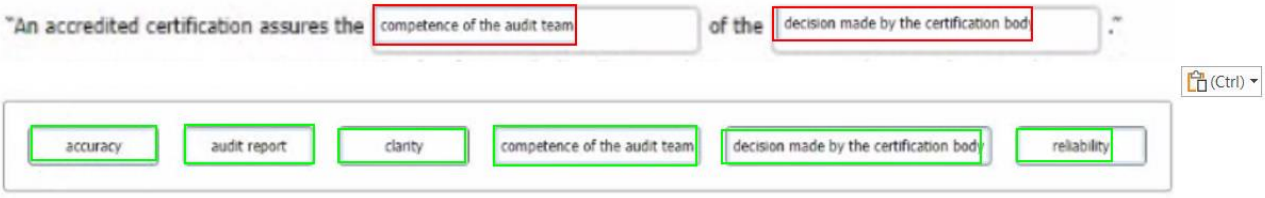
According to ISO 27001:2022 Annex A Control 8.30, the organisation shall ensure that externally provided processes, products or services that are relevant to the information security management system are controlled. This includes developing and entering into licensing agreements that cover code ownership and intellectual property rights, and implementing appropriate contractual requirements related to secure design and coding in

accordance with Annex A 8.25 and 8.2912 In this case, the organisation and the developer have performed security tests that failed, which indicates that the secure design and coding requirements of Annex A 8.29 were not met. The IT Manager explains that the encryption and pseudonymisation functions failed because they slowed down the system and service performance, and that an extra 150% of resources are needed to cover this. However, this does not justify the acceptance of the test results by the Service Manager, who is not authorised to approve the test according to the software security management procedure. The Service Manager should have consulted with the IT Manager, who is the owner of the process, and followed the procedure for handling nonconformities and corrective actions. The Service Manager's decision to continue the service based on access control alone exposes the organisation to the risk of compromising the confidentiality, integrity, and availability of personal data processed by the mobile app. Therefore, there is a nonconformity (NC) with clause 8.1, control A.8.30.
Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 345**
選出最能完成句子的單字：
要用單字完成句子，請點擊要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中點擊應用程式文字。或者，您可以將該選項拖曳到適當的空白部分。




***Answer:***




**QUESTION NO: 346**
---------- 與其他重要業務資產一樣，該資產對組織有價值，因此需要受到保護。
**A.**基礎設施
**B.**數據
**C.**訊息
**D.**安全
***Answer:*** C
Explanation:

Information is an asset like other important business assets, as it has value to an organization and consequently needs to be protected. Information can be in any form, such as electronic, paper, or verbal. Information security is the protection of information from unauthorized access, use, disclosure, modification, or destruction2. Reference: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) | CQI | IRCA

**QUESTION NO: 347**
您正在一家提供醫療保健服務的住宅療養院進行 ISMS
初始認證審核。審計計劃的下一步是召開末次會議。在最終審核小組會議上，身為審核組組長，您同意報告 2 項輕微不符合項和 1 項改進機會，如下：

**Cosmic Certifications Limited**

Summary of audit findings:

**Opportunities for Improvement (OI)**

| Item | Findings | Requirements | Follow-up |
|---|---|---|---|
| 1. | The organisation should improve the overall awareness of information security incident management responsibility and process. | Clause 7.4 and Control A.5.24 | N/A |

Nonconformities (NCs)

| Item | Findings | Grade | Requirements | Follow-up |
|---|---|---|---|---|
| 1. | During the audit on the outsourced process, sampling one of the outsourced service contracts with WeCare the medical device manufacturer found that ABC does not include personal data protection and legal compliance as part of the information security requirements in the contract. | Minor | Clause 4.2 and Control A.5.20 | Corrective actions are required. |
| 2. | During the audit on information security during the business continuity process, sampling one of the service continuity and recovery plans for the resident's healthy status monitoring service. The auditor found the recovery plan has not yet been tested. | Minor | Clause 8.1 and Control A.5.29 | Corrective actions are required. |

signed by *Audit Team Leader*

在閉幕會議上，管理系統代表 (MSR) 向您通報 ABC 將在未來 3 個月內與 WeCare
醫療設備製造商合併的資訊。合併後該組織的名稱將是 ABC。他詢問是否可以將 WeCare
醫療器材生產地點納入後續審核，以便認證中將其納入。他表示 WeCare 已通過 ISO/IEC 27001:2022 認證。
選擇一個選項以正確回應 MSR 的請求。

**A.**建議需要對 WeCare 進行初步審核，但這可以與 ABC 的後續審核結合起來

**B.**建議任何變更都會影響初始審核的認證範圍。該組織有責任在商定的時間範圍內更新認證機構，以便就合併 WeCare 做出決定。

**C.**建議沒有問題。如果WeCare能夠獲得其認證機構的同意，新業務可以立即納入認證範圍

**D.**建議最好延後認證流程並等待業務收購者完成

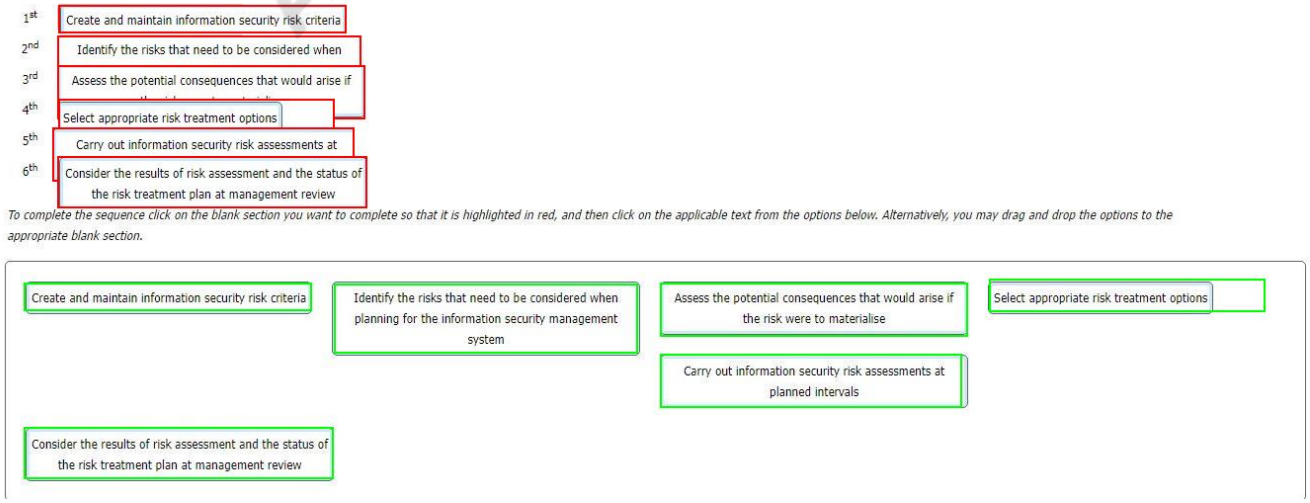
***Answer:*** B

Explanation:
According to ISO/IEC 27001 guidelines, any significant changes to the scope of the ISMS, such as a merger, must be communicated to the certification body. This ensures that the certification remains valid and that all locations and processes are included in the scope. The certification body will then decide the appropriate actions to incorporate the new entity into the existing certification.
Reference:
* ISO/IEC 27001 Lead Auditor Reference Materials

**QUESTION NO: 348**
您是一位經驗豐富的 ISMS
審核團隊領導，為培訓中的審核員提供指導。今天課程的主題是根據ISO/IEC 27001:2022的要求進行資訊安全風險管理。
您為班級提供一系列活動。然後，您要求全班將這些活動按照它們在標準中出現的順序進行排序。
他們應該向您報告的正確順序是什麼？




***Answer:***




Reference:
ISO/IEC 27001:2022, clause 6.1
[PECB Candidate Handbook ISO/IEC 27001 Lead Auditor], pages 14-15
ISO 27001 Risk Management in Plain English

ACTUAL4TEST.COM

**QUESTION NO: 349**
審計小組負責人正計劃在今年稍早完成第三方監督審計後進行後續審計。他們決定在考慮採取糾正措施之前先驗證需要糾正的不合格項。
根據以下的描述，下列哪四項是監督中發現的不合格項的修正？
**A.**新增了客戶資料服務供應合約中缺少的簽名
**B.** 未與新系統一起發送給客戶的軟體安裝指南已發布
**C.**已修正日期錯誤的新網路交換器採購訂單
**D.**未依照規定程序進行備份的資料中心員工接受了再培訓
**E.**顏色編碼為綠色（可用）而不是紅色（待銷毀）的硬碟 HD302 已從系統中刪除
**F.**預定的管理評審因錯過而被總經理優先安排，每年在特定日期舉行兩次
**G.**產品運輸的書面流程並未反映發貨團隊如何進行此活動，已被重寫，並對團隊進行了相應的培訓
**H.**組織未能維持其適用性表，將其更新責任重新分配給技術總監
***Answer:*** A,B,C,E
Explanation:
According to the PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, a correction is an action to eliminate a detected nonconformity, such as rework, repair, or replacement1. The examples of A, B, C, and E are corrections because they fix the errors or defects that caused the nonconformities, such as a missing signature, a missing guide, a wrong date, or a wrong colour code. The other examples (D, F, G, and H) are not corrections, but corrective actions, because they address the root causes of the nonconformities, such as inadequate training, poor planning, ineffective documentation, or unclear responsibility2. Reference: 1: PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, page 35, section 4.5.12: PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, page 36, section 4.5.2.

**QUESTION NO: 350**
場景
5：Cobt。位於倫敦的保險公司，提供各種商業、工業和人壽保險解決方案。近年來，Cobt 的客戶數量大幅增加。由於需要處理大量數據，該公司認為通過 ISO/IEC 27001
認證將為資訊安全帶來許多好處，並表明其對持續改進的承諾。儘管該公司擅長進行定期風險評估，但實施 ISMS
會為其日常營運帶來重大變化。在風險評估過程中，發現了一種風險，即組織的內部控制機制未能發現或預防重大缺陷。
公司遵循一套方法論來實施 ISMS，並在僅僅幾個月後就建立了可運行的
ISMS。分配了審核團隊成員的職責。
Sarah 承認，儘管 Cobt
通過提供多樣化的商業和保險解決方案實現了顯著擴張，但它仍然依賴於一些手動流程。
，特別是關於被審計方的可用性和合作以及獲取證據的管道。在本案中，Cobt的拒絕引發了人們對審計的完整性及其提供合理保證的能力的質疑。針對這些情況，Sarah決定在簽署認證協議之前退出審核，並將她的決定告知了Cobt和認證機構。做出這項決定是為了確保遵守審計原則並保持透明度，突顯了她始終如一地堅持這些原則的承諾。
根據上述情景，回答以下問題：
根據情境5提供的信息，Cobt拒絕向審計師提供有關風險管理的資訊。作為審計師，您將如何解決這種情況？

**A.**僅在現場或 Cobt 代表在場時存取此類訊息
**B.**拒絕審計任務，因為當不遵守保密協議時，審計員有權這樣做
**C.**透過提醒 Cobt 的代表，審計團隊負責人決定審計團隊在審計過程中應有權存取的信息
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer: When an organization refuses to share sensitive information off-site, the
B . Incorrect: The auditor cannot immediately refuse the mandate. Instead, an attempt to reach an agreement should be made first.
C . Incorrect: While audit leaders define audit access, they must also respect confidentiality agreements.
Relevant Standard Reference:
ISO/IEC 27001:2022 Clause 9.2 (Internal Audit)
ISO 19011:2018 Clause 6.4.5 (Audit Information Availability and Access)

**QUESTION NO: 351**
目標、標準和範圍是第三方 ISMS 審核的關鍵特徵。哪兩個問題是審計目標？
**A.**評估客戶流程與功能
**B.**評估是否符合 ISO/IEC 27001 要求
**C.**完成審核計劃
**D.**確認執行 ISMS 的站點
**E.**確定 ISMS 的範圍
**F.**檢討組織效率
***Answer:*** B,D
Explanation:
Audit objectives are the specific purposes or goals that the customer or the certification body wants to achieve through the audit. They define what the audit intends to accomplish and provide the basis for planning and conducting the audit. Audit objectives may vary depending on the type, scope, and criteria of the audit, but they should be clear, measurable, and achievable.
Some examples of audit objectives for a third-party ISMS audit are:
Assess conformity with ISO/IEC 27001 requirements: This objective means that the audit aims to verify that the organisation's ISMS meets the requirements of the ISO/IEC 27001 standard, which specifies the best practices for establishing, implementing, maintaining, and improving an information security management system. The audit will evaluate the organisation's ISMS documentation, processes, controls, and performance against the standard's clauses and annex A controls.
Confirm sites operating the ISMS: This objective means that the audit aims to confirm that the organisation's ISMS covers all the relevant sites or locations where the organisation operates or provides its services. The audit will verify that the scope of the ISMS is accurate and consistent with the organisation's context, objectives, and risks.
The other phrases are not audit objectives, but rather:
Evaluate customer processes and functions: This is not an audit objective, but rather a possible audit criterion or a requirement that the organisation's processes and functions

ACTUAL4TEST.COM

should meet. The audit criterion is the reference against which the audit evidence is compared to determine conformity or nonconformity. The audit criterion may include ISO/IEC 27001 requirements, customer requirements, or other applicable standards or regulations.
Fulfil the audit plan: This is not an audit objective, but rather a task or an activity that the auditor performs during the audit. The audit plan is a document that describes the arrangements and details of the audit, such as the objectives, scope, criteria, schedule, roles, and responsibilities. The auditor should follow and fulfil the audit plan to ensure that the audit is conducted effectively and efficiently.
Determine the scope of the ISMS: This is not an audit objective, but rather a prerequisite or an input for conducting the audit. The scope of the ISMS is the extent and boundaries of the information security management system within the organisation. It defines what processes, activities, locations, assets, and stakeholders are included or excluded from the ISMS. The scope of the ISMS should be determined by the organisation before applying for certification or undergoing an audit.
Review organisation efficiency: This is not an audit objective, but rather a possible outcome or a result of conducting an audit. The organisation efficiency is a measure of how well the organisation uses its resources to achieve its goals and objectives. The audit may help review and improve the organisation efficiency by identifying strengths, weaknesses, opportunities, and threats in its information security management system.
Reference:
ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) objectives and content from Quality.org and PECB ISO 19011:2018 Guidelines for auditing management systems [Section 5.3.1]

**QUESTION NO: 352**
在後續審核期間，您注意到在後續審核之前確定要完成的不合格項仍懸而未決。
您應該採取下列哪四項行動？
**A.**向組織的最高管理階層
報告未能針對突出的不符合項採取糾正措施的情況
**B.**由於已超過完成日期，因此立即提出不合格項
**C.**如果延遲合理，請與受審核方/審核客戶同意清除不合格項的修改日期
**D.**聯絡管理審核計畫的個人，尋求他們關於如何進行的建議
**E.**決定延遲解決不合格項是否合理
**F.**當收到不合格項已清除的保證時，取消後續審核並回傳
**G.**注意不合格項仍然突出，並遵循審核追蹤以確定原因
**H.**如果延遲不合理，請告知受審核方/審核客戶並同意採取補救措施
***Answer:*** A,C,E,G
Explanation:
According to the ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) course, the following actions should be taken when a nonconformity identified for completion before the follow-up audit is still outstanding:
A . Report the failure to address the corrective action for the outstanding nonconformity to the organisation's top management. This is part of the auditor's responsibility to communicate the audit results and ensure that the audit objectives are met12.
C . If the delay is justified agree on a revised date for clearing the nonconformity with the

auditee/audit client. This is part of the auditor's responsibility to verify the effectiveness of the corrective actions taken by the auditee and to close the nonconformity when the evidence is satisfactory12.
. Decide whether the delay in addressing the nonconformity is justified. This is part of the auditor's responsibility to evaluate the evidence presented by the auditee and to use professional judgement and objectivity to determine the validity of the reasons for the delay12.
G . Note the nonconformity is still outstanding and follow audit trails to determine why. This is part of the auditor's responsibility to collect and verify audit evidence and to identify the root causes of the nonconformity12.
Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) course, CQI and IRCA Certified Training, 1
2: ISO/IEC 27001 Lead Auditor Training Course, PECB, 2

**QUESTION NO: 353**
您是負責管理審核計劃並決定特定審核的審核團隊的規模和組成的人。選擇應考慮的兩個因素。
**A.**審核範圍與標準
**B.**客戶關係
**C.**審核團隊實現審核目標所需的整體能力
**D.**審核組組長的資歷
**E.**審核成本
**F.**受審核方首選的持續時間
***Answer:*** A,C
Explanation:
The overall competence of the12:
The audit scope and criteria: The audit scope defines the extent and boundaries of the audit, such as the locations, processes, functions, and time period to be audited. The audit criteria are the set of policies, procedures, standards, or requirements used as a reference against which the audit evidence is compared. The audit scope and criteria determine the complexity and extent of the audit, and thus influence the number and expertise of the auditors needed to cover all the relevant aspects of the audit.
The overall competence of the audit team needed to achieve audit objectives: The audit team should have the appropriate knowledge, skills, and experience to conduct the audit effectively and efficiently, and to provide credible and reliable audit results. The audit team competence should include the following elements12:
Generic competence: The ability to apply the principles and methods of auditing, such as planning, conducting, reporting, and following up the audit, as well as the personal behaviour and attributes of the auditors, such as ethical conduct, fair presentation, professional care, independence, and impartiality.
Discipline and sector-specific competence: The ability to understand and apply the audit criteria and the relevant technical or industry aspects of the audited organization, such as the information security management system (ISMS) requirements, the information security risks and controls, the legal and regulatory obligations, the organizational context and culture, the

ACTUAL4TEST.COM

processes and activities, the products and services, etc.
Audit team leader competence: The ability to manage the audit team and the audit process, such as coordinating the audit activities, communicating with the audit programme manager and the auditee, resolving any audit-related problems, ensuring the quality and consistency of the audit work and the audit report, etc.
The person responsible for managing the audit programme should not consider the following factors when deciding the size and composition of the audit team for a specific audit, as they are either irrelevant or inappropriate for the audit process12:
Customer relationships: The audit team should not be influenced by any personal or professional relationships with the auditee or other interested parties, as this may compromise the objectivity and impartiality of the audit. The audit team should avoid any conflicts of interest or self-interest that may affect the audit results or the audit decisions.
Seniority of the audit team leader: The audit team leader should be selected based on their competence and experience, not on their seniority or rank within the organization or the audit programme. The audit team leader should have the authority and responsibility to manage the audit team and the audit process, regardless of their seniority or position.
The cost of the audit: The cost of the audit should not be the primary factor for determining the size and composition of the audit team, as this may compromise the quality and effectiveness of the audit. The audit team should have sufficient resources and time to conduct the audit in accordance with the audit objectives, scope, and criteria, and to provide accurate and reliable audit results and recommendations.
The duration preferred by the auditee: The duration of the audit should be based on the audit objectives, scope, and criteria, and the availability and cooperation of the auditee, not on the preference or convenience of the auditee. The audit team should have enough time to conduct the audit in a thorough and systematic manner, and to collect and evaluate sufficient and relevant audit evidence.
Reference:
ISO 19011:2018 - Guidelines for auditing management systems
PECB Candidate Handbook ISO 27001 Lead Auditor, pages 19-20

**QUESTION NO: 354**
您是一位經驗豐富的審核團隊負責人，負責為其客戶設計網站的組織進行第三方監督審核。您目前正在審查該組織的適用性聲明。
根據 ISO/IEC 27001 的要求，下列關於適用性聲明的觀察哪兩項是錯誤的？
**A.**尋求 ISO/IEC 27001 合規性的組織必須出具適用性聲明
**B.**僅需要對組織選擇排除的任何控制進行說明
**C.**需要說明在適用性聲明中包含和排除附件 A 控制措施的理由
**D.**適用性聲明由組織的最高管理階層擁有和修改
**E.**如果組織選擇這樣做，則可以將附錄 A 中未包含的其他控制措施新增至適用性聲明中
**F.**適用性聲明必須包括必要的組織、物理、人員和技術控制
***Answer:*** B,D

**QUESTION NO: 355**
場景 2：
Clinic 成立於 20 世紀 90

年代，是一家專門治療心臟相關疾病和複雜外科手術的醫療器材公司。該公司總部位於歐洲，為患者和醫療保健專業人士提供服務。診所收集患者數據以客製化治療方案、監測結果並改善設備功能。為了增強資料安全性和建立信任，Clinic 正在實施基於 ISO/IEC 27001 的資訊安全管理系統 (ISMS)。
診所僅透過考慮內部問題、介面、內部和外包活動之間的依賴關係以及相關方的期望來確定其 ISMS 的範圍。此範圍已仔細記錄並可供查閱。在定義其 ISMS 時，Clinic 選擇專注於關鍵部門內的關鍵流程，例如研發、病患資料管理和客戶支援。
儘管最初面臨挑戰，Clinic 仍然致力於實施 ISMS，並根據其獨特需求量身定制安全控制。專案團隊從 ISO/IEC 27001 中排除了某些附件 A 控制，同時加入了額外的特定產業控制以增強安全性。該團隊根據內部和外部因素評估了這些控制的適用性，最終制定了全面的適用性聲明 (SoA)，詳細說明了控制選擇和實施背後的理由。
隨著認證準備工作的進展，被任命為團隊負責人的 Brian 採用了自我導向的風險評估方法來識別和評估公司的策略問題和安全實踐。這種積極主動的方法確保診所的風險評估與其目標和使命保持一致。
根據場景 2，診所決定 ISMS 僅涵蓋關鍵流程和部門。這可以接受嗎？

**A.**是的，但排除其他流程和部門的決定必須有理有據

**B.**是的，組織可以限制 ISMS 的範圍，但如果 ISMS 範圍不包括所有流程和部門，他們就不能要求進行認證審核

**C.**不，診所必須將所有流程和部門納入範圍，無論它們對 ISMS 的重要性或相關性如何

***Answer:*** A

Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer: ISO/IEC 27001 Clause 4.3 (Determining the Scope of the ISMS) allows
B . Incorrect: Organizations can request certification even if the ISMS scope is limited, as long as it is justified.
C . Incorrect: ISO/IEC 27001 does not mandate full inclusion of all departments in the ISMS.

**QUESTION NO: 356**

您是經驗豐富的審核團隊領導，指導審核員進行培訓。
您的團隊目前正在對代表外部客戶儲存資料的組織進行第三方監督審核。接受培訓的審核員的任務是審查適用性聲明 (SoA) 中列出的並在現場實施的人員控制措施。
從以下內容中選擇您希望接受培訓的審核員審查的四項控制措施。

**A.**保密與保密協議

**B.**如何實施針對惡意軟體的防護

**C.**資訊安全意識、教育與培訓

**D.**遠距工作安排

**E.**對人員進行驗證檢查

**F.**現場閉路電視和門禁系統的運行

**G.**機構對資訊刪除的安排

**H.**組織的業務連續性安排

***Answer:*** A,C,D,E

Explanation:

The PEOPLE controls are related to the human aspects of information security, such as roles and responsibilities, awareness and training, screening and contracts, and remote working. The auditor in training should review the following controls:
Confidentiality and nondisclosure agreements (A): These are contractual obligations that bind the employees and contractors of the organisation to protect the confidentiality of the information they handle, especially the data of external clients. The auditor should check if these agreements are signed, updated, and enforced by the organisation. This control is related to clause A.7.2.1 of ISO/IEC 27001:2022.
Information security awareness, education and training : These are activities that aim to enhance the knowledge, skills, and behaviour of the employees and contractors regarding information security. The auditor should check if these activities are planned, implemented, evaluated, and improved by the organisation. This control is related to clause A.7.2.2 of ISO/IEC 27001:2022.
Remote working arrangements (D): These are policies and procedures that govern the information security aspects of working from locations other than the organisation's premises, such as home or public places. The auditor should check if these arrangements are defined, approved, and monitored by the organisation. This control is related to clause A.6.2.1 of ISO/IEC 27001:2022.
The conducting of verification checks on personnel (E): These are background checks that verify the identity, qualifications, and suitability of the employees and contractors who have access to sensitive information or systems. The auditor should check if these checks are conducted, documented, and reviewed by the organisation. This control is related to clause A.7.1.1 of ISO/IEC 27001:2022.
Reference:
ISO/IEC 27001:2022, Information technology - Security techniques - Information securit y management systems - Requirements PECB Candidate Handbook ISO/IEC 27001 Lead Auditor, 1 ISO 27001:2022 Lead Auditor - IECB, 2 ISO 27001:2022 certified ISMS lead auditor - Jisc, 3 ISO/IEC 27001:2022 Lead Auditor Transition Training Course, 4 ISO 27001 - Information Security Lead Auditor Course - PwC Training Academy, 5

**QUESTION NO: 357**
您正在一家提供醫療保健服務的住宅療養院進行 ISMS
審核。審核計畫的下一步是驗證資訊安全事件管理流程。 IT
安全經理介紹了資訊安全事件管理程序，並解釋該流程基於 ISO/IEC 27035-1:2016。
您查看該文件並注意到一條聲明「任何資訊安全弱點、事件和事故應在識別後 1
小時內報告給聯絡人
(PoC)」。在訪問員工時，您發現大家對「弱點、事件、事件」意義的理解有差異。
您從事件追蹤系統中抽取過去 6 個月的事件報告記錄樣本，總結結果如下表所示。

| Type of report | Description | Resolution/Recovery Actions | Resolution/ Recovery Time |
|---|---|---|---|
| Information security weakness, report ID: 056 | The human resources manager's mobile phone was hacked by ransomware, asking for $1000 to unlock (decrypt) the data | IT department suggests the person shall pay the ransom to unlock the phone. No further action is needed. | 24 hours |
| Information security weakness, report ID: 078 | The medical staff's company mobile phone (with patient data) was hacked by ransomware, asking for $5000 to unlock (decrypt) the data | IT department suggests the company shall pay the ransom to unlock the company phone. No further action is needed. | 24 hours |
| Information security event, report ID: 090 | The cloud server does not respond and healthcare monitoring stops for 8 hours. | IT department reboots the cloud server remotely. No further action is needed. | 24 hours |
| Information security incident, report ID: 012 | The cloud server does not respond and healthcare monitoring stops for 48 hours. | IT department reboots thencloud server remotely. No further action is needed. | 24 hours |

您想進一步調查其他領域以收集更多審計證據。選擇兩個不會出現在您的審核追蹤中的選項。
**A.**收集有關人力資源經理如何以及何時支付贖金以解鎖個人行動資料（即信用卡和銀行轉帳）的更多證據。（與控制措施 A.5.26 相關）
**B.**收集更多有關醫療保健監測服務要求的證據。（與第4.2條相關）
**C.**收集更多證據，說明組織如何確定事件發生後無需採取進一步行動。（與控制措施 A.5.26 相關）
**D.**收集更多有關組織如何確定事件恢復時間的證據。（與控制措施 A.5.27 相關）
**E.**收集更多有關事件恢復程序的證據。（與控制措施 A.5.26 相關）
**F.**透過訪問更多員工了解他們對報告流程的理解來收集更多證據。
（與控制措施 A.6.8 相關）
**G.**收集更多關於公司如何以及何時支付贖金以解鎖公司手機和資料（即信用卡和銀行轉帳）的證據。（與控制措施 A.5.26 相關）
***Answer:*** B,G
Explanation:
According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), clause 4.2 requires an organization to determine the needs and expectations of interested parties that are relevant to its ISMS1. This includes identifying the legal, regulatory, contractual and other requirements that apply to its information security activities1. Therefore, collecting more evidence on what the service requirements of healthcare monitoring are may not be relevant to verifying the information security incident management process, as it is not directly related to the audit objective or criteria. This option will not be in the audit trail.

**QUESTION NO: 358**
場景 7：Lawsy 是一家領先的律師事務所，在新澤西州和紐約市設有辦公室。它擁有 50

多名律師，為商業法、智慧財產權、銀行和金融服務領域的客戶提供完善的法律服務。他們相信，由於他們致力於實施資訊安全最佳實踐並跟上技術發展的步伐，他們在市場上佔據了有利的地位。
Lawsy 已經嚴格實施、評估和進行 ISMS 內部審核兩年了。
現在，他們已向知名且值得信賴的認證機構ISMA申請ISO/IEC 27001認證。
在第一階段審核期間，審核小組審查了實施過程中所建立的所有 ISMS 文件。
他們還審查和評估了管理審查和內部審計的記錄。
Lawsy
提交了證據記錄，表明在必要時對不合格項採取了糾正措施，因此審核組約談了內部審核員。
訪談透過提供對內部稽核計畫和程序的詳細了解，驗證了內部稽核的充分性和頻率。
審計小組繼續驗證戰略文件，包括資訊安全政策和風險評估標準。在資訊安全政策審查期間，團隊注意到描述治理框架（即資訊安全政策）的記錄資訊與程序之間存在不一致。
儘管允許員工將筆記型電腦帶到工作場所之外，但 Lawsy
並沒有製定有關在這種情況下使用筆記型電腦的程序。此政策僅提供有關筆記型電腦使用的一般資訊。該公司依靠員工的常識來保護筆記型電腦中儲存的資訊的機密性和完整性。該問題已記錄在第一階段審計報告中。
完成第一階段審核後，審核組長準備了審核計劃，其中規定了審核目標、範圍、標準和程序。
在第二階段審核期間，審核小組約談了資安經理，資安經理起草了資訊安全政策。他透過指出 Lawsy
每三個月舉辦一次強制性資訊安全培訓和意識課程來證明第一階段中確定的問題的合理性。
面談後，審核小組檢查了 15 份員工培訓記錄（共 50 份），得出的結論是 Lawsy 符合 ISO/IEC 27001
有關培訓和意識的要求。為了支持這個結論，他們影印了檢查過的員工訓練記錄。
根據上述場景，回答以下問題：
審核小組透過檢查 50 份員工培訓記錄中的 15 份得出結論，Lawsy 符合 ISO/IEC 27001 與培訓和意識相關的要求（如場景 7 中所述）。

**A.**審核員

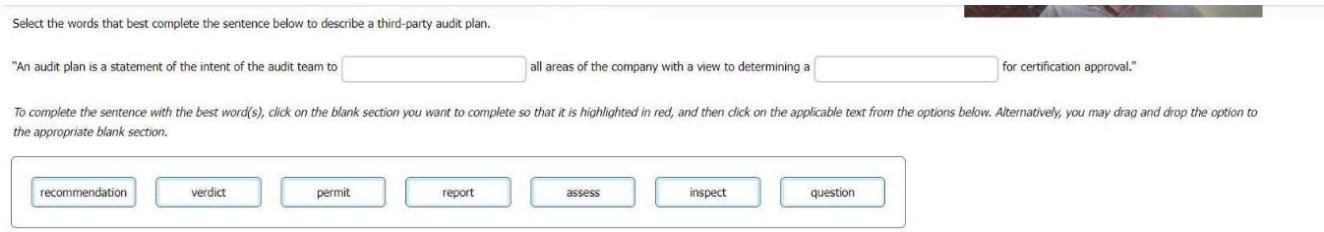
**B.**取樣

**C.**樣本大小

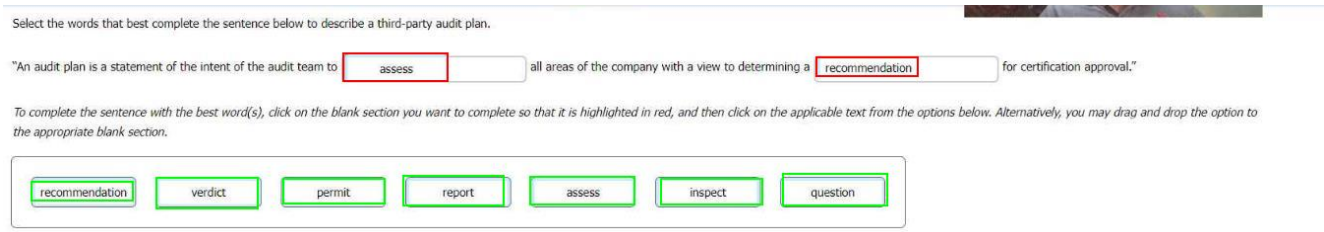
***Answer:*** C

Explanation:
This scenario presents a risk related to the sample size. Examining only 15 out of 50 employee training records may not provide a fully representative view of the entire organization's adherence to the training and awareness requirements of ISO/IEC 27001. There is a risk that this sample size is not sufficient to justify a general conclusion about the entire organization.

**QUESTION NO: 359**
選出最能完成下面句子的單字來描述第三方審核計畫。
要使用最佳單字完成句子，請按一下要完成的空白部分，使其以紅色突出顯示，然後從下面的選項中按一下適用的文字。或者，您可以將該選項拖曳到適當的空白部分。




***Answer:***




**QUESTION NO: 360**
在第三方認證審核期間，受審核方會提供您問題清單。下列哪四項構成 ISO 27001:2022 管理系統中的「內部」問題？
**A.**人口老化導致勞動成本上升
**B.**為因應高通膨而提高利率
**C.**訓練支出削減導致員工能力水準低下
**D.**由於員工假期減少而士氣低落
**E.**因管理不善導致缺勤增加
**F.**因政府政策改變而導致補助金減少
**G.**生產力下降與過時的生產設備有關
**H.**由於政府制裁而無法購買原料
***Answer:*** C,D,E,G
Explanation:
According to ISO 27001:2022 clause 4.1, the organisation shall determine external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended outcome(s) of its information security management system (ISMS)12 External issues are factors outside the organisation that it cannot control, but can influence or adapt to. They include political, economic, social, technological, legal, and environmental factors that may affect the organisation's information security objectives, risks, and opportunities12 Internal issues are factors within the organisation that it can control or change. They include the organisation's structure, culture, values, policies, objectives, strategies, capabilities, resources, processes, activities, relationships, and performance that may affect the organisation's information security management system12 Therefore, the following issues are considered 'internal' in the context of a management system to ISO 27001:2022:
Poor levels of staff competence as a result of cuts in training expenditure: This is an internal issue because it relates to the organisation's capability, resource, and process of developing and maintaining the competence of its personnel involved in the ISMS. The organisation can control or change its training expenditure and its impact on staff competence12 Poor morale as a result of staff holidays being reduced: This is an internal issue because it relates to the organisation's culture, value, and relationship with its employees. The organisation can control or change its staff holiday policy and its impact on staff morale12 Increased

absenteeism as a result of poor management: This is an internal issue because it relates to the organisation's performance, structure, and accountability of its management. The organisation can control or change its management practices and its impact on staff absenteeism12 A fall in productivity linked to outdated production equipment: This is an internal issue because it relates to the organisation's capability, resource, and process of ensuring the availability and suitability of its production equipment. The organisation can control or change its equipment maintenance and upgrade and its impact on productivity12 The following issues are considered 'external' in the context of a management system to ISO 27001:2022:
Higher labour costs as a result of an aging population: This is an external issue because it relates to the social and demographic factor that affects the availability and cost of labour in the market. The organisation cannot control or change the aging population, but can influence or adapt to its impact on labour costs12 A rise in interest rates in response to high inflation: This is an external issue because it relates to the economic and monetary factor that affects the cost and availability of capital in the market. The organisation cannot control or change the interest rates or inflation, but can influence or adapt to its impact on capital costs12 A reduction in grants as a result of a change in government policy: This is an external issue because it relates to the political and legal factor that affects the availability and conditions of public funding for the organisation. The organisation cannot control or change the government policy, but can influence or adapt to its impact on grants12 Inability to source raw materials due to government sanctions: This is an external issue because it relates to the political and legal factor that affects the availability and cost of raw materials in the market. The organisation cannot control or change the government sanctions, but can influence or adapt to its impact on raw materials12 Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 361**
下列哪一項敘述最準確地描述了進行文件審查的目的？
**A.**揭露文件化管理系統是否不符合審核標準並收集證據以支持審核報告
**B.**決定文件化管理系統是否符合審核標準，並收集調查結果以支援審核流程
**C.**根據記錄確定管理系統是否符合審核標準，並收集資訊以支援現場審核活動
**D.**偵測管理系統是否符合審核標準（如有記錄），並確定支援審核計畫的資訊
***Answer:*** C
Explanation:
A document review is a process of examining the documented information related to the management system before the on-site audit activities. The purpose of a document review is to: 12 Determine the conformity of the management system, as far as documented, with audit criteria, i.e., to check whether the documents are consistent, complete, and compliant with the requirements of ISO/IEC 27001 and any other applicable standards or regulations. Gather information to support the on-site audit activities, i.e., to identify the scope, objectives, processes, controls, risks, and opportunities of the management system, and to plan the audit methods, techniques, and resources accordingly.
The other statements are not accurate, because:

A document review does not reveal or decide about the conformity or nonconformity of the management system as a whole, but only of the documented information. The conformity or nonconformity of the management system is determined by the on-site audit activities, which include interviews, observations, and tests12 A document review does not gather evidence or findings to support the audit report or process, but information to support the on-site audit activities. The evidence or findings are collected during the on-site audit activities, which are then documented and reported12 A document review does not detect any nonconformity of the management system, if documented, but determines the conformity of the documented information. The nonconformity of the management system is detected by the on-site audit activities, which evaluate the performance and effectiveness of the management system12 A document review does not identify information to support the audit plan, but gathers information to support the on-site audit activities. The audit plan is prepared before the document review, based on the audit scope, objectives, criteria, and program. The document review is part of the audit plan implementation12 Reference:
1: ISO/IEC 27001:2022 Lead Auditor (Information Security Management Systems) Course by CQI and IRCA Certified Training 1 2: ISO/IEC 27001 Lead Auditor Training Course by PECB 2

**QUESTION NO: 362**
在第一階段審核開幕會議上，管理系統代表 (MSR)
要求擴大審核範圍，以包括自提出認證申請以來已擴展到的海外新地點。
選擇審計員應如何回應的兩個選項。
**A.**建議 MSR 可以納入範圍擴展，但必須履行既定程序
**B.**通知 MSR 審核範圍已根據其初始申請確定，因此審核必須按計劃進行
**C.**建議MSR取消審核合約並重新申請新情況
**D.**確定管理系統是否涵蓋新站點的流程，如果是，則繼續審核
**E.**通知MSR，在現有範圍內，可以毫無問題地包含新工作區
**F.**確認審核員將通知受審核方審核範圍將被修改以包含新的工作領域
***Answer:*** A,D
Explanation:
The correct options for how the auditor should respond are:
A . Advise the MSR that an extension of the scope may be incorporated but will have to go through established procedures D . Determine whether the Management System covers the processes at the new site and, if so, proceed with the audit These options are consistent with the ISO/IEC 27006:2015 standard, which states that any changes to the scope of certification should be notified by the client to the certification body, and that the certification body should evaluate and decide on these changes in accordance with its procedures1. The auditor should also verify that the ISMS is implemented and maintained at all sites included in the scope of certification1.
The other options are not appropriate for how the auditor should respond, because:
B . Advise the MSR that the audit scope has been determined based on their initial application so the audit has to proceed as planned: This option is too rigid and does not allow for any flexibility or adaptation to the client's situation. The auditor should be open to consider any changes to the scope of certification that may have occurred since the initial application, as long as they are properly notified and evaluated by the certification body.

C . Suggest that the MSR cancels the audit contract and reapplies for the new situation: This option is too drastic and unnecessary, as it would cause delays and costs for both the client and the certification body. The auditor should not suggest that the client cancels the audit contract, but rather that they follow the established procedures for requesting and approving an extension of the scope of certification.
E . Advise the MSR that, within the existing scope, the new work area can be included without any problem: This option is too lenient and does not ensure that the new work area meets the requirements of ISO/IEC 27001 and the ISMS. The auditor should not assume that the new work area can be included within the existing scope without any problem, but rather that they need to verify that the ISMS is implemented and maintained at the new site, and that any changes to the scope of certification are approved by the certification body.
F . Confirm that the auditor will advise the auditee that the audit scope will be revised to include the new work area: This option is too presumptuous and does not respect the authority of the certification body. The auditor should not confirm that they will revise the audit scope to include the new work area, but rather that they will advise the certification body of the client's request for an extension of the scope of certification, and wait for their decision.

**QUESTION NO: 363**
您是一位經驗豐富的審核團隊領導，指導審核員進行培訓。接受培訓的審核員的任務是審查適用性聲明 (SoA) 中列出的並在現場實施的技術控制措施。
從以下內容中選擇您希望接受培訓的審核員審查的四項控制措施。
**A.**資訊資產清單的發展與維護
**B.**在組織內部以及向其他組織傳輸訊息的規則
**C.**保密與保密協議
**D.**如何實施針對惡意軟體的防護
**E.**進出裝載區的通道
**F.**對人員進行驗證檢查
**G.**遠距工作安排
**H.**供應商協定中如何解決資訊安全問題
**I.**組織如何評估其技術漏洞的暴露程度
**J.**組織的業務連續性安排
**K.**機構對資訊刪除的安排
**L.**資訊安全意識、教育與培訓
**M.**如何管理對原始程式碼和開發工具的訪問
**N.**現場閉路電視和門禁系統的運行
**O.**組織對設備維護的安排
**P.**電源線和資料線如何進入建築物
***Answer:*** D,I,M,N
Explanation:
According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), an organization should select and implement appropriate controls to achieve its information security objectives1. The controls should be derived from the results of risk assessment and risk treatment, and should be consistent with the Statement of Applicability

(SoA), which is a document that identifies the controls that are applicable and necessary for the ISMS1. The controls can be selected from various sources, such as ISO/IEC 27002:2013, which provides a code of practice for information security controls2. Therefore, if an auditor in training has been tasked with reviewing the technological controls listed in the SoA and implemented at the site of an organization that stores data on behalf of external clients, four controls that would be expected to review are:
How protection against malware is implemented: This is a technological control that aims to prevent, detect and remove malicious software (such as viruses, worms, ransomware, etc.) that could compromise the confidentiality, integrity or availability of information or information systems2. This control is related to control A.12.2.1 of ISO/IEC 27002:20132.
How the organisation evaluates its exposure to technical vulnerabilities: This is a technological control that aims to identify and assess the potential weaknesses or flaws in information systems or networks that could be exploited by malicious actors or cause accidental failures2. This control is related to control A.12.6.1 of ISO/IEC 27002:20132.
How access to source code and development tools are managed: This is a technological control that aims to protect the intellectual property rights and integrity of software applications or systems that are developed or maintained by the organization or its external providers2. This control is related to control A.14.2.5 of ISO/IEC 27002:20132.
The operation of the site CCTV and door control systems: This is a technological control that aims to monitor and restrict physical access to the premises or facilities where information or information systems are stored or processed2. This control is related to control A.11.1.4 of ISO/IEC 27002:20132.
The other options are not examples of technological controls, but rather organizational, legal or procedural controls that may also be relevant for an ISMS audit, but are not within the scope of the auditor in training's task. For example, the development and maintenance of an information asset inventory (related to control A.8.1.1), rules for transferring information within the organization and to other organizations (related to control A.13.2.1), confidentiality and nondisclosure agreements (related to control A.13.2.4), verification checks on personnel (related to control A.7.1.2), remote working arrangements (related to control A.6.2.1), information security within supplier agreements (related to control A.15.1.1), business continuity arrangements (related to control A.17), information deletion (related to control A.8.3), information security awareness, education and training (related to control A.7.2), equipment maintenance (related to control A.11.2), and how power and data cables enter the building (related to control A.11) are not technological controls, but rather organizational, legal or procedural controls that may also be relevant for an ISMS audit, but are not within the scope of the auditor in training's task. Reference: ISO/IEC 27001:2022 - Information technology - Security techniques - Information security management systems - Requirement s, ISO/IEC 27002:2013 - Information technology - Security techniques - Code of practice f or information security controls

**QUESTION NO: 364**
「糾正措施」一詞是什麼意思？選擇一項
**A.**採取措施防止不合格或事件發生
**B.**採取措施消除不合格或事故的原因
**C.**管理階層針對不合格項所採取的行動

**D.**採取措施糾正不合格項或事件

***Answer:*** B

Explanation:

Corrective action is a process of identifying and eliminating the root causes of nonconformities or incidents that have occurred or could potentially occur, in order to prevent their recurrence or occurrence. Corrective action is part of the improvement requirement of ISO 27001 and follows a standard workflow of identification, evaluation, implementation, review and documentation of corrections and corrective actions. Reference: Procedure for Corrective Action, Nonconformity & Corrective Action For ISO 27001 Requirement 10.1, PECB Candidate Handbook ISO 27001 Lead Auditor (page 12)

**QUESTION NO: 365**

您工作的資料中心目前正在尋求 ISO/IEC27001:2022
認證。在為您的初次認證訪問做準備時，您集團內另一個資料中心的同事已進行了多次內部審核。他們在今年稍早獲得了 ISO/IEC 27001:2022 證書。
您剛剛獲得內部 ISMS
審核員資格，您的經理要求您在外部認證機構到達之前審查審核流程和審核結果，作為最終檢查。
以下哪六項會讓您擔心是否符合 ISO/IEC 27001:2022 要求？

**A.**審核計畫顯示年內不定期進行管理審核

**B.**審計報告不以硬拷貝形式（即紙本形式）保存。它們僅作為「.POF 文件」儲存在組織的 Intranet 上

**C.**審核計畫未考慮資訊安全流程的相對重要性

**D.**審核計畫要求審核員必須獨立於他們審核的領域，以滿足 ISO/IEC 27001:2022 的要求

**E.**雖然已定義每次內部審核的範圍，但尚未為迄今為止進行的審核定義審核標準

**F.**迄今為止的審計報告已使用關鍵績效指標資訊來僅關注 ISMS 流程的效率

**G.**審核計畫未引用審核方法或審核職責

**H.**審核程序不考慮先前審核的結果

**I.**根據審核計劃，在認證訪問之前不會審核高階主管對 ISMS 的承諾

**J.**審計流程規定審計結果將提供給「相關」經理，而不是最高管理階層

***Answer:*** A,C,E,F,H,I

Explanation:

According to ISO/IEC 27001:2022, which specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system (ISMS), clause 9.3 requires top management to review the organization's ISMS at planned intervals to ensure its continuing suitability, adequacy and effectiveness1. Clause 9.2 requires the organization to conduct internal audits at planned intervals to provide information on whether the ISMS conforms to its own requirements and those of ISO/IEC 27001:2022, and is effectively implemented and maintained1. Therefore, when reviewing the audit process and audit findings as a final check before the external certification body arrives, an internal ISMS auditor should verify that these clauses are met in accordance with the audit criteria.

Six of the following statements would cause concern in respect of conformity to ISO/IEC 27001:2022 requirements:

The audit programme shows management reviews taking place at irregular intervals during the year: This statement would cause concern because it implies that the organization is not conducting management reviews at planned intervals, as required by clause 9.3. This may affect the ability of top management to ensure the continuing suitability, adequacy and effectiveness of the ISMS.
The audit programme does not take into account the relative importance of information security processes: This statement would cause concern because it implies that the organization is not applying a risk-based approach to determine the audit frequency, methods, scope and criteria, as recommended by ISO 19011:2018, which provides guidelines for auditing management systems2. This may affect the ability of the organization to identify and address the most significant risks and opportunities for its ISMS.
Although the scope for each internal audit has been defined, there are no audit criteria defined for the audits carried out to date: This statement would cause concern because it implies that the organization is not establishing audit criteria for each internal audit, as required by clause 9.2. Audit criteria are the set of policies, procedures or requirements used as a reference against which audit evidence is compared2. Without audit criteria, it is not possible to determine whether the ISMS conforms to its own requirements and those of ISO/IEC 27001:2022.
Audit reports to date have used key performance indicator information to focus solely on the efficiency of ISMS processes: This statement would cause concern because it implies that the organization is not evaluating the effectiveness of ISMS processes, as required by clause 9.1. Effectiveness is the extent to which planned activities are realized and planned results achieved2. Efficiency is the relationship between the result achieved and the resources used2. Both aspects are important for measuring and evaluating ISMS performance and improvement.
The audit programme does not take into account the results of previous audits: This statement would cause concern because it implies that the organization is not using the results of previous audits as an input for planning and conducting subsequent audits, as recommended by ISO 19011:20182. This may affect the ability of the organization to identify and address any recurring or unresolved issues or nonconformities related to its ISMS.
Top management commitment to the ISMS will not be audited before the certification visit, according to the audit programme: This statement would cause concern because it implies that the organization is not verifying that top management demonstrates leadership and commitment with respect to its ISMS, as required by clause 5.1. This may affect the ability of top management to ensure that the ISMS policy and objectives are established and compatible with the strategic direction of the organization; that roles, responsibilities and authorities for relevant roles are assigned and communicated; that resources needed for the ISMS are available; that communication about information security matters is established; that continual improvement of the ISMS is promoted; that other relevant management reviews are aligned with those of information security; and that support is provided to other relevant roles1.
The other statements would not cause concern in respect of conformity to ISO/IEC 27001:2022 requirements:
Audit reports are not held in hardcopy (i.e. on paper). They are only stored as ".POF documents on the organisation's intranet: This statement would not cause concern because it

ACTUALTEST.COM

does not imply any nonconformity with ISO/IEC 27001:2022 requirements. The standard does not prescribe any specific format or media for documenting or storing audit reports, as long as they are controlled according to clause 7.5.
The audit programme mandates auditors must be independent of the areas they audit in order to satisfy the requirements of ISO/IEC 27001:2022: This statement would not cause concern because it does not imply any nonconformity with ISO/IEC 27001:2022 requirements. The standard does not prescribe any specific requirement for auditor independence, as long as the audit is conducted objectively and impartially, in accordance with ISO 19011:20182.
The audit programme does not reference audit methods or audit responsibilities: This statement would not cause concern because it does not imply any nonconformity with ISO/IEC 27001:2022 requirements. The standard does not prescribe any specific requirement for referencing audit methods or audit responsibilities in the audit programme, as long as they are defined and documented according to ISO 19011:20182.
The audit process states the results of audits will be made available to 'relevant' managers, not top management: This statement would not cause concern because it does not imply any nonconformity with ISO/IEC 27001:2022 requirements. The standard does not prescribe any specific requirement for communicating the results of audits to top management, as long as they are reported to the relevant parties and used as an input for management review, according to clause 9.3.

**QUESTION NO: 366**
審計測試計劃在審計過程中的目的是什麼？
**A.**制定詳細的審計報告
**B.**進行觀察、訪談等稽核程序
**C.**選擇管理系統的所有元素進行驗證
***Answer:*** B
Explanation:
Comprehensive and Detailed In-Depth
B . Correct Answer:
Audit test plans define the structured approach for conducting interviews, observations, and control testing.
ISO 19011:2018 describes audit test planning as essential for consistent evidence collection.
A . Incorrect:
Test plans do not generate reports-they outline procedures for evidence collection.
C . Incorrect:
Audit test plans focus on specific risks rather than evaluating all elements.
Relevant Standard Reference:

**QUESTION NO: 367**
您是審計團隊負責人，對一家線上保險機構進行第三方審計。舞台期間
1，您發現組織採取了非常謹慎的風險方法，並將 ISO/IEC 27001:2022 附錄 A 中的所有資訊安全控制措施納入其適用性聲明中。
在第二階段審核期間，您的審核團隊發現沒有證據顯示實施了適用性聲明摘錄中顯示的三項控制措施（5.3 職責分離、6.1 篩選、7.12 佈線安全）。未找到風險處理方案。

| Control Reference | Objective | Control driven by | | | Applicable | Last Assessed | Justification if not applicable |
|---|---|---|---|---|---|---|---|
| | | Business Risk | Legal requirement | Customer Contract | | | |
| 5.3 | Avoid conflicts of interest | Yes | No | No | Yes | 02/202X | None |
| 6.1 | Screen personnel | Yes | No | Yes | Yes | 02/202X | None |
| 7.12 | Cable protection | Yes | Yes | No | Yes | 02/202X | None |

選擇三個選項，說明您希望受審核方針對 ISO/IEC 27001:2022 第 6.1.3.e 條的不符合項所採取的措施。

**A.**分配提供證據的責任，以向審核員證明控制措施已實施。

**B.**制定定期評估與控制相關的風險的計畫。

**C.**對每項適用的控制措施實施適當的風險處理。

**D.**將書面控製程序納入組織的安全手冊中。

**E.**從適用性聲明中刪除三個控制項。

**F.**修改適用性聲明中的相關內容以證明其排除的合理性。

**G.**重新檢視與三項控制措施相關的風險評估流程。

**H.**對客戶進行調查，以了解他們是否需要這些控制措施。

***Answer:*** C,G,F

Explanation:

According to the PECB Candidate Handbook for ISO/IEC 27001 Lead Auditor, the auditee should take the following actions in response to a nonconformity against clause 6.1.3.e of ISO/IEC 27001:20221:

Implement the appropriate risk treatment for each of the applicable controls, as this is the main requirement of clause 6.1.3.e and the objective of the risk treatment process2.

Revise the relevant content in the Statement of Applicability to justify their exclusion, as this is the expected output of the risk treatment process and the evidence of the risk-based decisions3.

Revisit the risk assessment process relating to the three controls, as this is the input for the risk treatment process and the source of identifying the risks and the controls4.

The other options are not correct because:

Allocating responsibility for producing evidence to prove to auditors that the controls are implemented is not a valid action, as the audit team already found that there was no evidence of the implementation of the three controls.

Compiling plans for the periodic assessment of the risks associated with the controls is not a valid action, as this is part of the risk monitoring and review process, not the risk treatment process5.

Incorporating written procedures for the controls into the organisation's Security Manual is not a valid action, as this is part of the documentation and operation of the ISMS, not the risk treatment process.

Removing the three controls from the Statement of Applicability is not a valid action, as this is not a sufficient justification for their exclusion and does not reflect the risk treatment process.

Undertaking a survey of customers to find out if the controls are needed by them is not a

ACTUAL4TEST.COM

valid action, as this is not a relevant criterion for the risk assessment and treatment process, which should be based on the organisation's own context and objectives.

**QUESTION NO: 368**
場景 4：Branding
是一家行銷公司，與美國一些最著名的公司合作。降低內部成本。兩年多來，Branding 已將軟體開發和 IT 幫助台營運外包給
Techvology。技術學。配備必要的專業知識，管理品牌的軟體、網路和硬體需求。 Branding 已實施資訊安全管理系統 (ISMS) 並獲得了 ISO/IEC 27001
認證，表明其致力於維護高標準的資訊安全。它積極對技術進行審計，以確保其外包業務的安全性符合 ISO/IEC 27001 認證要求。
在上次審計期間。品牌的審計團隊定義了要審計的流程和審計計畫。他們採用了基於證據的方法，特別是考慮到 Techvology 在過去一年中報告的兩起資訊安全事件。所有方面。
此外，審計也對Techvology用於管理其外包業務和其他組織的治理流程進行了嚴格的評估。此步驟對於品牌推廣至關重要，可以驗證是否有適當的控制和監督機制來減輕與外包安排相關的潛在風險。
審計員對 Techvology 各級人員進行了採訪，並分析了事件解決記錄。此外，Techvology 還提供了記錄作為證據，證明他們為員工開展了事件管理意識會議。根據收集到的信息，他們預測這兩起資訊安全事件都是由人員不稱職造成的。因此，審計人員要求查看涉事員工的人事檔案，以審查其能力的證據，例如相關經驗、證書和參與培訓的記錄。
Branding 的審計員對所獲得的證據的有效性進行了嚴格評估，並對可能與收到的記錄資訊的可靠性相矛盾或質疑的證據保持警惕。在對 Techvology 進行審計期間，審計員堅持這種方法，嚴格評估事件解決記錄，並對不同級別和職能的員工進行徹底的訪談。他們不只把 Techvology 代表的話當作事實；相反，他們尋求具體的證據來支持代表們對事件管理流程的主張。
根據上述情景，回答以下問題：
審計人員是否認真遵守外包業務的審計流程？
**A.**是的，他們在審計實務中表現出了勤勉和判斷力
**B.**不，審計人員直到審計結束時才要求提供僱傭合約樣本
**C.**不，審計人員在審計期間沒有採訪 Techvology 的任何高階管理人員
***Answer:*** A
Explanation:
Comprehensive and Detailed In-Depth
A . Correct Answer:
ISO 19011:2018 (Guidelines for Auditing Management Systems) outlines diligent audit practices, including evidence-based assessment and professional skepticism.
The auditors critically reviewed records, interviewed staff, and validated incident response effectiveness.
They did not rely solely on verbal statements but sought concrete evidence, demonstrating due diligence and judgment.
B . Incorrect:
Employment contracts are not primary audit evidence for competence; training and certification records hold greater significance.
C . Incorrect:

ACTUALTEST.COM

The scenario does not mention that top management was excluded from interviews. However, their involvement is not mandatory for evaluating incident handling.
Relevant Standard Reference:

ACTUAL4TEST.COM